Mark Butterhoff
dr. Yuri Bobbert

Digital Security Leadership

Preface by **prof. Ron Meyer**

A CISO Handbook

Digital Security Leadership

Mark Butterhoff

Yuri Bobbert

Preface by prof. Ron Meyer

More information about this edition can be obtained from www.12ways.net or via info@12ways.net
Copyright © 2024 Yuri Bobbert, Mark Butterhoff

1st edition	August 2020
2nd edition	April 2024
Authors	Mark Butterhoff
	Yuri Bobbert
Design	Paul Gerlach
Editor	Michael Gould Associates (MGA)
Writing contributions:	Barry Derksen (section Trending) & Ed Lute (Interludes)

ISBN/EAN	978-90-9033513-1
NUR-Code	801
NUR-description	Management: general

All rights reserved, all copyrights and database rights with regard to these editions are expressly reserved. These rights are vested with Yuri Bobbert and Mark Butterhoff.

All rights reserved. No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form or by any means, electronic, mechanical, photocopying, recording or otherwise, without the publisher's prior consent.

Subject to the exceptions laid down in or pursuant to the Dutch Copyright Act 1912, nothing from this publication may be reproduced, stored in an automated data file or made public in any form or by any means, electronic, mechanical, photocopies, recordings or any other otherwise, without the prior written permission of the publisher.

Insofar as the making of reprographic reproductions from this publication is permitted on the basis of article 16.h, Dutch Copyright Act 1912, the legally due fees must be paid to the Reprorecht foundation (PO Box 3060, 2130 KB Hoofddorp, the Netherlands, www.reprorecht.nl). For copying part (s) from this edition in anthologies, readers and other compilation works (Article 16, Dutch Copyright Act 1912), one should turn to the PRO Foundation (Publication and Reproduction Rights Organization Foundation, PO Box 3060, 2130 KB, Hoofddorp, the Netherlands www.cedar.nl/pro). To take over part of this publication for commercial purposes, you must contact the publisher and the authors.

Although the utmost care has been taken in the preparation of this publication, the absence of any (printing) errors and omissions cannot be guaranteed and the author (s), editor (s) and publisher therefore accept no liability for the consequences of any common errors and omissions.

Digital Security Leadership

Mark Butterhoff

Yuri Bobbert

Preface by prof. Ron Meyer

“Good leaders organize and align people around what the team needs to do.
Great leaders motivate and inspire people with why they’re doing it.”

Marillyn Adams Hewson

chairman, ex-president and ex-chief executive officer of the aerospace and defense manufacturing company Lockheed Martin.

Contents

Preface 9

Introduction 13
Terminology 17
Why this book? 18
What will you find in this book? 19
The structure of this book 19

01 Leading 25
I told you not to do that… 25
I have a dream 26
Do as I say, not as I do? 29
So, who do we need? 33
The right leader for the right job 35
Leading is not a one-(wo)man show 36
The effective leader is a human being 38
Stuck in the matrix 43
Towards a high-performing security team 48
To know thyself is the beginning of wisdom 57
Don't be the Duck 62
Key takeaway messages on leading 67

02 Strategizing 75
Introduction 75
Information security strategy is about everything but the plan 76
Critical success factors for a security strategy: an examination 83
Some practical reflections 87
Know thyself and your external forces 91
To Really Know Your Enemy 99
Reflection on the use of existing management models 104
Security strategies in other sectors 110
Does security really enable business value? 112
Key takeaway messages on strategizing 115

03 Changing 119
Introduction 119
Change management 119
Eight reasons why changes fail 122
Eight reasons why changes can succeed 126
A fool with a tool is still a fool 130
Relational mechanisms 135
Prepare for action 145
Discipline equals freedom 148
Managing the Impact of Cyber Security Fatigue 151
Key takeaway messages on changing 157

04 Governing 161
Governing digital security 161
Digital security metrics and objectives 168
Governance versus regulations 176
Who will be your "Governor"? 180
The Compensation Trap 184
Why Less Cyber Security Staff is More 184
Key takeaway messages on governance 197
Ending the cold war in cybersecurity 198
Three digital security interludes 201
Interlude 1: Breaking the perverse model 204

05 Funding 209
Cyber economics 209
Business case 216
Return On Security Investment (ROSI) 219
Customer satisfaction research 222
Is Digital Security a market for lemons? 223
Interlude 2: The ethics & economics of cyber risk 233
Key takeaway messages on funding 237

06 Trending 239
Looking at trends up to 2100 239
Trending roles in digital security 276
The role of the Chief Information Security Orchestrator (CISO) 282
Key takeaway messages on trending 283
Interlude 3: Ecosystems & coalitions 284

07 Twelve ways to combat the silent enemy 289

Epilog 292

About the authors 294

Figures & tables 295

Appendices 296
A1 Business case criteria 296
A2 CISO (self) assessment template 301

“History teaches us that men and nations behave wisely once they have exhausted all other alternatives.”

Abba Eban (1915-2002)

Israeli Statesman

Preface

Throughout history, the importance of security, to countries and companies, has usually only been understood by finding out the hard way. Only after disasters have occurred do men and nations realize that it would have been wiser to think ahead, invest in security, and avoid catastrophe. Time and time again we have seen naive people running high risks without proper preparation, only to recognize afterwards that most of the damage could have been prevented by basic security measures. As Yuri Bobbert and Mark Butterhoff point out in this book, in the new world of digital security the same old dynamic of learning the hard way is playing out again. This is why they aim to support managers in taking the lead in building digital systems that are capable of fending off the silent enemy before they have exhausted all the other alternatives.

The approach taken by Bobbert and Butterhoff is unique and powerful in three mutually reinforcing ways. First, their approach to digital security is organizational rather than technical. To explain, let me make a short sidestep. If you think about military security, you immediately recognize that some people prefer to talk about the technical side – the hardware such as tanks and ships. While this is not unimportant, every military strategist will tell you that wars are not won by the side with the best hardware, but by those with the best way of organizing themselves and employing the hardware to achieve strategic advantage. If you talk about safety in a factory, again some people will focus on the technical side, such as hardhats and safety railings. Here too the hardware is useful, but safety needs to be organized. Successful companies encourage people to embrace safe working practices, while leaders support this behavior, building a strong safety culture in the process. Bobbert and Butterhoff take the same approach to digital security, acknowledging the importance of technology, but focusing strongly on creating the organizational capability to remain secure.

The second distinguishing characteristic is that Bobbert and Butterhoff's approach is strategic rather than operational. They argue that digital security is not only about operational risks, but also about strategic risks that could sink the whole organization. Just imagine leaving national security to local tank commanders at the border because that's where the problem will first appear, instead of making it the responsibility of the president or prime minister. In the same way, companies that are successful with security will tell you that it needs to be what the German's call a chefsache – on the plate of the CEO, because mistakes can deeply impact the entire organization. Bobbert and Butterhoff argue strongly that digital security needs to be on the strategic agenda of top management and explain how that can be achieved.

The third aspect of the authors' approach, complementing their organizational and strategic perspective, is that they make digital security an organization-wide issue instead of only a topic for the IT department. Of course, it's very attractive for people in the organization to dump digital security responsibility in IT's lap, so that they can focus on their own KPIs and topics they find more engaging. But digital security requires a collective effort and IT can only do so much on its own. Just imagine if politicians were to delegate national security to the military, while at the same time engaging in dangerous foreign policy. In the same way, companies that have made safety departments responsible for safety have found that such delegation allows all others in the organization to ignore safety, as it's the safety department's problem to solve. Bobbert and Butterhoff convincingly argue that, when it comes to digital security, the chain is only as strong as the weakest link, so an organization-wide approach is essential.

Taken together, these three angles – digital security as organizational, strategic, and company-wide – make this book a "must read" for any manager involved in the topic of digital security, which in the digitalizing world basically means almost all of us. So, it's time to put on your seatbelt on and enjoy the ride.

Prof. Ron Meyer

Managing Director, Center for Strategy & Leadership
Professor of Strategic Leadership, TIAS School for Business & Society, Tilburg University
& Antwerp Management School, University of Antwerp

"'Antifragile' is when something is actually strengthened by the knocks."

Nassim Taleb

Introduction

Nowadays it's impossible to imagine business without technology. Most industries are becoming "smarter" and more tech-driven. Ranging from small individual tech initiatives to complete business models with intertwined supply chains. We're seeing smart cities emerge and society is taking a more holistic view of the regulation of such high-tech developments. Not only from a privacy perspective: who collects what, and for which purpose? But also from a cybersecurity perspective: who protects our digital sovereignty and our "digital heritage"? For policymakers and business leaders technology is no longer a domain that is shrouded in mystery; rather it's an essential business discipline that is here to stay, and it's taught at business schools all over the world. It's also a professional discipline that has got the attention of analysts and supervisory boards[1]. However, at the same time, organized crime has arrived on the scene in a big way. Through hacks and denial-of-service attacks, all sorts of malicious actors are infiltrating our 'digital' society. They can easily take advantage of systems that are sloppily built and configured and they frequently use advanced "socially engineering" techniques to trick their way into organizations. Various scams trick people into thinking they have to update their account information by clicking on a link that's provided. By indiscriminately spamming extremely large groups of people, "phishers" can thus gain sensitive financial information from the small percentage (yet large number) of people who are fooled in this (and other) ways.

Did you know that in 2019 every month 590,000 unique malware[2] variants were created and that in 2020 we reached the milestone of 1 billion unique examples of malware created and

1 *In 2017 Boston Consulting Group reported a 150% increase in regulatory agency reports on Cybersecurity and 129% increase in investor research reports compared to 2013. .*

2 *Short for "malicious software," malware designed to damage a computer system.*

targeted at consumers and organizations.[3] Did you know that users are still the weakest link and that malware causes damage estimated at $150 million dollars per cyberincident?[4] Also that spending on cybersecurity is expected to increase globally to $248 billion in 2023[5]? We've all seen many examples of LinkedIn pages that have moved away from regular IT functions toward digital security functions, even though in the past they've never paid much attention to this topic. Nevertheless it's been calculated that the global shortage of security professionals will increase to 3.5 million open positions by 2021.[6]

Once we take a closer look at how the spending on security is spread, we see that most of the money is spent on the more technical part of cybersecurity[7]. Security awareness, i.e. the human factor in information security, seems to be of less importance.

Table 1 Spending on security, taken from Dutch Investments in ICT and cybersecurity

Cybersecurity Submarkets	Value in € Billions		Compound Annual Growth Rate
	2015	2020	
Security services	€13.1	€27.3	16%
Internet of Things security	€6.27	€26.39	33% (up to 55%)
Cybersecurity insurance	€2.3	€7	25%
Cybersecurity awareness training	€0.9	€1.66	13%

When we take a closer look at the providers of information security services, we see not only that the number of cybersecurity companies is growing, but there are also many new startups, with

3 *Source: https://www.av-test.org/en/statistics/malware/*

4 *According to Ponemon in 2020 the average cost of each data breach will be US$150 million. According to Juniper Research, cybercrime is expected to cost businesses around US$2 trillion dollar. source: https://www.cybintsolutions.com/cyber-security-facts-stats/*

5 *https://www.forbes.com/sites/louiscolumbus/2020/04/05/2020-roundup-of-cybersecurity-forecasts-and-market-estimates/#756db286381d / https://www.statista.com/statistics/595182/worldwide-security-as-a-service-market-size/*

6 *https://financesonline.com/cybersecurity-statistics/*

7 *Dutch investments in ICT and Cybersecurity, Putting IT in perspective, The Hague Centre for Strategic Studies, December 2016*

the possibility of being listed on the Nasdaq, and existing large-scale IT providers that now have their own security services line of business. For some of them this is the only actual growth market they have, e.g. Atos saw their main growth in Big Data and cybersecurity in 2018[8]. What's particularly interesting is that we've learned that some regular cloud service providers (e.g. Salesforce, Microsoft, etc.). have started delivering paid security services based on data they collect from your company. In other words, you can only access the transactions and user activities created by your employees, or unauthorized individuals, which are stored in "your" cloud service database and event logs if you pay additional fees. Well, at least they present this information to you in a nice dashboard, which they might call their Artificial Intelligence (AI) or machine learning engine.

Although all of these technical security measures and services are necessary within the current connected world, one could ask whether this is their core competence and where their real focus should be. Are these software and services providers actually not like the pharmaceutical companies, which often focus on "managing" diseases rather than treating or preventing them in the first place. Because preventing a disease doesn't allow you to sell more drugs and thus earn more money. Wouldn't it be better within digital security to focus more on the biggest causes of security incidents i.e. the vendors that keep producing technology with basic security flaws? How can it be that we as users, IT staff and security specialists accept that we have to pay more or buy more services to actually get a secure IT/Cloud service that you would expect when buying it, just like in other industries. In aviation, we just had a very tragic experience involving two Boeing 737 MAX airplanes that had a huge impact on the profitability and even the continuity of the entire Boeing company. An error like that in aviation or in the car industry will have a massive impact, but within IT or the Cloud, it appears that the user, IT and security departments are the ones who need to fix an issue caused by the vendor.

8 Het Financiele Dagblad (Dutch Financial Times), 6 September 2019.

We all know that the human factor is still the weakest link. Many publications have focused on behavioral and awareness aspects.[9] [10] [11] According to TechDirt, "almost" no one (fewer than 1% of users) reads end-user license agreements (EULAs). Apparently, in an attempt to prove that no one reads these agreements, anti-spyware firm PC Pitstop buried a note in its own EULA, saying they would give $1,000 to the first person who emailed them at a certain address. It only took four months and over 3,000 downloads before someone actually noticed it and sent an email (and got the $1,000). Also, 59% of the employees steal proprietary corporate data when they quit or are fired.

Nowadays, 56% of all mail is spam and this triggers most of the cryptolockers and ransomware. And who said in 2004 that spam will be a thing of the past in two years? That was Bill Gates.[12] According to many publications, users are the weakest link and should therefore also be the main focus for security controls.[13] Often the focus is on end-users clicking on all kinds of vulnerable links in their emails or providing sensitive data to people they shouldn't trust or with whom they are not allowed to share. In our opinion, the human factor also includes those who are actually managing IT systems, information processing facilities and HR. The question is, how often is ransomware, virus attack or a data breach not a result of weak passwords,[14] a lack of adequate patching, the design of insecure systems by default or just a lack of doing basic daily activities (e.g. monitoring the operations of e.g. your anti-malware software).

9 *Ashenden, "Information Security management: A human challenge?," Information Security Technical Report 13 195-201, United Kingdom, 2008*

10 *B. Lebek, J. Uffen and M. Breitner, "Employees' Information Security Awareness and Behavior; A literature review," in 2013 46th Hawaii International Conference on System Sciences, Hawaii, 2013.*

11 *P. Spurling, "Promoting security awareness and commitment," Information Management & Computer Security, vol. 3, no. 2, pp. 20-26, 1995*

12 *In 2004 Bill Gates had an interview with the BBC where he said, said quote. "E-mail spam will be a thing of the past in two years' time." Source: https://www.businessinsider.com/the-dumbest-things-bill-gates-ever-said-2016-4?international=true&r=US&IR=T*

13 *M. Workman, W. Bommer and D. Straub, "Security lapses and the omission of information security measures: A threat control model and empirical test," Computers in Human Behavior, vol. 24, no. 6, p. 2799–2816. And Kabay, "Using Social Psychology to Implement Security Policies," in Computer Security Handbook, 4th Edition , United States, John Wiley & Sons. , 2002.*

14 *In 2018 the most used password was "123456" and on the second "password" Source: https://www.skyhighnetworks.com/cloud-security-blog/skyhigh-research-finds-password-insecure-reuse-cloud/*

We believe that the effectiveness of cybersecurity will not increase when more money is added to the IT budget for cybersecurity.

Within business, IT, as well as information security, we often want to go from A to B with a "flashy" roadmap in PowerPoint addressing all the tangible deliverables to get there, which we tend to call "A strategy." The thing is however, if you start researching strategy, you come to the conclusion that it's about more than just a roadmap and the management of that roadmap. Strategy actually has three perspectives:[15] political, economic and technical. The roadmap is the technical part, the economic part is about the funding and the political part is about managing (and influencing) all your internal and external stakeholders to get them moving in the direction you need them to move to achieve a mutual goal. So, when did anyone of us see all these perspectives addressed in an information security strategy document or in the work of security professionals?

Terminology

We started this book with the term information security and Cybersecurity. Digital security is a more comprehensive and overarching term that covers the information security and cybersecurity domain. We use both terms in this book, since they are closely intertwined. Information security was the term used in 1990s and 2000s. Later came cyber-attacks, the dark web, and the deep web, etc., so the term cybersecurity was introduced and became a completely new topic and economy. But what is the difference? Information security refers to actions within a company and cybersecurity is related to external attacks. Nowadays, new perspectives come into play such as:

- Sophistication and dynamics of cyber attacks
- Machine learning and artificial intelligence (algorithms to program machines)
- Virtual identities
- Big Data

15 *Total Competition, Lessons in Strategy from Formula One, Ross Brawn and Adam Parr, 2016*

- Distributed hybrid environments (legacy, cloud, Operational Technology (OT))
- New ways of working (DevOps, Agile, Scrum) and autonomy's teams
- Continuous software development (CI/CD)
- Regulatory and assurance (Integrated reporting) (ISAE and SOC2 statements)

With all these actual developments we talk more about digital transformations and safe cloud journeys, so the term digital security is used to cover both domains. In fact, the three terms information security, cybersecurity, and business information security are increasingly being referred to as "*digital security*."

Why this book?

In recent years we as authors have worked in the domain of technology and digital assurance and we have learned the hard way. Helping companies prepare, undergo and recover from all sorts of incidents. In those years we wanted to gain a deeper understanding of root causes and how companies can develop the capability of "antifragility" to cope with stressors and Black swans.[16] We have examined many critical success factors for the implementation and execution of a security strategy.[17] The four main critical factors we have identified are: management and Board commitment, creating a security aware culture, the quality at the top (leadership) and cultivating lessons learned. However, years have passed, and we still don't see any significant change in the way digital security is led, managed, and/or implemented. Still most budgets are spent on technologies, expensive consultants that make PowerPoint presentations, outsourced services, and security products (e.g. insurance). We've seen the same struggle year after year over the last 15 years, apparently without success. Is this because you can't make money on digital security? Is security not sexy enough? Or is it – still – not important enough? Or is the security professional perhaps not capable of demonstrating real business impact or value? In our experience, it's because it takes hard work to change the habits and behavior of people and that

16 *Nassim Taleb wrote in his book Antifragile "When you ask people, 'What's the opposite of fragile?' they tend to say robust, resilient, adaptable, solid, strong. That's not it. The opposite of fragile is something that gains from disorder."*

17 *The book Critical Success Factors for Business Information Security from Bobbert & Papelard (2018) examines top success factors for successful implementation of security.*

is not simply a quick win but requires mental stamina. We also dare to state that in most cases digital security is led, managed, and implemented by people with the wrong skill set.

What will you find in this book?

So, what is this book about? This book describes how to make security a success and turn it into a "cherry experience."[18] We don't want to repeat what others have already written on cybersecurity or things that you already know. So, this book is mostly about the things other security or risk professionals are not talking about, but that are essential for you to know in order to make security a successful discipline in your organization. It will therefore focus more on the strategy, governance, and managerial competences of digital security and less on the technology side. We will not introduce a new control framework or tell you what has already been written by most other authors. We see that the technical side has been described by many people going back centuries. Centuries you ask? Yes centuries. Just think about how old encryption is! No, it was not invented by the Germans in the Second World War; you need to go back to the ancient Egyptians and maybe even further. Cybersecurity from a technology perspective is not new. We called it information security about 20-30 years ago, and before that we had access control and auditor privileges in RACF on mainframes, etc.

The structure of this book

In the following chapters we will write about these non-technical subjects. Often these subjects are actually disciplines from other sciences that we use within the world of cybersecurity. Since we think that the importance of the human factor in security is under-emphasized, this goes for leaders, end-users, IT and other staff responsible for information security measures as well as information security employees, we will therefore largely focus on the people factor. We will not be talking about frameworks because we believe that is akin to focusing on the technocratic

18 *Cherry experience refers to the Dutch expression "Kersensensatie," something that is nice, sweet and has a positive association. The book: "Discover the IT Cherry - How to become the most valued IT organization by using cherries" was written by Mark Butterhoff, Barry Derksen, and Aart van der Vlist.*

part of the governance of Infosec. "Technocracy is a proposed system of governance in which decision-makers are selected on the basis of their expertise in a given area of responsibility, particularly with regard to scientific or technical knowledge."[19] With a technocratic approach, we mean everything that is focused on tools, processes, and certification of the security skills of people, instead of the human factor of leading and changing people and culture to get the security level to the level the company aspires to achieve. Thus, a technocratic approach doesn't solve the social problems we face in implementing and running digital security. Because we believe the problem is not the latest security tooling or frameworks, the problem is the weakest link ….the human being.

So this book starts with a section on Leading. This section is not only about the leader, e.g. the Chief Information Security Officer (CISO), it's also about how to lead the company through the cybersecurity challenges and how the CISO role emerges to a Chief Information Security Orchestrator balancing and leading multiple stakeholders. We will not come up with a new organizational design of the security system since we don't think that this is a key differentiator to make information security a success. A new technocratic organization will not get you to the level where you need to be. Other interventions will, and we will present our key takeaway messages at the end of each section. This way you can read this book as a whole or just read certain sections at a time.

In the second section, we will focus on Strategizing. In digital security the term strategy is often mixed up with plans and the execution of the strategy is lacking. Not because the identified technical improvements aren't correctly identified, but because the strategy process and content itself is insufficient. Or the people executing the strategy lack the capabilities we have identified. We will address most of these issues and summarize the key takeaway messages at the end of the section.

19 https://en.wikipedia.org/wiki/Technocracy

In the third section we will focus on Changing. Changing the people working in digital security and the people who need to act in a secure manner. Because in order to make the human factor stronger, significant changes need to be made. These changes will ideally come from the intrinsic motivation that people want to do well. But why are people resisting this change? Why is it that this current technocratic approach mainly results in more resistance? We will deal with cultural and team change extensively, and of course close with our key takeaway messages.

In the fourth section we will address Governing. We will not design a new governance framework to manage risk, but we will give some tangible practices and metrics to measure and govern your digital security as well as the way to work practically and proactively with your governance, including regulators. Effective governance is about fact-checking, presenting and quantum communicating. Quantum communication means communication needs to be done more intensively (faster, with a higher frequency and more precise) than you have ever done before to keep everyone moving toward the collective destination.

In the fifth section we address the Funding of digital security. As already mentioned, strategy is not only about getting from A to B, but it has also an economic perspective. It has financial consequences that stakeholders want to know about and understand. We urgently need to move away from the Fear, Uncertainty and Doubt (FUD) decision-making and ostrich politics where decision-makers rely on others since "they don't understand it or don't want to understand it." With economic models we bring more rational arguments to the discussion, which enables more balanced decision-making and in the end more "bang for your buck."

In the sixth section we discuss a possible digital security future in Trending, because as a wise man once said: "It's not the strongest of the species that survives, nor the most intelligent that survives. It's the one that is most adaptable to change."[20] (We know, this is a quote that has often been used by other people and that some say that there is insufficient proof that Charles Darwin actually said this.)

20 Quote by Charles Darwin about the evolution of species (some question whether Charles Darwin actually said this)

Over the past years of writing, reflecting and getting feedback on our first edition of this book we wrote additional sections that shed new light on the topics we have addressed in that specific chapter of the book. They offer the reader novel insights or new takeaways we did not want to hold back.

To summarize each section, we drafted conclusive “key takeaway messages” to inspire your professional responses. These are quick wins that you can apply immediately or use to initiate meaningful information security conversations within your organization. And, at the end of this book we have formulated, based upon all takeways, twelve final ways about digital security that others don’t talk about, but you definitely should know in order to combat the silent enemy.

“Management is doing things right; leadership is doing the right things.”

Peter Drucker

01

Leading

I told you not to do that…

Digital security within organizations is still seen as a burden and employees still do "stupid things" that they shouldn't be doing, although security staff told them not to do so. The security officers and specialists in organizations usually have a long list of security gaps and actions that need to be resolved and implemented, but still nothing happens, although it seems to be obvious and logical that these issues should be addressed.

We notice that the people responsible for security and "security leadership" often don't sit at the "right table," have limited or no budgets, are pretty much internally focused and the person responsible for security is either a "crack" security expert or has in the opinion of the security staff no idea about security at all. The security team itself is like many teams, a group of individuals who think they're better than everyone else in the team.

Also, security staff are often involved after things have gone wrong. They are often not part of all the fun of creating new stuff, but they are the ones who are expected to clean up and keep firefighting. And how often doesn't it occur that the CIO will ask (or maybe more likely "will tell") the security staff responsible "how could this happen? Why didn't you prevent this from happening?." And, when the security staff are part of new developments, discussions are often about why security measures should be applied and about accepting the risk, instead of being eager to make the information or system as secure as possible.

Of course, the description above is a bit exaggerated. Still, we think most of us would agree that people outside of security don't "really" want to spend their time and budgets on digital security.

They want to say A, that security is important and needs to improve, but they don't want to say B, making all the changes and investments to actually be more secure. Also, it's not really nice to work with people who constantly tell you what you're doing wrong and what you should do to be more secure (this also goes for ethical hackers and auditors. Their work is very valuable, but it's the easiest job in security. Identifying vulnerabilities is one thing, but changing an organization toward a more secure one is much more difficult, because people are involved). Although most people currently find digital security important and necessary, they somehow don't want to do anything for it or give away some of the privileges they have. The main question here is, how can we make security everyone's priority and thus lead everyone to a more secure environment?

In our opinion, you need to start with the kind of leadership that guides the company to the right level of security. This requires leadership skills and not just management skills. Second, you need to create the right organization in which the security function can operate efficiently and effectively. Lastly you need the right security team that will take the organization to the next level in digital security, because "if you want to go fast, go alone. If you want to go far, go together."[1]

I have a dream

Leadership has a very long history; some of it goes back to the 6th century B.C. when the Chinese General Sun Tzu wrote "The Art of War." Over the last 180 years we've seen different leadership theories:[2]

- The Great Man Theory (1840 onwards): Thomas Carlyle described the leader as a hero. Although this is an old theory, we still see it used to describe Nelson Mandela, Steve Jobs and Elon Musk.

1 *African proverb that explains that you achieve more when collaborating*

2 *A historical perspective on leadership theories is described in this article. https://leadersquest.org/content/documents/A_short_history_of_leadership_theories.pdf*

- Trait Theory (1910-1948): This is about different personality traits and characteristics as the source of great leadership. It's the result of the previous leadership theory, after which investigations started into the nature of effective leadership.
- Behavioral Theory (1950-1970): After research by Stogdill the focus of leadership theory shifted from internal traits to specific behaviors and actions of leaders: are you born as a leader or can leadership be learned?
- Contingency Theory (1967-1990): This is the result of research that showed that no single style of leadership is the right one in all situations. It all depends on e.g. the tasks, situation, the organization, and people involved.
- Leader-Follower Theory (1990 onwards): Leaders assume followers' roles and followers assume leadership roles.[3] The follower is no longer subordinate and obedient of organizational tasks but opens up opportunities for innovation and growth.
- Transformational Leadership Theory (1985-2010): A focus on "transforming" others to get things done instead of mere "transactions." This can be done e.g. by leading by example, offering a compelling vision, using intellectual stimulation.
- Systems Leadership Theory (2015 onwards): This enables the leaders in an organization to create the conditions in which people at all levels can work productively to their full potential.[4] System leadership recognizes that collaboration is essential in solving problems.

So, why do we think leadership is so important for information security?

To explain why we think leadership is so important, let's start with the definition of leadership. Since there is not one universal definition about leadership, here are several definitions:

According to Dwight D. Eisenhower (1890-1969, former president of the United States), leadership is: *The art of getting someone else to do something you want done because he wants to do it.*

3 *Gilbert, Jillian and Matviuk, Sergio (2008) "The Symbiotic Nature of the Leader-Follower relationship and Its Impact on Organizational Effectiveness," Academic Leadership: The Online Journal: Vol. 6 : Iss. 4 , Article 16.*

4 *Systems Leadership, Creating Positive Organisations, Ian McDonald, Catherine Burke, Karl Stewart, 2006*

Stephen R Covey defines it as:
"leadership is communicating to another person their worth and potential so clearly they are inspired to see it in themselves."

The army definition of leadership is:
Leadership is the process of influencing people by providing purpose, direction, and motivation to accomplish the mission and improve the organization.[5] *(ADP 6-22, Army leadership)*

According to Warren Bennis,[6] the primary ingredient of leadership is a guiding vision; the leader has a clear idea of what he or she wants to do. The second basic ingredient of leadership is passion. The leader who communicates passion gives hope and inspiration to other people. The last basic ingredient of leadership is integrity.

The essence of these definitions or descriptions of leadership is *to guide people to a certain goal by positively influencing them. Meaning that these people actually* ***wanting*** *to go where they need to go to achieve the goals to be achieved*.

So, when we want an organization to be as secure as we need it to be (the goal), we need to start showing leadership to get there. We need to start influencing the people of the organization positively to make them want a secure organization and everything necessary to get there.

This is not only relevant for the security team, but also for the IT department, HR, Marketing and actually every employee in the organization, and even maybe the customers and suppliers of the organizations since security is only as strong as the weakest link.

So, what does it take to become that good leader? Let's try to find an answer to that question in the next paragraph.

5 *ADP-Army Doctrine Publications 6-22, Army Leadership, August 2012, Headquarters, Department of the Army*
6 *Bennis, Warren. On Becoming a Leader, 2003 revised edition, Basic Books*

Do as I say, not as I do?[7]

Defining how to become or be a good leader is not an exact science. Although there are many books on leadership (if you search for leadership on Amazon, you get 70,000 hits), it's hard to have one magic formula for leadership. However, researching the characteristics, or skills that make leaders successful or not, we end up finding some similarities. Below you'll find some models and theories that we came across, that are either really well known by most of us or we believe absolutely valuable to get to understand.

One of the first books ever on leadership is The Art of War by Sun Tzu. Sun Tzu characterized leadership as a mix of five traits: *Intelligence, Credibility, Humaneness, Courage, and Discipline*. As you might have read in some of the leadership theories, the question is whether these are achieved by nature or by nurture.

According to Ron Meyer and Ronald Meijers in their book Leadership Agility,[8] an effective leader *is capable of influencing other people to move in a certain direction*, which can be divided into four elements:

- "***Other people***," which means that it's not about the leader in isolation, but about the interaction between leader and followers, not about what the leader does, but also how the followers react.
- "***Influencing***," which ranges from using formal powers, such as hire, fire, reward, reprimand and reassign, to informal powers such as the ability to convince, charm, inspire, support and challenge. Informal powers are usually more effective and more lasting than formal powers.
- "***Is capable of***" and willing to influence followers. leaders must be willing to take the responsibility of the leadership role and invest in winning authority among potential followers.
- "***To move in a certain direction***" and to realize objectives. It's not the goal to gain powers as an end in itself, but as a means toward achieving objectives.

7 *A quote from the song "Jesus he knows me" by Genesis*

8 *R. Meyer and R. Meijers, Leadership Agility, Developing Your Repertoire of Leadership Styles, 2018*

One of the areas that we often refer to in this book is the military. It's interesting to see that in modern free democracies, people still go out to fight a battle that might not be theirs, probably pays little, with the risk of losing everything, namely their life. History teaches us that in war, leadership can make the difference between life and death, between winning and losing a war. The leadership of the army is also fascinating since it has been there for centuries, long before all those leadership books were available on Amazon and before leadership gurus started talking about it in seminars.

An interesting publication of the US Army is the Army Doctrine Publication (ADP) 6-22, "*Army leadership and the profession*." As put forward by the authors in the Introduction:
ADP 6-22 establishes and describes what leaders should be and do. Having a standard set of leader attributes and core leader competencies facilitates focused feedback, education, training, and development across all leadership levels (direct, organizational, and strategic). ADP 6-22 describes enduring concepts of leadership through the core competencies and attributes required of leaders of all cohorts and all organizations, regardless of mission or setting. These principles reflect decades of experience and validated scientific knowledge.

An ideal Army leader serves as a role model through strong intellect, physical presence, professional competence, and moral character. An Army leader is able and willing to act decisively, within superior leaders' intent and purpose, and in the organization's best interests. Army leaders recognize that organizations, built on mutual trust and confidence, accomplish missions.

In the most recent ADP publication (August 2019) a well-defined figure presents a logical map of leadership;[9] however, we believe the overview picture in the 2012 version provides a slightly better overview of leadership.

In addition to the leadership requirements model the 2012 model also stipulates *the levels of leadership and conditions of leadership*. While most of us think of the Army as dictatorial; in which orders are absolute, it refers to *trust, empathy, interpersonal tact, leading by example,*

9 *ADRP 6.22, Army Leadership – August 2019, Headquarters, Department of the Army*

developing others, etc. to be able to achieve goals. All designed to influence people in a positive manner (figure 1). We think this model doesn't need much more explanation.

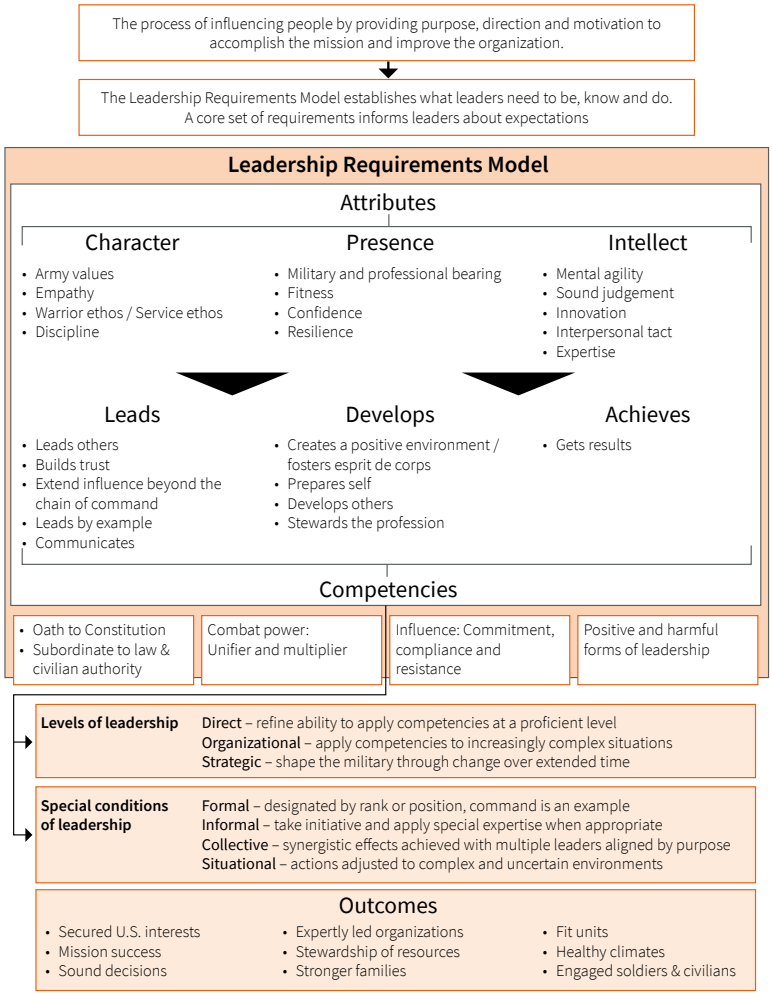


Figure 1 Underlying logic of Army leadership (taken from ADRP 6.22, Army Leadership – August 2019, Headquarters, Department of the Army).

The Good-to-Great framework proposed by Jim Collins[10] teaches us that building a great organization proceeds in four basic stages in which each consists of two fundamental principles. One of the principles is about leadership. Research shows that all the good-to-great companies had level 5 leadership at the time of transitioning to being great. The distinction between an effective leader, level 4, and a level 5 leader, the senior executive, has to do with humility and will (figure 2).



Figure 2 Level 5 Hierarchy Leadership by Jim Collins.

When you compare the skills of the different levels with the skills in ADP 6-22 and even Sun Tzu, you start to see a common theme in leadership. You also see that leadership is more than playing a hierarchical role, being a knowledgeable specialist, or a good manager.

10 Jim Collins, Good to Great, why some companies take the leap and other don't, 2001

For digital security this means that if you want to improve your security, don't just focus on getting the best technical security specialist or create a new target operating model; start focusing on leadership first. To be as successful as possible you need the best leaders who are capable of leading others to a more secure environment. When looking for a suitable CISO or assessing the current status of your digital security, don't just look at whether the person has the right certifications or knows the right tools; also look at the leadership skills the person has or needs to develop. The next paragraph will tell you more about how to assess these skills. Because, although you might think you're not at war, we believe organizations need level 5 digital security leadership to keep themselves secure (read safe) in the current fast-paced, digital, complex, and insecure cyber world.

So, who do we need?

Russell Reynolds, a UK HR agency developed a specific CISO assessment guide. They discovered that in carrying out cyber staff search assignments a considerable amount of progress was made by CISOs on defining policies, standards and understanding frameworks. At the same time there was little clarity and guidance on understanding what good or success looked like in the leadership of the cybersecurity function itself. Russell Reynolds developed a maturity model for CISOs. Their model shows four levels of CISO.[11] Level 1 CISOs are mostly heads of IT security who mainly focus on governance and controls. Level 4 CISOs are deeply intimate with their businesses; involved in the background in senior hiring and firing, M&A, divestments, supply chain, IP protection and anything shareholder sensitive. They also have regular sessions with the Chairman of the Board and train non-executives and their families.

The model also refers to capabilities needed in the several stages of cybersecurity (according to the National Institute of Standards and Technology (NIST))[12] for CISOs; capabilities of ***identifying*** critical assets and discussing with business leaders on how to use these assets and at the

11 Extracted from the website https://www.russellreynolds.com/insights/thought-leadership/cyber-security-the-ciso-assessment-level-model-calm

12 The NIST promotes U.S. innovation and industrial competitiveness by advancing measurement science, standards, and technology in ways that enhance economic security and improve our quality of life.

What is the organizational attitude towards cyber risk?	Level 1.0	Level 2.0	Level 3.0	Level 4.0
Cyber seen as an IT problem	✓			
Cyber seen as a broader problem than IT		✓	✓	✓
Cyber risks of third party suppliers evaluated	✓	✓	✓	✓
Cyber a regular topic with the audit / risk committee	✓	✓	✓	✓
Organization open to testing, e.g. phishing and penetration testing	✓	✓	✓	✓
Organization open to cyber transformation programs		✓	✓	✓
Innovative approaches encouraged to staff education, e.g. videos		✓	✓	✓
HR engages with CISO, e.g. access controls, 'Cyber Insider' and change programs		✓	✓	✓
CISO uses risk metrics to engage business leaders		✓	✓	✓
CISO is consulted widely in the enterprise on cyber issues			✓	✓
CISO trains NEDs in cyber awareness			✓	✓
CISO regulary briefs the main board on cyber and info risk			✓	✓
CISO involved in confidential situations, e.g. M&A plans				✓
Nature of internal relationships	transactional			Relational
Style of interactions	Reactionary			Anticipatory
Compensation	$	$$	$$$	$$$$
At what level do you need your CISO to influence internally	IT & operations level		Exco & board level	
Leadership competencies required to operate at this level				
Results orientation	High	High	High	High
Team leadership	High	High	High	High
Change orientation	Medium	Medium	High	High
Influencing and collaboration	Medium	Medium	High	High
Strategic capability	Low	Medium	Medium	High

Figure 3 CISO leadership competencies required per level (Taken from the Russell Reynolds Capability Model).

same time protect them; capable of understanding several ***protection*** levels and required controls needed to serve and not limit business processes; e.g. access control, training, educational programs. Capable of ***detecting*** breaches, anomalies, lacking behavior, or failing competences with people. And capable of ***responding*** to events such as communications, root causes analysis, investigations, mitigations and finally capabilities with regard to ***recovery***, such as improvement advisories, supporting in lessons learned, etc.

This CISO leadership self-assessment is taken as a template in Appendix A2.

The right leader for the right job

The Russell Reynolds model teaches us that every organization is unique and requires different leadership skills and styles. What we've also learned is that not one leader might fit in all stages of an organization development. Blanchard and Hersey introduced "situational leadership" in the late 60s. The model they presented is about which type of leadership is necessary based on the employees' needs.[13] This can be "delegating," "supporting," "coaching" and "directing." According to the Army Doctrine Publication (ADP 6-22) on leadership, leadership style also depends on who is being "led." Although this might be true, the question is whether all these kinds of leadership should be combined in one person?

The digital security profession has a long history and in the current era it's becoming even more important, with more people in organizations working on digital security. However, we often see those people having a more operational and tactical history and approach, without actual hands-on governance and leadership experience.

So, if you need to make digital security a success, you need a leader to lead you through the change and reach the end goal. In addition to how this leader needs to act based on employee's need, the leader also needs to consider the change curve (see the section on Changing)

13 *Hersey, P. and Blanchard, K. H. (1969). Management of Organizational Behavior – Utilizing Human Resources. New Jersey/Prentice Hall.*

a company needs to go through. For example, if you need to start getting digital security on the Board's agenda you might need someone with some good political and marketing skills. If you want people to go in a certain direction, you might need a visionary person. If everyone is aboard and you just need to get things done, you might need a more control-focused leader.

So, what does this mean? This means that you might need to choose digital security leaders not only based on what your employees need, but also based on which phase in the change curve digital security is actually in and the journey the company is going to embark on (e.g. mergers & aquisitions, global growth, hyper scaling). Also the culture (see also figure 9 in Chapter 3) of the organization has a high influence on the success of the CISO. It might mean that the person who created the vision and got digital security rolling is not the same as the one who actually made it a success. Does that mean that the first one is a worse leader than the second? We don't think so; it's all about who is the right person for the right moment in time. And if you don't do the selection thorough enough, you get the CISO you deserve.

Leading is not a one-(wo)man show

Another important observation is that leadership is not a one-(wo)man show and to be effective it shouldn't be. As the old African saying goes "If you want to go fast, go alone, if you want to go far, go together." And it's also true that the Agile enterprise needs us to work as a team, but perform as an individual.

In the Army a distinction is made between strategic (a global, regional, national, societal perspective), organizational (an organizational, systems and processes perspective) and direct leadership (an individual, small group, task-oriented perspective)[14]. The former commander of a nuclear submarine, David Marquet turned followers into leaders to significantly increase the quality of operations on the boat. Also "decentralized command" is a term that's often used in

14 ADP 6-22, Army Leadership, August 2012, Headquarters, Department of the Army

the army which means that junior officers are trusted to handle and lead certain tasks without being monitored.

Some might now think about the Agile way of working that has now been broadly introduced in all kinds of organizations, even outside software development. Although the Agile way of working might be very successful in some organizations, the twelve Agile principles don't refer to leadership. We also see Agile as mainly being a set of daily ceremonies and not bringing much more value than the previous way of working. We won't elaborate more on Agile in this book, but good leadership (as discussed in this chapter) might make a significant difference. Although there are several "Leadership in Agile" publications, many of them actually focus on management skills and using even more on tools and processes. Although there is a need for a team of skilled managers to execute the strategy, the importance of strong and persistent leadership is mostly ignored.

In addition to all kinds of research and books based on experiences, we've learned (in some cases, the hard way) that a "leading second (wo)man" is very useful, especially in large-scale organizations. As mentioned previously, the change curve might require different leaders, but you might require two leaders at the same time. In large-scale environments with large teams it's we believe an excellent practice to have a leader who is covering the outside (stakeholders) and a leader covering the inside (the team and deliverables). James Scouller published the Three Levels of Leadership Model[15] in 2011, introducing a personal, private and public level where the latter two mainly focus on the outer level and the first on the inner level. Although layer-wise our practice is similar, the distinction between public and private means a distinction between influencing two or more people (public) or just one-to-one.

What we often see in practice in these large-scale enterprises is that leaders who effectively cover the stakeholders (outside) don't have enough time to cover the inside that well and vice-versa. A possible way of solving this is to have one leader who is doing the outside and one that

15 *Scouller, J. (2011). The Three Levels of Leadership: How to Develop Your Leadership Presence, Knowhow and Skill. Cirencester: Management Books 2000*

is doing the inside coordination. You can compare it to someone that is acting as the CEO and someone that is acting as the COO and/or CFO; often different types of leaders have a different focus.

The effective leader is a human being

Research, studying and observing leaders brought us to an interesting conclusion: leadership is about someone being a person that others want to follow or be led by.

Daniel Goleman stresses the importance of emotional intelligence in leadership. In 1998 he published an article about "What Makes a Great Leader."[16] In this article he states actually that "The most effective leaders are all alike in one crucial way: they all have a high degree of what has come to be known as emotional intelligence. It's not that IQ and technical skills are irrelevant. They do matter, but…they are the entry-level requirements for executive positions." The article subsequently defines five components of emotional intelligence as reflected in Table 2.

Another research professor, Brené Brown, performed extensive research on brave leadership which led to the book "Dare to Lead."[17] According to senior leaders, brave leaders and more courageous cultures are needed to be successful in a complex, rapidly changing environment where we're faced with seemingly intractable challenges and an insatiable demand for innovation. To create these brave leaders, Prof Brown defined daring leadership as opposed to armored leadership. To give you an idea about the difference, a comparison between the two is made in the Table 3.

16 *Goleman, Daniel. (1998). What Makes a Leader? Harvard Business Review, 1998*

17 *Dare to Lead: Brave Work. Tough Conversations. Whole Hearts, Brené Brown, 2018*

Table 2 Taken from What Makes a Great Leader (Daniel Goleman)

	Definition	Hallmark
Self-Awareness	The ability to recognize and understand your moods, emotions, and drives, as well as their effect on others	Self-confidence Realistic self-assessment Self-deprecating sense of humor
Self-Regulation	The ability to control or redirect disruptive impulses and moods; the propensity to suspend judgment – to think before acting	Trustworthiness and integrity Comfort with ambiguity Openness to change
Motivation	A passion to work for reasons that go beyond money or status; a propensity to pursue goals with energy and persistence	Strong drive to achieve Optimism, even in the face of failure Organizational commitment
Empathy	The ability to understand the emotional makeup of other people; skill in treating people according to their emotional reactions	Expertise in building and retaining talent Cross-cultural sensitivity Service to clients and customers
Social Skill	Proficiency in managing relationships and building networks; an ability to find common ground and build rapport	Effectiveness in leading change Persuasiveness Expertise in building and leading teams.

Table 3: Taken from Dare to Lead (Brené Brown) the criteria for armored and daring leadership

Armored leadership	Daring leadership
Driving perfectionism and fostering fear of failure	Modeling and encouraging healthy striving, empathy, and self-compassion
Working from scarcity and squandering opportunities for joy and recognition	Practicing gratitude and celebrating milestones and victories
Numbing	Setting boundaries and finding real comfort
Propagating the false dichotomy of victim or Viking, crush or be crushed	Practicing integration – strong back, soft front, wild heart
Being a knower and being right	Being a learner and getting it right
Hiding behind cynicism	Modeling clarity, kindness, and hope
Using criticism as self-protection	Making contributions and taking risks
Using power over	Using power with, power to, and power within
Hustling for our worth	Knowing our value

Armored leadership	Daring leadership
Leading for compliance and control	Cultivating commitment and shared purpose
Weaponizing fear and uncertainty	Acknowledging, naming, and normalizing collective fear and uncertainty
Rewarding exhaustion as status symbol and attaching productivity to self-worth	Modeling and supporting rest, play and recovery
Tolerating discrimination, echo chambers and a "fitting in" culture	Cultivating a culture of belonging, inclusivity, and diverse perspectives
Collecting gold stars	Give gold stars
Zigzagging and avoiding	Straight talking and taking action
Leading from hurt	Leading from the heart

To be brave you need courage. According to Brown the four skills of courage are:

- Rumbling with vulnerability.
- Living our values. When it's clear what a leader believes, they need to make sure that their intentions, actions, thoughts, and behaviors align with them.
- Braving trust. One can earn trust by encouraging others to open up and providing a safe space for to disclose ourselves. Of course we must be willing to disclose ourselves as well. It also means that trust often doesn't come before vulnerability. Another important part in trust is being honest or as Brown states "Clear is kind. Unclear is unkind."
- Learning to rise. This is all about the way we respond to fear and failure. Will we see this as a learning situation which will make us grow, or are we going to blame or please others.

To summarize and show the relationship between these four skills, Brown states "The greatest barrier to courageous leadership is not fear—it's how we respond to our fear. Our armor—the thoughts, emotions, and behaviors that we use to protect ourselves when we aren't willing and able to rumble with vulnerability—move us out of alignment with our values, corrode trust with our colleagues and teams, and prevent us from being our most courageous selves."[18]

18 reference from Brown was extract for the website: https://daretolead.brenebrown.com

Another point of view on being an effective leader is by former Navy Seal Jocko Willink in his book Dichotomy of Leadership[19]. The essence of this book is about finding the balance in leadership, in understanding when to lead and when to follow; when to take action and when to let things develop; when to detach and when to micromanage. He states, in very clear language, that a good leader must be:

- confident but not cocky
- courageous but not foolhardy
- competitive but a gracious loser
- attentive to details but not obsessed by them
- strong but with endurance
- a leader and a follower
- humble but not passive
- aggressive but not overbearing
- quiet but not silent
- calm but not robotic
- logical but not devoid of emotions
- close with the troops but not so close that one becomes more important than another or more important than the good of the team; not so close that they forget who is in charge
- able to execute extreme ownership, while exercising decentralized command
- a good leader has nothing to prove, but everything to prove.

As you might recognize as we did while reading the studies and good practices from the field, leaders need to have a goal, a direction, and a vision that they want to achieve, but also need to show honest human behavior to be able to influence people in the right direction.

So, when choosing the security leader for your organization, think about what other areas of expertise can teach us. Since digital security is not just a small task that can be done by just one person, leadership becomes more than essential to face the internal and external security

19 *The Dichotomy of Leadership, Balancing the Challenges of Extreme Ownership to Lead and Win, Jocko Willink Leif Babin, 2018*

threats we are facing every day. Also consider the age in which we are living in the western world, where we have reached the top of the Maslow pyramid. People no longer follow you because you're the boss or because you pay them. To really understand the way current and future employees act, start working with millennials in your organizations. They have other incentives and habits than we or our parents had.

Stuck in the matrix

In practice we see that when the CISO finds something absolutely necessary to do, he finds him or herself dependent on the whims of the CIO and/or the manager of the department or Business Unit. Because, often, a CISO doesn't have their own budget or resources or can defend their own budget request to the CFO. If the CIO has other priorities or the manager finds it necessary to use the capacity of his/her people somewhere else, nothing happens. Or the CISO is squeezed or even worse overruled or bypassed by Business Unit CEOs when directives are not clear. The same goes for the digital security professional who wants to have security measures implemented and is dependent on people in the business or IT. An IT staff member might want to implement the measure but is caught up in the daily business or important projects. Helping the digital security professional is often seen as a "favor" that comes after the priorities of the CIO, IT Manager, or the business have been met.

In some cases, this is also caused by the perception by the business or management of IT since CISOs are often perceived as policemen, technicians who communicate badly. A well-respected HR firm once stated that 74% of CISOs don't have what it takes.[20] According to research by Deloitte 33% of current CISOs are technicians and 15% are seen as strategist. Also, a recent survey revealed that 74% of C-suite executives do not think CISOs should have a seat at the table or be part of their organization's leadership team. The sad thing is therefore that most current-day CISOs are merely "on the menu, but not at the table."

Please mind your own business

The situation described above is of course not only caused by the perception of the CISO, but often the result of the implementation of an inappropriate matrix organization. We also often see this in a project-based organization, where the project manager has a timeline and deliverables, but is dependent on the budget of the manager, who has other operational responsibilities.

20 *The CISO position faces many challenges. There is a general feeling among CEOs and others in the C-Suite that CISOs would be unlikely to succeed in other leadership positions outside of information security.https://www.boyden.com/media/cybersecurity-and-risk-management-170524/index.html*

A person in a matrix organization has two or more reporting lines: one to the hierarchical manager and one to the "functional" manager. To organize security in a large-scale or international organization, there is often no other solution than to implement the security organization in a matrix. To do it correctly, security needs to be a real part of the organization and should not be only a separate department somewhere located on the top floor of the head office building, as we often see with enterprise or IT architects.

So how can we improve this and no longer be stuck in the matrix? According to Herman Vantrappen and Frederic Wirtz[21], there are five ways to make the matrix organization work.

1. Adopt when purposeful. The matrix organization should only be used when it's necessary and when two conditions are met 1) there is a major need to coordinate on important business matters on a daily basis, 2) required coordination can't be achieved adequately through soft wiring only. When a CISO is responsible for digital security across all Business Units or departments, daily contact might be necessary and if there's a serious incident, these contacts can't be softly wired. They need to be in-person and frequent in that case.
2. Keep intrinsic conflict out. When groups are involved in a matrix, there might be a conflict between the two or more reporting lines. So, when defining the roles and accountabilities of the two matrix dimensions, make sure there are intrinsic reasons for them to collaborate rather than to compete. Make sure that a security officer in a Business Unit doesn't have to choose between the requirements of the CISO and the requirements of the Business Unit. We often noticed that when conflict occurs the person in such a matrix organization will almost always choose for the manager that has the most influence on their career or paycheck.
3. Limit breadth and depth. Don't make the matrix too complex by creating too many reporting lines for the people in the matrix. In general, one should limit this to two. In larger companies a security officer in a Business Unit might need to report to local management, the CISO, risk management, audit, etc. Make sure those reporting lines are limited to a maximum of two, where one is responsible for the development of the content (professionalism on dig-

21 Making Matrix Organizations Actually Work by Herman Vantrappen and Frederic Wirtz, HBR March 2016

ital security) and one is responsible for business contribution (e.g. net promoter score, new business, market growth, etc.) In this way, the security professional understands his or her business line responsibility as well as the responsibility to protect the organization.

4. Don't pretend. Make sure that the two reporting lines are fully balanced. So, the managers of both reporting lines must have a 50-50 ratio and not a 70-30 ratio. Vantrappen and Wirtz explicitly state not to use dotted lines in an organization chart, but full lines in different colors. So instead of the all-too-often dotted functional reporting line between local security staff in a department or Business Unit and the CISO, make this a formal reporting line. You can do this by drafting a clear target operating model with all parties involved and agree on objectives, timelines, and metrics before formalizing it with Human Resources in appraisal agreements.
5. Escalate by exception only. The manager of the different reporting lines should be able to make the decisions they need to be able to make without escalating to the other manager within the different reporting line. Within security this means that a CISO should have real authority and a mandate, and not be dependent on the budget and capacity of the line manager in the business unit or department. In practice we see that a decision of a CISO is often overruled by the person with the operational budget and the capacity. Our experience is that you can solve this by making sure the CEO or management of the unit supports clear objectives. We refer to the must haves of a company so that everybody understands these things must happen besides other strategic goals. Formulating "must haves" should always be a collaborative task between the CEO's management team and the CISO. In a matrix organization it helps that underlying relationships are well established.

Regarding the last two points a good comparison can be made to the Art of War. Sun Tzu makes a distinction between the Ruler and the Commander. The Ruler is the ruler of the state (cf. the manager in the business or in IT) and the Commander the commander of the army (e.g. the CISO). He states that the Commander must follow his own judgment, and not just follow any orders given to him by the ruler, who can't assess the situation as well as he can. Just as the commander must follow his judgment, not his orders, so the ruler must respect the authority he has given to the commander. Sun Tzu identifies three ways in which a ruler can confuse the army, lose the confidence of his soldiers, and invite the aggression of his neighbors: ordering

an advance or retreat when inappropriate; interfering with the administration of the army, or interfering with the military assignment.[22] So, think about what this means when a manager in the business or in IT interferes with the judgment of the CISO.

In addition to the problem of the matrix organization there is the problem of collaboration between people in different business units, silos, departments, etc. Although people may be part of a functional reporting line, they still might not have the incentive to collaborate. Although there might be a strong leader, a good strategy and clear roles and responsibilities in the matrix, people still might not feel inclined to collaborate outside their hierarchical group or they might think it's only a temporary assignment. To solve this, performance management across the two roles should be balanced as well.[23] One should be able to create shared goals and shared key performance indicators (KPIs) for the employee to make sure that the goals of both line managers are dealt with equally. As mentioned before, make sure the career of the people in the matrix is not just dependent on one of the two reporting lines.

The IT Policy Compliance Group reports that firms which standardize procedures and controls for digital security and manage digital security via dedicated digital security staff who are led by a CISO achieve 8.5% higher revenue than industry averages (n=3000 organizations).[24] This report also reveals – in benchmarks conducted during the past year – that one of the key factors influencing outcomes related to the loss or theft of customer data is whether a CISO is in charge of the digital security and assurance function of the organization. Recent studies by Accenture and Ponemon propose that the role of the CISO should be part of the CEO's Business Team. And companies that do this outperform others.[25] Our experience is that security staff who are sincerely engaged with the business and fully understand their line of business and how the company makes money are more likely to be involved in – new – projects and initiatives. This goes for the CISO and for the

22 *Total Competition, Lessons in Strategy from Formula One, Ross Brawn and Adam Parr, 2016, p91*

23 *The Helix Organization, Aaron De Smet et al, McKinsey Quarterly, October 2019.*

24 *TPC, "Best Practices for Managing Information Security," IT Policy Compliance Group, US, 2010.*

25 *Accenture, "The Cyber Security Leap: From Laggard to Leader," Accenture, 2015.*

Business CISOs (Business Security officers). Working on a mutual and very clear goal, e.g. a product or project with a clear "definition of done" helps teams in the matrix organization achieve success.

Will you take the blue pill or the red pill?

This famous sentence is taken from the movie "The Matrix." The red and blue pill represent a choice between taking either a "red pill" that reveals an unpleasant truth, or taking a "blue pill" to remain in blissful ignorance.

When designing the security organization, the following points should be taken into account:

- Only create a matrix organization when absolutely necessary. An organization where people only gather to "talk," but do not deliver results is not a reason for a matrix structure.
- Make sure the CISO has similar power over the people in the matrix as the hierarchal manager. This can be done via HR process and clear job descriptions that are endorsed by all line managers (CEO) from Business and Functional Units.
- Let the CISO do his or her job. Just like the hierarchical manager, the CISO should be sufficiently skilled. Interfering with that job is a recipe for disaster.
- The goals and incentives of the digital security department should be made part of the performance goals of the members in the matrix and should be similar to the goals of the hierarchy.

So before you decide to be part of the matrix organization make sure you prepare for some hard choices before you cross the Rubicon.[26]

26 Today, the phrase "crossing the Rubicon" is a metaphor that means to pass a point of no return.

Towards a high-performing security team

Nobody is perfect, my name is Nobody

Many of us think that we're the best, or at least in some cases better than others. Especially the people doing the more specialist type of work such as doctors, engineers, programmers, lawyers, etc., often think that they're better at doing their job than someone else. Also, they may tend not to share information or knowledge they have so that others can do their work better; they would rather see them fail.

Within digital security we see similar behavior. We observe strong individuals who usually think they are right and are better at doing the work than their colleagues. Although in some cases that might be true, still most of us probably don't think that Christiano Ronaldo or Lionel Messi can win the Champions League all by themselves. We also know that some soccer teams have big budgets and very expensive players; however, as we've seen in 2018, Ajax Amsterdam can still win against Juventus and Real Madrid, both of which have budgets that are between 4 to 6 times larger than Ajax. We've also seen that the star players at Ajax in that year were not always as successful as they were with Ajax when they moved to another club.

Information security teams of course don't need to win the Champions League, but on a daily basis they are facing battles at different levels that they need to fight and to win, sometimes with major consequences. They have the daily battles of making people do what needs to be done to be secure, they are often involved in internal and external audits, they face a daily battle with cyber threats, they face budget constraints, senior management who ignore important security risks, second-line information risk management departments that have their own approach to controlling digital security risks, etc.

So, what does this mean? This means, that either you need to hire Rambo or Terry Tate the Officer[27] or you start to make a team that collaborates and has the right skills to fight all of these

27 *Terry Tate: Office Linebacker was a series of short comedy television commercials created by Rawson Marshall Thurber, View via https://youtu.be/RzToNo7A-94*

battles. In this chapter we will first investigate what a great team looks like. At the end of the chapter we will provide some guidelines on how to create your own high-performing security team. You will also learn that the Agile way of working that your company follows helps but is not the reason that make teams successful.

SPARTANS! Prepare for battle! For tonight, WE DINE IN HELL![28]

I can do things you can't, you can do things I can't: together we can do great things.[29]

To get a good idea about what make teams successful, let us first take look at sports.

In Formula 1 there are two vital aspects required for a winning culture: 1) a no-blame philosophy, which is critical if you want individuals and teams to take risks and innovate, 2) the one-team mindset, where everyone is clear that ultimately they are all part of a single team and that learning is about improving the performance of that one team.[30] Those teams have several key traits that foster the type of teamwork that is required to win races. The members of the team:

- Share a clear, common goal
- Work at building trust
- Are willing to learn and collaborate
- Communicate openly and often.

From the 1992 USA Olympics Basketball team, also known as the "Dream Team," we can learn a lot on what makes a great team. One remarkable fact was that they didn't include Isiah Thomas in the Barcelona '92 team.31 Although he was one of the best guards during the NBA season, they decided not to include him due to the aggressive behavior he had shown during the season. His behavior could negatively impact the performance of the team as a whole, so he was

28 *Quote from the movie "300," Zack Snyder, Warner Bros that brings a winning spirit in a team*

29 *Quote by Mother Teresa to express what collaboration can bring us*

30 *Mark Jenkins et al, Performance at the Limit 3rd edition, Business Lessons from Formula 1® Motor Racing, 2016*

31 *In the Netflix documentary movie "Last Dance" with Michael Jordan, and described here is the full story of the US dreamteam and the decision to excluded Isiah Thomas from the team. https://en.wikipedia.org/wiki/1992_United_States_men%27s_Olympic_basketball_team#Isiah_Thomas_left_off_team*

left out. Some readers might remember this magnificent team and might think that the players themselves were at a level of their own, so they would never lose. However, history learned that although in 2004 the US still had the best basketball players (personal opinion), they nevertheless lost in the semi-finals against Argentina. In 2008 they won again, now as the "Redeem Team." You will notice that the name of the team implies a strong shared goal.

To explain the importance of the "Team," here is part of a speech by General S. Patton given to his troops in the United Kingdom in February 1944[32]:

All through your army career you men have bitched about what you call 'this chicken-shit drilling.' That is all for a purpose—to ensure instant obedience to orders and to create constant alertness. This must be bred into every soldier. I don't give a fuck for a man who is not always on his toes. But the drilling has made veterans of all you men. You are ready! A man has to be alert all the time if he expects to keep on breathing. If not, some German son-of-a-bitch will sneak up behind him and beat him to death with a sock full of shit. There are four hundred neatly marked graves in Sicily, all because one man went to sleep on the job—but they are German graves, because we caught the bastard asleep before his officer did.

An army is a team. It lives, eats, sleeps, and fights as a team. This individual hero stuff is bullshit. The bilious bastards who write that stuff for the Saturday Evening Post don't know any more about real battle than they do about fucking. And we have the best team—we have the finest food and equipment, the best spirit, and the best men in the world. Why, by God, I actually pity these poor bastards we're going up against.

All the real heroes are not storybook combat fighters. Every single man in the army plays a vital role. So don't ever let up. Don't ever think that your job is unimportant. What if every truck driver decided that he didn't like the whine of the shells and turned yellow and jumped headlong into a ditch? That cowardly bastard could say to himself, 'Hell, they won't miss me, just one man in thousands.' What if every man said that? Where in the hell would we be then? No, thank God, Americans don't say that. Every man does his job. Every man is important. The ordnance men are needed to supply the guns, the quartermaster is needed to bring up the food and clothes for us because where we are going there isn't a hell of a lot to steal. Every last damn man in the mess hall, even the one who boils the water to keep us from getting the GI shits has a job to do.

32 *https://en.wikipedia.org/wiki/George_S._Patton%27s_speech_to_the_Third_Army*

One excellent book about high-performing organizations was written by André de Waal.[33] We believe he gives many very important insights into what makes an organization, or in our case a team (which is a small organization) high performing. Many of these insights reflect on leadership, culture, HR policy, management style, etc. Based on extensive research he identified five validated factors, in which these insights have been included, that help to make organizations high performing:

- ***Management quality***: *Managers at all levels of the organization maintain trust relationships with employees by valuing their loyalty, treating smart people with respect, creating, and maintaining individual relationships with employees, encouraging belief and trust in others, and treating people fairly. They work with integrity and are a role model to others, because they are honest and sincere, show commitment, enthusiasm, and respect, have a strong set of ethics and standards, are credible and consistent, maintain a sense of vulnerability and are not self-complacent. They are decisive, action-focused decision-makers, avoid over-analysis and propose decisions and effective actions, while fostering action-taking by others. High-Performing Organization (HPO) managers coach and facilitate employees to achieve better results by being supportive, helping them, protecting them from outside interference, and by being available to them. Management holds people responsible for results and is decisive about non-performers by always focusing on the achievement of results, maintaining clear accountability for performance, and making tough decisions. Managers at an HPO develop an effective, confident, and strong management style by communicating the values and by making sure the strategy is known to and embraced by all organizational members.*

  When reading this first factor, we recognize many of the things we stated in the section on leading. This means, that to have a high-performing team, one first needs the right leadership. This is we believe not limited to just the one person we call the "leader" – it's also part of the role of every manager.

33 *André de Waal, What Makes a High Performing Organization – Five Validated Factors of Competitive Advantage That Apply Worldwide*

- ***Continuous improvement & renewal***: *The process of continuous improvement starts with adopting a unique strategy. After that, an HPO will do everything in its power to fulfill this unique strategy. It continuously simplifies, improves, and aligns all its processes to improve its ability to respond to events efficiently and effectively and to eliminate unnecessary procedures, work, and information overload. The organization also measures and reports everything that matters, so it measures progress, monitors goal fulfillment, and confronts the brutal facts. The organization continuously innovates products, processes, and services, constantly creating new sources of competitive advantage by rapidly developing new products and services to respond to market changes*.

  In other words, a team needs a security strategy or security vision to which everything that is done can be related to and progress is monitored and reported upon. It will however adjust the approach to respond to the changes we face daily in the security arena. We will talk more about this in the next section on strategizing.

- ***Long-term orientation***: *Long-term gain is far more important than short-term profit. This long-term orientation is extended to all stakeholders of the organization, that is, shareholders as well as employees, suppliers, clients, and society at large. An HPO also grows through partnerships with suppliers and customers, thereby turning the organization into an international network corporation.*

  To be successful the security team should focus on the long term. Of course, the issues and auditor's findings of yesterday are important, but to change and improve, focus on the future. As described by Hinssen,[34] we should focus on the "The Day After Tomorrow" which creates long-term value instead of focusing on the "Shit Of Yesterday" which actually only creates negative value. The following figure shows that we spend most of our time on today and things that went wrong yesterday, while the most value can be gained by focusing our time and energy on tomorrow and even better still the day after tomorrow.

34 *Peter Hinssen, The Day after Tomorrow: How to Survive in Times of Radical Innovation, 2017*

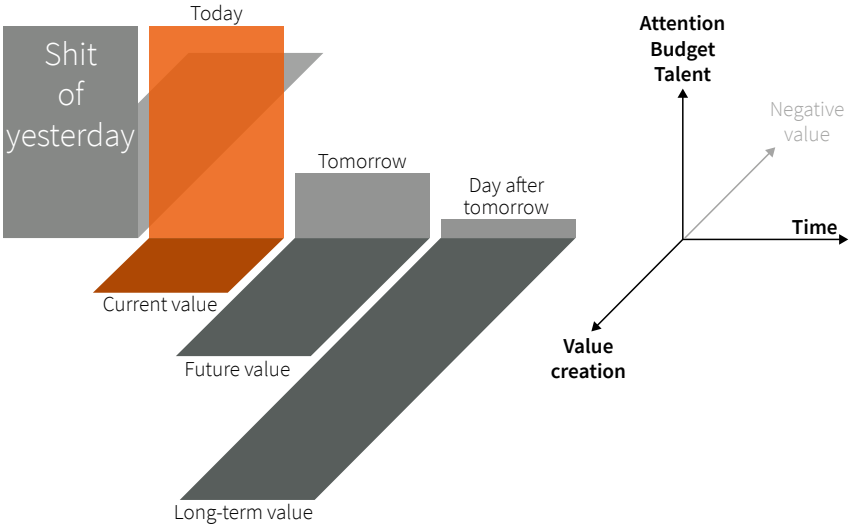


Figure 4 Managing the Shit of Yesterday (taken from Hinssen, The Day after Tomorrow).

Another important lesson is that, as a security team, you should never operate on your own. Build and maintain a relationship/network with your (security) providers and if possible, with your customers. Another good practice could be to build a network with your competitors or similar businesses, as we see in e.g. the financial sector. You can also read more about this in the strategizing section where we talk about "smart coalitions."

- ***Employee quality***: *An HPO makes sure it assembles a diverse and complementary workforce and recruit people with maximum flexibility to help detect problems in business processes and to incite creativity in solving them. An HPO continuously works on the development of its workforce by training staff to be both resilient and flexible, letting them learn from others, inspiring them to improve their skills so they can accomplish extraordinary results, and holding them responsible.*

For security teams this means that you don't need to look for just one type of person over and over again. You need to look for the best players in their field of expertise but those who are still flexible and eager to learn. You need a "security dream team" that consists of e.g. "John Doe" the white hat hacker, Professor "Robert Langdon" the compliance guy with a touch of boldness, "Templeton 'Faceman' Peck" the manipulator, "Ray Donovan" the fixer, and "Nelson Mandela" as the Leader. These best-in-class professionals all have different characters and their own set of skills but would create a team that has an answer for all issues that a security team might expect to face.

- ***Openness & action orientation***: *In an HPO, management values the opinion of employees by frequently having dialogues with them and involving them in all important business and organizational processes. HPO management allows experiments and mistakes by permitting employees to take risks, being prepared to take risks themselves, and seeing mistakes as an opportunity to learn. In this respect, management welcomes and stimulates change by continuously striving for renewal, developing dynamic managerial capabilities to enhance flexibility, and being personally involved in change activities.*

Again, a more significant part of this is what a leader should make possible within his or her own team and it's also part of what can be achieved while using the Johari Window (which you can read about in the next paragraph). We definitely support the insight of permitting employees to take risk. We too often see that people in large organizations no longer dare to take risk because they are scared of breaking the rules. Rules that are often just rules and don't really reduce the real risks, but they do limit speed, entrepreneurship, and profit (in some companies they even have specialized *Departments of Profit Prevention* for it). An approach we usually follow, when speed is of essence, is that when according to your common sense and gut feeling there is no reason not to do it, just do it without approval beforehand. Because what's the worst thing that might happen (besides getting things done quickly)? Usually the worst thing is that people will tell you that you didn't follow policy. Entrepreneurship is about taking risks, just as adding real value to the business as a security professional is about taking risks.

From the military we can also learn a lot about teams. As you have read in the speech by General S. Patton, the Army is a team and every team member has a vital role. After analyzing several books and articles about the military we have the following list of what contributes to a great team:[35] [36] [37]

- Trust between team members is key
- The leader trusts the members to handle the task
- Rehearse to familiarize everybody with all the things that could happen, what the relationships are, and how to communicate
- Have an overarching mission
- Communicate the mission
- Have the tough conversations
- Share the (personal) load that you might be carrying
- Core values and standards that reinforce those values
- Diverse opinions are valued
- Culture is considered when recruiting
- Over-communicate
- Embrace your team's knowledge
- Make contingency plans in case somebody is not present
- Teams can be more effective than individual team members
- Team cognitive processes play a significant role in team performance. What teams think, how team members think together, and how synchronized team members are in their perceptions and beliefs all significantly contribute to a team's ability to perform well.

35 *Teamwork and Leadership lessons: https://www.atlassian.com/blog/teamwork/teamwork-and-leadership-lessons-from-the-military*

36 *Gerald F. Goodwin et al, The Science of Teams in the Military: Contributions From Over 60 Years of Research, American Psychologist, 2018, Vol. 73, No. 4, 322–333*

37 *Daniel McGinn, What Companies Can Learn from Military Teams, HBR August 06, 2015, interview with Gen. Stanley McChrystal*

The leadership of the team has, of course, a significant impact on the team's performance. In "Turn the Ship Around" by David Marquet[38] he introduces leadership at every level of his team. The traditional style of leadership is "leader-follower," where orders are given and expected to be obeyed. As a result people who are treated as followers behave like followers, with expectations of limited authority and no true incentive to give of their best. Marquet decided to implement his own "leader-leader" approach among his submarine crew. On his submarine he believed that leaders should be at every level of an organization. Rather than delegate responsibilities, Captain Marquet helped the crew develop their own proactivity and ownership. As a result, his crew embraced playing to their strengths and became an effective, high-performing crew.

Another interesting piece of research is Google's five-year study of highly productive teams. Google found that five key dynamics set successful teams apart from other teams at Google:[39]

1. Psychological safety: Can we take risks without feeling insecure or embarrassed?
2. Dependability: Can we count on each other to do high-quality work on time?
3. Structure & clarity: Are goals, roles, and execution plans clear?
4. Meaning of work: Are we working on something that is personally important for each of us?
5. Impact of work: Do we fundamentally believe that the work we're doing matters?

In one of the speeches by Simon Sinek,[40] he discusses performance vs. trust. He found that Navy Seals – the highest performing teams in the world – choose team members with "Medium ability with high trust" over "high ability with low trust." While "*in business, they give bonuses to people who sacrifice others so that they may gain*." When thinking about the latter, one can hardly imaging that this situation is good for creating high-performing teams.

38 L. David Marquet, Turn the Ship Around, 2015

39 https://rework.withgoogle.com/blog/five-keys-to-a-successful-google-team/

40 https://www.youtube.com/watch?v=Y4dyADuYfbg

To know thyself is the beginning of wisdom[41]

The Johari Window is a technique that helps people better understand their relationship with themselves and others. It was created in 1955 by Joseph Luften and Harry Ingham.[42]The name is derived from the first names of the creators. The Johari Window can help people to understand their communication with each other better.

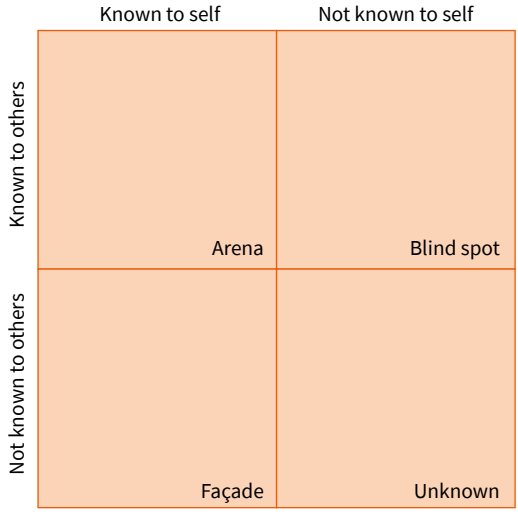


Figure 5: Johari window

The objective is to enable an individual to develop trust with others by disclosing information about him or herself and also to know how others feels about him or her through feedback. We mention this here since teams need to rely more and more on each other and their interactions inside and outside the group. When dealing with digital risks and security issues, a culture of openness, transparency and lack of blame is essential. Only then will people open up and the organization can learn and improve. Our experience is that by using the Johari Window in

41 A quote from Socrates

42 Luft, J., & Ingham, H. (1961). The Johari Window. Human Relations Training News, 5(1), 6-7.

teams enables openness, constant feedback and this improves learning and generates new insights. The Johari Window is a handy tool to reflect on individual capabilities and pitfalls. It consists of four quadrants that explain the overall relationship of an individual with him or herself and with other group members.[43] We define the following spaces:

Open space: known to you – known to others ...

This open space is about behavior that is known to you and is also seen and recognized by others. This can be communicated about in teams and between individuals. Yet it appears that sometimes there is behavior that is annoying for the environment that someone knows best about. Our experience is that extrovert technicians do "too much tech talk" and others therefore lose interest. The moment they are approached, they find it it's difficult to acknowledge that and it also could lead to behavior such as avoidance, aggression or backing out. Patience and caution are required to address this behavior.

Blind spot: unknown to yourself – known to others ...

The blind spot can be very annoying and causes others to talk about you. After all, others are aware of something that you yourself do not know about. For example, in our field body odor, the frequent use of abbreviations or the exaggeration of technical skills. The blind spot can also occur in the workplace; for example, a person doesn't can't realize that he or she works much slower than his colleagues. The others know this, which can lead to irritation. If feedback is not given in the right way, he or she will be stuck in old behavior and there is a good chance of falling outside the group. This goes for the micro level in teams, the meso level in departments or Boards and the macro level with working groups or external cyber committees.

Hidden area: known to yourself – unknown to others ...

Here people can keep certain information to themselves and not share it with others. For example, a team member hides that he or she has debt, mental issues, or dyslexia. This area

43 Verklan, M. T. (2007). Johari Window: a model for communicating to each other. The Journal of perinatal & neonatal nursing, 21(2), 173-174.

may be unknown to a limited number of others. Teams which openly share their interpersonal challenges such as dyslexia help others gain an understanding of the consequences but also encourage dialogue to help each other. For example, asking someone else to read or write the security policy rather than exercising power and causing stress. In that case, this hidden area slowly shifts to become an open space.

Unknown area: unknown to yourself – unknown to others ...

There is no communication about this area. Purely due to the fact that both parties are not aware of it and therefore it's not a topic for discussion.

If someone exhibits behavior that is perceived as difficult by the environment, then it's good to give this person feedback on this. It's very difficult for many to talk to others about their behavior. People are not always aware of their own behavior or they are aware of it, but won't admit it. Feedback is an appropriate way to address someone about their (disruptive) behavior. The Johari Window can help with this. It gives you insight into the actions of others, in combination with your own actions. It also enables personal development plans and continuous dialogue on hidden behaviors with both extrovert and introvert people.

Although the Johari Window provides the basis for clear information, it's of course not necessary to discuss everything in the open. If certain information is in the open space, it can still be confidential information that doesn't have to be out in the public space. In that case it concerns information that may or may not be made public. The Johari Window is very effective and can be used to tackle minor conflicts, negotiations, or incomprehension, among others. By asking open questions and entering into a dialogue with each other, the various parties can find out what someone's ideas, opinions and motivations were, which forms the basis for his or her actions. The blind spot then moves into the open space and there will be more respect for each other's opinions.

We personally used this to draft development plans for the Business Security Officers community so they can help each other but also exchange content knowledge. Based on these insights we address a couple of experiences from our profession that either limit or support a person.

- Deep technical knowledge (Johari window called the Arena, where you feel comfortable) versus a lack of empathy (blind spot)
- Results-driven (arena) versus no patience (blind spot)
- Super smart and analytical (arena) versus poor ability to understand the emotions of others (blind spot)
- Targeted (arena) versus vs non-punctual/precise (blind spot)
- Task-oriented (arena) versus lack of ability to abstract (blind spot).

We have also had meaningful conversations with Business Security Officers about their challenges in their own Business Unit. This helps them to exchange thoughts, offer each other help (more people know more than just one) and share common problems and solutions to these problems. Our experience is that 90% of these problems are in mindset and not in their environment or people close by. Often these problems are caused because they think that others are against them. We always say that in general "people are not bad; they act a certain way because they have different drivers," or as Patterson, Grenny, McMillan, and Switzler[44] put it: *Every sentence has a history. To better understand why we have these difficult conversations with others they mention that: "When mutual purpose is at risk, we end up in debate. When others start forcing their opinions into the pool of meaning, it's often because they figure that we're trying to win and the need to do the same." Another important lesson to better understand our own feelings and behavior is: "Just after we observe what others do and just before we feel some emotion about it, we tell ourselves a story. We add meaning to the action we observed. We make a guess at the motive driving the behavior... Since we and only we are telling the story, we can take back control of our own emotions by telling a different story."*

44 *Crucial Conversations – Tools for talking when the stakes are high" (2012 – 2nd edition) by Patterson, Grenny, McMillan, and Switzler*

Most the limitations can be mastered by changing mindset and have a group of like-minded people support you. That is why in practice we organized quarterly off sites and we spend lots of time on the inner person and how we interact with our self and each other.

An interesting read on creating a mindset for success is the book *Mindset – The New Psychology of success,*[45] *which includes some interesting views on how to motivate young people: "Rather than praising children for their personality or innate and permanent attributes, we should instead praise students for their growth oriented processes, what they accomplish through practice, study, persistence, and good strategies. It's even better to ask them about their work in ways that appreciate their effort and choices. "Praising children's intelligence harms their motivation and it harms their performance."* This means that we should support people's growth and not just assume that people can't do things because they're not good enough.

When selecting Business Security Officers or new security candidates or professionals, besides mindset, we seek signs of pessimism, complaining and optimism. In other words behavioral aspects that reflect a certain mindset. Sometimes these things are subtle, while at other times they are very explicit. For example, if the candidate complains about his or her boss, job, mandate, or current employer, then that is a sign of carping. Now, a little of that can be natural in an interview (he or she is changing jobs for a reason), but if the candidate goes there without prompting or comes back to it throughout the interview, we know you're sitting with a duck at the table. Adding "eagle or duck" to the interview criteria is an important hiring plan criterion, as well as assessing whether your team is a duck pond.[46]

45 *Mindset – The New Psychology of success," (2020 3rd edition) by Carol Dweck*

46 *See https://video.londonbusinessforum.com/detail/videos/hr-heroes/video/1932187262001/ken-blanchard---ducks-and-eagles?autoStart=true*

Don't be the Duck

In the Cyber security arena, we see many self-proclaimed security gurus in the media these days making a day job out of chasing ambulances. For those who don't know the term, an ambulance chaser is somebody looking for a victim and telling them what went wrong and why they should do better next time. For example, a lawyer who seeks to encourage and profit from the lawsuits of accident victims[47]. After a security incident or breach, most of them will tell the world how easy it was to prevent such an incident (e.g., the Kaseya, SolarWinds, and Maersk incidents were parroted by countless security "gurus" on LinkedIn). The incentive is often to chest pound themselves and prevails above others to sell themselves, a service, or a product. You can ask yourself, are these people who have or had end responsibility for cyber security? Did they experience a severe security incident themselves? Or do they have hands-on experience in actually fixing the damage after the proverbial "Shit has hit the Fan"? Or are they bystanders, coaches, or advisors? They perhaps never did more than just assess and advise or have never been responsible for securing things. We consider these bystanders to be "Duck" whereas "Eagles" really Lead cyber security towards success in their battle against the silent enemy.

Eagles and Ducks

As mentioned before, we don't think a negative approach will help bring security to the level we need. A clear explanation about these types of ducks is given by Dr. James Reese in "Ducks and Eagles"[48]. Eagles are strong, take care of others, and deliver results; ducks walk around quack, looking for leftovers, making noise about everything, and only responding if they are poked. They complain about everything and do that clamorous.

In Cyber Security, you can recognize Ducks by their focus on following processes and policies, complaining about budget and lack of mandate, not being able to sell the message internally, and thinking and acting out of the silo. Some examples of the behavior of the Eagles in Cyber

47 *https://www.thefreedictionary.com/ambulance+chaser, The origins of this phrase date from 1897, from newspaper articles about attorneys seeking clients through targeted mail solicitation. "Ambulance chasing" was one of the descriptive phrases employed by the media for this activity. It later became a derogatory term for direct advertising.*

48 *https://www.youtube.com/watch?v=e5jYAVTaopY. This video from Dr. James Reese explains the difference of leaders and servants and the parallel to Eagles and Ducks in the bird-kingdom.*

Security: They cover the entire empire, know important stakeholders, understand the forces they operate in (see also chapter Strategizing on Porter's 5 Forces Elements for a Digital Security Strategy), and are razor sharp on innovations, silent enemies and leads the group including their bosses.

As you can imagine, the ambulance chasers parroting each other fall into the Duck category.

In general, we understand that we are not all eagles, and you sometimes need a duck for the right biodiversity in the bird kingdom. However, business leaders like to work with eagles, are focused, razor-sharp, goal-oriented, and deliver results.

We've developed six traits for cyber security experts to become eagles and to lead and deliver on the promise.

Be Humble

A survey of 105 computer software and hardware firms revealed that humility in CEOs led to higher-performing leadership teams, increased collaboration and cooperation, and flexibility in developing strategies[49]. Also, Jim Collins found two common traits of CEOs that change companies from average to superior market performance: humility and an indomitable will to advance the cause of the organization[50]. Humility is not thinking more highly of yourself than you ought. So, it's better to show actual results than just discussing what might be.

Show Character

Like the Eagle, you need to show character. Show Ownership, Authenticity, Craftsmanship, and an inborn will to learn. Live by solid values, act with integrity, show empathy to others, have the discipline to perform consistently, and be a warrior. This also means being honest about your limitations and knowing when to ask for help. We learn a lot from talking to our peers and

49 *Do Humble CEOs Matter? An Examination of CEO Humility and Firm Outcomes, Amy Y. Ou, David A. Waldman, Suzanne J. Peterson, September 21, 2015, Journal of Management*

50 *Good to Great – Why Some Companies Make the Leap… and Others Don't, Jim Collins, 2001*

especially share what didn't go so well with them. Ultimately, this character will yield the proper gravitas that will persuade people to listen and collaborate.

Be an Intellect

This means that you need both IQ and EQ. IQ relates to the power or faculty of the mind by which one knows or understands and certainly doesn't mean that you have the most titles before or after your name (although certain institutes will tell you the opposite since they make money out of this). IQ also means mental agility, the ability to adjust quickly to new ideas or uncertain situations; sound judgment, objectively and well calculated; innovative; interpersonal tact to interact with others effectively and have expertise. Expertise means having the right technical or theoretical skills and know-how and the expertise to collaborate effectively. IQ without EQ is, therefore, a dead-end. EQ is the ability to recognize emotion in yourself and others and to use that awareness to guide your reactions and decisions, and, in essence, the ability to "read" and "influence" others.

Develop others and yourself

Life is a rollercoaster. You can either fight change or embrace the opportunity to learn more. We all know that adapting to change is the best way to survive, so stay foolish, and hungry[51] and be your critic. Also, make sure that you create a positive environment for others to develop because your team will never win if you want to remain the best of the pack. Consider training people "on the job" in line with the 70:20:10 principle from Charles Jennings[52]. This principle assumes that a working professional learns 70% through non-professional trainers or teachers. For example, from colleagues, friends, and relations in the working environment. We learn 20% through coaching and mentorship and 10% through formal training and courses.

51 Based on the Steve Jobs commencement speech at Stanford University in 2005 "Stay foolish, stay hungry"

52 https://702010institute.com/author/charles/. In this article Charles Jennings explains the 70/20/10 learning rule on how to adopt to knowledge.

Take Ownership and Show results

In the end, it's all about results. You're not making any progress by constantly telling what others are doing wrong or producing PowerPoint slides with advisories or scenarios that can or will unfold when these will only happen in theory or as perceived black swan scenarios. You make progress by taking ownership of the problem, the design of the approach to solving it, the goals, and, ultimately, the delivery of tangible results. In some cases, you probably cannot deliver results for whatever reason. When you do, take ownership and be sincere, even if that means that it's time for you to move on or go. As Nelson Mandela said, "The greatest glory in living lies not in never falling, but in rising every time we fall."

Spend more time Upstream preventing the silent enemy than downstream chasing him away.

An eagle selects a perfect perch to spot his next bit of food. This perch is carefully chosen by applying experience and inbred cunningness. He also takes his time before leaping into action. All this has to do with the capability of prework and study of the environment so that he covers all the angles. On the other hand, the duck lives only downstream; they do no pre-study and hence do nothing that looks like planning. In his brilliant best-seller Upstream Dan Heath[53] says, "Be impatient for action but patient for outcomes. The world is full of groups who engage in lofty discussions, like Ducks – and feel virtuous doing so – but never create meaningful change. Change won't come without upstream action." Therefore, being an Eagle, as per our definition of cyber war against the silent enemy, means being an upstream hero, a moment maker, and the go-to expert for the whole organization.

When eagles are silent, parrots begin to chatter[54]

In this book's final chapter, we generate 12 crucial lessons to combat the silent enemy. Those are the enemies we can't see with our own eyes, but we know, feel, and sense that it is there. The eagle sees and hears his target from miles away. To win this cyber war, we need more diligent, razor-sharp minds, determined mindsets, and craftsmen to observe, address, and deal

53 *https://danheath.com/*

54 *"When eagles are silent, parrots begin to chatter" Winston Churchill (British politician and Prime Minister, army officer and writer)*

with an issue or incident, an Eagle, we would say. These people deliver tangible results and often don't have the time to celebrate them. They are servant leaders who are busy enabling the business by removing security measures where they can be removed. They form coalitions inside and outside the company and orchestrate security impact throughout the supply chain. These people usually don't just stand and watch (and tell afterward what went wrong) during a crisis, but they act without going for fame. So, let's stop chasing that ambulance and listen to truly understand how you can learn from your own and other's mistakes.

Key takeaway messages on leading

As you may have learned from sports, the military and extensive research on companies and leadership, the way team members collaborate has a major influence on how the goals of cybersecurity are achieved.

To close this section, we offer several takeaway messages:

1. Make sure you understand what leadership is and what this means for achieving your defined cybersecurity goals.
2. Identify the type of digital security-leadership your organization needs based on a self-assessment. Also try to understand yourself, your talents, and areas where you can improve. Determine what you're best at and where others need to fill in your gaps.
3. Be passionate and humble.
4. Develop and repeatedly communicate a compelling vision. This shared vision or goal for digital security needs to be aligned so that people understand why this is important and how in its connected to the overall goals and values of the organization. (see the following section "The Golden Security Circle" for more information to create a Security Vision)
5. Find the right people for your A-Team. Appreciate each other's knowledge. It's better to have a team with people who aren't the same, but rather complement one person's weakness with the other person's strengths. Think about all the battles the security team is fighting. Hire the right people in terms of knowledge and personal skills, not necessarily the best. Underperformance is of course not accepted.
6. Find the balance between "giving" and "taking," between "controlling" and "letting go," between "leading" and "following." Don't over-control everything. Focus on what's real important. Try to empower others, give them responsibility, and hold them responsible.
7. Make sure there is trust between the members of your team and toward your leader. This means not only that people can rely on each other, but also that they share their personal "load." For this the "toughness" of the team members sometimes needs to be replaced by being vulnerable toward each other. Sometimes security professionals need to be a bit less techy and a bit more emotional by opening up and starting meaningful conversations. Be

open and honest to each other and give the necessary feedback so that everyone can improve.

8. Create core values that are important for the team and aligned with the organizational strategy and core values.
9. Collaboration starts on the inside – within the team and then it spreads out to the rest of the organization and finally outside the enterprise (to customers, partners, suppliers, and the competition).

The Golden Security Circle

An example of how to get to a Security Vision

A common practice in Digital Security is to improve the level of security by implementing a framework (e.g., ISO27001/2, ISF, COBIT, NIST, etc.). Deficiencies in compliance with these frameworks are then defined and improvements can be executed. These improvements are defined in a security plan, which is sometimes misnamed as a security strategy.

The main misconception is that this Framework implementation is a vision or a strategy, where it is only the remediation of the Framework. The same goes for words like "zero-trust" and "confidential-computing," which are dropped randomly. But these are not visions; these are basically (very good) strategic approaches to securing data that require a change of mindset, leadership, and craftsmanship.

Vision and Strategy

*The **Vision** is a goal. It is not the same as a **Strategy**; business strategy tells you how a company will achieve (or maintain) its **Vision**. The **Strategy** is a plan, the **tactics** are how the plan will be executed, and the Vision is the result*[55].

The problem with the above-mentioned Digital Security "strategies" is that they won't resonate with the people executing the "strategy," often leading to unsuccessful results (e.g., results are delivered too late and without a lasting result). One of the main reasons for this is that there is no clear vision or no vision at all for digital security that forms the basis for the "strategy". According to John P. Kotter[56], one of the eight reasons changes fail is the "lack of a Vision." Another reason why change fails is "Under-communicating the Vision."

55 Explanation about the difference between vision and strategy described on https://www.dougsguides.com/vision
56 Leading Change: Why Transformation Efforts Fail, John P. Kotter, Harvard Business Review, 1994

(In chapter 3, paragraph *Eight Reasons why changes fail*, we discuss these reasons in more detail)

Most digital security plans also consist of multiple changes that need to be made in the technology, processes, or people. Therefore, a Security *Vision* is required to change successfully and embed digital security more sustainably.

Since we noticed in practice that some security professionals think a "compelling" security vision is something like "*we need to comply with ISO27001 or COBIT*, " *we will shed light on creating and communicating* a more compelling vision than just compliance.

The "why"

A well-known management model that can assist in creating a compelling vision is the "golden circle" by Simon Sinek. Sinek became famous with his TED talk and book "Start with Why: How great leaders inspire everyone to take action.". The essence of his Talk and book is that "people don't buy what you do, they buy why you do it. " As a short recap, the most well-known part of the talk is:

If Apple were like everyone else, their marketing message might sound like this: "We make great computers. They're beautifully designed, simple to use, and user-friendly. Want to buy one?" "Meh."

Indeed, uninspiring. Then, the way Apple does it:

"Everything we do, we believe in challenging the status quo. We believe in thinking differently. The way we challenge the status quo is by making our products beautifully designed, simple to use, and user-friendly. We just happen to make great computers. Want to buy one?"[57]

57 *https://www.youtube.com/watch?v=qp0HIF3SfI4. In this TED talk from Simon Sinek the Golden Circle is explained*

As an example, below, we give a digital security vision based on our belief that human behavior, either a regular employee, IT user, or IT administrator, is the key differentiator in making digital security a success.

An Example:
We believe the key differentiator in making our company more secure lies in ourselves and our behavior. The way we try to accomplish this is by overcommunicating and training our staff in digital security to get secure behavior in everyone's DNA. We train to recognize threats and behave securely, implement clear reporting lines, and have solid standard operating procedures to prevent, detect, respond, and recover from an incident.

Involve relevant staff

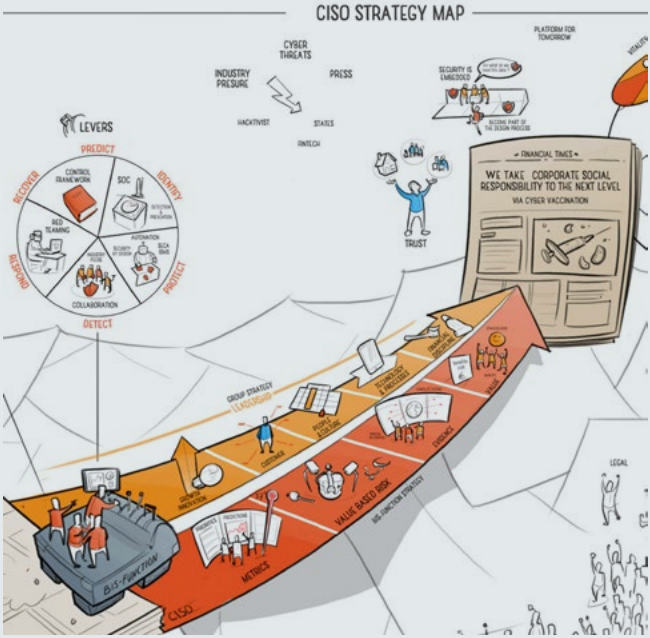
Next to the "attractiveness" of the Vision, it is also essential to involve relevant staff in establishing a compelling Vision. When doing this, involve security staff in the visioning process as well as staff from IT, HR, and the most crucial business processes. This will help you create a vision that more people than just the security staff understand.

One of the working methods we often use in workshops is the "Letter from the Future"[58]. In this working method, the participants write a letter to themselves from the future. The letter describes where they are, what they are doing, and what they did to get there. The participants can also advise themselves. In the session, this is discussed and used to work out actions that can realize an ideal situation in the future. Next to the Vision, this could also give a first idea about the strategy that needs to be followed.

58 *Sasja Dirkse-Hulscher, Angela Talen, Het Groot Werkvormenboek, dé inspiratiebron voor resultaatgerichte prestaties, vergaderingen en andere bijeenkomsten, September 2007, Boom*

A somehow similar approach, called “working backward,” is followed by Amazon[59]. A product owner starts by writing an internal press release about a finished product instead of starting with an idea for a product and trying to sell it to customers. The target audience is the customer. If the benefits mentioned in the press release aren’t very interesting or exciting to the customers, the product will most probably not be built.

Next to this working method, we often visualize the Vision and high-level strategy. A cartoonist is very well trained in visualizing the vision and ensuring the message is understood by everyone who reads it. An example of such a visualization is given below. This example is part of a larger strategic map used with permission.



59 *https://www.quora.com/What-is-Amazons-approach-to-product-development-and-product-management/answer/Ian-McAllister*

Quantum-Communicate

As mentioned by Kotter, Overcommunicating the Vision is also of the essence to make any change a success. As noted by Sinek the Vision also needs to be compelling to have people believe the Vision. Next, the message needs to be tuned to the different target audiences.

The article "Communicating a Corporate Vision to Your Team" describes the need to tune your message to the target audience[60]. It is noted that there are two essential things when you want to communicate a vision. First, you have to target your message. IT has different needs than marketing, HR, customer service desk, etc. Second, augment logical reasoning with an emotional appeal to inspire. That's how you get buy-in and shift the team's response from "I have to" to "I want to." It's common knowledge in many management models that if people "want it," change can happen. In summary, the writers use the following four steps to put people into action:

- **Think about your audience** – What do they care about the most?
- **Target the message to their needs** – how is the vision relevant to them?
- **Lay out action steps** – What are specific, measurable goals and deadlines?
- **Engage their emotions** – How will they benefit from being part of a dream?

Conclusion, "I Have a Dream"

Having a Vision is relevant for an entire organization and every change you want to make. Next to having a vision, over-communication the vision in a compelling manner that is tuned to the audience and has emotional engagement, is an absolute must to change people's attitude from "I have to" to "I want to."

60 Kelly Decker & Ben Decker, Communicating a Corporate Vision to Your Team, HBR, July 10, 2015

“Everybody has a strategy until they get punched in the mouth”

Mike Tyson

02

Strategizing

Introduction

In the literature, strategy generally involves setting goals, deciding on actions to achieve the goals, and mobilizing resources to execute the actions that contribute to realizing a vision. In practice we observe security leaders not having a vision but a list of activities. Before we dive into some elementary strategic perspectives and ingredients for a strategic plan, we sketch the current landscape.

In the practitioner and academic literature, the solution to solving information security risks lies in strategic planning, in directing and controlling predefined deliverables or outcomes. But what are the key differences? Strategy is a method or plan chosen to bring about a desired future, such as achieving a goal or solving a problem. In most cases strategic planning is not strategic thinking. Confusing these two can be misleading. Strategic thinking about the desired outcome is a topic that is usually discussed by "Boards." Executing (planning, monitoring, evaluating) the strategic plan to achieve these goals is the role of executive management.[1] This confusion lies at the heart of the issue: i.e. most successful strategies are visions, not plans. Mintzberg states: "*When companies understand the difference between planning and strategic thinking, they can get back to what the strategy making process should be: capturing what a manager learns from all his sources and then synthesizing that learning into a vision of the direction that the business should pursue.*"[2]

According to Ross Brawn, former Ferrari Formula One Team Principal and Brawn GP winning in total eight constructors' championships and eight drivers' championships, and Adam Parr,

1 *The Von Solms brothers wrote a paper on Information Security Governance; A model based on the Direct Control Cycle.*

2 *The Fall and Rise of Strategic Planning by Mintzberg (Harvard Business School)*

Strategy has three perspectives: political, economic and technical.[3] The technical part of digital security is about having the right people, processes, and technology. The economic part is about the funding of security and the political part is about influencing internal and external stakeholders.

Practicing information security as a strategic topic has been addressed by Von Solms and Von Solms. They emphasize the leadership role that Boards need to take ownership to articulate a security vision but usually this is not done by the board and not by the CISO.[4] The peculiar thing is that when CISOs are not doing it, then who else is? A study by Sveen points out that establishing a vision based on strategic thinking requires adequate knowledge and can hardly be done by someone who has limited knowledge about the context and resources.[5] Such knowledge gives meaning to the implications of the strategic plan, in the form of time, money and resources. And it indicates the interrelationships between stakeholders. But if the CISO is not doing it, who is actually doing it? Before we answer that question, it's important to understand why traditional security strategies fail.

Information security strategy is about everything but the plan

As mentioned, most of the security strategic frameworks and models are focused on creating a guideline for implementing controls in processes, technology, and human resources. Most of these framework lacks intangible factors such as resource capabilities (ownership, craftsmanship, tech capabilities), leadership requirements in certain stages (e.g. a change strategy requires another leader), the political arena and the required lobbying that needs to be done prior to talking about the security plan and finally an understanding of absorption capacity. If you're, for example, implementing a security program that is parallel to a large merger you don't have to be a rocket scientist to know what has priority. I'm surprised by the number of securi-

3 *Total Competition, Lessons in strategy from Formula One, Ross Brawn and Adam Parr, 2016*

4 *The 10 deadly sins of Information Security Management by the Von Solms Brothers*

5 *Blind information security strategy is a paper written by Sveen, F.; Torresa, J.; Sarriegia, S.J. based on empirical studies in Spanish critical infrastructure companies.*

ty professionals who complain that businesspeople do not understand the need for security. Could it be that they simply do not have empathy for someone else's agenda? Or are they not capable of activating the intrinsic motivation of others and therefore feel ignored? We often use the strategic theory of the Art of War. "*Victory is envisioned not as the result of brilliant battlefield decisions, personal courage in leading assaults, or blind luck. Rather, the "expert in battle" never wins an extraordinary or exceptional victory. The ideal commander knows to fight only when victory is certain, and hence victory is routine. Determining the certainty of victory is largely a matter of understanding hsing*[6]."

When drafting and executing a strategy, understanding your leader's capabilities, regardless of whether you or someone else is the leader (e.g. CISO), is vital for success.

We don't want to repeat all the other more architectural or technical strategic frameworks from bodies such as NIST, ISF or the Information Systems Audit and Control Association (ISACA), but we want to emphasize four topics that seem to be lacking in practice.

Courage

Sun Tzu introduces the characteristics of the ideal "expert in battle," who has "wisdom, integrity, humanity, courage, and discipline." Let's peel these off based on our own observation in the field of drafting the strategic plan, executing it, and communicating it. As mentioned before, a strategic leader must be capable of drafting a strategic plan where he or she engages with all stakeholders and collects important requirements and objectives. Thus, it's important to consult and engage with sources such as intelligence services (AIVD, MIVD, CIA, NSA), important regulatory bodies and policy-making bodies at an early stage. Understanding their priorities or key items and translating them into a strategy is hard and therefore rarely done. The reason why leaders often do not do this is because the functions of these institutions are simply not known to them and another reason is that both parties are often hesitant to disclose agendas. Very few security leaders or companies actively share intelligence, breach or near-loss data. Simply

6 *Hsing is strategic positions, a central concept in Sun-Tzu's military theory*

because they don't want to expose what has happened with them or they feel like losers. So, a little bit of courage to open up and exchange mistakes can be a valuable source of learning. For example, in the Dutch healthcare sector bad practice and mistakes are made publicly available with the goal of improving healthcare quality, but in practice we observed this is not always the case in digital security.[7]

Resource capabilities

Another good practice we rarely observe in security is checklists. In healthcare and aviation, the use of checklists is mandatory prior of releasing a patient or an airplane taking off. We have often met security professionals relying on their memories and professional judgment. We simply do not believe in that. When working in an IT factory or Security Operations Center it's cumbersome to absorb, digest, interpreted, structure, memorize and reproduce the hundreds of procedural steps and checks you need to follow. Let alone in an incident when stress levels are higher, and your blood is not in the brain but in the heart pumping to vital organs in order to survive the event. Thinking clearly and keeping your cool is simply harder in stressful situations. Thus, relying on predefined checklists appears to be a "best practice" that has proven successful in the medical, aviation and automotive industries. In the chapter "Discipline equals Freedom" in the section on Changing you can read more about the use of checklists within these other types of businesses.

We have often asked why IT and security people are not disciplined enough and don't want to draft and work with checklists. We once experienced someone who needed to leave the crisis site to pick up his kids. We don't think a nurse whose patient is in critical state on the IC would leave the site before she/he checked all items on the list and declared the patient stable. Nurses, doctors, pilots, firefighters, mechanics simply go the "extra mile" and embody ownership regardless of whether it means putting aside your own issues or feelings. You own your craft.

7 *More open publications from the Health inspection agency in the Netherlands called blacklist in Health care. Https://www.zwartelijstartsen.com/*

Using technology

Another item that relates to resource capabilities is technology. While drafting a strategic plan we rarely see Boards and CISOs assess and scrutinize their own capabilities and incorporate their firm's capabilities into their plans.

According to the theory the resource-based view (RBV), firms possess resources, a subset of which enable them to achieve competitive advantage, and a subset of those that lead to superior long-term performance. Resources that are valuable and rare can lead to the creation of competitive advantage. That advantage can be sustained longer to the extent that the firm is able to protect against resource imitation, transfer, or substitution. In general, empirical studies have strongly supported this resource-based view.[8] When we talk about resources we mean money, people, equipment (cars/buildings/ships, etc.) and technology. Most organizations do not fully use their IT. We have measured that organizations use just 25% of their security technology. Thus, to gain more strategic advantage of investments already made it's important to examine and assess your current equipment. Some examples: security information and event management systems without use cases or without relevant business-oriented use cases and only infrastructure-based use cases; limited connected devices to SIEM systems leading to limited visibility; logging on devices that are turned off due to performance or storage limitations; firewalls where the Intrusion Prevention System (IPS) capability is turned off, due to performance issues. Such IPS functions require more processing power since they need to inspect all traffic for malicious attacks or intruders; turning that function off has catastrophic consequences; encryption capabilities turned off or not used as a result of "oops I forgot" or "encryption is hard to manage"; web application firewall without proper rules simply because maintaining and establishing web application firewalls rules requires knowledge and skills and is complex for someone who is not experienced. These are some examples, not to speak of the technology that was bought by someone in the past, but nobody bothered to implement or configure properly.

8 *Bharadwaj, A. S. (2000) "A resource-based perspective on information technology capability and firm performance: an empirical investigation," MIS Quarterly (24) 1, pp. 169-196.*

We once advised a company not to invest in technology but to start first with configuring their infrastructure and application security capabilities that were already present but not activated. Thus, starting by configuring IPS on the existing firewall, put logging on, and forward logging on to one central server where somebody maintains a log interpretation process. Switch on segmentation via the VLAN function in the switch to avoid lateral movement in the network and turn on network-based security against well-known hacks such as ARP poisoning[9] and pass the hash, implement account management delegation for IT people, implement a password policy and enforce this via Windows. Work with checklists on password management, vulnerability management, incident response, etc. Make agreements with external parties as part of existing contracts, etc. Basically, it's not difficult to roll out a zero budget-based strategy, but it requires wisdom, courage, craftsmanship and discipline.

The moral of the story here is that you rarely see a security strategy that takes RBV approaches into account. Yet it's essential to know how fit your army and equipment is before you go into battle and how well you can cope with that unpleasant surprise.

Smart coalition

In several other industries we see smart coalitions. An example is the software industry. The Building Security In Maturity Model (BSIMM) is the result of a multi-year study of real-world software security initiatives. The model is built directly from data observed in sixty-seven software security initiatives, from firms including Adobe, Aetna, Bank of America, Box, Capital One, Citi, Comerica Bank, EMC, Epsilon, F-Secure, Fannie Mae, Fidelity, Goldman Sachs, HSBC, Intel, Intuit, JPMorgan Chase & Co., Lender Processing Services Inc., Marks and Spencer, Mashery, McAfee, McKesson, Microsoft, NetSuite, Neustar, Nokia, Nokia Siemens Networks, PayPal, Pearson Learning Technologies, QUALCOMM, Rackspace, Salesforce, Sallie Mae, SAP, Sony Mobile, Standard Life, SWIFT, Symantec, Telecom Italia, Thomson Reuters, TomTom, Vanguard, Visa, VMware, Wells Fargo, and Zynga. The BSIMM is a yardstick for measuring software.

9 *ARP spoofing is a hacking technique meant to steal some data intended for the target victim*

Companies that develop and build security products and services have a unique and important point of view to share with legislators and policymakers. To offer the expertise of the cybersecurity technology industry on critical policy issues, several leading companies founded the Cybersecurity Coalition. To achieve its mission, the coalition monitors and addresses interactions and intersections between government entities, researchers, and vendors. To educate policymakers with respect to issues, it engages in the full range of advocacy measures on behalf of the industry, including submitting written comments, offering testimony at congressional and regulatory hearings, drafting legal and policy white papers, engaging with policymakers directly, and holding events. All with the objective of improving the overall security of the sector.

This is a global initiative and there are also initiatives at the local level where industries form smart coalitions. The Center for Information Security and Privacy Protection (CIP) is a Dutch public-private network organization consisting of participants and knowledge partners. Participants are (employees of) government organizations, who participate in one or more community activities within the CIP network. Knowledge partners are private companies that are engaged through a covenant and have committed to a number of employee hours to be invested in the network, sharing knowledge. There are various ways in which CIP facilitates and stimulates the exchange of know-how, such as thematic meetings, workshops, and games. They offer a wide range of products for all to download and use freely under a Creative Commons license. The founding partners are Dutch government agencies such as UWV, the Dutch tax department, SVB (the Social Security Bank) and DUO (Dienst Uitvoering Onderwijs / Education Implementation Service) and they deliver secure software development guidelines within the Dutch government. Output includes serious games, which are freely available, and templates for contracting IT services. We have used many of their materials to embed in our strategies since these are freely available and directly usable.

Another initiative that has been used to improve the overall strength of the industry is the banking and insurance coalition that doesn't compete on cybersecurity since their mutual objective is to improve the overall resilience of the financial sector.[10]

The Dutch Government has guiding principles to establish smart coalitions.[11] Strengthening digital chain resilience is not something that just happens. It requires a vision, a plan, urgency, cooperation, coordination, investments, persuasiveness and insight into the collective goal and dependencies that are sometimes difficult to understand. Nevertheless, it's certainly worthwhile: chain collaboration is a good approach if you want to strengthen the digital resilience of your own organization by recognizing and reducing risks.

The government provides smart coalition guidelines for setting up cooperation and recommendations from the practice of companies that have already done this. In the section about future roles we explain the role of the cyberdiplomat who will play an increasingly important role in setting up smart coalitions.

10 The Dutch organization TNO has developed a chain coalition and provides directives for smart coalitions for vital value chains in certain industries. Source: https://www.tno.nl/nl/aandachtsgebieden/defensie-veiligheid/roadmaps/nationale-veiligheid/cybersecurity-het-belang-van-integrale-oplossingen/cybersecurity-ketens-en-processen-in-beeld/whitepaper-ketenweerbaarheid-tegen-cyberdreigingen/

11 Via the website : https://www.ncsc.nl/binaries/ncsc/documenten/publicaties/2019/mei/01/samen-in-keten/Handreiking_start_een_ketensamenwerking.pdf

Critical success factors for a security strategy: an examination

Friday May 12, 2017 is a day to remember (or a day to forget)? It was the headline in every newspaper: Hospitals, major companies and government offices have been hit by a massive wave of cyber-attacks across the globe that seize control of computers until the victims pay a ransom. With over 230,000 globally infected PCs in over 150 countries this is believed to be the biggest attack of its kind ever recorded, up until the day this book was written.

In different publications a business-oriented and more strategic approach was elaborated to involve many parties at all levels of the organization and in the digital chain of third parties.[12] With the increasing complexity of information security, it's important to ask ourselves how we can apply security effectively. This requires additional insights into relevant success factors that contribute to existing frameworks and models. We established a core set of Critical Success Factors (CSFs) that organizations can take into account.

Whereas information security has not received adequate attention for years, nowadays it's at the top of every Board's agenda.[13] It's no longer the question if a security incident will happen, but when, and whether the impacted organization has adequate information security in place. We have identified three key problems related to the ineffective implementation of an information security strategy within organizations.

Complexity. Organizations these days are aware that there is a need for information security. However, because of the complexity of business information security (BIS)[14], managers don't know where to start or what is relevant to ensure effective BIS within their organization. Due to the high-profile organizational failures of the past decade, legislatures, statutory authorities,

12 *In multiple articles we refer to the terminology Business Information Security to make more explicit Business has ownership over security as well. Since they hold legal ownership over data in their system, and not the security department. Y. Bobbert and J. Mulder, "A Research Journey into Maturing the Business Information Security of Mid-Market Organizations," International Journal on IT/Business Alignment and Governance, 1(4), 18-39, October-December 2010, United States, 2010.*

13 *V. Hooper & J. Mc Kissack, „The emerging role of the CISO," Elsevier, pp. 585-591, 2016.*

14 *M. Siponen and R. Willison, "Information Security management standards: problems and solutions," Information & Management, no. 46, 2009.*

and regulators have created a complex array of new laws and regulations designed to bring about improvements in organizational governance, security, controls, and transparency. Previous and new laws on information retention and privacy, coupled with significant threats of information systems disruptions from hackers, worms, viruses and terrorists, have resulted in a need for a governance approach to information management, protecting the organization's most critical assets: its information and reputation. The lack of awareness and knowledge of information security fuels this complexity. This makes it difficult for organizations to determine which factors contribute to the actual improvement of BIS.

The absence of intangible factors in frameworks. A range of information security models and frameworks consisting of formal policies, procedures, guidelines and activities and associated resources are collectively managed by an organization to protect its information assets. They show the security maturity level of an organization and what action needs to be taken to get to the level that is required in order to be in control. But the value of information security depends on more factors than those prescribed in these frameworks and models. Most of these frameworks do not take factors such as culture, tone at the top and awareness into account. For example, Von Solms[15] describes the fact that frameworks and technology solutions do not guarantee a secure environment for information. Besides these aspects we also need to consider the human aspects of information security. Chang et al. refer to the fact that research into intangible factors has been limited compared to other, more technical, aspects of security.[16]

Lack of governance. According to CSI/FBI Computer Crime and Security Survey[17], economic, financial and risk management aspects of computer security have become more and more pressing concerns for today's organizations, and such concerns are complements to, rather than substitutes for, the technical aspects of computer security. Solid security products or technology alone can't protect an organization from security breaches.

15 *R. Von Solms, F. Steven & N. Sohabi Safa, „Information security policy compliance model in organizations," Computers & Security, no. sciencedirect, pp. 70-82, 2016.*

16 *S. E. Chang & C. B. Ho, „Organizational factors to the effectiveness of implementing information security management," Industrial Management & Data System, pp. 345-361, 2006.*

17 *The 2008 Computer Crime and Security Survey from Robert Richardson, Director of the Computer Security Institute.*

As a consequence of the above, we have identified a clear need to identify critical success factors that can contribute to effective security strategy. The aim of an extensive study at Antwerp Management School together with security and business practitioners is to provide insight into potential CSFs that can be used to address the problems mentioned above.

The most critical success factors relate to intangible factors. Where frameworks and rules and procedures are perceived as less effective, cultural factors are perceived as highly effective for improving BIS within organizations. Our examination resulted in the following critical success factors:

1. Management and Board commitment. All the way up to the Board, so that the Board has ultimate responsibility for cybersecurity.
2. Create a security aware culture of acceptance, transparency, and protection.
3. Tone at the top. Lead by good example and setting a proper tone.
4. Lessons learned; Having a data breach and the fact that an incident can raise attention and be used in favor of effective BIS.
5. Sufficient budgets: adequate resources to set up and maintain BIS.

An overall conclusion in this study is that culture and behavior is essential to enable BIS and cultural factors can improve the effectiveness of BIS. The enabler 'Culture, ethics and behavior' scored a five unanimously and can therefore be seen as essential for the maximum chance of success.

Security experts had different definitions of when they feel being in control and successful in BIS. The research question "What is considered 'successful' with regard to BIS?" was answered as follows: "Being able to reduce the average time needed to resolve incidents and vulnerabilities. There is an opportunity window (being open) for hackers if you have vulnerabilities or incidents you're aware of, so they can get into your network. If you have defenses up and running, then good luck! The question is: if you know about vulnerabilities and their severity, how long does it take to close this window? The shorter the time taken to resolve issues, the more ma-

ture you are." (CISO from a large telecom). A CSO of a financial organization in the Netherlands: "The highest reachable (goal) is if there is no particular security role needed anymore, and all departments/services by themselves have a high standard of safety and deliver accordance this standard. Security is fully embedded in the genes and business of the organization, as a natural and integral part of the business." (CSO at a large bank).

Some practical reflections

In a 2010 publication on Maturing Business Information Security[18], a framework to establish the desired state of security maturity, we focused on seven security principles companies must adhere to in order to mature their security level.[19] These still stand today (e.g. identify applicable regulations, measure and monitoring, management involvement, etc.). But they are somewhat obvious in current cybersecurity nowadays.

From our work as a CISO and as an academic researcher we have distilled additional critical factors related to investing in cybersecurity and we believe that these will subsequently allow you to improve your organization's maturity level.

What to do when your Board doesn't believe information security is to be put so high on the agenda? Get your facts together. Know why you claim more budgets; don't rely on gut feeling or vendor reports. Be aware of the number of attacks you're undergoing every day: is it 5, is it 5,000 or 50,000? Knowing the numbers will help you to build your story for your Board and convince them to invest in cybersecurity. Storytelling by the way is claimed as a CSF by other publications but was not mentioned by our participants.

Value your assets

Make the investments in your digital security tangible. We once succeeded in integrating our work in cyber protection in the annual report of a large government organization (20K FTE), that one of us worked for as a CISO in 2014 and 2015. Before that, the annual report was rather a financial document, but we managed to convince the Board and CFO it was important to write and prove how our cybersecurity protected our customers' assets. "It was critical in order to make cybersecurity part of the company's DNA and it clearly made people more cyber aware." Supporting your storylines with visuals is something we experience as very powerful

18 *Y. Bobbert and J. Mulder, "A Research Journey into Maturing the Business Information Security of Mid- Market Organizations," International Journal on IT/Business Alignment and Governance, 1(4), 18-39, October-December 2010, United States, 2010.*

19 *The book "Maturing Business Information Security" describes the complete method, Bobbert 2010.*

to convince senior management and Boards. Visuals speak for themselves. Also, this was not mentioned directly by the participants in this study.

Demystify your jargon

Don't talk about the necessity of logging and monitoring software to your Board. Use the same language as the C-suite: translate information security into a business model such as Michael Porter's Five Forces analysis. On Sandra McCarthy's balanced scorecard, you have four perspectives for your organization: financial, internal, external and innovation. What's the impact of cybersecurity on each perspective? How do external parties perceive the security of your company?

We experienced that making use of management models grounded in other theoretical fields helps Boards better understand security and its value. Using Balanced Scorecards for cyber performance measuring has become a standard practice in for example the Masters programs at the Antwerp Management School.

Faulty cybersecurity impacts the value of your company

Complement the theory of the frameworks you use with the feedback you get from your customers and from your peers. Cybersecurity impacts your company's success, but also its failure: 60% of the hacked companies won't survive within 18 months after a breach.[20] It also impacts the perceived value of companies. Analyst firms increasingly rate companies on their ability to manage security risks.

As cybersecurity is a rat race, the critical factors for a successful security strategy are continuously changing. The industry is currently looking at automation of manual, high fault-tolerance tasks such as access rules or firewall verification, for instance. The participants in our study also mentioned this.

20 G. Miller published that "60% of small companies that suffer a cyber-attack are out of business within six months," according to the Denver Post, October 23, 2016

We need to embed business information security in our organizations and get those maturity levels up. This will allow us to embrace the breach, safeguard our respected businesses, and undoubtedly our positions, too.

Conclusions and lessons

1. Actionable items that reflect a direct financial benefit. Being able to reduce the average time needed to resolve incidents and vulnerabilities. There are two moments. First when a security incident is detected, and the second moment is when you mitigated the security incident. The shorter the time taken to detect and resolve issues, the more mature you are. If you manage to report on this and translate it into financial data, you will receive stronger support from the Board.
2. Intangible factors make a significant difference. The most critical success factors are related to intangible factors. Where frameworks and rules and procedures are perceived as less effective, cultural factors are perceived as highly effective for improving BIS within organizations. Tangible factors are also mentioned in the core set of CSFs (e.g. budget and comply with law and regulations). But the main conclusion of this research is that intangible factors need to be taken into account as an extension of the common frameworks, models and procedures from security communities and bodies.
3. Responsible disclosure on how the company deals with cyber and information security risks in the annual report determines the tone at the top. Rating agencies, shareholders, analysts, and all sorts of stakeholders who benefit from a cyber-resilient company directly influence the awareness of Boards and therefore the allocation of sufficient budgets. The CISO needs to communicate to these stakeholders in order to “create a pull for safety” toward Boards and senior management.
4. And last but not least, never waste a good incident to create a sense of urgency, allocate budgets, and collectively determine priorities.

Hopefully, we learned a lesson on Friday the 12th of May. Never waste a good incident, having enough budget to invest in the protection of the organization and commitment and responsibility from the Board for BIS scored high in this research and are all relevant success factors if

you want to protect your organization against these kinds of sophisticated threats. But the main conclusion of this thesis is that intangible factors need to be taken into account as an extension on the common frameworks, models and procedures from security communities and bodies.

Know thyself and your external forces

We are usually caught by surprise that a certain vulnerability in software or in a system is being exploited and leads to disastrous impacts. Many companies are still in a reactive waiting mode and do not anticipate what's coming. For this reason, regulators start programs such as collective red teaming and value-chain-based penetration testing TIBER.[21]

To determine the external and internal forces that influence your security strategy we can use common approaches that address certain factors, actors, and risks. The financial implications of a cyberbreach should be enough for most organizations to reconsider their security strategy. The economic impact of breaches on organizations has been studied. Cashell studied movements in the stock price in the aftermath of an information security breach or after a privacy incident.[22] All of these studies confirm the need for a dedicated security strategy. But designing security strategy is a challenging task, especially when certain knowledge is not available. Pai[23] states in his study, that sharing knowledge with all stakeholders at a very early stage is necessary. Early engagement of all stakeholders and preparing the political lobby internally and externally are preconditions for engagement along the journey, also when things go wrong, because that unexpected setback is just a matter of time and will definitely happen. Michael Porter states that knowledge sharing about influential forces is essential in order to determine which battle to choose. Harvard professor Michael Porter's Five Forces model is an example of a management instrument that can assist business leaders in making strategic plans and reveal knowledge on why certain forces must be controlled and others need not. Initiating the right forces that are relevant during execution is essential. Porter states: "*A perfectly executed but mediocre strategy won´t really help the organization*."[24] To get an understanding of strategic knowledge items we might consider using proven methods or models for strategizing and re-using these in information and cybersecurity. At the Infosec Dialogue in London (UK) on October 4,

21 *The Governing Council of the European Central Bank (ECB) has decided to set up TIBER-EU to increase the cyberresilience of market infrastructures and financial institutions throughout Europe. TIBER: Threat Intelligence Based Ethical Red Teaming.*

22 *Cashell, B.; Jackson, W.D.; Jickling, M.; Webel, B. (2004) The Economic Impact of Cyber-Attacks*

23 *Pai, J. L. (2006) An empirical study of the relationship between knowledge sharing and strategic planning in Information Security. Emerald Group Publishing Limited*

24 *Porter, M (1979) publication on "How Competitive Forces Shape Strategy" in Harvard Business Review*

2015 we polled 30 CISOs on their acquaintance with Michael Porter's Five Forces model. None were familiar with the model. Below we demonstrate how this model can help to identify relevant threats, actors and forces that shape a strategy but, above all, how Porter's model can be used to close the language gap between IT nerds and people on the Board.

Situational awareness

Forty-one experienced security managers and officers, all of whom have worked for 10 years or more in the field, were asked a range of questions about the forces they deal with when formulating their security strategy.

The questions within the survey were based on Michael Porter's Five Forces analysis. Porter's Five Forces are a commonly used tool to analyze how attractive an industry is. Porter distinguishes:

1. Competition from rival sellers
2. Competition from potential new entrants
3. Competition from substitute products producers
4. Supplier bargaining power
5. Customer bargaining power.

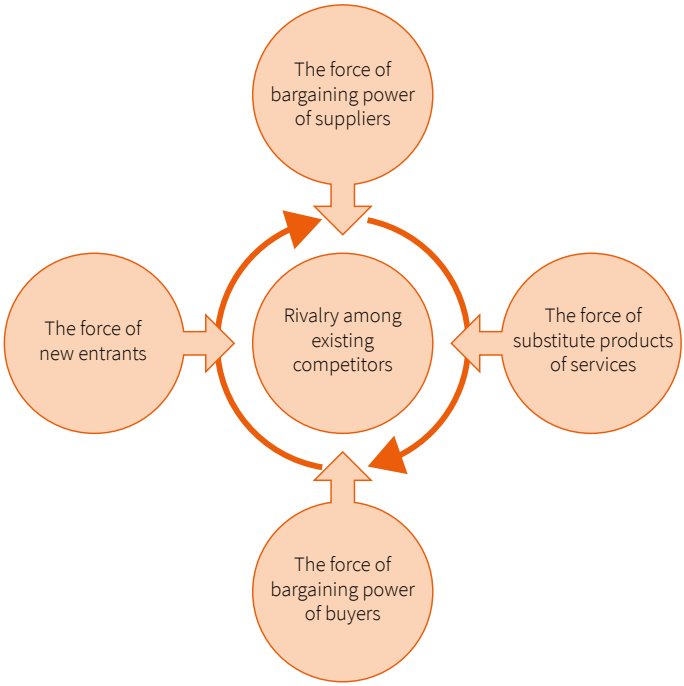


Figure 6: Porter's Five Forces Model.

This model can be used as a frame of reference to examine numerous forces a security professional can reckon with when establishing his 'security strategy.'

In the survey, managers were asked whether the various forces they faced were dynamic or static in nature and whether the managers felt able to bend these forces to their strategic advantage. The results were used to compile a list of suggestions meant to help managers develop a more robust strategy.

The results were sobering. Two-thirds of the forces participants said they face are dynamic. In other words, they are unpredictable factors such as intellectual property theft, extortion, hack-

ing, social media rumors gone wild and other new-technology phenomena. Only one-third of the forces they deal with are static, such as compliance legislation, ISO standards and mandatory audits. 58% considers it important to address these external forces in their strategy formulation in the future. Yet, they did not do this up until the survey. The survey results show that security managers focus their strategy on the more predictable, recurrent forces (compliance related), rather than on the more plentiful and potentially more damaging forces.

Blind spot vs situational awareness

It's not as if security managers are naive. They are not. In response to the survey, they overwhelmingly indicated that supply chain risk management (e.g. cascade failures due to overlooked forces) should be one of the highest priorities in their organization. So they understand they have a blind spot preventing them from anticipating risk. But knowing that is not enough. The survey showed that managers are poorly informed about the specific dangers they face and the potential impact of dynamic forces, much less about how they should respond in the event of a full-blown crisis. 78% of the respondents is poorly or fairly able to influence these forces once they impinge.

An example of this can be seen through the April 2013 distributed denial-of-service (DDoS) attack that paralyzed ING Bank, a global financial institution based in the Netherlands. The incident slashed shareholder value and a flurry of criticism via social media cost ING customers[25]. If the bank had understood and respected the power of such dynamic forces – in this case uncensored social media caused confusion – and been transparent about the attack, the damage could have been limited. Instead, ING denied the seriousness of the attack, evaded questions and remained silent for far too long [26] allowing the conversation on Twitter to proliferate and leave the lasting impression that the bank had failed to respond. This incident, in addition to

25 *RTL News, "Disruption at ING Caused Hours of Unclearness About Account Balances," 3 April 2013, www.rtlnieuws.nl/nieuws/storing-ing-urenlang-onduidelijkheid-over-saldos*

26 *Chantal van der Lans; "Online Disruptions, Don't Lose Your Customers' Trust," Usability.nl, 10 March 2014, www.usability.nl/2014/online-storingen-verlies-niet-het-vertrouwen-van-uw-klanten/*

many others[27] reveals a lack of preparedness—a gaping hole in the ICT security strategy that is all too common.

Positive exceptions are observed now and then, at least in terms of crisis management. An excellent recent example is how a Dutch hospital, Het Groene Hart Ziekenhuis, responded when it was hacked in October 2012.[28] On discovery that thousands of patients' medical details had been leaked, the hospital immediately responded to the media and notified other stakeholders. Management wasted no time in admitting they had a problem and swiftly followed up with preventive measures so the leak could not recur. The hospital's candid response profoundly influenced the tone of the ensuing (social) media debate, leading to more favorable public perception in the long term.

Containing vs. averting damage

Surely, though, it would be better if organizations averted such a crisis in the first place. By the time it was discovered that Impairment Resources , LLC had lost control of medical records belonging to the roughly 600 insurance companies it served, the damage was done. The lawsuits quickly piled up and no amount of transparency could have stopped the company's impending demise.[29] So an ounce of prevention is worth a pound of cure. Businesses need to develop an overall business strategy in which security is genuinely integrated, employing two of Michael Porter's management frameworks: the Five Forces analysis and the value chain. It has been shown how the Five Forces can be subdivided into dynamic and static forces and how inadequate security strategy is, with its inordinate focus on static forces. The second important concept that should be borrowed from Porter is the value chain. And here too, according to the survey findings, IT security misses the mark, typically focusing on individual activities of the organization rather than considering the role each activity plays on the broader picture. For

27 *NU.nl, "The Netherlands: Number One in Online Banking Disruptions," 13 January 2014, www.nu.nl/tech/3674517/internetbankieren-relatief-vaak-getroffen-storingen.html*

28 *NU.nl, "Hospital Regrets Data Breach to the Public" ("Groene Hart Ziekenhuis betuigt spijt voor lek"), 2012, www.nu.nl/internet/2932335/groene-hart-ziekenhuis-betuigt-spijt-lek.html*

29 *Stech, K.; "Burglary Triggers Medical Records Firm's Collapse," Bankruptcy Beat blog, Wall Street Journal, 12 March 2012*

instance, security specialists see that their business has relationships with third parties, but seldom recognizes these parties as potentially influential forces.

Understanding the value chain and the five forces is a prerequisite for business success. Yet, surprisingly, Porter's frameworks have yet to take hold in the security field.

These five forces are ranked out of 13 forces as the top five forces of which security managers say they recognize the impact:

1. Legislation – 95%
2. Inspection and supervisory agencies – 88%
3. Law enforcement (district attorney and police) – 69%
4. Partners in the (digital) chain (e.g., freight forwarders, internet service providers, payment handlers) – 64%
5. Public opinion – 60%

The top five forces of which security managers and officers say they do not recognize the impact are:

1. Trade unions – 79%
2. Social media (uncensored reporting) – 57%
3. Criminals – 48%
4. Customers – 48%
5. Suppliers – 43%

It's too easy to say that organizations simply need to get a grasp on the dynamic forces in the chain and all their problems will be solved. However, the problem is that very few management tools, steering mechanisms, or key performance indicators (KPIs) are available to deal with these forces. Let alone that current cybersecurity leaders address these type of models into their practice.

Dynamic forces can have major consequences. A surprising 71% of experts surveyed indicated that these forces are critical to their business and strategy. They require the attention of every manager, Board member and shareholder.

The top three elements for an information security strategy, are:

1. ***Stakeholder approach*** – When developing a strategy, involve the Board of directors, management, business, and all external stakeholders in the chain. Know the business drivers, stakeholder expectations, and how to translate these demands, using the right metrics and KPIs, into concrete benchmarks for the organization, management, and Board.
2. ***Beware of blind spots*** – Many forces are dynamic. Ensure the organization is not caught unaware and punched in the mouth. No one person can stay abreast of every development in this field, so let others update stakeholders on what they do not know.
3. ***Do the right things well*** – It may seem easier to "learn by doing," but those who prepare a good strategy are less dependent on impromptu solutions. And to be better prepared when things really go wrong.

After this study we examined a large web retailer as part of an ad-interim CISO role. We developed a "stakeholder analysis" and advised the Board of Management on their strategic direction.

This strongly internet-dependent Dutch business with annual revenues of €500 million used these elements, Porter's forces, to help it gain a better overview of its stakeholders. The organization realized that it had 266% more stakeholders involved in critical business processes than it had previously thought. By identifying all 166 digital stakeholders and their technical and/or legal dependencies, the organization was able to effectively map out and quantify all risk factors and feed this information back to process owners so risk management could be integrated throughout the organization. This made it easier to specify the knowledge and competencies needed to manage risk and to identify blind spots. In this case, it became clear that the business lacked the expertise to manage the entire value chain strategically and to set the right KPIs.

The conclusion is simple: Each security leader needs to be able to zoom in on specific threats and prepare for them and then zoom out and consider the entire context in which the organization operates. Jocko Willink mentions this in his book Leadership Strategy and Tactics – Field

Manual when he talks about Detach (abstract yourself from the situation and look at it objectively) as one of the most powerful tools a leader can have.[30] The capability of zooming in and zooming out to identify potential (new) forces that might pose a digital risk is key. The capability of influencing those forces and take appropriate decisions is an important aspect of executing the strategy.

30 Jocko Willing, Leadership Strategy and Tactics – Field Manual, 2020, First Platoon: Detach

To Really Know Your Enemy

There is a saying by Sun Tzu in the Art of War in which he states, "*If you know the enemy and know yourself, you need not fear the result of a hundred battles. If you know yourself but not the enemy, for every victory gained, you will also suffer a defeat. 'If you know neither the enemy nor yourself, you will succumb in every battle*". Also, in the book About Face by Colonel David H. Hackworth, you can learn that "*you take fewer casualties attacking than retreating: Your job is not to die for your country but to make the other son of a bitch die for his country.*"[31]

How to know your enemy?

As mentioned by Sun Tzu, it is crucial to know yourself and to know your enemy. In general, we can distinguish the following "enemies" in digital security[32]:

- **(Organized) Crime**: Profits primarily drive these cybercriminals. They typically seek personal sensitive information or to hijack and ransom your digital system's resources.
- **State-Sponsored**: Groups with political, economic, technical, or military motivation. Often interested in competitive information or information about users for espionage purposes.
- **Hacktivists**: Their goal is to either create high-profile attacks that help them distribute propaganda or to cause damage to organizations they are against.
- **Internal Users**: This can be either an (ex-)employee trying to steal or break anything on purpose or internal users making mistakes, however, having a significant impact.
- **Script-kiddies**: amateur "hackers" trying to gain access by "downloadable" scripts or applications.

31 *About face, the odyssey of an American warrior, Colonel David H. Hackworth & Julie Sherman 1989, 2020 reprint – page 15*

32 *Cybersecurity in 60 minutes by Yuri Bobbert & Melvin Broersma ISBN 9789461263032*

To deeply apprehend the threat actors and their techniques that we're facing from these enemies, we can distinguish three types of Threat Intelligence Data[33]:

- **Tactical**: This intelligence focuses on the tactics being used. The actors' so-called TTPs (Tactics, Techniques, and Procedures) can be found in research groups from the different security providers, like Palo Alto's UNIT42, or threat research groups, such as Group-IB. This type of information aims to determine whether configurations in certain technologies need adjustments or additional measures need to be taken. The biggest downside is that this type of information is scattered in multiple sources and hard to aggregate on threat and relevance for your specific environment, especially if you are an individual company.
- **Operational**: Information about CVEs (Common Vulnerabilities and Exposures), current attacks, etc., that are used to, e.g., monitor the present network traffic and identify vulnerable systems in the network. This type of information aims to prevent security incidents from happening on a day-to-day basis. These CVEs are translated into a CVSS (Common Vulnerability Scoring System) score based on which follow-up actions are defined. However, this way of working is limited since it only contains the known and not the unknown vulnerabilities and is often a manual process of analysis, interpretation, and communication.

Also, the reliability might be limited. For example, UNIT42 is the most significant contributor, while Microsoft is far from that. Even though many vulnerabilities are still present in Microsoft products after more than 25 years, which might be caused by the massive earnings Microsoft makes on Cyber Security. In 2022, their revenue surpassed 20 billon in security services[34], a business based on securing customers from their own Microsoft Vulnerabilities

33 *Cyber Threat Intelligence Overview – ENISA Threat Landscape, From January 2019 to April 2020*

34 *https://www.fool.com/investing/2023/07/18/microsoft-announces-new-cybersecurity-products-but/#:~:text=There%20are%20a%20lot%20of,surpassed%20%2420%20billion%20in%202022.*

A better way of gathering vulnerability information from all available sources automatically and determining the actual risk and actions in an automated way, for example, via SOAR technology (Security Orchestration, Automation, and Response), is a way forward but still in its infancy.

- **Strategic**: Information about developments in the type of threats, geopolitical changes, threat actors and their motives, capabilities, etc. The goal is to determine whether new threats might hit your company, and you should prepare for them in advance.

CrowdStrike, a leading cybersecurity provider, provides an overview of the industry. They list adversaries to industry types. They also show industries you're not a target from state-sponsored hackers but are a target for (Organized) Crime.



Taken from the Crowdstrike 2023 Threat Hunting Report

Next to what you need to do yourself, there are also initiatives of governments but also communities, like the Ransomware Task Force (RTF), consisting of a group of 19 security firms, tech companies, and non-profit organizations, that try to help all of us to understand mainly our own threat landscape. In general, however, the focus is on helping you defend your data assets against an enemy that will never stop coming at you instead of defeating the enemy.

To Really know your enemy

In addition to that famous line by Sun Tzu, which is often misquoted by stating, "*To know your Enemy, you must become your Enemy*", there is a comment made to the original line by the commentators in the Art of War. Chang Yu said: "*Knowing the enemy enables you to take the offensive; knowing yourself enables you to stand on the defensive. The attack is the secret of defense; defense is the planning of an attack."It would be hard to find a better epitome of the root-principle of war*". Besides, as the introduction by Colonel David H. Hackworth mentioned, "*you take fewer casualties attacking than retreating*".

Therefore, we must do more than just defend ourselves and focus on our strengths and weaknesses to anticipate TTPs, developments, or CVEs. We must understand the enemy's motives and weaknesses and take the offensive route to exploit them. Like the Dutch Intelligence Agency, AIVD did this by infiltrating to detect Russian State-sponsored hackers Cozy Bear or APT29[35]. AIVD would have been in their network learning about how they operate, where they work, what they look like, etc. Perhaps we need more of that.

Based on what great army leaders in history taught us, only the defensive approach is not the right way. We need to do more and go into the offensive mode. The question, however, is whether we need to start countering cyber-attacks or whether it is sufficient to get into

35 *https://nos.nl/nieuwsuur/artikel/2213767-dutch-intelligence-first-to-alert-u-s-about-russian-hack-of-democratic-party.html*

the closed hacker networks and bring them out in the open. Perhaps we can shed light on these attackers and bring the criminals to justice. Have a meaningful conversation with State Leaders, and we might be able to master this war.

Reflection on the use of existing management models

Providing direction to the organization is like steering an airplane in which all members of the flight crew talk the same language and understand the destination. Airplane staff are trained in common terminology and associated language. When IT or security people talk to captains of industry, their language is mostly full of jargon that doesn't resonate and thus rarely leads to results. We have also observed that senior non-tech people avoid these conversations and quickly lose interest in security people.[36] This can be solved by security people using more business-oriented language and commonly used models. When we look at Michael Porter's model for strategy formulation, for instance, and whether this management model could help the security manager by a) enabling this by providing a better understanding of the external forces that he/she needs to reckon with, and b) getting his or her message across thanks to the use of existing management models (and not complex jargon). We carried out an evaluation on September 10, 2015 at Erasmus University in Rotterdam. This session raised some important results. The audience consisted of IT managers, CIOs, and security professionals. Through the use of Group Support System (GSS)[37] software, which we often use for research, 28 respondents participated. The main conclusions from this session were:

- According to the respondents, current management models can be re-used. The Harvard professor Michael Porter's Five Forces model can be used by the Chief Information Security Officer to determine the strategic forces of influence and to advise Board members. Or it can be used to explain and communicate strategy.
- Knowledge is not a limitation for a Board member, but awareness is. This statement requires some additional explanation since knowledge is content- specific and awareness is knowledge of existence. Awareness is about knowing what knowledge you have or don't have. In this case having basic awareness of certain security and risk-related topics was addressed three out of twelve times by the participants. Knowledge was mentioned twice out of twelve

36 *A. Vlist, "How do I get the mystic language of security experts in plain language?," 3 September 2015. [Online]. Available: https://www.linkedin.com/pulse/hoe-krijg-ik-de-geheimtaal-van-security-experts-mn-aart-van-der-vlist*

37 *Group Support System Software facilitates group discussions and decision-making processes. It makes it possible to generate ideas and choices (diverging) and captures all the steps and arguments needed for making choices (converging).*

times by the participants when they were asked about the critical success factors for adopting a security strategy. One of the participants made the point mentioned above that knowledge is not a limitation for the Board, but awareness is. Therefore, in-depth knowledge is not required, but a minimum level of security awareness by Boards is essential.

Other critical success factors that were mentioned were: knowledge, innovation, awareness, knowledge through gaming, and accountability.

After a discussion among the participants it became clear that most of the effects can be found in the softer factors such as "tone at the top," a "walk the talk" culture and other non-instrumental elements. Typically, items that are lacking in current security strategy models or approaches.

Collectively strategizing and decision-making

Within NN Group we established stakeholder engagement via annual collective strategy sessions in which we identified blind spots and challenged them. These were then prioritized and specified as "must haves." These were the things that require Board approval and which every CEO and CIO needs to adhere to in order to do the right things well.

Sun Tzu's statement: "*He who knows the enemy and himself / will never be at risk in a hundred battles*" was often the reason for using Group Support System Software (GSS) facilitated sessions to draft and prioritize the top risks for a company. Such meetings make it possible to generate ideas and choices (diverging) and capture all the steps and arguments needed for making choices (converging) in a collective manner. Therefore everybody is involved at an early stage and everyone remains committed. In the next paragraph we elaborate in more detail how we have used GSS as a method for consensus building and decision-making and to involve all organizational layers from the Board to operations and guide them in strategic planning.

Smart decision-making

Decision-making during business meetings is an elusive phenomenon[38], for a couple of reasons. Thomas Kayser defined business meetings as "*…a gathering where people speak up, say nothing, and then all disagree*."[39] The effect of this is an unbalanced engagement of all the participants and therefore poor decision-making. This poses a risk to organizations. The main objective of meetings is to facilitate and enable decision-makers in exchanging knowledge and discussing complex topics, such as the progress of strategic projects and this all happens under pressure and with considerable uncertainty.[40]

These pressures and uncertainties often result in:

- Cost to the business in man-hours due to prolonged decision-making.
- Business risk due to delayed actions as complexity causes paralysis.
- Increased risk of making a bad decision because of complexity.

The impact on the future of organizations if any of these happens can be dramatic. In contrast getting these decisions correct and made in a timely manner can provide a tremendous strategic advantage and secure the future of your business.

Technology and proper meeting facilitation can help with these pressures and uncertainties. For example, the absence of so called "evidence trailing." The collecting, storing and "trailing" during the decision-making process, about who made which decision based on what evidence seems rather complex, but doesn't need to be since technology can facilitate it.

In the absence of efficient process facilitation, meetings lack balanced engagement of all participants and the "law of the decibel" can quickly take over. Meetings then become chaotic, which

38 *S. Elsayed-Elkhouly and H. Lazarus, "Why is a third of your time wasted in meetings?" Journal of Management Development, vol. 16, no. 9, p. 672, 1997.*

39 *T. Kayser, Mining Group Gold; Third Edition: How to Cash in on the Collaborative Brain Power of a Team for Innovation and Results, vol. 2, Illinois United States: Irwin, 2010.*

40 *A. Riabacke, "Managerial Decision Making Under Risk and Uncertainty," IAENG International Journal of Computer Science, Vols. 32-4, no. IJCS_32_4_12, 2012.*

leads to frustration among the participants and little to no smart decision-making. Managing the process of the meeting is as important as the content, if not even more important.[41] This is especially the case with projects that are complex and require a certain level of technical knowledge and a longer time period.

The digital security and risk management domains are largely managed by professionals who are well educated in IT, security, or other content-related topics. They often only receive limited training in business management principles and therefore it seems hard to find a fruitful balance between content and process.[42] As a result, most meetings are managed based on the content instead of the process. This can result in outcomes that fall far short of your desired objectives.[43]

Meetings without a steering process may lead to disappointment.[44] To avoid these disappointments and increase the effect of collaborating on predefined targets, meeting software can be employed to help facilitate your goals. According to a longitudinal study of 900 meetings, a 56% saving in man-hours can be achieved with the use of this technology and an experienced facilitator. Then to consider that the average manager spends 25-80% of his/her time on meetings, the company-wide savings are easily calculated, not to mention the quality of the decision-making process.[45]

Digital security, a complex and tedious profession

Digital security is a necessary but tough topic since the environment is constantly subject to numerous dynamic forces. For example, innovations, technology, and regulations. What's new

41 *J. Altier, " Process Expertise - A Critical Managing Fundamental," Business Horizons, no. January, pp. 10-15, 1993*

42 *S. Miranda and R. Bostrom, "Meeting Facilitation: Process Versus Content Interventions," Management Information Systems, vol. 4, no. 15, pp. 89-115, 1999.*

43 *J. Pai, "An empirical study of the relationship between knowledge sharing and IS/IT strategic planning (ISSP).," Management Decisions, Vols. Jan 1-44, no. Emerald Group Publishing Limited, pp. 105-22, 2006.*

44 *N. Romano and J. F. Nunamaker, "Meeting Analysis: Findings from Research and Practice," in 34th annual Hawaii International Conference on System Sciences, Maui Hawaii, 2001.*

45 *Vreede, G.; J. Boonstra; F. Niederman; "What Is Effective GSS Facilitation? A Qualitative Inquiry Into Participants' Perceptions," Proceedings of 35th Hawaii International Conference on System Sciences, Institute of Electrical and Electronics Engineers, 2002*

today will be old tomorrow. Thus, it's important to collect and exchange the right amount of knowledge and bring this to the decision table. But the question arises: how to do this in a very effective way? Group Support Systems (GSS) software – also referred to as meeting software - enables complex and knowledge-intensive decision-making processes to be carried out faster and more efficiently than is commonly experienced in business. For example, in the topic of risk management and digital security, GSS makes it easier and swifter to arrive at an informed decision, which is a primary desire within the digital security industry.

Everybody has a voice

GSS can facilitate mastering intersubjective dilemmas among participants such as culture, matrix organizational steering, attitudes, or hierarchic relations. Due to anonymous participation in meetings individuals are more willing to be open and transparent. Hence ideas are judged based on their content instead of their origin. This also solves the issue of differences between introvert or extrovert participants, an issue that is seldom discussed, but a dominant factor in meeting effectiveness as it impacts both process and content and therefore outcomes.

It's evident that boardroom involvement in cybersecurity strategies is essential; this is nothing new[46]. Involvement is more than just appointing a CIO or IT department which has to deal with it. Sincere involvement and commitment require knowledge management: active knowledge generation, capturing and sharing. Especially during meetings designed to formulate viewpoints on items that justify the decision-making process. In boardrooms this becomes increasingly important because the individual member of the Board needs to form his or her own meaning and opinion on a certain topic in order to make a justified decision.

From strategy to operations

By quantifying the economic value of the core assets (crown jewels) and mapping these on the most relevant strategic threats, directors can evaluate the organization's improvement options based on economic criteria of cybersecurity. By adopting these, boardroom members improve

46 *Q. Hu, T. Dinev, P. Hart and D. Cooke, "Managing Employee Compliance with Information Security Policies: The Critical Role of Top Management and Organizational Culture.," Decision Science, Vols. 28-43, no. 4, pp. 615-60, 2012.*

financial decision-making on cybersecurity investments. The internationally known "security economics" model of Gordon and Loeb[47] can be used for this. This model has been cited in numerous journals. A publication in the Wall Street Journal elaborates on their model and is animated on YouTube.[48] This animation helps managers, directors, and authorities understand their company's cybersecurity investment considerations better. The Gordon and Loeb model provides the relevant ingredients for a GSS session, in methodological steps, from strategic direction to tactical security initiatives and funding. Thus, in this case it appears that existing models shed new light on the digital security domain and GSS can be seen as a successful method of collaborative learning and decision-making. It can be perceived as a method for investigating disruptive innovations and better anticipating future forces. It also helps prioritize operational tasks and monitoring progress during meetings.

By making use of knowledge facilitation technologies such as GSS in combination with an experienced facilitator, boardroom members can prioritize more effectively. Meetings become more pleasant and efficient. GSS-facilitated meetings bring more insights, viewpoints, standpoints and evidence collection that demonstrate smart decision-making.[49] By achieving a mutual level of knowledge, directors and managers are able to filter out the jargon from the conversation with security professionals and focus on the essence. Proven technology and theory such as "double loop learning" provide managers with more grip, so that they can take full responsibility and ownership.

47 *L. Gordon and M. Loeb, "The Economics of Information Security Investment," ACM Transactions on Information and System Security, vol. 5, no. 4, pp. 438-457, 2002*

48 *L. Gordon and M. Loeb, "You May Be Fighting the Wrong Security Battles: How IT executives can determine the right amount to spend—and where to spend it," The Wall Street Journal, 2011.*

49 *S. R. Pfeffer, " Evidence Based Management," Harvard Business Review, Vols. Pfeffer, J., Sutton, R.I.; (2006) Evidence Based Management, Harvard Business Review Jan 2006, no. January, pp. 1-13, 2006.*

Security strategies in other sectors

"Any system which depends on human reliability is unreliable." (Gilb's Second Law of Unreliability)

It's interesting to see how other sectors, which also face a reputational and business impact from incidents, cope with security strategy.

Automotive

Transportation is the backbone of modern society. There are 1.2 million deaths and 50 million people get disabled worldwide each year. In addition, the sector adds significantly to CO_2 emissions and major congestion problems in cities.

Car manufacturers must assure safety from a regulatory perspective in the form of brakes, lights, a horn, etc. During the evolution of airbags, stability control and ABS systems were integrated. The car industry has evolved through the evolution of its threats. It considers security an elementary part in car design. Knowledge gained from incidents and crashes has further influenced the design and manufacturing of a car and how it operates in traffic. But the security functions of the car are related to the person who drives the car and how it interacts with other drivers in traffic. Recent incidents with for example Toyota's flagship Prius have led to modifications in safety. Primarily to avoid future incidents but secondarily to avoid public shame that might damage the reputation of Toyota. Volvo's vision 2020 is "that no one should be killed or seriously injured in a new Volvo car." (Quote by Håkan Samuelsson, President and CEO).[50] This sector has been improving due to rigorous testing before and during production and working with checklists.

Aviation

The aviation industry has evolved due to several incidents. The Tenerife airport disaster in 1977 involved two passenger aircraft on the runway of Tenerife North Airport. With 583 fatalities, the crash remains the deadliest accident in aviation history. About 70 crash investigators from Spain, the Netherlands, the United States, and the two airline companies were involved in an

50 Volvo Vision 2020. https://www.unece.org/fileadmin/DAM/trans/roadsafe/unda/Sweden_Volvo_Vision_2020.pdf

extensive investigation into the crash. Misinterpretations and false assumptions were partly to blame. Analysis of the black box transcript showed that the pilot was convinced that he had been cleared for take-off, while the Tenerife control tower was certain that the plane was stationary at the end of the runway and awaiting take-off clearance. It appears that the co-pilot was not as certain about take-off clearance as the captain. Eventually KLM took 70% of the blame and was forced to pay extensive penalties.

The Tenerife accident led to numerous safety improvements. For example, the ICAO[51] enforced interventions to improve English communication between captains, flight towers and crew. Plane manufacturers improved "fog" view equipment. Cockpit procedures and checklists were sharpened, i.e. the crew became involved in the decision-making process.

Healthcare

Within the healthcare industry extensive research is continuously being done to reduce incidents. The healthcare industry can be compared to the aviation industry, in that work is done by people who interact in an organization with processes and structures. It's a complex working arena that requires those involved to be highly qualified and have knowledge and skills. Although the medical arena is dynamic and complex, budgets are tight and the pressure to keep the production rate high is enormous. A minor mistake can lead to devastating events. It's from this perspective that the medical industry is stringent on checklists and incident reporting especially on near-incidents reporting. The objective is that people learn from each other in an open environment where there is transparency about "medical missteps." In the Netherlands, an investigation[52] revealed that between 1500 and 6000 people die annually because of medical errors. The report also showed that the current hospital culture doesn't support safety and security. One result of this study was to implement a security management system containing

51 *The International Civil Aviation Organization is a specialized agency of the United Nations*

52 *The Faster Better project started at the end of 2003 to improve transparency, efficiency, quality, and innovation in curative care, for example by examining care thematically. In the first half of 2004 the theme was 'patient logistics' central. TPG provided its specific logistics expertise for this theme. The second theme concerns safety in healthcare. Minister Hoogervorst asked Shell to advise on possible improvements in the safety of patients and employees based on her vision on safety management. Source: https://www.vmszorg.nl/wp-content/uploads/2017/07/rapport_rein_willems_2004.pdf*

a “blame-free reporting” mechanism. The objective was to learn from incidents and prevent them in the future.

Does security really enable business value?

In 2016 NN Group CIO Amir Arooni asked: Let’s assume we see a security capability as a competitive advantage which removes user pain points. What would be your approach to organize this and why? What is your best practice from your own experience and what have you learned from this?

Our answer to this question was two-fold. Firstly, having security contributing to the business objectives in a very explicit way is what we call “value-based.” When embracing this principle all security professionals, under the direction of the CISO, are encouraged to investigate initiatives, activities, controls, etc. rigorously and start dialogues about the effects of security and the contribution it makes to the business. We explain this with some examples:

- A pension fund had “beating benchmarks” put into their business goals. We helped the CISO (in a consultative role) make – together with his Board – a definition of what this means for the security function. In this case the De Nederlandsche Bank (the Dutch National Bank; DNB) control framework also contained benchmark details. By defining the DNB digital security benchmark, this pension fund knew exactly what to aim for and which level to beat. In this way security contributes to organizational goals.
- Another example is that we have encouraged the teams of UWV to report on information security and privacy in their annual report. This contributes for example to Corporate Social Responsibility (CSR) goals (in this case the CSR ladder indicator 31). This allows the CISO to make clear all the past quarter initiatives and results. For example, access management initiatives, BIR (the Baseline for information security for the Dutch Government) implementation initiatives, etc. This new form of “Integrated reporting” also requires reporting on non-financial risks. The annual RvC indicator encourages Boards to be transparent when reporting on non-financial risks.

What we have learned is that by making the digital security contribution to business goals more explicit the CISO enables:

- Active engagement of the digital security professionals in "what their business is about."
- Have security professionals rigorously reflect their activities and have them linked to business value.
- Create an open and transparent culture on failures with the objective of learning (ensuring that peers do not make the same mistake).
- Increase the perceived value of the company because this is also based on the level of cyber-resilience. Investors are aware of cybersecurity threats being a risk factor for their investment. Private Equity, banks and insurance agencies also use instruments such as Bitsight or Security Scorecard for their investment analysis. According to the New York Stock Exchange this new risk profile identification will increase.

Secondly, the CISO needs to do this to encourage a mutual basis of knowledge and awareness on "why" we are doing this and "what" we need to do. When drafting an initial strategy we would, as a CISO, start up the following activities in order to increase the perceived value and use digital security as a competitive advantage:

1. Integrate digital security in the Corporate Social Responsibility programs and activities. Incorporate risk and security management into the "integrated reporting" principles. We learned at NN Group that this encourages the entire organization to take ownership of risk and security as well as privacy of customer data and bring it to the next level.
2. Actively engage the CISO in the investor relations and communication of the firm about cyber-resilience. Do roadshows with major customers/investors and participate in expert panels outside the security community.

Does knowledge management matter?

Encouraging a continuous "knowledge management" mindset among senior management seems obvious, but it's vital. Within the digital security profession it's not about buying new

tools that mitigate the risks, it's about the people developing, constructing, implementing, testing, maintaining, and managing the technology, processes, and structures. Incentivize all fresh and new ideas that stimulate this "knowledge sharing" behavior, thus I expect freedom and a mandate from senior management to do this.

In UWV we have started a digital security Masterclass. In half a day a professor introduces a certain topic and talks about the "why," an internal practitioner presents the "how" and the "what" and is closed off with discussion with drinks. This enables the employees to interact, gain new insights, and share knowledge. It also puts team members in the spotlight and motivates them to share their knowledge. The CISO is the initiator, driver, and moderator of this initiative. Some other examples:

- Form smart coalitions, internally and externally. With the collective knowledge of the industry we can achieve higher cyber-resilience. For example, coalitions with the High-Tech Crime Team, NCSC, Joint SOCs (RijksSOC), National Detection Network, Heavy ISACS / banks, etc.
- Human Resource Management: Continuously recruit the best security people. This requires a committed talent program to recruit and attract the best people.
- Rewarding: Reward top security performers or developers who incorporate security into their processes. Participate in "Capture the flag" events and other hacking events. Reward special contributions your people make to the community (publications, presentations, articles, blogs, etc.). Our experience is that by doing this people are proud and their environment is encouraged to do the same. Create a best-in-class environment. This requires out-of-the-box management, a mandate, and sponsoring from the top.

Our experience is that, once you do this well, security budgets are no longer an issue. Especially when the investment in BIS initiatives are clearly based on the value they bring and the risks they cover.

Key takeaway messages on strategizing

1. *Information security strategy is about everything but the plan*. Where others prepare plans to implement a framework, true cyberleaders first start to establish a coalition of the willing which can decide quickly in times of stress and is anchored in the top of the organization. And people who support each other all the way, even during the corona crisis, in tough fights, and during hacks (e.g. NotPetya – the most devastating cyber-attack in history[53]). So the plan is one thing, but strategic buy-in from "rainmakers" in the company as well as outside the company is key. When things go wrong, nobody will talk about the strategic plan, but they will look at the ones making sure the companies survive.

2. *Use existing technology to the max*. We have seen many strategic approaches include the pitfall of buying new technology, e.g. expensive contracts from a single vendor (e.g. Microsoft, SalesForce.com, Cisco, etc.). Two strategic approaches are needed:
   - Re-using existing technology is a far smarter approach and saves you money, but you need expertise for that. Did you know that within companies only less than 25 percent of the technology functions are used, and that 50% of the technology is not maintained.[54] So focus on getting more bang for your buck.
   - Make a smart choice of vendors. Separate security services from your traditional office automation supplier. We have seen large integrators or office automation suppliers fail to provide adequate protection and specifically when things went wrong were not equipped to help. They can even make things worse by sweeping their flaws under the carpet.

3. *Form a smart coalition with industry peers*. This way you understand your strategic context and industry dynamics better. Another positive effect is that every company has previously suffered from your problems so you don't want to reinvent the wheel but rather re-use oth-

53 *NotPetya Ransomware Attack Cost Shipping Giant Maersk Over $200 Million: https://www.forbes.com/sites/leemathews/2017/08/16/notpetya-ransomware-attack-cost-shipping-giant-maersk-over-200-million/#4994da404f9a*

54 *Only 50% of the implemented technology is subject to strict maintenance processes such as patch and vulnerability management. Source: Y. Bobbert and J. Mulder, "A Research Journey into Maturing the Business Information Security of Mid- Market Organizations," International Journal on IT/Business Alignment and Governance, 1(4), 18-39, October-December 2010, United States, 2010*

er companies' best practices. Frameworks, best practices, games, methods, virtual reality games, crisis playbooks, etc. – there's a lot freely available, so you don't need to pay expensive consulting firms. Within Antwerp Management School we produced artifacts that many companies have already profited from in solving wicked strategic cyber-problems. These include checklists for industrial control systems, checklists for Agile security, API strategies, etc. So, make sure educational institutions are part of your strategic coalition as well.

4. *Value your assets*. Many companies have started to protect their IT systems and IT processes. What is overlooked most of the time is the value of the digital asset that houses valuable customer data. We have seen companies protecting non-valuable assets with expensive security technology, processes, and procedures. Strange, right? Since other assets such as buildings and inventory are listed on the balance sheet but usually data isn't. Data is obviously makes a valuable contribution to the strategic direction of the firm but strangely enough it's not included on the balance sheet. Most external accounting is focused on gaining assurance about systems that influence the integrity of the financial figures that end up in the annual report. Two things are important:
   - Every system that you have in your company is part of the "digital footprint" of the company and therefore an entry point for hackers. So even your Microsoft Excel macro with sales forecasting models or actuarial models represents an attractive target for a hacker who wants to enter your corporate network. All assets should be taken into account when drafting the strategic plan. We know from experience that these "rogue" systems can be the reason you're being attacked. Because hackers have often gained access via an Excel macro and thus infiltrated the entire network.
   - When drafting a strategic security plan, business assets and their owners need to be part of the conversation and proactively taken into account. Only they can determine their value for the business and the potential impact if these assets are stolen or compromised. This is why in the academic literature information security is often described as Business Information Security (BIS) since the focus must be on strategic Business assets. Appointing asset owners also helps when incidents occur, since they are better informed and you can find them quickly during a crisis.

5. ***Demystify the jargon***. We see many strategic plans shelved because of the jargon and abbreviations used. Many stakeholders who should be part of this plan simple won't get onboard if they can't empathize with the message and the tone. In our experience using strategic models such as Porter's, McCarthy's (the four Ps) or Simon Sinek's "Why, What and How"[55] or Balanced Score Cards can really help to get non-tech supporters onboard.

6. ***Smart decision-making*** on intermediate steering of plans (to avoid unpleasant attacks). When you're executing the strategic plan, intermediate decisions might be needed. Multiple parties will try to intervene or influence the execution simply because they are following their own agenda or don't see certain benefits. Getting the right strategic people into this coalition is key. This is usually a formal organ, but decisions are often made over a cup of coffee. This decision-making body should have strategic vision, authority, and credibility within the organization. And it should have the guts to support the CISO.

55 Start With Why: How Great Leaders Inspire Everyone to Take Action is a book by Simon Sinek.

“Changing an organization, a company, a country – or a world – begins with the simple step of changing yourself.”

Tony Robbins

03

Changing

Introduction

In digital security we often say that the human element is the weakest link. We often make policies, we draft a security plan, we provide users with annual mandatory training sessions. We simulate phishing attacks. We check for clear (or clean) desks. Yet, users still don't behave the same as they do at home. At home? Yes, because at home usually they don't leave their doors open, don't let everyone who rings the bell in, they don't give their key to the cleaning lady or their pin code to the neighbor. However, at work they share their passwords with their colleagues, they provide information to unknown people on the phone, they install software of companies they don't know, etc.

So how can we change this? How can we get employees to behave the way we want? By employees we don't only mean the end-users in the business, but also IT staff. As you can read in this book, IT staff also have their own set of behavioral issues that represent a huge threat for digital security.

To answer this question, in this chapter we talk about change management , we address corporate culture and the way this might be changed, and we discuss the role of "soft controls."

Change management

Changing an organization to achieve a certain goal is not new. An important part of changing organizations is the human element. We learned in the research conducted by P. Lally that it takes

a human being on average 66 days before a new behavior becomes automatic.[1] This means that mandatory online training will not only be the thing that makes change successful.

Over the last 100 years many methods, studies and understandings have been developed. Some of the following persons brought great contribution: Arnold van Gennep (1909), Kurt Lewin (1948), John Kotter (1996), Spencer Johnson (1998), etc.

To start with understanding change management, here is a definition by Prosci, a current well-known change management methodology:

The discipline that guides how we prepare, equip and support individuals to successfully adopt change in order to drive organizational success and outcomes.[2]

Although many definitions are available, in general all approaches prepare, support, and help individuals, teams, and organizations in making organizational change. Although change management might also cover other disciplines in their approach, such as information technology and business solutions, we mainly focus in this section on the people and the change they need to make.

A model that probably many us have seen on LinkedIn in recent years is from Tim Knoster and Mary Lippitt, who identified six variables that are crucial for change (see figure below).[3]

1 *How are habits formed: Modelling habit formation in the real world, Phillippa Lally, Cornelia Jaarsveld, University College London, London, UK*

2 *What is Change management: source url: https://www.prosci.com/resources/articles/what-is-change-management*

3 *Dr. Mary Lippitt's model from 1987, later adapted by Knoster, Villa, and Thousand (2000)*

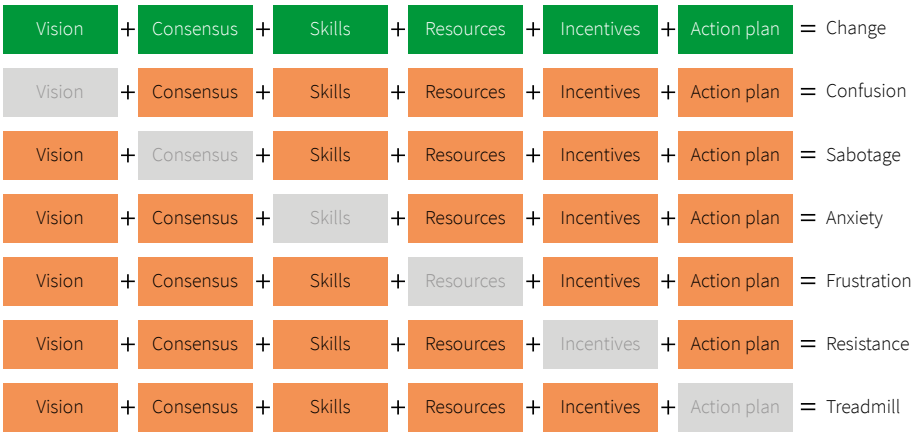


Figure 7: The Lippitt & Knoster Change Model.

While reading this introduction about change management, one might think, "and why should this be relevant for digital security?" To answer that question, in the next paragraph we show why change management is very relevant for digital security.

If you're walking down the right path and you're willing to keep walking, eventually you'll make progress.[4]

4 *Quote by Barack Obama*

Eight reasons why changes fail

To better explain the importance of change management for digital security we used the eight reasons why transformations fail provided by John P. Kotter.[5] He identified these reasons based on an analysis of about 100 companies. In the table below (Table 4) we made a short analysis of how digital security improvements are managed within organizations. Our observations are based on our combined 45 years' experience within about 150 companies (profit and nonprofit), mainly in Europe and in the USA. We also highlight important interventions we have carried out, which were designed to change the status quo.

Table 4: Eight reasons why "Digital security change management interventions fail"

No	Reason why change fails	Digital Security Observations
1	Lacking a Sense of Urgency	Although security professionals constantly stress the importance of information security, they often are unable to establish a real sense of urgency at the right level in the organization and with the right tone of voice. An external audit or regulator is often the only way to make security urgent, or in some cases security specialists are lucky and are smart enough to use a "good security incident."
2	Lacking a Powerful Guiding Smart Coalition	In most cases we see that security specialists are working in their own team or by themselves, are placed somewhere in operations, report to the CIO or the CISO is a part-time role of the infrastructure manager, etc. They often try to implement security by "themselves" instead of building a strong coalition with internal/external stakeholders at the levels that are able to influence. Security if too often just an operational task that somebody looks after in a siloed part of the organization.
3	Lacking a Vision	Although we see that security professionals often say that they have a security strategy (which is often a plan based on ISO 27001/2; see also the section on strategizing), a vision on security is mostly missing. ISO is simply about "What" you're going to execute the strategic plan; it should also encapsulate "Why."
4	Under- communicating the Vision by a Factor of Ten	Communicating the vision, the direction, the goal of security is again often lacking. We sometimes see a policy on intranet, security awareness training sessions are held, etc., but really taking the time to repeatedly communicate a vision (e.g. when communication is bi-directional) is lacking. Communicating your vision requires quantum communication.

5 *Leading Change: Why Transformation Efforts Fail, John P. Kotter, Harvard Business Review, 1994*

No	Reason why change fails	Digital Security Observations
5	Not Removing Obstacles to the New Vision	Improving digital security is often done based on a plan with concrete security measures. Although a security specialist might be full-time available and have sufficient resources, this is not the case for staff who need to implement these measures. Obstacles are other company priorities or the priorities of the manager of the department (see also "Stuck in the Matrix " in the section on Leading). Thus, this is all about aligning and influencing the backlog and agendas.
6	Not Systematically Planning for and Creating Short-Term Wins	As mentioned before, often there is some kind of plan available for digital security. In some cases the plan is actually managed, and deliverables are delivered according to the plan. The question remains whether this is also systematically done in order to create short-term wins.
7	Declaring Victory too soon	We believe a good security professional will never say they're done. They will always see new risks and will probably not declare victory too soon. Since you never know when you're next going to be attacked. So, this is definitely not a pitfall for digital security.
8	Not Anchoring Changes in the Corporation's Culture	Digital security is often too technocratic. The focus is on technical measures, processes, and procedures. Awareness is on the agenda and training sessions are held (between 15:00 and 17:00 on a Wednesday. On Thursday people go back to work, doing things the way they've always done them); however, digital security is hardly ever seen as part of organizational change, let alone as part of a corporate culture that needs to change.

To summarize, from the eight reasons why transformation fail, according to John P. Kotter, we can state that digital security is closely related to seven of them. This means that we need to start seeing information security improvement programs as part of organizational change, which also needs to be managed as such, and not as a small project for implementing a minor tool.

A common pitfall that we also see but isn't one of the reasons mentioned by Kotter is the wrong person driving the change. The change is often handled by an external expert or change manager instead of the responsible management. In a short article by Ron Ashkenas, a leading voice on organizational transformation, leadership, simplification, innovation, and merger integration, he states "The content of change management is reasonably correct, but the managerial

capacity to implement it has been woefully underdeveloped." Although managers are sent to training sessions, they still depend on external experts to make the plan and execute the actual change.[6]

Kotter also mentioned the following improvements:

1. *Establishing a sense of urgency*
   - Examine market and competitive realities
   - Identify and discuss crises, potential crises, or major opportunities.

   E.g. Create and communicate a clear sense of urgency specifically for the company that you're in. Don't just state that cybersecurity is important. Tailor the urgency to the company. See also some – practical – reflections of our work in the section on Strategizing.

2. *Forming a powerful guiding coalition*
   - Assemble a group with enough power to lead the change effort
   - Encourage the group to work together as a team.

   E.g. Don't try to change the world by yourself. Involve the relevant stakeholders who have the power to influence people in making digital security a success.

3. *Creating a vision*
   - Create a vision to help direct the change effort
   - Develop strategies for achieving that vision.

   E.g. As mentioned in the section on Leading, a vision is hugely important to set a direction and give people purpose.

4. *Communicating the vision*
   - Use every vehicle possible to communicate the new vision and strategies
   - Teach new behaviors by the example of the guiding coalition.

6 Change Management - Needs to Change, Ron Ashkenas, Harvard Business Review, April 16 2013

E.g. Don't just communicate the vision once; keep communicating it in different ways so that it sticks in people's minds. Just think about those annoying TV commercials that you don't like but you can't forget.

5. *Empowering others to act on the vision*
   - Get rid of obstacles to change
   - Change systems or structures that seriously undermine the vision
   - Encourage taking risks and nontraditional ideas, activities, and actions (as you can read in the section on high-performing teams); André de Waal also stresses the importance of action orientation and risk-taking as we addressed in the section on high-performing security team.

   E.g. Take ownership of the change and act. Support people in being able to move in the right direction even if they have to take a risk.

6. *Planning for and creating short-term wins*
   - Plan visible improvements in performance
   - Create those improvements
   - Recognize and reward employees involved in the improvements.

   E.g. When starting with the improvements in security, focus on a few instead of all at once. Focus on the most important ones and deliver a big win quickly. As someone once said to us: "the only way to eat an elephant is bit by bit."

7. *Consolidating improvements and producing still more change*
   - Use increased credibility to change systems, structures, and policies that don't fit the vision
   - Hire, promote, and develop employees who can implement the vision
   - Reinvigorate the process with new projects, themes, and change agents.

   E.g. Keep up the momentum of an improvement to make even more improvements.

8. *Institutionalizing new approaches*
   - Articulate the connections between the new behaviors and corporate success
   - Ensure leadership development and succession.

E.g. show some successes and, while presenting them, make a connection with a new behavior that is one of the reasons for success.

Eight reasons why changes can succeed

Some practical examples (gained from practice):

1. ***Establishing a sense of urgency***: Establish a collective sense of urgency, since it's the entire organization needs to be involved, starting at the top. In UWV we organized a collective session to implement the Baseline Information security Rijksdienst (BIR) for governments and invited member of the Board Jose Lazeroms to kick it off. All directors in the organization received this BIR, including a manual; we provided them with training sessions, roadshows, and a job description. We also threw a small party. The fact that Lazeroms was intrinsically motivated to implement the BIR helped a great deal and she was one of the few Board members in 2015 who was actively involved in the entire program. And of course, the directors complained afterwards, asking why the CISO made such a circus out of it. But that's all part of the change game: "get the first dancer onto the dance floor and the rest will follow."[7]

2. ***Forming a powerful guiding coalition*** that supports your security vision and strategic plan. But how do you do that? Simple, but not easy to execute; ask the CEO and CIO onto the dance floor. Let them talk and discuss the major risks and security activities in their own Business Unit and what activities they can tackle collectively. Having meaningful debates about what DevOps and continuous software delivery brings in terms of risks and what this requires from "new" distributed risk management methods in teams. The Business Unit Security Officers (BSOs) at NN Group were asked to bring their bosses (CIO/CRO) and

7 *First Follower: Leadership Lessons from Dancing Guy, source; https://youtu.be/fW8amMCVAJQ*

second-line risk managers to this dancing party organized by the group CISO. Basically this came down to a group of 150 people brainstorming on risks, resources, security measures and how to translate these into their own security plans and it was the role of the CISO to aggregate these into one Group Business Information Security (BIS) plan with "must haves," five things the CEOs of the units were accountable for, and that everybody should adhere to. And again, it takes courage for the Board member to, stick his or her neck out, support this "strange new thing," and make sure the CISO gets full Board support to invite all the senior managers to this party. At NN Group this was CRO Doug Caldwell, a risk veteran who already successfully disentangled NN Group from ING Bank and brought the NN Group to an IPO. His intrinsic motivation was to help the CISO and have the CISO positioned as a sustainable role. This was his last major action before he would leave the company to go back to the United States. He sincerely believed in the security vision, that taking better care of customer data and assuring a safe digital transformation would lead to more customers and higher perceived value by the market. Nowadays we would call this data centric security strategy a "Zero Trust" based strategy where the data should be secured regardless of the location. And again, most people will laugh at you when you present out-of-the-box ideas, and the CISO was the first onto the dance floor to get things going. After three years, these same people led the pack in their own units, were part of the smart coalition and most of the past silos were broken.

3. *Creating a vision*: The vision starts with a dot on the horizon that describes who you want to be for which target group. Amazon's newspaper way is a successful method to describe your vision. What makes this vision resonate with your target audience is not only describing it, but also visualizing it with drawings or pictures. We have observed that the power of drawing helps people to understand the vision better, but also to take ownership of their responsibilities. Once people start thinking, drawing, and writing things down for themselves and you put this into goalsetting agreements, ownership starts to grow. Within UWV the implementation of the BIR was one element of the vision of the CISO. Another vision was to create "one entry" for all citizens and to create a smart coalition between other levels of government. The first was realized via the Digital ID portal (DigID) and clear security requirements for this.

In 2016, Wiekram Tewarie of the UWV received an award from the organization's CISO for establishing this for all government agencies in the Netherlands. And this smart coalition (Centrum Informatie Beveiliging & privacy) grew to become one of the Netherlands' leading government bodies with 3000 members, all part of the CISO vision drafted in 2015.

4. *Communicating the vision*: When quantum communicating your security vision and strategic plan you need to have a dedicated person, channel or some kind of resource that keeps this going continuously. When there is already something in place such as steering committees, intranet, workshops, educational programs, inspirational talks, onboarding programs. Just make sure that during the change you're represented everywhere. We were surprised how many people were willing to help communicate the message on your behalf or want to include you in their program. In NN the CISO was 50% of his time engaged with non-security-related initiatives. Think of young professional programs, labor marketplaces, onboarding, Business Units talks, call center internships, etc. just to show your face, your sincere interest in the business and to align your vision with other people's activities and agendas. One golden rule is to always align with branding, since some activities might impact things such as share value.

5. *Empowering others to act on the vision*: We have experienced that this requires a two-way approach; bottom-up and top-down. We have seen that collectively drafting the above-mentioned "must haves" helps the thinking process. People start thinking by themselves how they are going to do this and when. Of course, there are always people who overload them with work and just don't take no for an answer. Helping people to say a smart NO to things that do not matter is a good strategy.

6. *Planning for and creating short-term wins*: We have learned that communicating Mike Tyson's lesson "Everybody has a plan, until they got punched in the mouth" resonates with everybody. Most economies were strong and super resilient early 2020, until COVID-19 literarily knocked out all countries in less than three months. In security planning we have learned the hard way. You had better have some intermediate result that you quantum com-

municate to your peers and management before you're wiped out. In this case it's all about communicating what you have delivered and not what you're planning to do. For example, must-have, people-trained, onboarded applications in the security logging and monitoring system, enrolled secure endpoints, the number of crisis exercises or successful penetration tests; tangible and factual results that protect the company.

7. *Consolidating improvements and producing still more change*: Declare intermediate results and share them collectively. Award whistle blowers in the organization who report violations. And if you take over someone's responsibility, never complain about how they did it wrong, since that says more about yourself than your predecessor. Awarding teams and people is a perfect way to create goodwill and ownership throughout the organization since if claim a victory which is not theirs, the group will correct that immediately.

8. *Institutionalizing new approaches*: Making digital security the DNA of the Business start with renaming it Business Information Security (BIS). People always asked us why we add business and don't just say digital security. Since the business is the owner of the asset, they also should take ownership of it. This begins with a clear definition of BIS. By having meaningful conversations about the why and what, not the how (e.g. ISO 27000) you really transfer ownership and responsibility to the first line of the business. This is similar to finance and other quality and control functions that we have had for 150 years. Did you know that it took 70 years to formalize a financial structure, process, and culture in a company, and yet we still see slip-ups in financial control?

In other sections of this books we talk about the importance of a vision and strategy, about leadership, about "never wasting a good incident," corporate culture, and about the importance of politics. We will not repeat these statements here. In this section we try to give some additional tools to support you in making the relevant change that haven't been discussed in other sections.

A fool with a tool is still a fool

As mentioned in the article by Ron Ashkenas, while change management content may well be correctly formulated, management capacity is often lacking. In the same article he noted that there are over 83,000 books on Amazon about change management, and most studies still reveal a 60-70% failure rate for organizational change projects — a statistic that has stayed constant from the 1970s to the present.

So, what are we going to do about improving that rate, especially for digital security? We are going to give you some of the models from the 83,000 books that might help you when making that change for digital security within organizations. In our opinion, it's not about the specific tool, model, or methodology, it's about being aware of the cyberinformation that isn't technocratic but is more than relevant for making digital security a success.

One day at a time

In 1969 psychiatrist Elisabeth Kübler-Ross developed the Kübler-Ross model in her 1969 book "On Death and Dying" that described the five stages of grief. This model was designed to explain the series of emotions experienced by terminally ill patients prior to death, or people who have lost a loved one.[8] Based on this work the change curve developed by Kübler and Ross shows how we react emotionally to the announcement and subsequent implementation of significant change (Figure 8). For the changes that we want to make in digital security to ensure that the organization is more secure we need to recognize that this involves emotional experiences. When we acknowledge these emotions, we can start to manage them.

There are several versions of the change curve available; however, most them are consistent in terms of the following basic emotions which they evoke:

Denial: Once information has been received about an upcoming change, the natural reaction is to deny that there is a need for change and that it's in fact not happening. Typical reactions: "it

8 The Kübler Ross model is described at https://en.wikipedia.org/wiki/Kübler-Ross_model

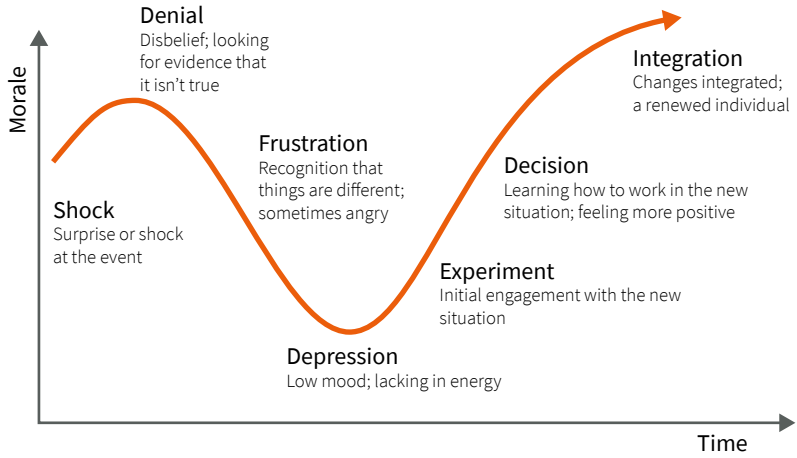


Figure 8: The Kübler-Ross change curve.

won't work here," "we have tried it before, but it didn't work," "we already gave users awareness training and still we have many users causing security incidents."

Anger/frustration: The next emotion related to change is to go through the anger phase once one realizes the change won't go away. "It's so childish that we need to lock our screen when leaving the desk," "what would a patch management procedure help if the applications won't support the versions (and the application owners are too lazy to upgrade(right?))," "we don't need change management, because we know the risks and would still do the same without the registrations."

Depression. Then the all-time low emotion comes by when the anger begins to wear off and the change really hits. You can recognize this when people stop complaining and start moaning, while executing security measures or taking part in progress meetings.

Acceptance. At this point the negative emotions start to disappear and a more optimistic and enthusiastic mood begins to emerge. At this stage people start to say things like "it's actually not as hard as I expected" or "we now have a more stable environment and are no longer running after these security incidents" and people might even start to point out to each other when somebody is engaged in risky activity.

Integration. Now people start to focus on the future and there is belief in the change. At this stage people come with suggestions for improvement themselves or start giving you information about certain areas where they see many security risks.

To help you through this change curve, we have the following advice:

- Keep communicating about why the change has to happen, why does security need to be improved and why do the people need to act differently.
- As mentioned before, define, and communicate a compelling security vision.
- Keep listening to concerns. It even helps people to know that others are experiencing the same feelings. So don't just keep giving more and more reasons why we need to be more secure without listening, but show some empathy and take time for people. Or maybe even use the principles of Aikido, but in this case without the physical contact.
- Support people when they experience loss. Help them.
- Allow people to ask questions about the change and take time to answer them.
- Coach and guide the people through the change.
- Involve people in designing the new future and moving toward it. Although you might be much quicker by yourself or know much more about security then others, it's an excellent approach to let people help to design the security measures and get the "buy-in" from them that you need. Because would they be against security measures when they have designed them themselves?

In addition to this, please be aware that not everyone goes through the curve at the same pace. It might also be that at some stage people move back on the curve from depression to being

angry again. So, this is not a panacea. It's good to know about these phases, but you need to be creative and have the empathy to do the right things at the right time. Sound easy, doesn't it?

In addition to the change curve there are some other change management approaches that might be useful and support you in this change you're making when you start improving digital security. We have selected the best-known methods, or methods that have been used a lot lately.

The Prosci ADKAR model

Currently there is a more tangible model than the change curve which you can use to manage change within your organization. The Prosci ADKAR® model guides individual and organizational change. Created by Prosci founder Jeff Hiatt, ADKAR is an acronym that represents the five tangible and concrete outcomes that people need[9] to achieve lasting change: awareness (of the need for change), desire (to be part of the change), knowledge (of how to change), ability (to implement the change) and reinforcement (to sustain the change).

Lewin's change management model

Lewin's change management model was developed in the 1940s. The model is quite simple because it only has three stages: *Unfreeze, Change, Refreeze*

First, leaders "unfreeze" the employees by creating a compelling message to encourage employees to let go of the way things have always been done and open up to something new. In this phase the security vision, but also stressing the core values, is important to address. One needs to question whether this can be the work of the current CISO, which according to research by Deloitte (see "Stuck in the Matrix" in the section on Leading) is mainly a guardian and technologist, rather than a strategist or advisor

9 *Source: https://www.prosci.com/adkar/adkar-model*

Second, effective "change" requires clear and constant communication during and after the change. According to Lewin, leaders should focus on change by communicating regularly, killing any rumors, and involving people in the process. As you can see, this is similar to the change curve and the Prosci model.

Lastly, the "refreeze" step. The word "refreeze" is used here to make clear that like with ice molds, teams and organizations need to unfreeze from an old mold before they can fit into a new one. Again this is similar to the last steps in the change curve and the Prosci model.

McKinsey's 7 S Model

The McKinsey 7 S model is often mentioned within change management methodologies as one of the top ten models. The 7 S's are: *Strategy, Structure, Systems, Shared Values, Skills, Style,* and *Staff*. However, we believe this model is a mainly process-centered method around the alignment of seven fundamental elements of any organization and are mainly technocratic. As a result, we don't think it's very relevant for managing the human side of change.

There are many more theories and methods out there, such as the Nudge Theory and the Bridges' Transition Model. Some might focus more or less on certain phases in a change process or on the human side of change. It's unnecessary to explain all these models and theories in further detail in this book. The essence of our message is that we need to start seeing improvements in digital security as a change within an organization and manage this change as a real change program.

Relational mechanisms

Culture eats strategy for breakfast[10]

In the previous section we talked about changing organizations and several models that address the need to manage the change toward the required state. Another important subject that might have a significant impact on the implementation of a more secure organization is the culture within organizations. Because, without the right culture for security, it will be challenging to achieve your goals.

In the financial sector we learned in the crisis of 2008 that culture and behavior can have a significant impact on the risks that we're facing. You just have to watch movies such as "Wolf of Wall Street" and "The Big Short" or read the book "Among the Bankers" by Joris Luyendijk and you know how culture and behavior can affect taking risks. As a result, we now see that external regulators in the financial sector start monitoring the behavior and culture within financial institutes based on a supervision methodology (e.g. supervision methodology behavior and culture of the DNB[11]).

For digital security the same is applicable. As noted by many researchers, digital security is mainly a managerial issue rather than a technical one; without a profound change in its organizational security culture, an organization can't achieve effectiveness in managing its digital security.[12]

In this chapter we focus on what corporate culture is and how to get to a security culture that will support your goals.

10 *Quote by Peter Drucker to express the impact culture can have on realizing the strategy*

11 *https://www.dnb.nl/binaries/Toezichtmethodieken%20gedrag%20en%20cultuur_tcm46-380402.pdf*

12 *Y. Bobbert & J. Mulder, "Governance Practices and Critical Success factors suitable for Business Information Security," International Conference on Computational Intelligence and Communication Networks, 18 August 2015*

What is corporate culture?

In the literature, you'll find "*the way we do things around here*" (Deal and Kennedy, 1982)[13] one of the easiest explanations of what culture is. A more elaborate definition of culture was made by Needle (2004): *organizational culture represents the collective values, beliefs and principles of organizational members and is a product of such factors as history, product, market, technology, and strategy, type of employees, management style, and national culture; culture includes the organization's vision, values, norms, systems, symbols, language, assumptions, beliefs, and habits*.[14]

Ravasi & Schultz (2006) wrote that *organizational culture is a set of shared assumptions that guide what happens in organizations by defining appropriate behavior for various situations*.[15]

So how can we ensure that the "way we do things around here" is as secure as necessary?

Various studies have shown that you can identify different cultural types or styles. Quinn and Rohrbaugh (1983), for example, distinguish four types of culture within their Competing Values Framework[16], which have the following characteristics:

- ***Human Relations Model***: with a focus on cohesion, morale, and human resources development as criteria for effectiveness.
- ***Open Systems Model***: with a focus on readiness, growth, resource acquisition and external support.
- ***Rational Goal Model***: with a focus on planning, goal setting, productivity, profit, and efficiency as well as effectiveness.
- ***Internal Process Model***: with a focus on stability, efficiency, rules and procedures and control.

13 *Corporate Cultures: the Rites and Rituals of Corporate Life, Deal and Kennedy, 1982*

14 *Needle, D. (2004). Business in context: An introduction to business and its environment (4th ed.). London: Thomson Learning*

15 *Ravasi, D., & Schultz, M. (2006). Responding to Organizational Identity Threats: Exploring the role of Organizational Culture. Academy of Management Journal, 49(3), 433-458*

16 *Quinn, R. E., and J. Rohrbaugh. (1983). A Spatial Model of Effectiveness Criteria: Towards a Competing Values Approach to Organizational Analysis. Management Science, 29(3), 363-377*

Edgar Schein, a former MIT professor once said: "*The bottom line for leaders is that if they do not become conscious of the cultures in which they are embedded, those cultures will manage them*." Schein created a model for organizational culture in which he identifies three levels[17], which refer to the degree to which the different cultural phenomena are visible to the observer:

- ***Artifacts and behaviors***: the most visible level with any tangible, open or verbally identifiable elements in any organization. These are things such as organizational structures, processes, but also dress code, office jokes, office design, etc.
- ***Espoused values*** are the organization's stated values and rules of behavior. These are organizational strategies, goals and official philosophies and public statements of identity.
- ***Shared basic assumptions*** are invisible and include unconscious, beliefs that are taken for granted, perceptions, thoughts, and feelings.

In addition to these studies there are many more studies by, for example, Shalom Schwartz, Geert Hofstede, Daniel Denison, Charles Handy. An article published in HBR by Boris Groysberg *et al*[18] studied 100 of the most commonly used social and behavioral models and identified the styles that distinguish a culture and can be measured. In the article they identify eight styles and also make a comparison to statements by leaders of well-known companies in an integrated culture framework. Reflected in Figure 9.

In this article they also state pros and cons of these culture styles. This is we believe not the essence of the article. The most relevant insight is that "When aligned with strategy and leadership, a strong culture drives positive organizational outcomes." In other words, "any culture could be effective as long as it's aligned with strategy and leadership."

17 *Schein, Edgar H. (2004). Organizational culture and leadership (3rd ed.). San Francisco: Jossey-Bass. pp. 26–33*

18 *The Leader's Guide to Corporate Culture, Changing your organization's culture can improve its performance. Here's how to do that. by Boris Groysberg, Jeremiah Lee, Jesse Price, and J. Yo-Jud Cheng, HBR, January-February 2018.*

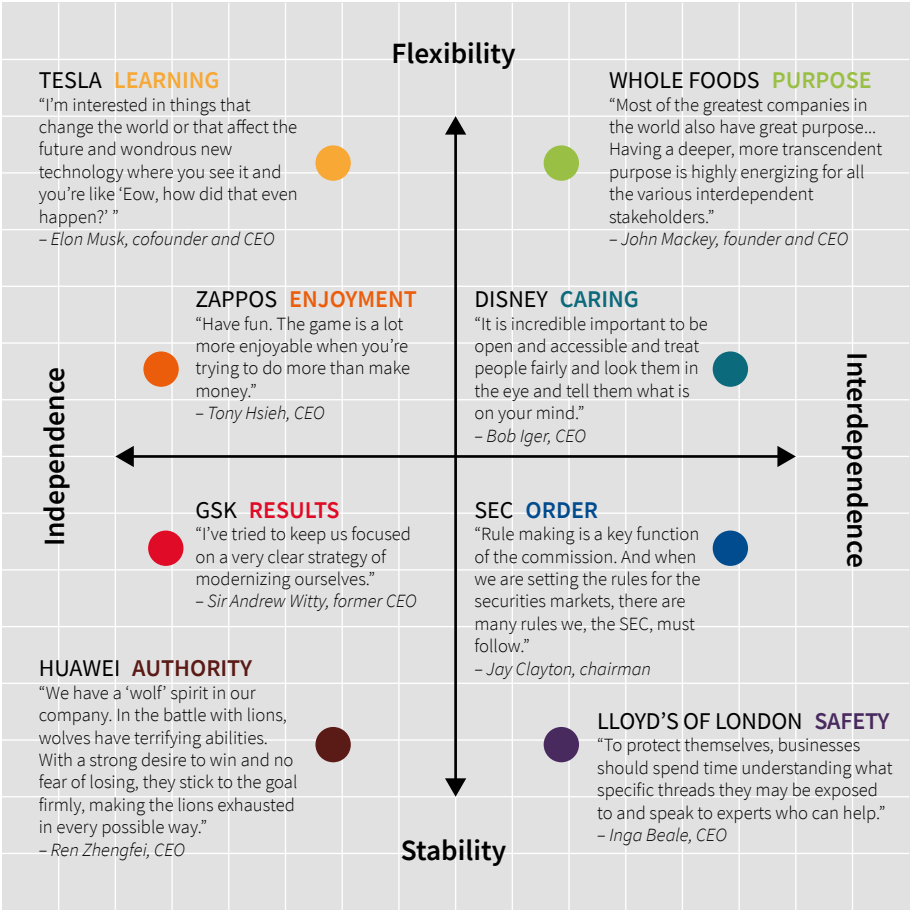


Figure 9: Integrated Culture: Leader Statements from "The Leader's Guide to Corporate Culture," by Boris Groysberg et al, HBR.

Other interesting relationships that were identified during their analysis of the cultures of more than 230 companies along with the leadership styles and values of more than 1,300 executives across a range of industries, regions, and organizational types (public, private, and nonprofit) are:

- Employee engagement is most strongly related to greater flexibility, in the form of *enjoyment, learning, purpose*, and *caring*.
- A positive relationship was observed between customer orientation and those four styles plus *results*.
- Engagement and customer orientation are stronger when employees are in close agreement about the culture's characteristics.

When reading the above, some readers might think we as security professionals now have a problem. On the one hand we see companies that want to have better employee engagement and customer orientation, while on the other hand digital security is perceived by many people as the opposite of flexibility. Does it mean that if you're in a company that is more focused on *order* and *safety* you might have an easier life?

One could also read it in another way. If you want more engagement for your security, you might need to create a security culture that contains *enjoyment*, *purpose*, *learning*, and *caring*.

In order to install security in the DNA of the employees of your organization, the culture needs to be aligned with the strategy. And the top leadership must also be doing that. It's not the first time that you might focus on the culture of the future being aligned with the strategy, while in the rest of the company there's complete misalignment between the strategy, leadership, and the culture with no changes being made. So be smart in the way you create that security culture.

Another observation we've made in our daily work is that, not only your organization culture counts, but also the culture of your own security team. If you want more employee engagement while the company is safety and order focused, you still might want to create a more flexible culture in your own team.

So now that we know what culture is, let's discuss the way we get to that security culture.

Getting security into the DNA of your company

Culture trumps strategy every time, so changing the culture is essential to achieving your strategy. Changing culture is, however, one of the hardest things to do. Specifically, for security culture there are some publications available e.g. a chapter in a book by Ira Winkler.[19] Often these are focused on "leading by example," "strong policies and procedures," "awareness and explanations," "peer pressure" and in some cases "reward good behavior and punish bad behavior." We believe these recommendations might change habits and behavior a bit, but this will not lead to an intrinsic change in behavior or a really secure culture.

According to Workman *et al*. studies that have investigated organizational aspects of digital security deterrents have shown that increasing the severity of punishments associated with contraventions may reduce their actual (rather than potential) incidence. They found both punishment and ethics training can be effective in mitigating the threat to software and digital security. Furthermore, they determined that people who follow rules to avoid punishment or negative consequences (as well as those for whom the concept of authority was the motivating factor) are more likely to be deterred by punishment than by ethics training. However, Workman *et al*. address problems related to this as well. Using a punitive methodology to modify the behavior of insiders creates a mechanistic organizational environment[20] in which people tend to refuse taking actions not specifically defined for them for fear of punishment. They focus on documented rules and procedures stipulating how work is to be carried out, and they strive to avoid risks, creating a rigid, often ineffective, and even hostile work environment.[21] So, what does this factor do to innovation, creativity, and the flexibility of the organization? Herath and Rao suggest that intrinsic and extrinsic motivators significantly influence security behaviors, whereas certainty of detection was found to be significant and severity of punishment has a negative ef-

19 *Advanced Persistent Security, A Cyberwarfare Approach to Implementing Adaptive Enterprise Protection, Detection, and Reaction Strategies, Ira Winkler et al, 2017*

20 *G. Stalker & T. E. Burns, „The management of innovation," SSRN, 1961*

21 *M. Workman & J. Gathegi, „Punishment and Ethics Deterrents: A Study of Insider Security Contravention," Journal of the American society for information science and technology, pp. 212-222, 2007.*

fect on intentions related to security behavior.[22] The factors zero trust and rules and procedures to control the business also scored as less effective.

So, what would be the right way to create that desired culture? According to Jon R. Katzenbach[23] it's to (1) make sure that your strategy and culture match. Not in a vague way e.g. "the current culture needs to be more open to support the strategy," but where a few cultural traits truly do match and support the strategy. As an example, see the way Disney connects to a culture of *caring*. (2) Focus on a few critical shifts in behavior. Change is hard. So you need to choose your battles. (3) Honor the strengths of your existing culture. If you can find ways to demonstrate the relevance of the original values and share stories that illustrate why people believe in them, they can still serve your company well. Acknowledging the existing culture's assets will also make major change feel less like a top-down imposition and more like a shared evolution. (4) Integrate formal and informal interventions (formal, such as reporting structures, processes and policies, performance management, internal communications and informal such as meaningful manager-employee connections, cross-organizational networks, communities of interest, ad-hoc gatherings and changes to the physical environment, resources, and aesthetics. (5) Measure and monitor cultural evolution. It's essential to monitor progress and adjust where necessary. Attention should be given to "business performance," "critical behaviors," "milestones" and "underlying beliefs, feelings and mind-sets."

Boris Groyberg[24] presents four levels for evolving a culture that should be taken into account to move to the required situation. (1) Articulate the aspiration, (2) Select and develop leaders who align with the target culture, (3) Use organizational conversations about culture to underscore the importance of change and (4) Reinforce the desired change through organizational design.

22 *T. Mincong, Meng'gang & T. Zhang, "The impacts of organizational culture on information security culture: a case study," pp. 179-186, November 18, 2016*

23 *Cultural Change that sticks – start with what's already working, Jon R. Katzenbach, Ilona Steffen, and Caroline Kronley, HBR, July-August 2012*

24 *The Leader's Guide to Corporate Culture, How to manage the eight critical elements of organizational, B. Groysberg, J. Lee, J. Price, J. Yo-Jud, HBR, January-February 2018.*

Knowing all the above doesn't make it much easier for digital security as part of a larger company culture. Changing the intrinsic and extrinsic motivator seem to have the most influence on security behavior. But the actual message and approach to changing the security culture and behavior also significantly depend on the current and desired culture style of the organization. Not to speak of whether the management of the organization "talks the talk" and "walks the walk" or not.

Criteria of a security culture & behavior

Now that we know what culture is and how we can get to the required security culture, we also need to be able to measure it. We found two interesting pieces of work that are very useful for measuring digital security culture. In particular, the soft controls must sound like music to compliancy-focused digital security and risk professionals.

In a whitepaper from CLTRe on measuring security culture[25] we found seven usable security culture dimensions, which seems to be mainly behavioral aspects, to measure security culture:

- ***Attitudes***: Employees' feelings, thoughts, and emotions about the various activities that relate to security culture.
- ***Cognition***: Employees' awareness, knowledge and beliefs regarding practices, activities, and self-efficacy that are related to security culture.
- ***Behavior***: Actual or intended activities of employees who have a direct or indirect impact on security culture and information security, including risk-taking behavior.
- ***Communication***: The way that employees communicate and interact, exchange support regarding security issues and incident reporting.
- ***Norms***: Unwritten expectations regarding appropriate behaviors relating to use of information technology in organizational context, as well as perceptions of what practices are normal and unproblematic.
- ***Responsibility***: Perceived obligations to behave correctly toward maintaining security culture.

25 *To measure security culture, A scientific approach, Dr. Gregor Petric and Kai Roer, 2018, CTRLe*

- *Compliance*: Awareness of existing organizational policies on digital security, understanding and making significance of them, acting in accordance with them.

Muel Kaptein identifies eight cultural drivers[26] or "soft controls" which most influence the behavior of people in organizations. The more prominent these are present in an organization, the greater the chance of people engaging in desired behavior and the smaller the chance of risks and incidents. Although this model was not specifically designed for digital security, it can be used to create a better security culture within your organization (see Figure 10).

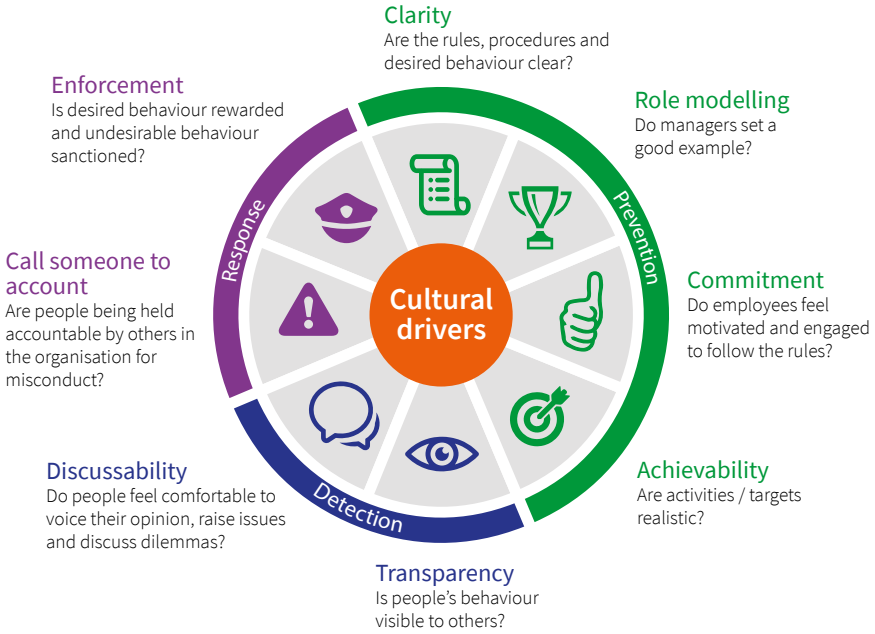


Figure 10: Eight soft controls, Muel Kaptein.[27]

26 *Muel Kaptein, 'Waarom goede mensen soms de verkeerde dingen doen, 52 bespiegelingen over ethiek op het werk', 2011.*

27 *Figure has been taken from https://home.kpmg/au/en/home/insights/2018/08/soft-controls-model.html*

Getting the security culture you need

In this chapter we've described several cultural models but also some developments that we as security professionals should take into account. You probably understood that there is not a good or a bad organizational culture; there is mainly misalignment between the strategy and the culture within your organization that might be counter-productive when it comes to security. So we provide some guidelines about what you should do:

- Acknowledge the importance of the power of culture. There must be alignment between security leadership, the security strategy, and the required security culture. The only way to be successful is by getting the required security requirements in the shared values, beliefs, and DNA of the culture.
- Try to understand the strategy of your business, but also consider the requirements of internal and external stakeholders when determining your required culture. E.g. A significant number of the companies hope to be the next Apple, Tesla or Netflix and want to work in an Agile way, with DevOps, etc., which means that you need a certain amount of freedom and responsibility within the operational teams. However, if you work in a regulated environment such as the financial sector you need to be aware of the controls required to limit risks. This means that you need to align these and create a culture that supports both requirements, instead of having two cultures working against each other (e.g. your risk management department vs. your Agile software development teams).
- Although research shows that of the four culture types flexibility delivers the highest employee engagement, some characteristics of an order and safety culture may be required.
- Have the right tone at the top and instill the company's values within your organization.
- Choose your battles. Focus mainly on the cultural aspects that are important for change, instead of wanting to change everything.
- Choose people who align with your future required culture.
- To make sure that your security risks are adequately managed, think about metrics or experiments to measure the security culture within your organization, e.g. a phishing test.

Prepare for action

Let's ask our security guy what to do

When (security) incidents, disasters or data breaches occur, employees are often left in confusion. We don't know what to do to limit any possible further impact of a breach. Or we don't know who to inform or involve and pray that our last back-ups are available and hopefully know how to restore them and in which order. After the incident, we hope that it's over, and we promise to do everything better from now on. We then test our disaster recovery plans and data breach procedures, install a crisis team, and train people in dealing with a crisis. However usually after a few month those initiatives will come to a silent standstill.

Prepare, prepare, prepare

"*Give me six hours to chop down a tree and I will spend the first four sharpening the ax.*" – Abraham Lincoln

We often think that emergency procedure, data breach procedures, disaster recovery plans and security incident procedures are merely documents that we need to be compliant with regulations of auditors and regulators. As a result, we often don't have them, we forget to test them, we forget to inform and train the people involved who need to follow them or we forget to update them. So what happens when the crisis occurs? We start panicking and become inefficient, losing valuable time or we start remediating but forget essential actions or make irreversible mistakes. To prevent this from happening, you need to start preparing.

To start your preparations, start by creating the right procedures and plans for emergency situations. In the military these are called Standard Operating Procedures (SOPs). SOPs have been developed so that commonly performed tasks can be completed in the safest and most efficient manner possible[28]. What is the first action that you do when you discover ransomware in your environment? Shut down the infected system or safeguard your backup? A general rule

28 https://echelonfront.com/testing-your-sops/#

in creating these SOPs or procedures and work instruction is to have the people involved who need to work with them, so don't just let external consultants write them from behind their desks. Not only will the adoption rate be higher, but the people involved will usually have a very good idea about what the best SOPs are.

In addition to preparing your organization with the right SOPs, you need to prepare for different scenarios. In Formula One use is made of a race strategist, who plans the strategy for the race. This plan is not a fixed plan with only the best time to do a pitstop based on known variables (tire wear, position, weather, etc.), but will also plan for unexpected eventualities (crashes, etc.).[29]

An essential part of making sure that you covered all the possible scenarios is to determine your attack surface. You can do this by trying to see your company through the eyes of a hacker.[30] Understand where your major risks are and how hackers might aim to exploit them. Also make sure that you have an overview of all your assets. Although most readers might already know this, it's not yet common practice, because most of them don't exactly know their surface, right?

When you implemented all these theories, you need to start testing them, rehearsing them, and refining them. According to Gladwell our brain needs 10,000 hours to absorb all knowledge and to excel into a certain profession.[31] This means that if you want to be sure that you're capable of doing your job right, you need many practice hours. It doesn't mean that you need this number of hours to train in every procedure, but it does mean that you need to train, to be able to excel in what you're doing.

The worst way to train people in these SOPs is to let everybody just read them or inform them by means of "death by PowerPoint" sessions. According to the learning pyramid of National Training Laboratories in Figure 11, these are the least effective ways to get people to learn some-

29 Total Competition, Lessons in strategy from Formula One, Ross Brawn and Adam Parr, 2016

30 See Your Company Through the Eyes of a Hacker, Nathaniel C. Fick, HBR, March 2015

31 Gladwell, M., Outliers. Penguin Books Ltd, 2008

thing. The second-best way to learn is "practice by doing," so now you might understand why in Formula 1 use is made of a simulator, or why Navy Seals train before going into the battle. This is probably one of the reasons why gamification has become so big in recent years. The very best way to learn is through teaching others; however, that is not always possible for testing and training procedures.

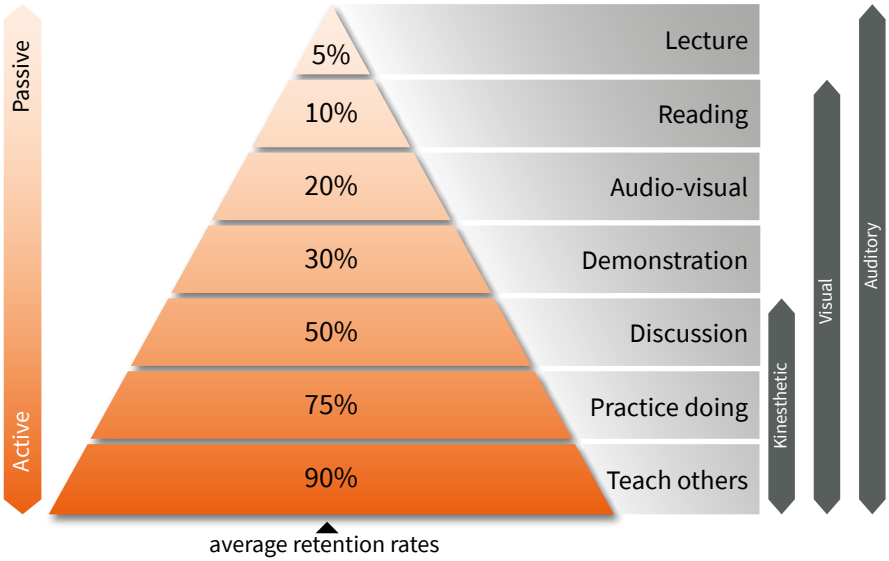


Figure 11: The Learning Pyramid of National Training Laboratories.

For digital security this means that those disaster recovery tests in which an actual disaster is simulated, crisis meetings are held, buses start driving to the DR site, and the DR site is actually started are much more effective than a "dry-run" that is more like a test on paper. Also, a penetration test helps you identify possible vulnerabilities, but doesn't train your team in the way that a red-teaming action can do. And a security awareness game in which users have a role is therefore much more effective than an online training on your latest learning platform. Yet, games are not always possible in large-scale global organizations.

Discipline equals freedom[32]

Just leave me alone, I know what I'm doing[33]

Security incidents are often the result of unpatched systems, insecure coding, or not having the latest virus signature files installed. Although misuse is caused by vulnerabilities in software, the cause of the breach is mostly not technical, but human. In most cases IT staff (IT Infrastructure, Developers and Application Managers) are responsible.

Some of the reasons we've heard from IT staff:

- We have too much work, so don't have time to do the patching.
- We automated the task, so why didn't it work?.
- We couldn't upgrade because the application doesn't support it.
- The business wanted to go live, so we didn't have time for a pen-test or code review.
- The backup software seemed not to have worked, and during office hours we don't have time to restart it.
- I was planning to do it next month.
- I forgot we had that system or how it was connected.

Whether the above reasons are valid or not, many security incidents could have been prevented if people just did their work in a disciplined manner. Even though it might not be the most challenging work to do on a day-to-day basis, it's essential to do it consistently…..every day, just like pilots, soldiers, doctors, and nurses to stay alive or keep people alive.

Discipline is the consistency of action[34]

Although IT staff often see themselves as real craftsmen, professionals, and engineers, we see an interesting distinction when we look at different sectors.

32 Quote by Jocko Willink

33 Quote by Kimi Raikonen, nicknamed "Iceman," is a Finnish racing driver, Abu Dhabi 2012

34 Quote by James C. Collins

In October 1935 Army Air Corps and Boeing took its Model 299, later the B-17, also known as "the Flying Fortress," on a second evaluation flight. The plane took off and at three hundred feet the aircraft stalled and crashed, killing the army and Boeing pilots. Others survived with injuries. Investigation showed that nothing mechanical had gone wrong and that the crash had been due to "pilot error." The crew had forgotten to release the "gust lock" devices that held the bomber's movable control surfaces in place while the aircraft was parked on the ground. The newspaper called the plane "too much airplane for one man to fly," because it was substantially more complex than its predecessors. As a result, Boeing almost even went bankrupt. Since some people were convinced the plane could fly, more tests were performed. Some technical modifications were made, but the most important improvement was the introduction of a checklist. The reason for this was that this new plane was too complicated to be left to the memory of one person, even though these were absolute experts. The checklist had step-by-step checks for take-off, flight, landing, and taxiing. After that the army ordered about 13,000 of these planes, which flew about 1.8 million miles without an accident.[35] [36]

Other examples where checklists are used to make sure all necessary work is done are e.g. in the ICU and in Formula 1. In the ICU (Intensive Care Unit) of a hospital an average patient requires 178 individual actions per day. Before it was observed that an error was made in just 1% of the actions, which is still about two errors a day with every patient. In this case the complexity of the number of actions was also too high to remember, so here, too a checklist was introduced.[37]

In Formula One, a high-tech sport, having the best in business employees, with a huge budget, checklists are used to make sure that when a driver goes out and races at speeds up to 350 km/h, they don't have broken brakes, mirrors, seats, belts, etc.[38]

35 Atul Gawande, The Checklist manifesto, 2010

36 Source: https://en.wikipedia.org/wiki/Boeing_B-17_Flying_Fortress

37 Atul Gawande, The Checklist manifesto, 2010

38 Total Competition, Lessons in strategy from Formula One, Ross Brawn and Adam Parr, 2016

So, what does that say about people within IT? Are they smarter than the average pilots, doctors, and Formula One engineers? Is the IT environment not so complex that one person can't remember all the necessary daily, weekly, monthly and annual activities? Are they indeed too occupied with putting out daily "fires," business requirements and project changes? Or maybe digital security is not as important as a human life or winning a race? Or is it that IT staff are simply too lazy and just want to do some cool projects? Whatever the answer may be, the problem remains that the result of security incidents is that a great deal of time and money is lost to repair the cause, investigate the impact, and report to Governance bodies or the Board.

So, what should we do to get out of this never-ending story? We need discipline. Not what people think is the army way of making the life of the soldiers hard. Discipline is the consistency in performing the actions that you need to do to get better, get in control, get secure. As Jocko Willink puts it: "Discipline equals freedom." Although they might seem to be opposites, discipline is the only way to get freedom. "*If you want financial freedom, you have to have financial discipline. If you want more free time, you have to follow a more disciplined time management system. You also have to have the discipline to say 'No' to things that eat up your time with no payback.*"[39] As you've seen in the leadership section of this book, Jim Collins also has a lot of "discipline" in his approach to move from "being good to being great."

For IT this means that for less "firefighting," you need fewer fires. To get fewer fires, you need to get the basic things in order. For that you need to do the correct things in a consistent and disciplined manner. Discipline leads to consistency. Discipline helps you make the right choice for your goals today, then tomorrow, then the next day, and so you become consistent in your behavior. To do that, you can use checklists. Not only for IT infrastructure management staff for patching the systems, but as well as for developers creating secure applications by default, for application managers to consistently update applications according to the life cycle of the software versions and for IT purchasing to make sure that what it buys complies with the internal architectural guidelines. To be better, you need discipline.

39 *Jocko Willink. https://www.forbes.com/sites/danschawbel/2017/10/17/jocko-willink-the-relationship-between-discipline-and-freedom/#461c2d526df8*

Managing the Impact of Cyber Security Fatigue

Every day, security and IT staff get overwhelmed with information about cyber security. Whether it is security staff monitoring security logs, IT staff constantly patching, or managers hearing about required improvements, the list goes on and on. As a result, people develop cyber security fatigue. Cyber security fatigue is virtually giving up on proactively defending against malicious actors. According to a CISO benchmark study of technology vendor Cisco, 42% of the surveyed respondents suffered from cybersecurity fatigue[40].

Information about threats and cyber risks will get our attention in the short term, as bad news does. Still, it will not keep our attention in the long term. Think about certain high-impact news items that first are part of our daily life, will soon get less of our attention, and, ultimately, not seem to bother us anymore. Cybersecurity fatigue is a problem for security staff, IT staff, Management, and even end-users. The following section will address this fatigue for the different stakeholders in information security and provide steps to prevent this.

The Risk of Combat Exhaustion for Operational Security Staff

A comparison can be made to investigate that impact on security staff, e.g., operators in Security Operations Centers (SOC) or Incident Response Teams (CSIRT) with the soldiers in combat. Both are fighting an enemy, one virtual, the other physical.

When researching army literature, a lot is written about combat stress and its impact on combat efficiency. In the book “On Killing” by Army veteran Dave Grossman, the relation between stress and the development of combat exhaustion to the combat efficiency of the average soldier is described and visualized in the curve below[41].

40 Securing what’s now and what’s next – 20 Cybersecurity consideration for 2020 – Cisco Cybersecurity Report Series 2020, CISO Benchmark study

41 On killing, The Psychological Cost of Learning to Kill in War and Society, Dave Grossman, 2009

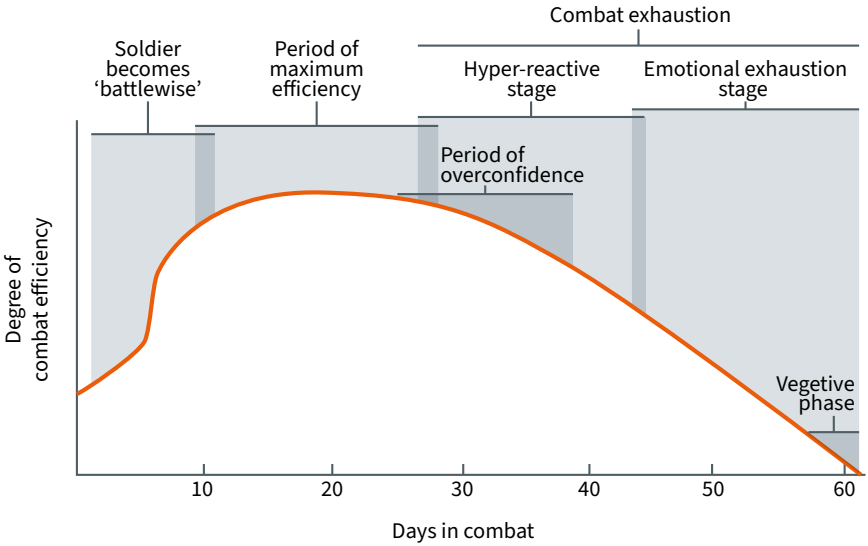


Figure 12: The relation of stress and the development of combat exhaustion to the combat efficiency of the average soldier.

After about ten days in combat, the soldier reaches maximum efficiency; however, the efficiency decreases after thirty days of fighting. Of course, it is crucial to understand what combat stress is. In the Leaders' Manual for Combat Stress Control of the Department of the Army, a distinction is made in several stressors. These stressors are included in the picture below.

Physical stressors	Mental stressors
Environmental	**Cognitive**
• Heat, cold, or wetness	• Information: too much or too little
• Vibration, noise, blast	• Sensory overload versus deprivation
• Hypoxia (insufficient oxygen), fumes, poisons, chemicals	• Ambiguity, uncertainty, isolation
• Directed-energy weapons/devices	• Time pressure versus waiting
• Ionizing radiation	• Unpredictablility
• Infectious agents/diseases	• Rules of engagement, difficult judgements
• Skin irritants or corrosives	• Organizational dynamics
• Physical work	• Hard choices versus no choices
• Bright light, dakness, haze, and obscuration	• Recognition of impaired fuctioning
• Difficult or arduous terrain	

Physical stressors	Mental stressors
Physiological • Sleep debt • Dehydration • Malnutrition, poor hygiene • Muscular and aerobic fatigue • Impaired immune system • Overuse or underuse of muscles, organ systems • Illness or injury	**Emotional** • Fear- and anxiety-producing threats (of injury, disease, pain, failure, loss, personal or mission failure) • Grief-producing losses (bereavement) • Resentment, anger- and rage-producing frustration, threat, loss, and guilt • Boredom-producing inactivity • Conflicting motives (worries about home, divided loyalties) • Spiritual confrontation or temptation causing loss of faith • Interpersonal feelings

Figure 13 Combat Stress factors – taken from Leaders' Manual for combat stress control[42]

Although several stressors applicable for soldiers in a physical battle are not relevant for cyber warfare. In cyber warfare, the cyber soldier has no risk (yet) of dying in combat, and the environmental stressors are less pertinent. However, several of the Physiological, Cognitive, and Emotional are applicable. To control this combat stress for security staff, the following can help to prevent the stress and keep cybersecurity staff effective and alert for combat:

- Automate the analysis, interpretation, treatment, and handling of log events. This way, only accurate information requires action.
- Make sure that workloads are divided across different teams or staff. This way, all staff get the same experience in combat but also creates leeway with less time pressure.
- Have clear standard operating procedures (SOPs) and train them. This way, it is clear who needs to do what and when. SOPs are common in aviation, military, and lab environments where checks and balances are necessary to avoid catastrophes or atone phase three and four in the curve (combat exhaustion).
- Keep the "fun" at work. Don't constantly tell people about the fear of hacking, but keep it light in some cases. Showing a YouTube movie from the Russian Federal Security Service

42 *Leader's Manual for Combat Stress Control, Headquarters, Department of the Army, 29 September 1994*

(FSB) catching the REvil ransomware gang[43] in their underwear portrayed as filthy nerds might also put things a bit in fun and perspective.

- Stay connected with your people emotionally, and don't just see them as computer machines dealing with nerdy stuff.

The risk of Indifference from your IT staff

The people from IT are essential in implementing and maintaining the security measures in an organization. To keep the environment secure, they must patch and update systems in a timely and often ad-hoc manner and ensure that security systems run and follow strict procedures. Built and developed secure code, safeguard backups, test restore processes, and be careful with opening new connections to the outside world—all to keep a security incident from happening. And when something happens, they need to work during nights and the weekends to get everything cleaned and restored in time.

When nothing happens, the need to perform these "Standard Operating Procedures" might become less relevant for IT staff since they spend a lot of time on these 'household" activities but never experience the added value when danger arises.

To make sure that IT staff keeps following the Standard Operating Procedures, it remains crucial to:

- Update IT staff what the value of their activities is. This can be done by, for example, demonstrating to them how hackers work and what techniques they use in combat.
- Support IT, staff, in automating their tasks to limit the time on mind-numbing tasks and involve them in more energizing work.
- Involve and "engage" them in decisions about new or changing security measures. Rotating jobs also helps to keep first-line professionals activated and alert.

43 *Russia Arrests Alleged REvil Ransomware Hackers at the Request of U.S. https://www.youtube.com/watch?v=OqEWuF-mzhzs*

The risk of underestimating by Management

Another stakeholder in information security that might suffer from Cyber cybersecurity fatigue is the management of an organization. Security professionals constantly discuss security threats and need a budget, which never seems enough. Next to that, external stakeholders, customers, and regulators require more and more certifications and control statements to prove that a company's security is guaranteed. While starting a security improvement often begins as a very well-supported program, in time, the "never-ending story" loses interest since progress is slow or the added value remains unclear.

To prevent Management from losing interest in getting Cyber security fatigue, the following can be considered:

1. The principal starting point is to assess your Cyberleader (sometimes called the Chief Information Security Officer) and their capabilities in developing a vision and a plan that suits the organization's needs and taking the organization through this change.
2. Make investments in cyber security in dialogue with management based on "real" risks rather than theoretical ones. Management nowadays is fully aware of to which level they want to accept risks. Be aware that not all organizations and management are similar. So, applying a "one size fits all" approach might not work. In a company where the founders are on the Board, the acceptable risk level might be higher than in a company with a hired Board or when the company is under regulatory supervision. In general, entrepreneurs take a higher risk than managers who are part of a Board, and personal agendas play a role.
3. Measure and report the effectiveness of your security investments or communicate the Return on Security Investment described in Chapter 5, just like any other business process or investment.

Strip all the facts from Fear, Uncertainty, Doubt, and other fuzzy jargon, and challenge and scrutinize the real priorities. Maintain military discipline in overseeing any violation of Standard Operation Procedures.

The risk of recklessness from end-users

A study from the National Institute of Standards and Technology (NIST)[44] found that most of the typical computer users they interviewed experienced security fatigue that made users show risky computing behavior at work and in their personal lives. This is caused by the security measures the users face in their day-to-day work and life. A well-known one is the massive number of passwords a user needs to remember to access their data.

To respond to cyber fatigue, the NIST researchers offer three specific suggestions:

1. Limit the number of security decisions users need to make;
2. Make it simple for users to choose the right security action and
3. Design for consistent decision-making whenever possible.

This means that in the design of a system, the ease of use of security measures needs to be considered. Also, training of users in the use of security measures and monitoring of "risky" behavior should be considered.

Don't let fatigue reverse your change efforts

The constant pressure of threats, mandatory procedures, and mind-numbing manual tasks wears people out, making them tired. This gives us a severe risk to the effectiveness of security measures and the security level in general and can even reverse all the efforts you have put into changing the organization for the better. Digital leaders should be aware of cyber security fatigue and take the relevant precautions to prevent this.

44 Security Fatigue, in IT Professional, Sept.-Oct. 2016, pp. 26-32, vol. 18

Key takeaway messages on changing

As mentioned at the beginning of this chapter, making an organization more secure must be seen and managed as part of organizational change. In addition to new systems and processes, people are an important part of this change. By default, digital security professionals are either good at processes and/or in the technology side of digital security, which we believe is the technocratic side of change. However, as we've seen in the pitfalls related to a successful change, more needs to be done to achieve a successful change in digital security. In this book we 've described several of these subjects, and in this section, we gave you an idea and hopefully some guidance on how to make change more successful by managing change in people. We offer the following key takeaway messages:

1. Create a compelling vision that shows a clear direction. Quantum communicate this dot on the horizon and strategic direction.
2. Show empathy and acknowledge the feelings of employees who need to go through the change.
3. Educate and involve people in the changes that need to be made. Try to avoid the "not invented here syndrome."
4. Plan for wins and celebrate them. Show people that change has been successful.
5. Establish a productive atmosphere of collaboration and openness. Create an environment that people want to join.
6. Make sure that you're prepared for all relevant digital security threats that your organization might be facing. Some practical tips:
   - Set up standard operating procedures, test them, and refine them where necessary
   - Investigate the possible attack scenarios and determine your approach for dealing with them
   - Train involved staff as much as possible "by doing." Some examples are "red and blue teaming," "real-life disaster recovery testing," "awareness games," such as the crisis game devised by CIP (https://www.cip-overheid.nl/productcategorieën-en-worshops/workshops-en-serious-games/crisisgame/) or the targeted attack game from Trend Micro (http://targetedattacks.trendmicro.com)

- Refine, repeat, refine. As Seneca said: “Luck is what happens when preparation meets opportunity.”

7. Start acting in a disciplined manner. Current IT environments are too complex and, although we can automate a lot, we can’t rely on this automation 100%. The best way to start working in a disciplined manner is to start introducing checklists. These checklists should contain the daily tasks that need to be performed consistently and correctly to make sure the security of information is not endangered.

“Bureaucracy is a construction by which a person is conveniently separated from the consequences of his or her actions.”

Nassim Nicholas Taleb

04

Governing

Governing digital security

Digital security has become a world on his own, with its own complexity, its regulations, processes, a lot of technology, and, of course, people. People who work in digital security and people who need to act securely. To steer this complexity, digital security, as a profession or business process within a company, needs to mature. Some serious focus is necessary.
In order to actively steer the outcomes of digital security based on tangible metrics, we will discuss some research that we have done about metrics for digital security. Although governance is a much broader field than just measuring metrics or KPIs, it will reveal what is seen as important by 30 CISOs who took part in our research.
Here are some definitions:

Businessdirectory.com describes governance as: *Establishment of policies, and continuous monitoring of their proper implementation, by the members of the governing body of an organization. It includes the mechanisms required to balance the powers of the members (with the associated accountability), and their primary duty of enhancing the prosperity and viability of the organization*[1].

And

Corporate governance is: *The framework of rules and practices by which a Board of Directors ensures accountability, fairness, and transparency in a company's relationship with its all stakeholders (financiers, customers, management, employees, government, and the community).*

1 *http://www.businessdictionary.com/definition/governance.html*

The corporate governance framework consists of (1) explicit and implicit contracts between the company and the stakeholders for distribution of responsibilities, rights, and rewards, (2) procedures for reconciling the sometimes conflicting interests of stakeholders in accordance with their duties, privileges, and roles, and (3) procedures for proper supervision, control, and information-flows to serve as a system of checks-and-balances.[2]

De Haes and Grembergen[3] define enterprise governance of IT as: *"the responsibility of the Board of Directors and executive management. It's an integral part of enterprise governance and consists of the leadership and organizational structures and processes that ensure that the organization's IT sustains and extends the organization's strategies and objectives."*

Nowadays digital security management is a strategic issue for business leaders and several institutions and communities have launched initiatives to encourage business leaders to ensure good stewardship in this area.[4] The associated compliance obligations and the increase in security breaches have made many business leaders aware of its impact on the business continuity[5], civil and legal liabilities[6], reputation[7, 8], employability, and financial position[9, 10] of companies. This is why digital security management should be part of corporate governance. The IT Governance Institute (ITGI) states that ownership of data and its information risks are the

2 *http://www.businessdictionary.com/definition/corporate-governance.html*

3 *De Haes and Grembergen Book on Enterprise Governance of Information Technology: Achieving Alignment and Value, Springer*

4 *World Economic Forum, "Partnering for Cyber Resilience; Risk and Responsibility in a Hyperconnected World - Principles and Guidelines," World Economic Forum,, Davos, Swiss, 2015*

5 *B. Cashell, W. Jackson, M. Jickling and B. Webel, "The Economic Impact of Cyber-Attacks," Congressional Research Service, The Library of Congress, United States, 2004.*

6 *Fox-IT, "DigiNotar Certificate Authority breach, "Operation Black Tulip,"" FOX IT in assignment of the Ministry of the Interior and Kingdom Relations, Den Haag, 2011*

7 *G. Walsh, V. Mitchell, P. Jackson and S. Beatty, "Examining the Antecedents and Consequences of Corporate Reputation: A Customers perspective," Britisch Journal of management; Blackwell Publishing LtD, UK, 2009.*

8 *F. Peters, Reputatie onder druk; Het managen van reputaties in een veranderende samenleving, Den Haag: SDU Uitgevers, 2012*

9 *M. Ishiguro, H. Tanaka, K. Matsuura and I. Murase, "The Effect of Information Security Incidents on Corporate Values in the Japanese Stock Market," Institute of Industrial Science, The University of Tokyo, Tokyo, Japan, 2011.*

10 *H. Cavusoglu, B. Mishra and S. Raghunathan, "The Effect of Internet Security Breach Announcements on Market Value: Capital Market Reactions for Breached Firms and Internet Security Developers,," International Journal of E-Commerce, Dallas, Texas United States, 2-2002.*

responsibility of businesses and their owners.[11] We therefore sometimes use the term "Business Information Security."[12] Managing Business Information is a prerequisite for improving Business Information Security maturity.[13] The International Federation of Accountants (IFAC)[14] and ISACA[15] describe digital security as an integrated enterprise activity requiring proper governance of the work done in this area by the Board and executive management.

Information security governance exists at three levels: *The strategic level (Board of Directors and Executive Management), the tactical level (senior and middle management) and the operational level (lower management and administration)*. Figure 12 presents these layers and the associated activities. All directive setting and controlling activities (including monitoring and evaluating) are seen as part of the strategic level of governance.[16] All activities designed to put these directives into practice take place at the tactical management level. The tactical level involves formulating policies and guidelines, for example establishing minimum standards that the organization needs to adhere to, such as incident management and supply chain management. The level below the tactical level is where these policies and guidelines are translated into procedures and working methods. For example, this is the level where monitoring software is configured which triggers incident response processes or imposes stricter guidelines for suppliers. Once these organizational levels are defined and associated processes are in place, it becomes appropriate to use metrics in order to measure security performance.

11 *ITGI, "Information Risks; Who's Business are they?," IT Governance Institute, United States, 2005.*

12 *V. Solms, "From Information Security to Business Security," Computer & Security, Elsevier, South Africa, 2005.*

13 *J. Allen, "Governing for Enterprise Security (GES) Implementation Guide," Carnegie Mellon University, Software Engineering Institute, CERT , US, 2007.*

14 *IFAC, "Enterprise Governance: Getting the Balance Right," International Federation of Accountants, London, 2004*

15 *ISACA, COBIT5 for Information Security, United States: ISACA , 2012.*

16 *R. Von Solms and B. Von Solms, "Information Security Governance; A model based on the Direct–Control Cycle," Computers and Security , vol. 2006, no. Elsevier Computers and Security 25, pp. 408-412, 2006*

Historical background of metrics

Practitioners have developed numerous BIS metrics for organizations, for example NIST[17] and ISACA[18]. Pironti[19] stated: "*Information security is an ever-changing and evolving activity. To have accurate visibility to these changes, an organization must establish, maintain, monitor, interpret and report effective metrics and measures. The threats that an organization's information infrastructure faces, along with the controls and capabilities that must be deployed to counteract these threats, are constantly changing, and evolving. This requires the measures and metrics that are employed to monitor the performance of information security governance to be adaptable and flexible to be a positive and valuable asset to the organization.*" Here Pironti emphasizes the need for clear metrics that Boards of directors can understand and monitor.

In COBIT5 for information security, ISACA developed a set of metrics per COBIT domain. This resulted in a huge number of metric candidates that can be selected and implemented, from the governance level down to the operational level, according to the COBIT5 EDM (Evaluate, Direct, Monitor) model. Jaquith[20] developed metrics for operational, technical and security programs.

17 *NIST, "Directions in Security Metrics Research NISTIR 7564," National Institute of Standards and Technology , Gaithersburg, 2009.*

18 *ISACA, "Cobit5 Executive Overview "Optimise Your Information Systems; Balance Value, Risk and Resources," ISACA, p. 4, 2012*

19 *J. Pironti, "Developing Metrics for Effective Information Security Governance," ISACA, US, 2007.*

20 *A. Jaquith, Security Metrics. Replacing Fear, Uncertainty and Doubt, US: Pearson Education, 2007*

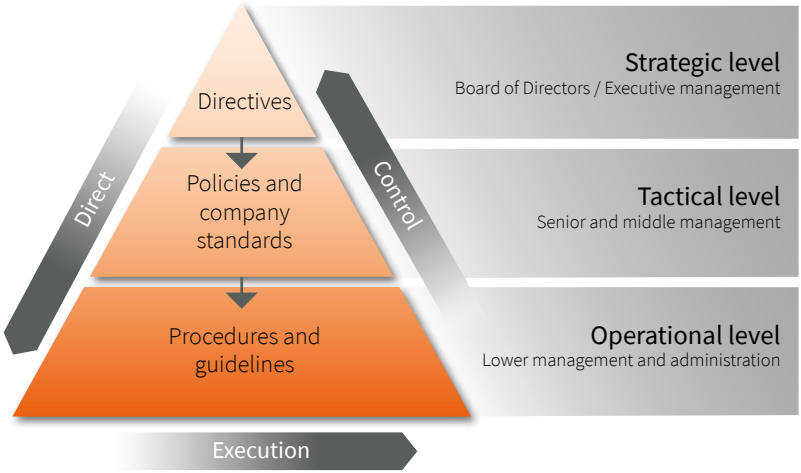


Figure 13: COBIT5 EDM model for defining processes (taken from ISACA).

In 2005 Chapin and Akridge[21] studied information security metrics in order to measure and then improve their incorporation into a continuous Total Quality Management process. They adopted the ISO 17799 standard (now ISO 27001) to develop a complete security program (the Security Program Maturity Model), which involves a large number of security elements (10 ISO elements) that would eventually provide insight into the state of security maturity. This study, which was adopted and published by ISACA, is a good example of making maturity measurement practical for large as well as mid-size organizations.

Maturity is the process an organization undertakes while moving toward the desired state of control in protecting critical assets. The objective is to provide analysis and insight, based on a maturity model, into the current state, and to provide analysis and insights into the capabilities and requirements for the desired state. The steps needed in order to achieve the desired state

21 *D. Chapin and S. Akridge, "How Can Security Be Measured?," Information Systems Audit and Control Association Journal, Volume 2, 2005, United States, 2005*

of maturity are described as interventions. Interventions can be denoted as 'planning' interventions, 'doing' interventions, 'checking' interventions and 'acting' interventions (PDCA):

- Planning interventions (Plan) have the characteristics of formulating plans to establish objectives and processes that are necessary to deliver results in accordance with expected output. This planning requires alignment with all stakeholders involved.
- Doing interventions (Do) are concerned with the execution of interventions articulated in the plan. A major component of this phase is implementing controls and/or collecting factual data (evidence) to measure and monitor, to provide input for the 'check' and the 'act' phase.
- Controlling interventions in order to check if a certain intervention is executed to establish the desired state (Check). This phase requires actual and factual data collected in the previous phase in order to ascertain deviations and examine the appropriateness and completeness of the plan to enable execution.
- Interventions that are corrective in nature (Act). In the previous phase it is checked whether the steps taken, which are distilled from the plan, reveal an improvement according to the prior standard (baseline) or require additional corrective interventions in order to achieve the desired state. If the CHECK shows that the PLAN that was implemented in DO is not an improvement, then the existing standard (baseline) will remain in place and require some additional learning through repeated PDCA cycles.

Continuous process improvement

Continuous improvement, as part of Total Quality Management[22] is implemented by executing this PDCA cycle numerous times and studying interventions, in order to understand their effectiveness during the maturing process. Edward Deming refers to this learning element as the PDSA cycle, a Plan-Do-Study-Act[23] cycle, which builds deductive and inductive learning into learning and improvement cycles. Most of the maturity models and frameworks developed within the security arena have PDCA elements incorporated.

22 *Deming (1952) on Elementary Principles of the Statistical Control of Quality*

23 *Moen, R, (2009) Foundation and History of the PDSA Cycle in Associates in Process Improvement-Detroit*

Bowen *et al*. (2006) developed an information security program in order to define security metrics and act on them. This program outlines several steps that are used to define measurable processes and to collect valid metrics. However, the information security metrics program only reports on business impact, efficiency/effectiveness, and implementation.[24] In addition to earlier research by Chew *et al*. (2008) it seems that quality is not part of the metrics collection program reported on in the literature.[25] Furthermore, according to ISF (2015) reporting is to take place according to KPIs on digital security results and the risk associated with activities/processes. In addition, ISF (2015) highlights the importance of engaging stakeholders during the process of determining and measuring KPIs for information security. According to ISF (2015), in order to receive necessary organizational support, an organization must involve all relevant stakeholders in defining a KPI and keep them informed.[26]

24 *Bowen, Hash and Wilson, "Information Security Handbook: A Guide for Managers," October 2006. [Online]. Available: http://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-100.pdf.*

25 *Chew, Swanson, Stine, Bartol, Brown and Robinson, "Performance Measurement Guide for Information Security," July 2008. [Online]. Available: http://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-55r1.pdf.*

26 *ISF, "Engaged Reporting: Fact and fortitude - Report," 25 April 2015. [Online]. Available: https://www.isflive.org/docs/DOC-18085*

Digital security metrics and objectives

Chew *et al*. (2008) reports there are two types of metrics that can be used for information security KPIs. Specifically, the effectivity and efficiency of controls. Whereas the effectivity of the process is noted in the effectiveness of output, the efficiency of a control provides evidence on the timeliness of controls. Finally, this research indicates that the quality of processes and products are not evaluated. Effectivity may be influenced by the execution, but also by the quality of execution. SANS institute (2007) states that information security metrics are necessary in every organization. Such metrics can visualize the performance of digital security.[27]

The Saylor Academy states that in order to make an objective measurable the objective must first be defined. In order for activity objectives to create value, they must be linked to the strategic objectives of an organization.[28] The academy adds that operational objectives can be relatively short-term and might not necessarily add to the strategic objectives of an organization. Therefore, the academy describes the importance of also defining overarching long-term objectives. Based on these strategic objectives, the organization can define how to measure the success of an objective. To clarify, if the operational objectives are linked to strategic objectives, the success of the operational objective will be tailored toward the achievability of the strategic objective(s). Drucker (1954) adds to this statement by saying that objectives need to be relevant to the organization in order to have any reason for achieving them.[29] Based on this literature, objectives need to be aligned with strategic objective(s) in order to warrant existence and determine the outcome of objectives. Bora *et al*. define strategic objectives as the objectives needed to execute the vision or mission of an organization.[30] Therefore, it can be suggested that objectives that are engineered toward strategic objectives create value for an organization. In contrast, objectives without direction or purpose do not necessarily create any value.

27 *SANS, "A guide to security metrics," 2007. [Online]. Available: https://www.sans.org/reading-room/whitepapers/auditing/guide-security-metrics-55*

28 *Saylor Academy, "Chapter Goals and Objectives," June 2011. [Online]. Available: https://www.saylor.org/site/wp-content/uploads/2011/06/BUS208-4.2.pdf.*

29 *P. F. Drucker, The practice of management, New York: Harper & Row, 1954.*

30 *Bora, Borah and Chungyalpa, "Crafting Strategic Objectives: Examining the Role of Business Vision and Mission Statements," 2017. [Online]. Available: https://www.omicsonline.org/open-access/crafting-strategic-objectives-examining-the-role-of-business-vision-andmission-statements-2169-026X-1000205.pdf.*

Taylor defines a metric as a "quantifiable measure that is used to track and assess the status of a specific process" (e.g. increase in vulnerabilities per month).[31] Whereas Taylor defines a measure as a dimension of a certain object, process or project (e.g. the height of an object).

Metrics of processes can be gathered using existing performance management methodologies. The existing performance management methodologies suggested are the Balanced Scorecard and Six Sigma. TWDI argues that using existing methodologies for performance management creates additional assurance of measuring the right metrics.[32] Brotby states that one criteria of a metric is that it is the result of a measurement which is compared to a point of reference.[33] An example reference point can be timespan. According to Brotby (2009) metrics should remain quantifiable, in order to maintain the possibility of cross-referencing data with each other. Finally, in order to define a valuable metric, a metric should have a clear relationship with a specific objective.

Example metrics - KPIs

An article by Taylor in 2017 defines KPIs as a metric that shows the progression of a team, person, or activity toward an absolute objective. PWC adds to this definition by stating that KPIs need to be relevant to performance; that's why they are called key performance indicators. PWC describes the word 'key' as relaying the progression toward a key objective.[34] If a performance indicator doesn't relate progression in reference to a current objective, it's not considered a relevant metric.

On account of the information security objective to reduce risks, a different kind of KPI can be developed, such as Key Result Indicators (KRIs; see Koning (2007)). According to ISF (2015) a KRI

31 *Taylor, "What is a KPI, Metric or Measure?," 22 Februari 2017. [Online]. Available: https://www.klipfolio.com/blog/kpi-metric-measure.*

32 *TWDI Research, "Performance management strategies," 2009. [Online]. Available: https://www.microstrategy.com/Strategy/media/downloads/white-papers/TDWI_Performance-Management-Strategies.pdf.*

33 *W. K. Brotby, Information security management metrics: a definitive guide to effective security monitoring and measurement, Boca Raton: Taylor & Francis Group LLC, 2009*

34 *PWC, "Guide to key performance indicators," n.d.. [Online]. Available: https://www.pwc.com/gx/en/audit-services/corporate-reporting/assets/pdfs/uk_kpi_guide.pdf*

is an indicator that indicates the risk associated with an activity. A KRI indicates the key result expected, and required, as the result of an activity.[35] KRIs can relate a level of risk associated with an activity, or might simply be a security result metric which indicates risk (e.g. the number of critical vulnerabilities in a system). For reasons of consistency, KRIs will be interpreted as KPIs in this section.

Insights from experts

In 2013-2018 extensive research among experts was held to explore the field of security metrics.[36] To explore security metrics per organizational level we made use of Delphi research with 38 experts working in the security field. The Delphi method was used to collect qualitative data from individuals and eliminate any form of group influence, in contrast to GSS. In this case the objective was to get experts thinking about which SMART[37] metrics they find suitable for their organization to improve the maturity of the BIS process and to generate new ideas.

Results on management metrics

The result of this was a list of 25 SMART metrics. When analyzing the data set, clear process-oriented metrics can be distinguished, and these are marked in bold. These can be used to initiate direct, measure and monitor the BIS maturity process.

- **Overview of realized versus planned BIS improvements and changes per period**
- **Compliance audit reports per period**
- Percentages of contribution to meeting business goals
- **Frequency of meetings (e.g. steering committees)**
- **Presence of a BIS organization (steering committee, CISO, CRO)**
- **Business impact analysis (frequently performed) and GAP analysis (on e.g. ISO 27K)**
- **Presence of a working risk management process**

35 *H. d. Koning, "Scientific grounding of lean six sigma's methodology," 2007. [Online]. Available: https://pure.uva.nl/ws/files/4369110/52724_Proefschrift_henk_de_koning.pdf.*

36 *Y. Bobbert, Improving the Maturity of Business Information Security: On the Design and Engineering of a Business Information Security Administrative tool, Nijmegen: Radboud University, 2018*

37 *S.M.A.R.T. is the abbreviation for Specific, Measurable, Attainable, Realistic, Timely*

- Presence of policies and guidelines
- Number of deviations in penalties, incidents, and violations (benchmarked)
- Presence of an audit policy and an appointed auditor
- Number of deviations according to the agreed BISG objectives and issues
- The cost of BIS as a percentage of revenue/profit
- Level of compliance with internal and external policies
- Number of business continuity disruptions due to BIS incidents
- Success due to well working security practices
- Number of audit remarks (for example ISAE3402 or compliance audits) in relation to the SLAs of suppliers and the internal organization.

Although it's debatable whether they are actually governance metrics, these are perhaps examples of instruments that can operationalize the measurement process. A risk register can be used to monitor the effectiveness of a risk management program as well as measure and assess risk-related items. Below are two examples of fresh insights into metrics:

- Risk register and rating against this register
- Reporting security roadmap, incidents, projects and KPIs.

Fresh new insights on metrics although it's debatable whether these are governance metrics (and not management or operational metrics):

- Percentage of business-driven innovative programs in which security was involved in an early stage
- Percentage of IT-related projects in which security was involved at an early stage
- Number of security incidents.

Management metrics

The result of the second step (question) was a list of 24 management metrics for BIS. The most relevant items were filtered out, creating the following clean list of management metrics ac-

cording to the experts; again the items that address the BIS maturity process are marked in bold.

- **Number of security incidents, effectiveness of security controls, development of the maturity level.**
- **Level of BIS awareness at management level (to be tested).**
- Number of adjustments made to the security baseline during a certain period.
- **Follow ups to previously set KPIs.**
- **Working incident management process (#disruptions outside the SLA).**
- **Number of tested BCM plans.**
- **BIS program progression.**
- The number of new business opportunities that were acquired due to the security proposition of the organization (Security as a Unique Selling Point).
- **The positive feedback on customer surveys on the security position and trust they have in the organization. Measure the perception of customers.***
- Number of data breaches per period.
- Customer damage as a result of security incidents.
- Number of questions toward the security organization during a certain period.
- Availability of a full-time security officer.
- Involvement of security at the early stage of projects.
- Achieved CMM level per BIS domain (i.e. physical security, BCM, governance,, etc.).
- Time spent on repressive versus preventive measures.
- **Number of audit remarks (for example ISAE3402 or compliance audits) in relation to the SLAs of suppliers and the internal organization.**

*This fresh idea of getting customers involved in BIS assists the manager in reflecting on the efficiency and effectiveness of the internal security program. Although this is not directly a process metric it can help to address it. For example, when organizations reach a certain maturity level, they can actively engage their customers in their security programs.

Examples of ideas that arose during the Delphi research questionnaire but actually are mechanisms used to operationalize measurement:

- Report on the number of risks that occurred during a certain period
- Risk register and rating against this register.

Examples of metrics that arose during the survey but are more operationally oriented:

- Overview of number of managed end-point devices
- Number of successful entrances (attacks) during a certain time period against the total number of attacks
- Pen-test findings
- Number of (over) authorizations
- Percentage of ex-employee with withdrawn accounts.

Operational metrics

The result of the third step is a list of 24 items which is presented below. Again only the most BIS relevant items are adopted, to present a final clean list. The experts listed the following operational metrics:

- Reporting on data from Intrusion Detection Systems (IDS), firewalls (FW), anti-virus (AV) systems and proxies.
- **Number of operational incidents that occur during a certain period**
- Results on Access Control Management (factual figures versus baselines)
- Average detect, response and fix rate on security incidents
- **Level of awareness of security with operational personnel (testing)**
- Percentage of failed pen tests
- **Level of compliance with the security baseline**
- Performance on KPIs
- Number of tested backup procedures

- Number of incidents within or outside the SLA
- Number of deviations based on the security guidelines (unpatched systems, cleaning of over- authorizations)
- Number of applications with no security incidents/vulnerabilities
- Percentage of systems that undergo frequent vulnerability analysis
- Percentage of critical perimeter devices/applications and the pen-test results
- Mean time between failures and mean time till failure as a result of security incidents
- Average time of security change requests
- Percentage of unpatched systems and active anti-virus software
- Number of business disruptions of the primary business process considered urgent
- KPIs on vulnerability management
- Number of resolved versus unresolved security incidents.

The metrics below were described as operational but are indeed more managerial, perhaps residing within the HRM department:

- Percentage of new employees who followed a BIS awareness program and the periodically refresh of this program.
- Percentage of employees with a screening.
- Number of certified IT personnel
- Cost of BIS as percentage of revenue/profit.

Sub-conclusion: choose wisely, but don't forget!

We have mentioned a huge number of metrics. Depending on the type or organization as well as the leadership and management style, some metrics might be more useful than others to measure and/or report. And, although these metrics are very useful to choose from, these are mainly technocratic. We believe that the technocratic approach is not the way to lead your company in the current and future cyber war. This means that, although our research group might be very skillful security professionals, the question remains whether these skills will be sufficient for tackling current and future security risks.

Areas in which we miss metrics:
Metrics for the quality of the digital security staff themselves. Although certification might say something about technocratic skills (if the huge number of certifications actually say anything these days), it doesn't say much about leadership skills. And by leadership we mean leader-leader and not leader-follower.

Metrics also don't touch on whether people are actually "aware" and whether there is a real "security culture." As you read in the section on "changing," culture eats strategy for breakfast. If the culture is not right, will the current measurable metrics give you enough confidence about the chance you'll have a data breach in the future?

Governance versus regulations

In God we trust, the rest we audit

Nowadays we live in an overregulated world. We need to comply with all kinds of rules, regulations, frameworks, nationally, internationally, branch-specific, etc. “We need to prove to others that we comply with these rules, while they really don’t understand anything of what we are doing. Why are they interfering with our business! It costs way too much money and it adds absolutely no value!.”

This could have been said by anyone working in a company that is under the supervision of an external supervisor, e.g. stock exchange registered companies and financial companies. Within the financial sector the supervisors are particularly “mean.”

Or,

Aren’t they? Maybe if we look from the perspective of the customers, the shareholder, those who were impacted during the last financial crisis we can understand why regulations have been tightened. Because isn’t it so that many companies under supervision actually damaged the trust in all, while the people at these companies still earned a lot of money or received a lot of money when they had to leave such companies?

Specifically, for digital security we see that part of the “controls” with which a company need to comply are within the scope of digital security. E.g. frequently used frameworks such as COBIT that focus on information security as well as privacy legislation (e.g. GDPR) have sections on information security. This means that information security is under pressure as well, as for most regulatory bodies and auditors this high-tech domain is also quite new or difficult to understand. Specifically, when you’re not tech-savvy it’s hard to understand how certain technical risks manifest and thus have an impact on the financial position of a firm.

To get trust, you need to earn it

Instead of complaining about the supervisors we suggest that you start earning their trust. To earn trust, one can use the trust equation[38], a concept that's often used in the world of leadership development and the evolution of partner relations with customers in which trust plays a large role.

T (Trustworthiness) **= C**(Credibility) **+ R** (Reliability) **+ I** (Intimacy) **/ S** (Self-orientation)

The trust equation consists of a numerator and a denominator. The idea is to increase the numerator as much as possible and reduce the denominator. The variables are:

Numerator:

- Credibility: which relates to the expertise of the organization and the quality of management.
- Reliability: which relates to the extent to which agreements are met.
- Intimacy: which relates to the quality of personal contact, or the "rapport."

Denominator:

- Self-orientation: which relates to whether a company is focusing on itself or the external environment.

When you think about the "customer focus" strategies companies currently have, one can imagine that they should add trust. Some readers might think it is "customer focus in name only," right? The answer to that is irrelevant, but if people start asking that question, you need to understand that they still don't trust their company because the equation for them doesn't have the right numbers.

For the regulatory part we believe it's pretty much the same. If the regulator starts trusting you, you'll be fine. So, this could mean that you need to show that you actually do comply with the

38 The Trusted Advisor, David H. Maister, Charles H. Green, and Robert M. Galford, 2000.

controls you need to comply with or have a credible story why not. If you make agreements with them, make sure you meet all of them. Better even would be to impress them by over-delivering. You also need to start building a relationship with them. Don't see them as the bad guys, because in the end they are just doing the job society is asking them to do. And lastly stop focusing on yourself by explaining why it's so hard for you to comply with the rules and regulations and start showing some empathy. Make their life as easy as possible, instead of making each other's life miserable.

When companies breathe fear like we have experienced at the Dutch Healthcare Authority (the NZA) or the Dutch Tax departments[39] you know for sure nothing is going to be done successfully. A sad low point was an incident at the NZA. Here things went wrong on all fronts. Their digital security failures (free access to data on file shares), failing processes (no policy and assurance thereof) and failing management and supervision. In fact, the Board was guilty of mismanagement. Whistleblower Gotlieb raised the alarm with the following words: "Unfortunately I see no other route than to report you along this unsympathetic away. The ghost must come out of the bottle and the lid off the jar. So that management can make timely adjustments." Two weeks after he submitted this file to his employer, Arthur Gotlieb committed suicide.[40] The increasing political pressure as a result of this case led to the resignation of both directors of the NZA. The NZA case goes further than the improper handling of digital security risks. There is a failing organizational culture and what Professor Sumantra Ghoshal refers to as "the smell of the place" is that of hot summers in Calcutta.[41] Several clear signals were systematically ignored. After several digital security-related incidents and events supervisors and regulators called for action to implement digital security frameworks and associated reports of applicability. Other examples of failing governance

39 *Tax office employees feel unsafe at work, reports FNV Government on the basis of a survey completed by nearly a thousand employees. Source; https://www.nu.nl/economie/6013755/fnv-overheid-signaleert-angstcultuur-op-werkvloer-van-de-belastingdienst.html*

40 *Source for the NZA Case: Nobody listened to Arthur Gotlieb. Url: https://www.nrc.nl/nieuws/2014/04/12/niemand-luisterde-naar-arthur-1368467-a1271777*

41 *Famous INSEAD Prof. Sumantra Ghoshal refers to cultures of fear and pressure as summers in Calcutta. These summers are too hot, uninspiring and the only thing you want is do is nothing or get out. Source: YouTube: https://youtu.be/YgrD7yJwxAM*

on digital security are Equifax[42] and DigiNotar. Bill Black, a well-known professor in Economics and Law revealed in detail how Equifax failed on all fronts in this YouTube video (see footnote below).[43]

Report cards and certificates

When working in companies under supervision, one knows that part of the work of digital security is about proving to the supervisors that you actually did what you needed to do. This world is full of frameworks (e.g. COBIT, PCI-DSS), certificates (e.g. ISO 27001/2), assurance reports (ISEA3402, SOC2) and maturity scores (level 0 to 5). All being the report cards for digital security to be shown to the supervisors, direct or indirect (if you're a service provider). For many people this is a world of documentation, signatures, complaining people and nasty auditors. In the best case this leads to a "green" report, which means that you're safe again for another year.

And what do you do when you're done with this yearly pain of compliance? You go back to the work you were doing. We fully understand that people are doing this because ensuring security is no fun. Well, at least for many us. But that isn't the right way of doing things, is it?

From explaining to telling

We believe to change the game one needs to change perspective. Instead of explaining to supervisors what you did, you need to start telling, which will increase trust significantly. For example: when we are running a project or program and need to report to the steering committee, we try to take ownership. Instead of waiting for questions from the steering committee and explaining what we did, we start telling them where we are, what the problems are, showing some facts, how we're managing risks, and possibly asking for some support in a specific area which is outside of our reach. This way we're showing that we're in control and know what we're doing, instead of explaining why we think we're doing a good job. To do that in digital security, you need to start taking ownership of digital security. And you don't do that by following the guidelines of the different frameworks and using their maturity models to measure whether you're a 2.7 or a 3.2; you do that

42 *The infamous 2017 Equifax breach not only compromised millions of citizens' data, but the breach also left Equifax vulnerable to lawsuits that claim the company acted negligently. By A. Glenn, "Equifax: Anatomy of a Security Breach," Georgia Southern University, 2018.*

43 *https://youtu.be/xfQWvf2k2lw*

by arranging your digital security governance. Use the relations, wording, clarifications, and "C'est le ton qui fait la musique" to tell and not to explain. Bruce Potter, a self-made CISO in the US said: "In 2019, people are FREAKING OUT and perceive risk even in places where there is no risk." We spend too much time thinking and not enough time doing." Digital security is not about all kinds of difficult risk assessment methodologies; it's about fixing things.

Therefore, we believe that security or IT governance is NOT the same as implementing COBIT. It's about steering your organization toward a more secure situation using many more non-technical security controls than frameworks such as a COBIT address.

Who will be your "Governor"?

Why do CISOs have low retention in firms and leave after 1-2 years? Is this because recruiters and HR professionals find it hard to discover what is actually needed and "copy-paste" function profiles with the exact requirements rather than looking at the real need in the organization: M&A strategy, family business, scale-up phase, consolidation, preparing for sales of the company, cultural differences, etc.? The CISO role is embryonic compared to the CFO, and not one hundred percent clear about exact expectations.

Four archetype CISOs

To better understand the infancy issue of the CISO role, let us elaborate on four archetype CISOs based on our experience and research. We detail our observations on the span of control, mandate, organizational position, and main challenges of the archetype. We do this to empathize with the current challenges we see on why certain CISOs are more successful than others, and it has to do with getting the CISO you deserve/getting the right CISO to get the job done.

(Corporate) Information Security Officer (CISO)

Advisor to the corporation, most of the time the board or CIO. Has no staff and no budget. Enforces the strategy via functional steering and has limited control or power in the Business. Build "security-in" afterward. Primarily found in Governments or non-tech-born companies with limited technology dependencies, like traditional industries.

Chief IT Security Officer (CISO)

Is positioned in the IT and sometimes in the CIO Office. Small staff and no budget. Budgets are mainly the annual CIO-related IT budgets calculated via old-school budgeting methods of percentage of IT, mainly HR cost. Very little interaction with the Business and working in the IT silo on implementing IT security controls. Limited focus on Security returns (e.g., ROSI modeling, discussed in Chapter 5) and limited opportunities to sell to board or business executives that hold the "real budgets." It is mostly found in decentralized enterprises where IT (security) is separated in a central delivery organization. This CISO is in hierarchy conflict with his boss who is ultimately the boss and can overrule. This CISO is more in a squeeze when his ally, the DPO, is also in a "staff" position at the central organization.

Chief Information Security Orchestrator (CISO)

Orchestrates their security control via multiple third parties, such as IT service suppliers, cloud providers, pen-testers and SOC suppliers. Organizations that are part of an eco-system of suppliers, aka hybrid environments. They oversee the full field of responsibilities and expected outcomes. Aligns with their business executives as partners and makes business agreements on first line business ownership, craftsmanship and KPIs. Has a Target Operating Model in place to exercise their first-line responsibility of directing policies and standards and their 1.5-line oversight and quality assurance on control effectiveness. Has own staff, budget, and board support. Is independently positioned from IT and is an enabler towards new business initiatives and has a seat at the business and board table. You typically see this CISO in organizations that understand security is part of doing business. Understand that talent is scarce, and you are better off buying it from the market via RFPs and tenders with clear SLAs rather than building your own team of "less sharp knives in the drawer" or nagging ducks that cannot swing like an eagle. This CISO applies clear economic drivers to justify investments and understands they are "part of the business".

Chief Information Security Officer (CISO)

Is the new generation CISOs in tech companies (Uber, Google, ZOOM, Booking.com) that "is the business". Has a direct reporting line to the management board and/or supervisory board. Is

in constant dialogue with key stakeholders like 2nd line risk management, internal and external auditors and regulators. Their board understands that the word "chief" actually entails mandate, budget, and personnel to fix the job, and the chief can actually take full accountability. This CISO has direct lines to the IT security department and has "hire, admire and firepower." They own their profession and organize their security via clear Target Operating Models with internal and external SLAs to measure and monitor the entire security performance of the entire extended enterprise (cloud, IoT, OT). IT and business are fused, and at every new business initiative, the CISO (or team member) is at the table. The deputy CISO organizes the internal security organization as a "COO" and ensures the administration is up to par and team talent is nurtured, educated, and constantly challenged. The enterprise security architect in the team ensures that the complete environment is designed and implemented with the latest comprehensive technologies and methods. We sometimes refer to the level 4 CISO[44].

The last two CISOs emerge increasingly and become the de facto for well-prepared companies. In more and more cases, this is a woman with non-IT backgrounds with strong alignment and leadership skills. But we also understand that every organization has a legacy, organizational structures and attitudes that cannot be changed overnight.

Guidance on getting the CISO you deserve is still in limited availability, especially on the last two CISO archetypes we mention. The European Competence Framework (eCF) defines the role of the CISO as strategic and mainly focuses on the hard capabilities but never on softer organizational aspects.

The digital security profession has a long history and in the current era it is becoming even more important, with more people in organizations working on digital security. However, we often see those people having a more operational and tactical history and approach without actual hands-on governance and leadership experience.

44 *Level 1 CISOs are mostly heads of IT security who mainly focus on governance and controls. Level 4 CISOs are deeply intimate with their businesses; involved in the background in senior hiring and firing, M&A, divestments, supply chain, IP protection and anything shareholder-sensitive. They also have regular sessions with the Chairman of the Board and train non-executives and their families.*

Which CISO do you deserve?

So, if you need to make digital security a success, you need a leader to lead you through the change and reach the end goal. In addition to how this leader needs to act based on employees' needs, the leader should also consider the change a company needs to go through. For example, if you want digital security on the Board's agenda, you might need someone with good political and marketing skills. If you want people to go in a certain direction, you might need a visionary person. If everyone is on board and you need to get things done, you might need a more control-focused leader. So, what does this mean? This means that you might need to choose digital security leaders not only based on what your employees need but also based on which phase digital security is actually in and the journey the company is going to embark on (e.g., mergers & acquisitions, global growth, hyper scaling). Also, the organization's culture has a high influence on the success of the CISO. It might mean that the person who created the vision and got digital security rolling is not the same as the one who made it a success. Does that mean that the first leader is worse than the second? We do not think so; it is all about who is the right person for the right time. And if your selection is not thorough enough, you get the CISO you deserve.

To help you get that CISO you deserve, we propose the use of the globally recognized CISO self-assessment of Russel Reynolds, a global HR firm that has also been included in Chapter 1. Looking also at Leadership, Change needed, Stakeholder Management, and Strategic Capabilities. What archetype CISO you need depends on the organization the CISO needs to be in and the challenges that lie ahead.

The Compensation Trap
Why Less Cyber Security Staff is More

Introduction

Security departments are growing out of their seams. While demand for cyber security professionals is growing, finding and retaining good staff takes hard work. According to the 2023 ICS2 Cybersecurity Workforce Study[45], about 67% of respondents said their organizations don't have enough cybersecurity employees and, 92% report having skill gaps in their organization. And while the number of professionals is growing, security must still be at its required levels. Are we utilizing our resources wisely? If so, you can ask, why, then, are companies still being hacked? We may be doing something wrong here because cyber threats and regulatory requirements are increasing in this digital era. This paragraph will address several generic pitfalls and industry-specific flaws that require attention.

Current situation

The current approach in cyber security needs to be corrected in the basics. Some take the word cyber security literally and "try" to protect "cyber," which is undoable since cyber as a concept is endless. This makes cyber security a "wicked problem." In 1973, design theorists Horst Rittel and Melvin Webber suggested that wicked problems have specific characteristics:

- They do not have a definitive formulation.
- They do not have a "stopping rule." In other words, these problems lack an inherent logic that signals when they are solved.
- Solutions to wicked problems are not true or false or right or wrong but somewhat better or worse.
- There is no end to the number of solutions or approaches to a wicked problem.
- Wicked problems can always be described as the symptom of other problems.

45 *ICS2, Cybersecurity Workforce Study, How the Economy, Skills Gap and Artificial Intelligence are Challenging the Global Cybersecurity Workforce*

Rittel and Webber,…. "Climate change, like problems in an education policy or public health, is a wicked problem. It avoids straightforward articulation and is impossible to solve in a way that is simple or final."[46] As researchers and practitioners, we observe a natural tendency to throw more resources at the cyber security problem, hoping this might solve it. But we tend to forget that simply throwing money at it buying more tools and services capable of managing cyber security is not the solution. It might be a way to get to the required security maturity; however, it is not the most efficient, effective, or sustainable one either.

A Security Manager once told us some twenty years ago that his main goal was to make himself obsolete. When that happened, he knew that information security - now branded as cyber security - was embedded across his organization. While some security professionals might think this is a utopia, setting this as the main goal is the key to success.

Let us elaborate on why we think having less, or no, cyber security staff should be the ultimate goal to make cyber security a formal management discipline.

People will only take ownership when they feel accountable

> "People Support What They Help Create."
> *This principle is one of the greatest lessons that any leader can learn because if we want the commitment of our people at the point of implementation then we need to involve them at the point of creation.*

In many organizations, cyber security professionals often take over parts of the work of the people being accountable for the implementation and maintenance. In practice, people will sit back and look at the security staff to do it for them. For example, patch management is a crucial and repetitive task for any organization. We often notice that a security professional does vulnerability monitoring. In applying the patch, progress is monitored, and systems are scanned to verify whether

46 Rittel, H. W.,; Webber, M. M., Dilemmas in a General Theory of Planning., Policy sciences, 1973, page 155-169

the patches are applied. Once a vulnerability is identified, a ticket is registered in the ticketing system, alert emails are sent, and people are called to mobilize IT staff to apply the necessary patch.

While this all might get the job done, it's the world upside down. It's not only inefficient, but it's also annoying for IT staff being chased and security professionals that need to pursue IT staff. Don't ask your neighbor to empty your dishwasher and chase him if he forgets. It's your role and your accountability.

The main issue we observe is that security professionals are filling the gap IT staff is leaving. And, as a result that it will become a never-ending story that is too dependent on individuals and not sustainable. We refer to the "compensating trap" behavior. The problem is that although IT staff might be accountable in the organizational chart for vulnerability and patch management, they sometimes don't feel that responsibility for it if they don't take ownership of this process.

The reason why people, in general, might feel they need to be more accountable and take ownership can be diverse. Some of the reasons might be a lack of education or a need for more awareness about their roles and responsibilities. Another cause might be a lack of incentive or consequence management for changing or exhibiting the desired behavior. Therefore, it needs to be a Key Performance Indicator (KPI) on which the management of the IT department manages them. Or even a KPI for the IT department itself. In the book "Critical Success Factors for Effective Business Information Security,"[47] one of the Critical Success Factors is clear roles and responsibilities with KPIs. To change this, not only does IT governance need to be changed, but also the mindset and behavior of IT staff need to change through training and education. Changing people's behavior is, however, not a one-time activity.

47 *Y. Bobbert and T. Papelard, Critical Success Factors for Business Information Security, Antwerp: Dialoog Publishers, 2018.*

A positive result of IT staff taking ownership is that things can be more effective and efficient. IT staff likes automating things, so they will do the same with security management, making it more efficient and effective. Our experience across multiple companies shows that this reduces "waste" of time and money. Sustainability is the most significant long-term benefit of improved ownership, craftsmanship, and automation.

Delegate, Delegate, Delegate

By now, you might think, "But security is such a broad profession, I don't think that I can reassign all the work to different departments."

Of course, that is partly true, and you probably can't reassign all work. The "mastermind" in security, the leader, must remain in charge of leading security in the right direction. Let us look at all the tasks and see what can and can't be reassigned, assuming that we can change and educate the people in IT and Business processes to take the necessary ownership.

An overview of all security tasks is created and updated by Rafeeq Rehman in his CISO mindmap[48]. Our aim is not to present a complete list here but to provide general guidance on the most common responsibilities.

48 https://rafeeqrehman.com/wp-content/uploads/2022/04/CISO_Mindmap_2022_no_headings.pdf

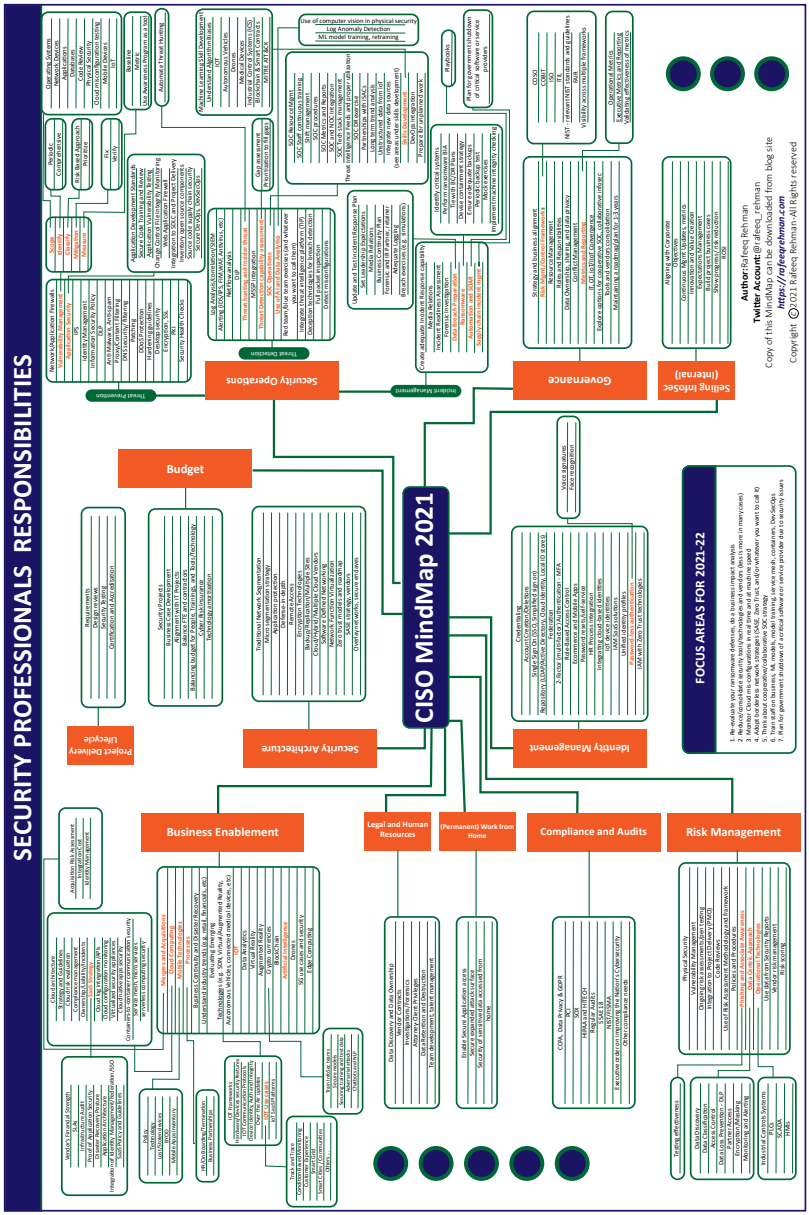


Figure 14 The Chief Information Security Officer Mindmap 2021, by Rafeeq Rehman

Based upon the CISO MindMap, we conducted an assessment per area to which level cyber security activities can be assigned to -other- operational processes (IT and Business):

- *Business Enablement*. This area focuses on security in technologies, sourcing models, Mergers and Acquisitions (M&A), and safety within business processes. Security professionals want to be involved in all these areas, set the relevant security guidelines, design the strategies, and monitor compliance with these requirements and procedures. In practice, the downside is that security professionals are not involved, don't have the proper knowledge for all these areas, or don't have the time or expertise to support the business. This impacts the effectiveness of security maturity. A different approach is not focusing on bringing the proper security knowledge to the table but ensuring that the people responsible for these business areas understand security risks, know the latest security practices and technology, and ask for help where needed. This means that CISO can support education, expertise, or exercises. The advice here is not to use jargon and abbreviations and train yourself in business "language."
- *Project Delivery Lifecycle*: this is the process for new developments from requirements to testing to certification. With the proper implementation of Security by Design or Secure Application Development, this process is suitable for assigning all activities to those responsible for delivering developments or projects. Education, training, and tooling can support this process sufficiently.
- *Security Architecture*: Today, enterprise, domain, solution, and product architects have security as part of their education and experience, incorporating it into their designs. Likewise, suppliers push security configuration as part of their solution. Since most of these architects are also domain or solution experts, they usually understand what to implement and how it can be implemented successfully. Where things can't be implemented, a security or risk expert might come into play to determine whether certain risks should be taken. However, in the end, it's a business decision, so one should question whether a security expert must come into play.
- *Legal & Human Resources*: On the legal side, our experience is that if you have the correct legal and privacy expert, the added value of a security expert is to support in translating

specific legal requirements into tangible measures or translating these measures into the level of compliance to particular rules. However, whether specific incidents or lack of measures have a legal implication is something a legal expert understands much better. Where a security expert might raise a red flag for GDPR compliance, a legal expert might see this differently based on experience and jurisprudence. The human resource part regarding the development of people is part of the manager's role. However, for new products in security, security experts must be involved in guiding the development of people in the right direction for the future. Another important aspect is to develop clear KPIs for managers about specific security objectives. Where they can take ownership over these objectives and KPIs might evolve since the maturity process requires different approaches and changes. That can be incorporated into the HR role descriptions. Our experience is that those clear role descriptions based on the European Competence Framework (ECF) and transparent assessment criteria will receive lots of enthusiasm.

- *Work from Home*: Working from home has been a specific area of attention for security experts, but COVID-19 made a secure way of working from home something fully designed and implemented by architects in collaboration with infrastructure and workplace staff.
- *Compliance and Audits*: Security controls from the relevant compliance frameworks must be designed, implemented, and tested. Operational activities should deal with implementing these controls and delivering the evidence pertinent to test the effectiveness. This seems like an open door, but we still observe many ISO's doing this testing work instead of the responsible line manager. The same is true in our example of patching; this is compensating behavior. Proper governance is needed to implement this behavior and mindset—governance in directing, monitoring, controlling, and communicating. Security is a functional leadership capability that is rarely hierarchical. This functional discipline is necessary within the strategy, and auditors must form a judgment over this. Bringing this -functional- leadership and governance into place significantly helps anchor cyber security for the long term and pass audits successfully.
- *Risk Management*: The subject in the Mindmap is broader than just pure Risk Management. Rehman emphasized all activities you can undertake to identify, assess, and mitigate risks. You want all your first-line managers and product owners to be equipped with this capa-

bility. Provide them with clear instructions, guidelines, and training so that they can do the following:

- Identify new risks that need to be identified via pen-testing or red-teaming activities. The business is active in all environments, such as Industrial Control Systems, Point of Sales systems, or Cloud. Tooling can support this. Many vendors provide essential risk and vulnerability functions so product owners, engineers, and developers can do this to support daily operations.
- Physical security is often specific expertise too broad for Digital Security experts to understand, identify, and asses what your facilities department understands better and what effective treatment plans look like. Since many of our physical devices are connected to the internet, it is good to collaborate with first-line facilities and safety departments.
- Vendor Risk Management nowadays is an integral part of Vendor Management and the procurement process; they might need some education and training where digital risk metering technology can support the security department in identifying rogue or orphan assets. It can also help the procurement officer identify the supplier's risk posture. Or to identify third-party risks in the supply chain. This becomes more evident in NIS2, the DORA Act, and other legislation[49].
- Policies are usually standard and widely available for copying. However, this might need some guidance from a security expert about what is feasible for the organization. Our best practice described in previous papers is applying the Kipling method to corporate policy, a technical standard or procedure, so it provides the precision needed nowadays. The Kipling method[50] is also known as the 5W+1H method by Rudyard Kipling. Kipling is a common practice in auditing[51]. Mills stated, "*The auditor should always use Kipling's*

49 *The NIS Directive is the first piece of EU-wide legislation on cyber security. The Directive on security of network and information systems (the NIS Directive) Requiring member states to be appropriately equipped. See: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A52020PC0823&qid=1681116036420*
The DORA is designed to consolidate and upgrade ICT risk management requirements throughout the financial services sector -and their contractors- to ensure that all participants of the financial system are subject to a common set of standards to mitigate ICT risks for their operations. European Commission, And the Digital operational resilience act (DORA) for the financial sector and amending stakeholders. Source: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A52020PC0595

50 *Kipling, R. "Just so stories", Double Day, 1902*

51 *Mills, D., Working Methods, Quality Auditing, 1993, page 122-142*

checklist… during this stage of the auditing process. In Zero Trust, conditions for access are formulated in an abstract (i.e., technology-independent manner) via the Kipling method: WHO gets access, WHAT exactly access is provided, WHEN, (from) WHERE, WHY, and HOW (i.e., under which conditions is access granted). This allows first-line managers or product owners to implement the vendor-neutral policy and prevents the security staff from doing it via "compensating behavior."

  - Awareness can be fully incorporated into the Human resources and Learning & Development departments. Our experience is that L&D staff understands how people learn and how knowledge is transferred sustainably. Using intelligence learning experience platforms, learning experience methods, and interactive games, they know how to design and create the most effective training. And this can, most of the time, create more effective and fun activity than we have ever seen security staff doing.

- *Identity Management*: Security experts can set the requirements, e.g., MFA, on a "need-to-know" basis. They know how to design, adjust, and make processes as SMART as possible. However, our experience is that when businesses and HR understand access control and identity management, it is much more effective and efficient for them to implement and maintain this themselves.
- *Budget*: Make all security expenses part of the regular IT and Business Operations Budget. Security departments often don't have a budget and need others to purchase. When you make security part of the budget of everyday processes, they will do something with the money spent to make it a sensible investment. For example, why should investing in EDR software be a responsibility of Security while buying Anti-Virus scanners isn't?
- *Security Operations*: A lot of digital security operational work needs to be performed by IT. In the previous section about vulnerability management, you read more about our view. Security Monitoring, however, is a specific activity and crisis management. However, when reviewing current security monitoring software and the SOC's work, we noted that more and more knowledge for analyzing is part of the tooling. A well-educated IT administrator and network engineer understand certain events well. However, The main question is the 7*24 monitoring you might need. Does IT have the capacity and capabilities available to do that?

- *Governance & Selling Digital Security* (internal): this is the primary role of the digital security leader. Governance involves leading and managing security within the company over the whole company and not micro-managing it. Selling Digital security is an integral part of governance to set goals, lead people to achieve these goals, monitor progress, and adjust where needed. To do this, stakeholder management (including selling) plays a significant role.

The above shows that a lot of the tasks of a security professional (or CISO) can be executed by people in the IT and Business processes. Instead of hiring more staff, reduce staff acquisition and delegate it to existing methods.

By doing this, we establish a formal risk and security function "engineered" into the organization (a.k.a. the discipline of enterprise engineering[52]) with proper governance and management and utilized by transparent, structured processes and relational mechanisms that embrace automation and speed.

Focus on what's essential and reuse what you can

When a company becomes regulated, e.g., financials, pharma, Stock exchange listed, assurance statements, and security certifications come into play. This increases the amount of overhead in digital security. Mainly due to the different reporting processes regulatory bodies require.

These developments and requirements significantly impact the efficiency and focus of a company and the security department. A common condition is performing periodic documented and auditable risk assessments. Although assessing and analyzing risks is essential, the work associated with current risk assessments is immense. Often, the requirements for risk assessments are created by people who have studied risk methodologies and have the time to develop complex risk models and extensive risk questionnaires. While managing risks might be a daily discussion, organizations must document these assessments to make this as easy as

52 *Enterprise engineering is the body of knowledge, principles, and practices used to design all or part of an enterprise.An enterprise is a complex socio-technical system comprising people, information, and technology that interact with each other and their environment to support a common mission. Source: https://en.wikipedia.org/wiki/Enterprise_engineering#cite_note-Gia10-1.*

possible, e.g., with some small and proportional-oriented questionnaires. In the end, our experience is that most security requirements are by default necessary, and only for some does it need to be decided whether it is required. The main reason is that about 10-15 years ago, specific security measures like encryption and redundancy were expensive and difficult to implement. Nowadays, you can get encryption for free on a hard disk level, and redundancy can be achieved in the cloud with almost a button click. So many old-school and traditional controls come either out of the box or must be more relevant in certain situations. So, applying a proportional amount of power to treat the risk cures the patient; too much treatment with medicine can kill the patient. In other words, it suffocates business operations.

A significant amount of documentation and an audit trail is needed for compliance, which can be time-consuming. In our experience, a central Information Security Management System (ISMS, not the ISO27001), an application automating and centrally documenting all required privacy, risk management, and security control evidence, is very efficient. As we had two decades ago, before the MCI and Enron scandals, we can document financial processes in separate Excel-based systems that have proven unsustainable. This urges the need for ERP and economic systems like SAP or AFAS. Mainly because financial processes require a single version of the truth, which is happening now in the security space as well. Tighter regulatory requirements urge a professional level of Administrative Organization and Internal controls. Specific Governance, Risk, and Compliance (GRC) tools embody ISMS functions but are, for many organizations, an overkill. Managing a GRC becomes a task on its own. This can suffocate the business mainly because these tools are complex. Basic Information Security Management Systems facilitate automated control testing and can create periodic tasks that need to be executed by operational staff, which they might already be doing. Centrally documenting the outcomes of controls will make Governance over Digital security and complying with frameworks and requirements a “Test once Comply Many” way of working. We do what we must to govern our security maturity and reuse it to comply with external frameworks.

Stop the compensation trap

A "compensation trap" refers to a situation where an individual or organization becomes reliant on compensating or a temporary fix for a problem rather than addressing and solving the root cause of the problem.

By removing the security safety nets and embedding security tasks inside the organization with proper training and guidance, the "compensation trap," as explained in those mentioned earlier, can be removed and eliminated over time. More often than not, when a security professional asks an IT employee why specific changes were not done yet, the answer might be that an essential ERP or Digitalization project was more important or that they thought that it was "you from security that was going to do that." When this safety net or compensation trap behavior is no longer around, they must start arranging and planning themselves. Think about the adolescent constantly lying on the couch gaming when living with their parents and unwilling to make a healthy meal. When adolescent finally lives by themself or become a parent, most of them will be capable of making a healthy meal, decent living, and even raising an infant. This is what is referred to as the process of maturing[53].

Conclusion: Future digital leaders lead and think as C-level

The growing number of security personnel needed in companies is not a sustainable way forward. This is not caused by the scarcity of good security staff in general but by our belief that security can only be effective and efficient when people accountable for executing security measures take ownership. These first-line business people operationalize the criteria daily, have all the insights into how they work, and usually know how to organize their work efficiently. Simply throwing more people at this Wicked Problem that continues compensating the wrong behavior will not contribute to security maturity enterprise-wide.

53 *In the book "on Maturing Business Information Security" all these processes are dealt with phase by phase and what is needed after level 3 or 4. In terms of administration, internal control, and (high levels of) automation. Source: https://repository.ubn.ru.nl/bitstream/handle/2066/192437/192437.pdf*

This change in behavior does not remove the need for security experts capable of leading digital security at a sustainable level. They should be capable of overseeing where measures are implemented successfully and where additional attention is needed, with the capability and courage to change the status quo and people's behavior and institutionalize it as a function without the enterprise-wide "compensating trap" behavior.

People are responsible for the organization's different business processes and IT systems. They should govern and monitor new IT developments and changing business models, which might result in new threats. In some cases, additional in-depth knowledge of specific technologies might need to be hired temporarily until this knowledge is embedded within the organization.

Galina Antova, in her article "Why CISOs Make Great Board Members,"[54] suggests that the role of the CISO has evolved from being a risk metrics presenter to a translator of risk to the business. Therefore, the expertise CISOs have developed in recent years in explaining risk to the board makes them valuable contributors to these conversations.

Consider what your company's CEO, CFO, or CIO is doing. They lead the company and manage others to achieve specific goals instead of micromanaging operational staff. So, to learn from them, one can start thinking as a C-level player, set clear goals, roles, and responsibilities, capture these goals and KPIs into your central ISMS, functionally lead people to encourage first-line ownership, and monitor and report on the effective execution. Don't hire more security staff.

54 https://www.securityweek.com/why-cisos-make-great-board-members/

Key takeaway messages on governance

In this chapter we deal with the history of metrics and measurement methods in digital security. We have established a "frame of reference" of metrics per organizational level, taking into considerations the limitations of leadership and awareness that in our experience need additional attention. We also talked about the pressure of regulations and the way to deal with them, because you can complain, but they won't go away anytime soon. We offer the following key takeaway messages:

1. The more you think, the more likely you're going to make a mistake. Minimize thinking and maximize doing; implement controls, improve them, respond to incidents, measure improvement.
2. Don't reinvent the wheel, but learn from others in your sector.
3. Cherry pick the metrics in this section as a frame of reference and tailor them to your organization.
4. Gain trust from your internal and external stakeholders, show that you know what you're talking about, build a relationship, and deliver what you agreed on. Try to empathize with these stakeholders.
5. Embed compliance in your daily business. Then it will become automatic, which means that it will become as simple as driving a car.
6. Start telling and stop explaining. Take ownership of your work.

Ending the cold war in cybersecurity

We all know about the cold war period of geopolitical tension between the Soviet Union with its satellite states, and the United States with its allies after World War II (until 1989-1991). George Orwell used the term cold war in his essay "You and the Atomic Bomb" (published on 19 October 1945 in the British newspaper Tribune), contemplating "a world living in the shadow of the threat of nuclear warfare (a military conflict or political strategy in which nuclear weaponry is used to inflict damage on the enemy. Nuclear weapons are weapons of mass destruction)."[55]

After decades of arms racing, spying (e.g. by means of phone taps, pigeon cameras, spy shoes with a heel transmitter, gun-mounted lipstick heads, pens with a hidden camera, etc.[56]), crises and constant threats, through which many companies became very rich, the solution was not to create even more weapons or more threats; the solution came from different politics and a revolution of the people.

In digital security, we are also currently in our own cold war. We see hackers getting more organized, state-sponsored, and more sophisticated on the one hand, while on the other hand, we see cybersecurity products, services and startups rise massively and constantly creating new and more sophisticated tools. But do we see a decrease in the damage caused by security incidents? According to Ponemon[57] the average total cost of a data breach increased from $3.54 million in 2006 to $8.19 million in 2019 and the odds of experiencing a data breach within two years increased from 22.6% in 2014 to 29.6% in 2019.

There are actually three types of "events" for which you pay the most: *Marriage*, *Babies*, and *Cybersecurity*.

The result of this cyber cold war is that both the hackers and the cybersecurity companies make massive profits. We move to more self-learning, artificial intelligence, machine learning security

55 *https://en.wikipedia.org/wiki/Nuclear_warfare*
56 *https://www.technocrazed.com/39-most-amazing-spy-gadgets-from-the-cold-war-era*
57 *Ponemon Institute, Cost of a Data Breach Report 2019*

products (e.g. Darktrace, SentinelOne, and a whole lot more[58]) while attacks become more intense using the most recent technologies and social engineering. The question is: will this ever stop? Will this cold war end in a truce, in peace, in a place where companies and citizens can again focus on things that really matter, instead of constantly being on guard against the threats that are out there?

Looking at history, one can doubt whether this cyber-arms war is the right way to go. Knowing this, shouldn't we shift toward a new approach? Two "crazy" thoughts on how we can change this paradigm and move to a truce.

1. Remove the incentive for "good" and "evil" people engaging in this cold war. Because is "Anonymous" really evil when all they want is justice? Or is that hacker in a country where hacking pays the bills actually evil or just finding a way to survive? Is that security company that is constantly selling more security products, trying to go the stock exchange as soon as possible, really good? The question here is how can we remove the incentive from both sides to continue with this cold war? Isn't that a social-political question in which governments need to play a role?

2. Is an Open Internet really the right way to go? Haven't we proved that we actually can't take that responsibility? Not only hackers, but also governments and citizens? If we know that about 45% of all email traffic is spam, the dark web is full of illegal content and activities and there are somewhere between 150,000 and 500,000 phishing websites active each month (COVID-19 has led to a 350% increase in phishing sites).[59] [60] Is the Open Internet not a complete failure? What if we would try to implement a "zero trust" approach for the whole internet? (*Zero trust eliminates the concept of trust from an organization's network architecture. Rooted in the principle of "never trust, always verify, by leveraging network segmentation, preventing lateral movement, providing Layer 7 threat prevention, and simplifying granular*

58 *https://builtin.com/artificial-intelligence/artificial-intelligence-cybersecurity*

59 *https://www.statista.com/statistics/266155/number-of-phishing-domain-names-worldwide/*

60 *https://atlasvpn.com/blog/google-registers-a-350-increase-in-phishing-websites-amid-quarantine*

user-access control[61]) People might think about the Great Chinese firewall or other internet controlling states, but it's a question whether the solution itself is wrong or the way the solution is being applied is wrong.

Although these ideas might not be easy to implement, the current approach is we believe not the right way to a lasting solution. To end this cold war, we need to change direction. On a macro level we need to need to change the global social-political direction. At the meso level we need more awareness, "soft controls" and education. And at the micro level we need technology.

61 https://www.paloaltonetworks.com/cyberpedia/what-is-a-zero-trust-architecture

Three digital security interludes

Introduction

We talk a lot about the astonishing speed of IT developments. Yet, these quotes from a twelve-year-old book[62] are still remarkably topical:

"*Risk starts from the time someone decides to open the doors for business and doesn't end until the company is out of business"*
"Like any risk, IT risk is something to be managed, not eliminated"
"Management of IT risk has kept pace with the reality of IT risk. IT risk in many enterprises is still handled as a technical issue... "
"IT risk is now business risk, with business consequences, enterprises must change the way they manage it."

So, not much has changed. What is now described as 'digital security', 'cyber risk' or 'cyber-security' was previously called information security.

One of the things that has changed is that cyber specialism has become better appreciated in the past twenty years. Whoever wanted to sell digital security in the nineties, commonly knocked on doors that remained hermetically closed. There were hardly any compelling events like there are today. Board accountability is very real nowadays and people who mess things up are actually getting fired, or worse, sent to prison. In that regard, the accumulation of scandals has had a positive effect. Cyber risk is hot and it's top of mind for many people. Moreover, it's no longer an irrelevance, but a welcome protection against real threats.

62 *IT RISK. Turning business threats into competitive advantage – Westerman, George; Hunter, Richard; © 2007*

The flip side is that there is some fatigue nowadays. For example, the various seminars on cyber risk are poorly attended. A possible cause of this is the strong 'Fear', 'Uncertainty' and 'Doubt' (FUD) association with cyber risk. The customer side of the market is suffused with FUD. "If you do not purchase this solution now, your company will perish!" By indoctrinating companies with this fear policy, many suppliers are eroding the essence of cyber risk. It becomes an empty shell and companies that have let themselves be fooled. The market is congested with inadequate tools and solutions.

By now the phrase 'cybersecurity' has taken root in society. Unfortunately, it's a contradiction in terms. The field is really about cyber risk since you can't secure the entire 'cyberworld'. You protect yourselves against cyber risks. Nothing more, nothing less.

"*Like any risk, IT risk is something to be managed, not eliminated*"

Only when all risks have been eliminated can we speak of cybersecurity. And that, let's face it, will remain an illusion.

During practical experience over the years the authors have developed a deep belief of how cyber risk within companies should be dealt with. However, not everything can be made practical instantly. Our approach to cyber risk is holistic. Cyber risk, essential though it may be, is just one part of the whole.

Our interludes focused on the following three main topics:

1. Breaking the perverse model. It seems that suppliers of solutions more often than not have a different agenda than their customers.
2. The ethics and economics of cyber risk. Why not charge companies that make a mess of things? The big cyber polluters such as botnet hosts should pay a cyber tax. And

vice-versa, those whose cyber-risk practice is in pristine condition should pay correspondingly less tax.

3. Winning the cyber war by working together in an ecosystem. Bundle knowledge – such as checklists – and experience in a smart coalition.

These Interludes were intially recorded and written down by writer Ed Lute

Interlude 1: Breaking the perverse model

Too many people still think cyber risks are not real. “It won’t happen, because it has never happened before.” There lies the biggest challenge. The employees of a company pose a challenge for cyber-risk professionals. Time and again they turn out to be the weakest link in the chain. There are also charlatans which appear on the market. Security is a growth market where a lot of money can be made. Every opportunist can present himself as a cyber-risk professional in order to get his share of the pie. Separating the wheat from the chaff is not a simple task. How do you choose the right provider for your organization? And what do the various certifications mean?

Many providers make it a sport to collect as many certificates as possible. The abbreviations fly around on their websites – CISSP, CISM, GISF, CASP, SSCP and so on. Behind every abbreviation there is a very banal revenue model. For each certification one has to pay, which is odd. Why should you have to pay to prove your own expertise? Just as in education, a certificate stating your level of skill, should not be associated with a financial incentive. These certificates can’t then possibly be independent. The European e-Competence Framework and its specifications for security professionals needs to be adopted by nonprofit educational institutions.

A curriculum vitae may perhaps tell you more about the expertise of a person you may hire. What is someone’s education, where did he/she work, are there recommendations? Or in the case of a provider: which customers have they served and how satisfied are they with the delivered services? That way you get a better insight. So proper due diligence is key. Make sure that you’re hiring a reliable party. Consult peers who are not in IT. Get advice from someone who works in a different, more mature sector, such as finance or aviation.

And the golden rule 'penny wise, pound foolish' also applies to services in the field of cyber risk. Suppose you need to hire a penetration tester. Be aware that offers that only charge a fraction of what the market usually requires, can't possibly give you what you need. At best you may get some kind of refined vulnerability scan.

A leader should be able to spot that intrinsic drive in people and thus in a provider. Good leaders have self-knowledge. They must know their own strengths and weaknesses. When it's clear what you're not so good at, you know what skills you need to get elsewhere. This can be managed with a science-based 'resource-based view'. That framework helps you to optimally exploit the strategic resources of an organization – people, money, resources, technology. Where are the good people and the good teams? Who should I hire?

A leader must also be able to rely on himself too, for example, be able to resist the perverse incentives. How far do I allow myself to be carried away by FUD emotions? How strictly should I sail my own course? Those who are good at this are real CISOs who can truly separate the sense from the non-sense.

Among many definitions, leadership can be portrayed as motivating people in such a way that they will do the right things on their own. On the other side of the spectrum, there is still the 'leader' who belittles his/her people and mainly points out what they have done wrong. "Didn't I tell you to set up that firewall like this? Now see what has happened: we've been hacked." To break this kind of non-constructive vibe, you can only tell those 'leaders' that they should restrain their negative inclinations.

When you can't get rid of these people, the most practical thing is not to involve them in projects. You don't want their destructive influence to affect a team's flow. The same applies to employees. Nobody wants a grumbler in their team. Notorious complainers are

best helped by saying: “You need to tackle your problem on your own, or the time has come for you to think about whether this is the right place for you.”

As a leader, the trick is to find the right balance between standing firm on your vision and being flexible, open, and transparent. Both are needed. Specifically when things absolutely need to happen, because if they don’t, harm will be done.

Employees who really love their profession do not want their skills to be called into question by their managers. Recognize the craftsmanship of your people. “You’re the expert!” That way you encourage someone to go that extra mile. That woman or man works an hour extra to really understand a topic and learn more about it or in order to complete an important checklist after working hours.

This is related to the corporate culture, or what Professor Sumantra Ghoshal refers to as ‘the smell of the place’.[63] It’s not helpful when there is little or no mutual understanding between IT and the business. Anyone who hears conflicting messages will not easily maintain that intrinsic motivation. It has to do with both nature and nurture. The intrinsic motivation must be there naturally, and the right incentive can make it thrive. The danger of an overly strict hierarchical corporate culture is that it can kill intrinsic motivation. When someone has tried for half a year in vain to be recognized and treated as an expert, she/he will no longer fight. They have been crushed and will not go the extra mile. The true craftsmen will make sure they leave the ‘stinking place’.

Another question is: how good or reliable are the digital giants with their security service offerings? How deeply entangled is Chronicle Security from Alphabet with all the other endeavors from Google? Or Sentinel from Microsoft for that matter? Companies such as ATOS, HP and IBM have many hosting services, while their cybersecurity divisions are rap-

63 The Smell of the Place - Talk on Corporate Culture by Prof. Sumantra Ghoshal. https://youtu.be/YgrD7yJwxAM

idly growing as well. It seems like they are cleaning up their own mess, so perhaps their security services should be free of charge.

Is the perverse incentive a given or can we make it disappear? For example, recent protests against financial exploitation by IT vendors, who keep their customers imprisoned in a lock-in, are getting louder. This too has to do with maturity.

Many providers, such as Salesforce, charge their customers extra for safe data processing. That is strange when we compare this with the automotive industry, where many features – electric windows, airbags, cruise control – are just standard issue. These are not regarded as extras. Major steps have been taken in the automotive industry to make cars safer. This increased quality of the product as part of the service is driven by the wishes of customers. On the other hand, the regulations act as an incentive for improvement. The automotive sector is highly regulated because the consequences of malpractice by manufacturers can be dire: a lack of quality can result in deaths. The same applies to healthcare and aviation.

Similarly, the cyber-risk field benefits when security suppliers and security professionals must comply with stricter regulation. That will only happen with stricter regulations or more attacks. And more maturity, where true customer focus results in added services and quality without charging more, is also needed.

“People who are selected and compensated to find complicated solutions do not have an incentive to implement simplified ones.”

Nassim Nicholas Taleb

05

Funding

Cyber economics

In this chapter we discuss cyber economics and the various views on how to look at cyber investments. Do we spend enough money on cybersecurity initiatives? How do we balance the risk versus the investment? Do we need to buy all those cool new security tools that are being sold by numerous Nasdaq-registered companies? Where can we get more bang for our buck and do we need to follow up on IDC and Gartner predictions? Or do we just need to ignore these predictions and do we need to use technology better?

We need more money!

According to research institute Gartner, cybersecurity spending growth worldwide was 8.7% in 2019 ($124 billion). This growth will exceed general IT spending, according to Gartner. The top drivers of security spending are building detection and response capabilities, privacy regulations such as GDPR/CPAA, and the need to address digital business risks.

Another research agency IDC[1] states: "However, you can spend 15% of your IT budget on security and still not achieve the level of assuredness that you desire if your architecture is complex or the assets being protected are very valuable. Likewise, a spend of 5% may be appropriate." The art of gaining more effect from past security investments is to understand the exact cost behind cyber risk once the risks manifests and how effectively the security investment covers the risk.

Cybersecurity breaches can impact an organization in many ways. We distinguish direct, short-term, and long-term economic consequences.

1 https://www.csoonline.com/article/3432138/how-much-should-you-spend-on-security.html

Direct consequences are the costs for repairing or changing systems, stopping or slowing down production, the costs of legal action, etc. Shipping company Maersk experienced damage worth $200 million as a result of the NotPetya virus harming their critical systems.[2]

"According to a statement issued by the company, the total cost for dealing with the outbreak will land somewhere in the $200 to $300 million range. NotPetya-related costs contributed to a $264 million quarterly loss despite revenues rising from $8.7 billion to $9.6 billion year-over-year."

Direct consequences also include answering questions from regulators or the media and investigating the root cause. From experience we know that this can take weeks or months. especially if there are few log files or third-party agreements on log retention or treatment.

Short-term consequences can include the loss of existing customers and damage to your reputation. Companies may lose business because of security breaches, which harm their trust relationships with customers and possibly also with suppliers. In December 2011, Impairment Resources, LLC was the victim of a digital burglary which ultimately led to their bankruptcy due to a loss of trust among customers. Dutch certificate authority DigiNotar in the Netherlands fell victim to a state-sponsored hack which created a lack of public trust and ultimately led to the bankruptcy of the firm.[3]

Long-term consequences include the loss of stock/market value. In some case security breaches might influence the stock value of the company as demonstrated in Japanese research among listed companies that suffered a breach.[4] In 2011 Shackelford wrote: "Over 90% of respondents to a survey by the Ponemon Institute reported experiencing a cyber-attack during the last year,

2 *NotPetya Ransomware Attack Cost Shipping Giant Maersk Over $200 Million: https://www.forbes.com/sites/leemathews/2017/08/16/notpetya-ransomware-attack-cost-shipping-giant-maersk-over-200-million/#4994da404f9a*

3 *Rechtbank van Amsterdam, "Gerechtelijke uitspraak Diginotar." Available: https://uitspraken.rechtspraak.nl/inziendocument?id=ECLI:NL:RBAMS:2014:4888&keyword=internet%20ontbreken. And Fox-IT, "DigiNotar Certificate Authority breach," "Operation Black Tulip,"" FOX IT in assignment of the Ministry of the Interior and Kingdom Relations, Den Haag, 2011.*

4 *M. Ishiguro, T. Hideyuki, K. Matsuura and I. Murase, "The Effect of Information Security Incidents on Corporate Values in the Japanese Stock Market," The Graduate School of Interdisciplinary Information Studies, The University of Tokyo, p. 15, 2011.*

costing on average more than $2 million per organization." Such attacks have been shown to negatively impact the stock prices of targeted firms. An example is DoubleClick; after a serious violation of their existing privacy statement and a subsequent lawsuit the value of their stock fell by 20%. The same happened to Equifax and Target.[5] This also happened with ChoicePoint; their stock value fell by 17% after a data breach. Thus an important part of building trust is by assuring security and privacy.[6] At Target and Equifax in particular public trust was damaged since "bad practices" and sloppy housekeeping appeared to be the root cause of the events.

Cybersecurity is not only a negative driver in a cost/benefit analysis. It may both cause additional costs and avoid other costs, but also may contribute to the competitive position of the firm. Harvard professors Hunter and Westerman examined companies that treated risk management as a continuous improvement process and revealed the fact that those who did were perceived to have higher value.[7] Gordon examined companies that are open to voluntary disclosures concerning digital security and publicly accept feedback on their security investments and activities. Here, too, there was an increase in company value.[8] As you've read in section on Governance this might have something to do with you "telling" others (showing you're in control), instead of "explaining" the situation to others (have others control you) . Both Gordon and Shackelford warn investors to be careful with investing in firms that do not proactively treat security risks. Shackelford quotes: *"As losses mount, investors will likely stop treating cyber-attacks as a corporate nuisance. Instead, they may start treating such attacks as the serious threat they are to the survival of firms and, at a macro level, the long-term competitiveness of knowledge economies built on intellectual property."* For some companies digital security is perceived as a competitive advantage which helps them distinguish themselves from competitors.[9] In 2015

5 *Forbes, "Target's CEO Steps Down, Company Shares Drop," http://www.forbes.com, United States, 2014. S. Srinivasan, "Cyber breach at Target," Harvard Business School, 2016.*

6 *Camp. L.J., Wolfram, C: Pricing Security. Proceedings of the CERT Information Survivability Workshop, Boston MA, 2000.*

7 *Westerman and R. Hunter wrote the book, IT Risk, Turning Business Threats into Competitive Advantage, Boston MA: Harvard Business School Press, 2007.*

8 *"The impact of information security breaches: Has there been a downward shift in costs?," from L. A. Gordon, M. P. Loeb, and L. Zhou in Journal of Computer Security, 2011.*

9 *Gordon, M. Loeb, and T. Sohail, "Market Value of Voluntary Disclosures Concerning Information Security," MIS Quarterly, vol. 34, no. 3, 2010.*

Ponemon and Accenture suggested in their research publication *The Cybersecurity Leap: From Laggard to Leader* that companies that address BIS as a strategic topic perform better and can 'leapfrog' others. In particular proper protection, when communicated properly to the market, will generally establish trust.[10] Trust, which is a basic driver for a "better image" with customers and business partners and consequently for improved revenues.[11] In the section on Governance, we talked about the trust equation, which might help you to improve trust.

By communication we mean communication with relevant stakeholders who benefit from the wellbeing of the firm. These days, the Board's responsibility goes beyond strict financial performance and organizations must demonstrate good governance and take ownership of Corporate Social Responsibility (CSR)[12] and associated Sustainable Development Goals (SDGs). Within AEX-listed Dutch insurance company NN Group the annual report makes explicit, based on sustainability indices, how the company performed on the CSR ladder. NN Group reported over 2018: "Overall NN scored 78 (out of 100), compared to the average industry score of 47." From this perspective, it should be no surprise that half of all C-level executives have cybersecurity issues on their Board's agenda once a quarter.

Direct and indirect costs are not exactly justifiable via mathematical models but can be calculated quite accurately by making use of models that make use of actuarial data on historical events. So why don't we make more use of historical data when drafting our cybersecurity investment plans? Or make use of these models in our cybersecurity activity decisions. As Harvard professor Michael Porter states: "The essence of strategy is choosing what not to do." So listing out all digital security risk versus the security controls based on economics seems logical, but don't exaggerate with e.g. having a specific risk-management department focusing only

10 *The Cyber Security Leap: From Laggard to Leader.*

11 *F. Innerhofer-Oberperfler and R. Breu, "Economics of Information Security and Privacy," in Potential Rating Indicators for Cyberinsurance: An Exploratory Qualitative Study, Springer US, 2010, pp. 249-278.*

12 *Within the NN Group and UWV annual report the CISO made explicit, based upon sustainability indices, how the company performed on the CSR/MVO ladder. NN Group reported over 2018: Overall NN scored 78 (out of 100), compared to the average industry score of 47. See the reports here for UWV. https://2017.uwvjaarverslag.nl/jaarverslag-2017/s1072_jaarverslag/s1095_beveiligingenprivacy/ and NN here : https://www.nn-group.com/Media/Article/NN-Group-remains-included-in-Dow-Jones-Sustainability-Indices-2019-.htm*

on these risk and control models. Focus on getting things done with a focus on where security risks might hurt the most. As you've read in the section on Changing, don't try to do everything at once. Traditional checklists for traditional investment and business cases such as internal rate of return and Net Present Value can also be used for cybersecurity investments.

We believe that it's not possible to protect against all threats, but it is possible to identify which threats have the most significant potential impact and the associated security controls that reduce the biggest risks for the business. Based on historical data. Don't be stubborn and think you can do that from the top of your head. Every situation is different, and every event has different outcomes; the only person capable of doing this is some who has all of this historical data. But how do get that?

Why shall we give you more money?

Common approaches to cybersecurity include risk management, security frameworks, and regulatory compliance. While these approaches provide important input for developing a security strategy, they are just a start. Shortcomings in current approaches make it difficult to establish an appropriate budget and measure progress toward a successful financial outcome. An outcome that is understandable by businesspeople who talk in the language of finance—euros and dollars. For cybersecurity to be managed like other business processes, it must articulate value in the same language as the rest of the business. The CIO, CEO and Board of Directors are fluent in the language of risk and finance. They understand terms such as Return On Investment (ROI), Net Present Value, Internal Rate of return and expected loss. It's important for cybersecurity leaders to prepare strategies and communicate their recommendations this way. To translate the cybersecurity activities of people, processes, and technologies into the familiar, objective language of owners, namely critical assets, dollars, and cents, requires cybersecurity economics.

For cybersecurity to be treated as a business process, it must be measured objectively so that there is confidence in the accuracy of the results, the same confidence that leaders have in revenues and margins. Therefore you need data such as research data from prior breaches,

valuation differences in data types and attack patterns for various industries across the globe to inform your cyber-risk model. Some models and techniques are KOVRR and Cytegic. All make use of historical event and breach data to determine per sector the likelihood that a certain event might occur. Preconditions for these models and techniques are to identify and model the business characteristics such as size, revenue, presence, regulatory requirements, etc. into the model. They are sometimes augmented with telemetry from the client technology environment as empirical evidence to further improve the model (as a reflection of the company's specific reality).

Thus threats, past events, and business characteristics are reflected in existing security controls and as a result potential improvements are presented including their investments, again based on historical data of past investments. If possible, some technologies map these measurements on existing frameworks such as NIST, CIS, ISO, or Critical Security Controls. The adoption of frameworks in these areas ensures that the analysis is comprehensive and objective.

These approaches calculate the likelihood of a particular threat in a certain segment and its potential business impact, yielding inherent risk. They then evaluate the effectiveness of the control environment to remediate and reduce that risk. The sum of threats and impacts along with remediated risks provides an organizational overview of the total inherent and residual risk, expressed in euros. Because the risk scenarios are listed, you can see which have the highest inherent risk and residual risk and which are most likely areas of financial loss. Cost-benefit analysis of risk treatment options for those risks allows the business to prioritize security measures. This also helps inform leaders about the expected value of the investment and specific ROI of projects and allow them to make informed decisions based on a holistic view of many projects. This makes it possible to compile a security program that is purely based on data and not on experience from the security officer, gut feeling, or what worked last year at another company. The key here is that the data sources that feed the model are up to date and continuously maintained with relevant information.

In addition to that all the above it is necessary to explain to others why you need money and what the benefits are, so don't get stuck in making these models. In the end a model doesn't solve security risks, action does. Also if the budget holder or Board of Management still doesn't want to invest even though you have a very positive ROI, move on, and get things done with less budget in the best possible way. Sometimes the "time is not right" or security risks don't "hurt" enough, so the business focus might be on other important business programs that need the available money.

Get more bang for your buck

Where can we get more bang for our buck and do we need to follow up on IDC and Gartner predictions or should we just ignore these predictions? And do we need to use corporate resources such as technology better?

By making use of current models and actuarial data you leave out subjective opinions or individual biased preferences. By explaining the exact costs of the risks versus the treatment you can prioritize projects, although sometime you also need to give the budget holder what he or she thinks it important as an add-on, to give them the idea that they know about digital security as well. Projects that seem to exceed the average cost can be subject to scrutiny of resources such as people or technology. In our experience most of the security technology already available in companies is being used only 25%. Do you think that would be possible in aviation, automotive or healthcare? Where every minute and robot are used to the full. Why isn't that the case with digital security? Do we really think we don't need to do that and that simply throwing money at it will solve the problem? Thus scrutinizing new investment and using existing resources might eventually help in reaching the research institute IDC quoted 5% of the IT budget which can be spent on security and still achieve success.

Business case

In 2013 we performed a large-scale study of the formulation of Business Information Security strategy. Among other things, we investigated whether today's CISOs work on "context or content." In other words, in strategy formulation do they evaluate external environmental influences or exclusively focus on internal rules and guidelines. These environmental influences (hacktivists, media, etc.) are essential for the resilience of the organization. After all, there are numerous examples of the strongly negative impact that insufficient inclusion of external influences (forces) in the security strategy can have on business continuity. This impact can relate to a sudden decrease in the value of the company,[13] to a lack of trust, influence on continuity,[14] reputation (on the resignation of directors)[15] or even bankruptcy.[16]

In our research, we asked more than forty security professionals and managers to specify the metrics that they find relevant for their operational level, their tactical level, and their strategic level. Identifying a limited number of specific metrics per industry makes it easier for us to guarantee the desired change (such as increasing or maintaining security maturity), simply because we do not have 160 criteria, but only four or five. The strategic metrics of security maturity can be taken into account when initiating the business case. Researcher Kim Maes of the Antwerp Management School gives the following definition of a business case: *"A business case is a dynamic, formal document specifying all relevant information of an investment, which is purposefully used throughout the entire investment life cycle by key stakeholders."*[17] Maes and his co-authors De Haes and Van Grembergen make a number of important observations that we present below and that accompany a few specific examples in the field of security. We also offer guidelines with which business cases for cybersecurity projects can be better prepared.

13 *Guardian, 23 April 2013. 'AP Twitter hack causes panic on Wall Street and sends Dow plunging'.*

14 *Los Angeles Times, May 24, 2011, 'Bank of America data leak destroys trust'.*

15 *BBC News, 'Target CEO resigns after data breach fallout. Gregg Steinhafel steps down in wake of a hack last December that affected as many as 110 million Target customers'. http://www.bbc.com/news/business-27283872*

16 *Wall Street Journal, 'Burglary Triggers Medical Records Firm's Collapse' [3]*

17 *Maes, „Identifying Multiple Dimensions of a Business Case: A Systematic Literature Review," Electronic Journal Information Systems Evaluation, vol. 16, no. 4, pp. 302-314, 2013*

A business case is more than financial numbers

In many cases, the business case describes value creation in a financial sense. In the case of security, the value added to the company can't always be expressed in money. Protecting against reputation and/or image damage is very relevant for every organization, but its value is difficult to express in euros. Maes and his colleagues call addressing "non-financial benefits" an important criterion to include in the initiation, evaluation, and decision-making process regarding the investment. They provide some content criteria (what should be included) on which the business case can be designed, as well as process criteria (see the Appendix: Business case criteria). Namely the criteria that shape the business case, maturity, and desired results. *"After implementation, a business case can help to evaluate the investment outcome, and to understand failure reasons and lessons learned for future business case developments and investment implementations."*

It's not just about developing a business case

It's not only about drafting but also about maintaining and evaluating the business case. By assessing the ingredients, decisions, and outcomes of the business case before, during and afterwards, perspectives for new investments can become visible. In our view, an essential step in preparing a business case is the consideration of alternatives. We always ask what the alternative can be for an investment that the organization intends to make. Often there is no answer and one goes back to the essence of the problem and to its potential solutions. A good example is an organization that we once advised on in the field of a new defense perimeter. The IT manager already had firewalls in the shopping cart, so to speak, but when the question came as to what the alternative could be, there was no answer. By then having a good conversation about the alternatives to purchasing this firewall, new insights emerged. In this example, a firewall functionality on the router (via software) was ultimately chosen. This was a considerably better financial alternative with the same desired profit (benefit realization). This question is relevant when it comes to investing in resources, but this also remains the case when hiring people. Hired specialists may be able to do the work many times more efficiently at lower cost than your own unskilled people. According to research by McKinsey high-performing workers are

about 800% more productive in highly complex jobs.[18] This means that even though a hired specialist might seem to cost double the cost of your own unskilled person, the hired specialist in fact costs only a quarter of the cost of the own staff. This is because the high-performing hired specialist is eight times more productive.

The literature also shows that there is a scarcity of knowledge in the field of business cases. This knowledge is essential to be able to substantiate and make investment decisions yourself and not based on advice from vendors or consultancy firms.

In practice, we regularly see that senior management are not aware of the investment and decision-making process. People are aware of the fact that an investment has been made (it's usually on a current budget), but if you continue to ask, it's rarely based on a thorough analysis of the decision-making process. The literature also supports this. There is only a business case accompanying half of the investment decisions.[19] Even less often asked is the important question: For whom? For whom is this investment made? Which stakeholders have an interest in it?

The researchers (Maes *et al.*) state *"Various publications identify multiple stakeholders that can be involved with a business case, yet none provides a complete list of who should really be involved."* In Appendix A (Business Case Criteria)we provide guidance as to which stakeholders may be involved, and which business goals can be set. This makes it clear which stakeholders will benefit from the investment. And a "stakeholder analysis" gives the business case the right direction.

Including these business case criteria in Governance Risk and Compliance (GRC) or Information Security Management System (ISMS) tooling creates added value for the security field. In this way, it's possible to proceed fairly quickly after finding criteria such as: objectives, acceptance criteria, expectations, alternatives, resources, funding, etc. That is all input for the business case as well as for the project initiation document. Essential advice that results from an assessment

18 https://www.mckinsey.com/business-functions/organization/our-insights/attracting-and-retaining-the-right-talent

19 Maes, "Identifying Multiple Dimensions of a Business Case: A Systematic Literature Review," Electronic Journal Information Systems Evaluation, vol. 16, no. 4, pp. 302-314, 2013

based on those business case criteria can be included in tools such as ISMS, GRC, or ticketing systems. These are the costs of the recommendation – which comes as advice based on the assessment – and the lead time of the recommendation. By structurally explaining the costs and the lead time of all interventions, one can immediately assess whether a change (for example, improving the security maturity level) can be realized. A document management system or reference to storage media (for example a SharePoint portal) in such tools makes it possible to collect the associated burden of proof and thus support evidence-based decision-making.

Some source of truth that provides evidence the factual status of security control effectiveness is necessary since this also forms the input for future investments.

Return On Security Investment (ROSI)

Return on Security Investment represents the amount of risk reduced, less the amount of money spent, divided by the amount spent on cybersecurity controls. The business would like to know how much they should spend on security to reduce the risk and when the investment has the largest return. The goal of the ROSI is how much the business can save by investing in IT security. Parallel to that, look at all cybersecurity investments and prioritize the investment portfolio.

But before we can do a ROSI calculation we need some information. We have to conduct a Business Impact Analysis (BIA) first to identify the critical business functions and associated assets. This starts with figuring out which processes are critical for the company's success. Another important perspective for an organization is derived from analytical risk exposure methods that explain the cost of security incidents. We take the Single Loss Exposure (SLE) and multiply it by the Annual Rate of Occurrence (ARO) and the result of this is the Annual Loss Exposure (ALE).

Example:

$$ALE = ARO \times SLE$$

500 Employees * 44 hours (ARO) * 22€ Average cost per hour (SLE) = 484,000€ (ALE)
Loss of productivity can have a serious impact on the business. Just a few minutes of downtime can result in a significant loss of money.

To do the actual ROSI calculation you need these parameters:

- Single Loss Expectancy (SLE) = The expected amount of money lost during a single security incident.
- Annual Rate of Occurrence (ARO) = The probability of a security incident occurring in a year.
- Annual Loss Exposure (ALE): The total annual financial loss expected from a security incident.
- Recurring Security Costs (RSC) = Annual security costs (licenses, audits, specialized staff).
- Mitigation Ratio = Percentage of threats deterred by the security solution.
- Security Cost (Scost) = Initial investment in the digital security measure.

Examples:

$$ROSI = [(ALE \times \% \text{ Risk Mitigation} - Scost)] / Scost$$

In this example calculation:

ALE:	€400,000
Risk Mitigation:	94% by adopting a security measure
Scost:	€60,000
ROSI:	526%

The accuracy of your ROSI

It's not only that accurate ROSI calculation can deliver more benefits but reliable data is also crucial for your investments and forecasts. Besides calculations of potential losses and investment there is also "threat intelligence." This is another important tool, which can reduce the

annual cost of a data breach. Threat intelligence is information that leads to action and can change behaviors. The development of intelligence is a circular process of Tactics, Techniques and Procedures (TTPs). Cyber threat intelligence is a continuous process of re-evaluating the new information and it identifies intelligence gaps during the re-evaluation phase. There are three types of "threat intelligence":

Tactical Intelligence: Here the focus is on the immediate future. It's more technical and it identifies indicators such as bad IPs, URLs, and API integrations. These indicators actually also give you information about what might go wrong in the near future that will cost you money. On the one hand it makes your ROSI more reliable, on the other hand it reduces your SLE and ARO, when it's used properly.

Operational Intelligence: A specific incident provides a high specialized technical focus. Such intelligence is often related to campaigns, malware, and tools. Behind every attack is a "who," "why," and "how." The "who" is called attribution. The "why" is called motivation. The "how" is made up of TTPs adversary employs. This type of information can reduce the impact of an incident, so it can reduce the SLE and ARO as well. This will also give you more accurate data for your ROSI calculation.

Strategic Intelligence: This helps decision-makers understand the risks posed to their organizations by cyber threats. It informs decisions on logging issues and provides a timely warning of threats. Organizations can make cybersecurity investments that effectively protect them and are aligned with their strategic priorities. This gives you again more accurate data for your ROSI calculations, as well as more reliable insight, so "more bang for your buck."

Cyberthreat intelligence provides the organization with up-to-date and actionable data to prevent an attack or to contain a breach once it occurs. This data can also be used to draft a security strategy with a focus on predictive analytic controls besides the traditional detection and protection controls. Active cyber intelligence feeds can also inform you of potential threats in your sector or country. The more accurate this threat intel data the more relevant it is to test

if your organization is vulnerable to certain attack scenarios that this intel might provide you with. To proactively test this, red teaming or penetration testing (validation of security control effectiveness) is recommended and sometimes mandatory in certain sectors such as financial services. Control effectiveness is the synergistic risk reduction benefit from finding out how well the controls are implemented. An organization's control effectiveness score is calculated by multiplying its control implementation value by the maximum control effectiveness value per risk scenario per control within a cybersecurity control framework.

Customer satisfaction research

A tool that can be used to measure the value delivered by a product or service is the customer satisfaction survey. This not only gives you insight into the quality of the product or service as perceived by customers, but it also provides a good prediction of whether people will keep using your product or service, or whether they might be going to a competitor soon.

What this has to do with digital security? Quite a lot. According to research by Zimmermann Montesdioca and Gastaud Maçada *user dissatisfaction with security practices can be a risk for information systems protection and, ultimately, represents a security threat for organizations.*[20] Or, in other words, since the human factor is the weakest link, security policies are not adhered to which creates a greater risk of an incident.

In addition to that, we believe it's always a good thing to get feedback about the functioning and perception of the security function as a whole to be able to implement security more effectively. With implementation we don't necessarily mean a new organizational structure; this could also mean that communication needs to change, or the security professionals need to show more empathy for the business. We observe that having a meaningful conversation based on the experience substantiated with financial figures helps to improve the overall perceived satisfaction of users and therefore increases your Return on Security Investments.

20 Measuring user satisfaction with information security practices, Gustavo Percio Zimmermann Montesdioca and Antonio Carlos Gastaud Maçada, Elsevier, Computers & Security, Volume 48, February 2015, Pages 267-280

Is Digital Security a market for lemons?

A story on how to make Digital Security even more valuable

Although information security has a long history, it wasn't top of mind of senior management, Board, or other employees until the late 2010s. A "security professional" became a real job, and market demand has grown ever since. Awareness about security risks increased significantly. The thriving forces for this were significant security breaches such as Snowden, NotPetja, and WannaCry shocking the world, but also regulators demanding companies to protect their critical assets, including non-tangible ones such as data. As a result, we can now state it has the Boards attention by default.

Since the number of security specialists, hardware and software technology vendors, and security service providers has increased over the past decade, we have also experienced a significant increase in security spending. These security budgets have become important to the organizations' financial planning cycle. Recent predictions indicate that budgets will continue to grow, and it's not clear where it will end.

We think, however, that at a particular stage, the novelty of digital security will wear off, and budget pressure will increase. We simply cannot try to empty the ocean with a thimble. To prevent this from happening, staff responsible for digital security will have to show the added value of their investments, as well as their own. Just as any other business process or department manager within the company deals with budget pressure daily.

To shed some historical light and background about our reasoning, we first compare digital security with regular IT and the IT department, and what has happened to IT when it cannot show value and is misaligned with the business. After that, we will provide guidance on demonstrating "true" value and making it taste as sweet as *cherries*.

Why the second-hand car market is a lemons market

In the used car market, some dealers sell good cars, and dealers sell bad cars. The exact definition of 'good' and 'bad' doesn't matter in this case because we start from the buyer's perspective. He has an image of a good or bad car. The main problem is that it is unknown to potential buyers in advance which dealer sells good and which dealer sells terrible vehicles. After all, it is often difficult to see that from the outside. And if someone thinks they have bought a good car but it is terrible in practice, the buyer feels cheated. In the US, they speak of a 'lemon'. This uncertainty for the buyer leads to specific considerations and decisions with far-reaching consequences for the entire market, as we will describe in a moment. This negative dynamic is known as the lemon problem. The lemon problem was described in 1970 by the famous economist George Akerlof. In short, the problem boils down to this.

The question now is, what does a potential buyer do in this uncertain situation? Well, the intelligent, rational potential buyer makes a trade-off and is willing, for example, to pay 10,000 euros for a good second-hand car and 2,000 euros for a bad one. But because it has yet to be known which car is good or bad, the potential buyer averages and is willing to pay 6,000 euros. With this price in mind, the potential buyer starts looking.

But what is the consequence of this rational consideration? The lemon dealers are happy to sell at 6,000 euros and make a profit. But the good dealers, let's call these the cherry dealers, need help. They can only sell at a loss. The consequence is that the cherry dealers will disappear or, out of necessity, they will also have to become lemon dealers. Many of you will probably think by now that this is the risk of the buyer and seller because that's how the market works. Right?

However, there is a fundamental problem. Due to the 'lemon problem,' the quality of the entire market is deteriorating. Because not only is a second-hand car now synonymous with poor quality, but the price consumers are willing to pay is also decreasing. After all, 6,000 euros quickly becomes 2,000 euros. This is an annoying dynamic that ultimately leads to market failure. At the heart of the lemon problem is 'information asymmetry,' which leads to a downward spiral that affects the entire market. Here's how this dynamic works. As described, the seller knows

more than the buyer. However, the seller is unwilling or unable to inform the buyer properly, so he cannot make a good trade-off between good and bad products.

This leads to uncertainty and a certain distrust on the part of the buying party. To compensate for this, the buyer is only willing to pay a lower price for the product she wants to buy. As a result, only more inferior quality products are offered and sold because better quality products are made at a loss.

These lesser products then confirm the buyer's distrust – so they have bought a lemon!

As a result, the buyer is only willing to pay an even lower price. This, in turn, is at the expense of the quality of products offered. Etc. With this reasoning, Akerlof demonstrated the importance of information symmetry for a market and was awarded the Nobel Prize[21].

What happened to IT will happen to Digital Security

Business-IT alignment has been an issue since the seventies and is mainly caused by;

- Lack of collaboration,
- Lack of mutual understanding and a
- Lack of tangible added value.

Multiple business and IT alignment models have been introduced to overcome these alignment issues and improve this relationship. Over the last few years, we have also seen multiple 'Value of IT" methods, including ITIL, introduced to focus on showing value to the business. However, these models often focus on the more generic objective value (ROI, KPIs, SLAs) instead of the subjective value (customer satisfaction score and how people perceive and experience IT). Later more about that.

21 This paragraph is based on the book "Discover the IT Cherry", 2016, Butterhoff, Derksen, van der Vlist.

The main reason for this switch from more process-focused to value-focused is the result of Boards and Senior Management starting to ask the question, "What is the value of IT for the money we spend on it?". Maybe this is caused by the experience they had in their personal life during the consumerization of IT. What we mean by that is they experience in their personal life that IT can work smoothly and that iPhones are safe by biometric access, something the IT department never delivered to them. This department of "no" had a sour taste of lemon. But they also experience budget pressure. The main reason for this budget pressure is that budget holders could not judge the value delivered by IT. If you can't understand or see the benefits of something, you start trying to lower your spending on it. They simply squeeze the people who do not deliver or indeed contribute.

Due to the digitalization trend, IT staff shortages and previously COVID19, budget limitations have become less of an issue. One can, however, question whether companies spend their money on digitalization out of fear of being the next Kodak or Nokia or whether they know the digital value they are getting for their money.

Are IT and Digital Security both a Market for lemons?

In the book "Discover the IT Cherry"[22] we compared the 1970 paper "Market for Lemons" of Akerlof and whether IT is a Market for Lemons as well. The paper examines how the quality of goods traded in a market can degrade in the presence of information asymmetry between buyers and sellers, leaving only "lemons" behind[23]. In the table below the Criteria for a lemon market are stated and the parallel with IT organizations is made. The parallel with Digital Security is made based upon our own experience to determine whether Digital Security is also a market for lemons. We consider Digital Security in this case as a whole and not only the security software or services providers.

22 *Mark Butterhoff, Barry Derksen, Aart van der Vlist. "Discovery the IT Cherrry – How to become the most valued IT organization by using cherries", July 2016.*

23 *Akerlof, George A. (1970). "The Market for 'Lemons': Quality Uncertainty and the Market Mechanism". Quarterly Journal of Economics. The MIT Press (see also: https://en.wikipedia.org/wiki/The_Market_for_Lemons)*

#	Criteria for a lemon market	Parallel with IT organizations	Parallel with Digital Security
1	The buyer is unable to fully determine the value and quality of a product before the product is bought. The salesman is aware of this value (asymmetric information).	Business (the consumer) has too little information to determine the actual costs and quality of an IT service. The internal or external IT organization or IT suppliers could or do hold this information. For example, looking at the selection of an outsourcing partner a comparison between suppliers is hard to make and it is unclear what quality is actually given for the paid price.	Business has too little information to determine the actual costs, benefits and quality of digital security. Although the seller market increased significantly, it remains difficult to understand the difference between products and services. Decisions are mainly made based upon "can we afford this?" instead of understanding the benefits or ability to determine the value.
2	The seller is stimulated to disguise a lower-quality product as a higher-quality product.	The uncertainty of the consumer, as a consequence of asymmetric information, often brings IT under the yoke of cost reduction. Often, the forced solution is to deliver lesser quality for a lower price, however this does not meet the expectations of customers. As a consequence, the Lemons Problem continues to grow.	Security providers and security software providers often state that their software or service will solve all the problems and prevent hacks from happening. In practice however software can't meet that expectation, is harder to implement then expected or has unexpected higher costs (e.g. storage costs when using a SIEM). (See also the "Research Report Cybersecurity Technology Efficacy – Is cybersecurity the new "market for lemons"[24])
3	The salesman doesn't have a credible story or technique to represent the high quality of his product.	IT itself is unable to clarify the quality, or added value, of its products and why the price is righteous.	Sales is often done based upon Fear, Uncertainty and Doubt. "If you don't buy my product you'll be hacked". Value delivery based on an outcome or committed SLA is rarely done. Comparison with other products can hardly be made, except for what e.g. Gartner or Forrester state. However, these parties cannot be seen as completely reliable and independent.

24 Research report cybersecurity technology efficacy, Is cybersecurity the new "market for lemons"?, October 2020, Debate Security

#	Criteria for a lemon market	Parallel with IT organizations	Parallel with Digital Security
4	Buyers are pessimistic and suspicious concerning the seller and the quality of his products.	Unfortunately, the IT organization is often known as of poor quality and too expensive. For example, IT knows many cases of absence and projects often turn out to cost more than initially anticipated or fail. Due to this, often IT already has a 1-0 arrear.	Buyers become more pessimistic and suspicious since expectations are often not or partially met. Products can't deliver what was expected or are not fully implemented or used. Also due to the increase in competitors, large discounts are already given with the first offer. Instead of being thankful for this discount, it usually makes buyers suspicious about the real value of the product. Lots of point solutions are perceived as spaghetti only making things worse, let alone hard to rationalize since nobody really understand what they do.
5	There are no effective public supervision or general guidelines for consumers to guarantee quality standards.	There is no guideline for business to control the quality of IT. The frequently chosen guidelines (CMMi, ITIL, COBIT, etc) are internal IT standards, which, however, poorly correspond to the business experience. The supervision that does exist is focused on internal control and not on quality for customers	Certain sectors (e.g. financials), and even countries, are regulated and supervised which leads to an increase of the digital security maturity. In most sectors and countries there is however no effective public supervision or guideline for business to control the quality of digital security. A general HACCP[25] norm for security providers is highly desirable. Simple stated; if you don't comply you are not allowed to operate, similar like restaurants, lawyers, airlines, hospitals etc. There are means such as ISO27001 certification or a SOC2 report, but ISO27001 certified parties are also hacked (e.g. Kaseya, ID-Ware) and SOC2 often focuses insufficiently on digital security and provides only limited security. The European NIS imposes more legal requirements, but supervision remains limited until now.

25 HACCP is a management system in which food safety is addressed through the analysis and control of biological, chemical, and physical hazards from raw material production, procurement and handling, to manufacturing, distribution and consumption of the finished product.

To be ahead of the game, start showing the value of Digital Security

The current situation can't last forever. At a certain stage, a company wants to have a sufficient level of security and wants to focus its attention and spending on things that generate revenue or contribute to business goals. More and more questions will be asked about why certain investments in Digital Security must be made and whether security budgets can decrease. This will be the case when security incidents will not occur or will have limited impact. When a board's mindset is "assume the breach," the focus is on reducing the blast radius rather than reducing all the blast. That is simply throwing money down the drain. To precede this budget pressure, Digital Security professionals, Tech vendors and Suppliers should now start showing their value.

Showing the value of Digital Security might be more difficult than one thinks. The value of Digital Security is more than reporting the number of vulnerabilities found and remediated, the number of security incidents resolved, the number of people trained in awareness training, or the number of auditor findings resolved. To understand the value, it is good start to with a definition of value:

Value concerns the relationship between benefits and costs. Value can be measured partially objectively and partially subjectively (perception) and can depend on a group or even an individual[26].

The above definition shows that digital security value is more than just reporting objective numbers about security occurrences. Based on this definition we can divide the value in four areas of attention:

Objective Measurement

This way of showing value is the way most of us learn in management schools via business cases etc. A good way to measure Digital Security value objectively is using ROSI (Return on Security Investment) (see also Chapter 5 for more information on ROSI and business cases).

26 *Mark Butterhoff, Barry Derksen, Aart van der Vlist. "Discover the IT Cherry – How to become the most valued IT organization by using cherries"*

An easy way to increase or keep the same level of benefits but lower the costs is to start using the software and licenses to the fullest instead of buying additional software that provides the functionality you might already have. We refer to the term technology utilization. During operations it is a good practice to measure the security occurrences and show the impact of newly implemented security measures. Make reporting about benefits and cost effectiveness as a part of your daily routine, just as every other manager or director in the company is doing.

Subjective Measurement

Subjective value is all about the perception of the person or group experiencing the security measures or level of security. In this case, it becomes important to start managing people's perceptions. The perception can be for example, "we're way to secure and not a bank!", "we're completely unsecure" or "security makes my work so much more inefficient, can't we shut this down?".

To manage the perception of the security users and stakeholders (e.g. Board, Regulators) we need to understand what their current perception is as well as what their expectation is, since perception is the result of expectation. A well-known rule to manage expectations:

- When you deliver *under expectation*, people are unhappy and want to stop using what you're "selling".
- When you deliver *according to expectation*, people are satisfied but are also still open to other opportunities.
- When you deliver *above expectations* people are happy and become loyal ambassadors.

The best trick to make people happy is then, of course, to make sure that the expectations are as low as possible or be an absolute overachiever.

Value for the Group

Value for the Group is often shown in standard reports made by suppliers or in publicly available information. In general, this covers the basic need and is something that is according to expec-

tation. A well-known example in IT is a Service Level Report and Digital Security reports that show how many security incidents have occurred, how many phish have been stopped, and how many people have been trained. However, the real value is in the value for the individual.

Value for the Individual

Value for the individual is often measured with Customer Satisfaction Scores. You might recognize them from your personal life when you order something online and a week after the delivery you are asked about how happy you are with the product or the service, often based upon a score from 1 to 10 or with a smiley face. In some cases, there is also room for a comment.

In Digital Security we haven't seen this way of measuring value yet. Within IT we do see Customer Satisfaction scores, but a follow-up of these scores is often limited. In our experience, spending some time following up on this valuable feedback often results in an "above expectation" experience. So, customer satisfaction scores can be a valuable instrument for understanding your users' and stakeholders' perceptions of digital security.

Next to customer satisfaction scores, we love the empathy factor; this is about understanding the people who have and hold the budgets. Understanding what these people find important in Digital Security is to be able to manage their perceptions or expectations. An article by Gartner about "Beyond individual passions and concerns", boards collectively generally care about three things:

- *Revenue/mission*: Operating or nonoperating income and enhancing nonrevenue mission objectives
- *Cost*: Future cost avoidance and immediate decrease in operating expenses
- *Risk*: Financial, market, regulatory compliance and security, innovation, brand, and reputation[27]"

27 *https://www.gartner.com/smarterwithgartner/5-security-questions-board-will-definitely-ask/*

These three things are generic statements. So, as a Tech leader, Digital Security professional, or/CISO, understanding the budget-holder's needs, agenda, desires, and what's important to them, understanding what's essential for the company, understanding the strategy and mission, etc, is very important. Demonstrate sincere empathy.

Showing Value is not a step-by-step roadmap

The hard part about value is the subjective part for the individual. What's essential for one person might not be necessary to someone else. As a result, decisions are not always made based on rationality. When people don't understand, trust, or like you or the idea, they tend to decide to go in a different direction, which will leave you in confusion. One thing that can support you in these irrational processes is the use of collaborative technologies that facilitate interaction between business and professionals in specific domains (e.g., business or security), like Group Support Systems[28] or 'brown paper' exercise that can facilitate interaction between the different departments and stakeholders, in which you can brainstorm collectively on viewpoints, opinions and novelties. Then, categorize them into what is essential to a particular group or individual. Make the opinions of the group more tangible, clarify them and collectively discuss them and deal with them more rationally. In the end, however, you still need to understand the "environment" since not every organization has the same context and experiment a bit with what is valuable for the different stakeholders.

For example, start measuring customer satisfaction scores about a specific security solution or experiment with ROSI on individual investment scenarios or a complete portfolio, demonstrating the actual value of investments. Asking for the help of somebody outside of IT helps you understand the opposite position and cross the gap between IT & Digital security in the business. All of this is to prepare our profession for the coming years.

28 *Bobbert & Mulder (2016) on GSS in Digital Security in ISACA Journal (https://www.isaca.org/resources/isaca-journal/issues/2016/volume-5/boardroom-dynamics-group-support-for-the-boards-involvement-in-a-smart-security-decision-making-proce)*

Interlude 2: The ethics & economics of cyber risk

With regard to privacy, regulators are licensed to impose fines on underperformers. Shouldn't that also be the case with cyber risk in general? Somehow the ethics and economics of cyber risk follow a different path. The regulatory imperative that acts as an incentive for improvement in many sectors, seems to be non-existent when it comes to cyber risk. One might say that we need more incentives for maturing analysis of cyber risk. Initiatives in that area can come from governments or can be triggered by public opinion.

One encouraging initiative is that of CyberGreen.[29] This global community measures cyber health and makes a serious effort to improve it. CyberGreen shows which countries cause the biggest pollution – botnets and the spreading of viruses – on the internet. Countries that actively participate in hack prosecutions and cooperate on other cyber-risk initiatives get better scores. Their website shows an index that indicates how countries perform. The goal is to come to joint agreements. Just like the CERT-initiatives in insurance banking and healthcare, CyberGreen is a nonprofit organization.

Being a collaborative organization, their mandate and their means of persuasion are limited. Nevertheless, it can influence public opinion and that is likely to stimulate governments to take action to improve the rating of their country.

The impact of an incident can generate negative publicity, direct and indirect damage, or a fine from a regulator. A major lesson from practical examples so far is don't try to cover up. An organization that doesn't come clean to the outside world after an attack may see the confidence of shareholders and customers evaporate in an instant. Think of what happened to Equifax. Somehow the idea is still out there that your reputation will suffer if you have to admit that your company has been attacked. The fact that you have been hacked

29 www.cybergreen.net

is no indication of the quality of your security. Companies such as Gemalto and ASML immediately came forward about what had happened, who was behind the attack, and explained that things were under control again. If you can do that, you can demonstrate both good leadership and effective security.

The incentive for leading companies to become CyberGreen is obvious. But how do you motivate small and medium-sized businesses? Financial incentives still have the most effect. So why not incentivize organizations to improve their cyber-risk efforts through tax reduction. A government could impose a cybertax, which can vary according to the cyber-risk performance of a company.

Governments could perhaps get a reduction on their NATO contribution or their EU membership contribution (for European countries) or on any other international fee, depending on their CyberGreen rating. As always, this requires leadership and vision.

Are there perhaps smarter ways to invest our money via tax reduction?

The government invests millions in the growth of our cyber security sector. Multi-millions of euros go to research and development of techniques and methods to make the Netherlands more resilient to the risks of cyber-attacks. The question then arises whether sufficient techniques and methods have not yet been developed. According to Potomacs' cyber report on the Netherlands [30] we have many initiatives but little leadership, coordination, or aligned benefits. So why not spend our government money the other way around on rewarding companies that use the existing methods and techniques? This would de-

30 *The Potomac Institute for Policy Studies is an independent, nonpartisan, not-for-profit, science and technology (S&T) policy research institute. https://www.potomacinstitute.org/academic-centers/cyber-readiness-index and publishes their view on Dutch initiatives on: https://www.thehaguesecuritydelta.com/media/com_hsd/report/139/document/CRI-Netherlands-Profile-PIPS.pdf*

monstrably make the Dutch economy more resilient to risks and give the economy a boost. Two birds with one stone.

Businesses are currently insufficiently able to protect themselves properly against cyber influences. The question therefore arises as to whether the proposed millions poured in research is the right form of financing to help the Netherlands cope with the cyber crisis? Should we not work in the food processing chain like in the 70s with a HACCP-like standard for "cyber-resilience"? Wearing this standard could give certain privileges. For example, only give an organization a Chamber of Commerce registration or corporate financing if it meets a cyber-resilience level or standard: a quality mark. This cyber "due diligence" would cause more than 60% of Dutch companies to fail at their first exam and thus be "out of business."

Greater resilience is needed to better protect our economy and to grow at the same time. Investing in even more new methods and techniques therefore doesn't seem to be a solution. The solution should rather be sought in the direction that companies are rewarded that increase this level of resilience. We may have to opt for tax cuts for companies that are demonstrably making progress in their cyber-resilience. After all, these companies make less use of our judicial system. As a result, the €50 million in extra spending on a "cyber army" could perhaps also be used for tax deduction schemes.

Reward organizations, such as municipalities, that are struggling with the implementation of government policy for cybersecurity (for example, the mandatory DigID audits in the Netherlands[31]) while their government funds are cut back. Reward these municipalities, instead of punishing them by closing down their digital citizen services. Reward Dutch companies that actively share experiences and knowledge with other companies about incidents, attacks, and hacks and what they have done about them. Promote whistleblowers

31 The Central identification and Authentication system for the Dutch Government

and consider the role of insurers. Can digital security become part of insurance agreements in which organizations and companies are encouraged to take preventive measures? Could economic incentives be built in to influence laconic and irresponsible behavior? For years there have been organizations and institutions that make the resilience of organizations measurable and thus demonstrably increase. Why does the government not link a reward mechanism to the improvement of a demonstrable increase in resilience? For example, a tax reduction or advance deduction. In order to strengthen the motto “the government can’t do it on its own” based on entrepreneurship. Allowing tax money to circulate, from the government to companies and vice-versa, in rewarding organizations. All this instead of (over) regulation and more cyber agents who tell corporate Netherlands how to do it. And write big research reports and policies that are rarely read and are prone to become outdated due to the swift changes in the cyber world.

Key takeaway messages on funding

As you've learned in this section, funding your digital security strategy and plan is more than just asking for money. It's about being smart with what you already have and showing the value of potential investments. We offer the following takeaway messages:

1. Make a cost-benefit analysis of "risks and investments," but never forget to "fix" problems and show results. The best way to add value is to show what you've fixed.
2. Start doing less and prioritize on returns on investment. The best way to "eat an elephant" is in small pieces.
3. Demystify the jargon. Present your business case in the language of the target audience.
4. Question your CI(S)O on extra use of installed SecTech. Many of the security features are already part of the technology that you have. Using those capabilities can be much cheaper than buying additional software that does the same job. This way you can keep that budget request for the things that are really necessary.

“Innovation distinguishes between a leader and a follower.”

Steve Jobs

06

Trending

The author of this chapter is Prof. Barry Derksen

Looking at trends up to 2100

In this chapter we discuss the topic of trends in Digital and the associated security. Different views on the effects of technology developments and their effects on security are also discussed. Will these trends affect security initiatives? Is security possible when trends such as quantum computing become business as usual. How do you protect yourself from smart dust (tiny microelectromechanical systems (MEMS) such as sensors, robots, or other devices, that can detect, for example, light, temperature, vibration, magnetism, or chemicals).[1] Begin with the end in mind[2] is habit two according to Steven R Covey in his book on good leadership. This means to begin each day, task, or project with a clear vision of your desired direction and destination, and then continue by flexing your proactive muscles to make sure things happen. In this chapter we begin from the vantage point of 2120 and then look back at today. It is not our intention to be very precise and accurate on our ideas but mainly want to provide a window toward the future.

Artificial Intelligence, just a hundred years from now

In 2120 human brains will not be separate entities but will often be merged with AI, greatly extending human capabilities. Although it's to be expected that some people will reject the merging of humans with AI, (almost) virtual and robotic employees will be common within enterprises, government, the army, and industry. According to Futuretimeline.net it's ubiquitous, large-scale automation that will lead to vast swathes of human employees being replaced by robots.

1 *https://en.wikipedia.org/wiki/Smartdust*

2 *Stephen R. Covey, 7 Habits of Highly Effective People*

In 1956 the computer scientist John McCarthy defined Artificial Intelligence as 'the science and engineering of making intelligent machines'.[3] Almost seventy years later the field of AI has grown immensely. Chen and others[4] introduced an artificial intelligence techniques overview (see Figure 13). They concluded that AI techniques are increasingly being used to replace classical techniques. A few methods that are being used are:

- Case-based reasoning, a kind of analogical reasoning that focuses on reasoning based on previous experience.[5]
- Rule-based systems: systems that automate problem-solving know-how, providing a means for capturing and refining human expertise.
- Artificial neural networks are physically cellular systems which can acquire, store and use experimental knowledge.[6]
- Fuzzy models, mathematical means of representing vagueness. Fuzzy sets are a generalization of conventional set theory that's used as a mathematical way to represent imprecision.[7]
- Genetic algorithms are probabilistic search procedures designed to work on large spaces involving states that can be represented by strings.[8]
- Swarm intelligence, using the basic rules for collective behavior of a group of animals, such as ants, termites, or bees.

3 *John McCarthy, 'What is Artificial Intelligence', Stanford University, January 1998.*

4 *Serena H. Chen, Anthony, J. Jakeman, John P. Norton, ' Artificial Intelligence techniques: An introduction to their use for modeling environmental systems', Mathematics and computers in simulation, July 2008.*

5 *Janet L. Kolodner, 'Instructional Design: Case-Based Reasoning', Georgia Institute of Technology*

6 *Jacek M. Zurada, 'Introduction to Artificial Neural Systems', West Publishing company, 1992.*

7 *James C. Bezdek,'Fuzzy Models-What are they, and Why?', IEEE Transactions on Fuzzy Systems-March 1993.*

8 *D.E. Goldberg, J.H. Holland, 'Genetic Algorithms and Machine Learning', Machine Learning, 1988.*

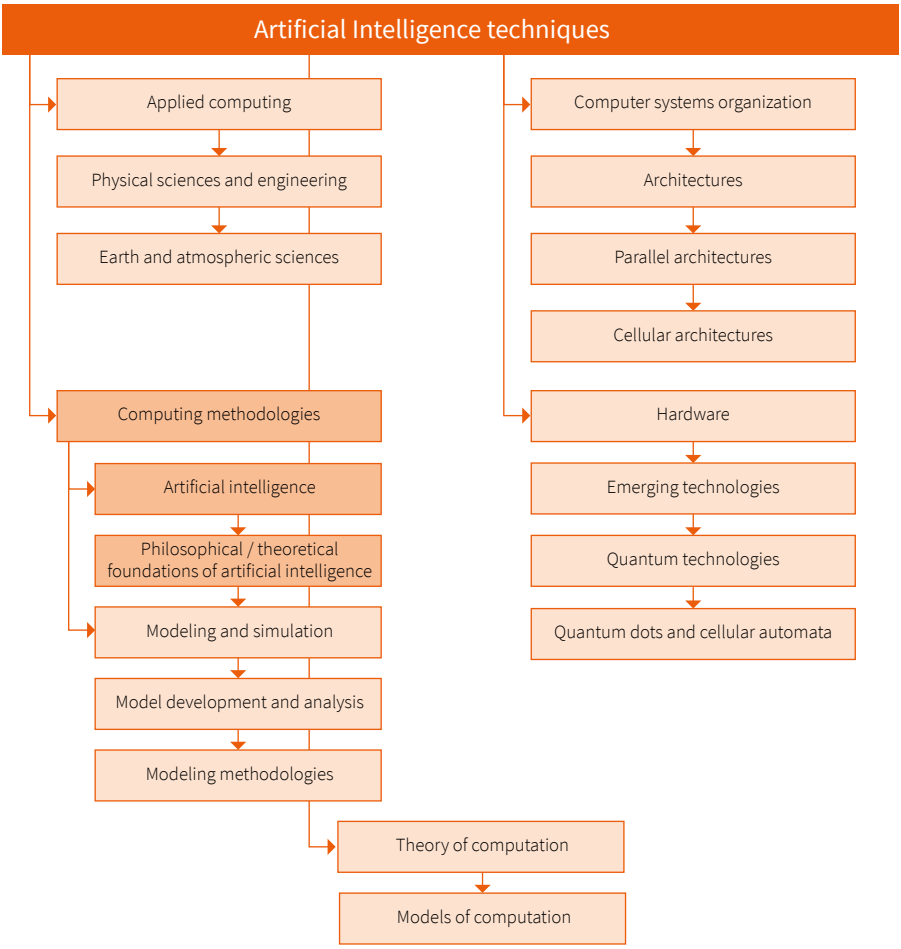


Figure 15: Artificial intelligence techniques (source: Chen and others).[9]

9 *Serena H. Chen, Anthony, J. Jakeman, John P. Norton, ' Artificial Intelligence techniques: An introduction to their use for modeling environmental systems', Mathematics and computers in simulation, July 2008.*

In figure 13 several techniques of artificial intelligence are displayed. In order to reach expectations in 2120 these techniques need to evolve.

Observation: AI techniques need to evolve to merge AI with humans.

According to Ray Kurzwell,[10] by 2120 humans will have already been using AI to expand brain capacity for over 50 years, so the expansion will be huge and humanity will have started to expand beyond the solar system.

Observation: Humans will merge with AI and reach an extreme level of intelligence.

There are expectations that AI will have full human-level capabilities somewhere around 2030, based on the Turing test.[11] The capabilities of IT will then already be superior in terms of sharing knowledge. Based on these forecasts it's almost inevitable that humans and computers will merge.

Observation: Without merging AI with human brains, we can't keep up with AI.

Currently technology is not even close to this, but considering the speed of technology enhancement, it is almost possible to mathematically predict when it will be happening. Experts stated that human-like AI will emerge in 5 to 10 years.[12] The respondents agreed that AI will have a great impact. Five sectors will be impacted most:

- Healthcare.
- Logistics.
- Customer Service.
- Banking & Finance.
- Agriculture, software development, and manufacturing.

10 Lomas, 'As good as the Human brain', ZDNet, March 2010

11 Turing Test, Alan Turing, 1936

12 Survey at Joint Multi Conference on Human Level Artificial Intelligence, August 2018.

Currently researchers aim to apply AI and machine learning methods to get cybersecurity to a higher level.[13] Yampolskiy[14] states: "For narrow AIs safety failures are at the same, moderate, level of criticality as in cybersecurity; however, for general AI, failures have a fundamentally different impact. A single failure of a super-intelligent system may cause a catastrophic event without a chance for recovery. The goal of cybersecurity is to reduce the number of successful attacks on the system; the goal of AI Safety is to make sure zero attacks succeed in bypassing the safety mechanisms." Unfortunately, such a level of performance is unachievable. Every security system will eventually fail; there is no such thing as a 100% secure system.

In the near future it's to be expected that new and specific AI techniques will be developed using knowledge-based systems, probabilistic reasoning and Bayesian updating to achieve higher levels of security. But while security will invest in these possibilities, so too will hackers use AI as weapon.

According to Legrand:[15] "AI is a double-edged sword that can be used as a security solution or as a weapon by hackers. AI involves developing programs and systems capable of exhibiting traits associated with human behaviors. These characteristics include the ability to adapt to a particular environment or to intelligently respond to a situation. AI technologies have been applied extensively in cybersecurity solutions, but hackers are also leveraging them to develop intelligent malware programs and execute stealth attacks."

Observation: AI is a new tool for cybersecurity as well as for hackers.

AI is a game-changer in the use of technology but not with regard to the battle between hackers and cybersecurity professionals. Hackers have already started to use AI to accelerate malware, causing code to constantly change and making it almost impossible for it to be detected by detection engines.

13 *Samuel Greengard, Cybersecurity gets smart, Communications of the ACM, April 2016.*

14 *Roman V. Yampolskiy, M.S. Spellchecker, 'Artificial Intelligence Safety and Cybersecurity: a Timeline of AI Failures,' Computer Science, October 2016.*

15 *Julien Legrand, Artificial Intelligence as Security Solution and Weaponization by Hackers,' CISO MAG, December 2019.*

Observation: If a tech leader doesn't invest in AI for cybersecurity…the hacker will.

AI is currently being used in many areas in order to improve processes and technologies. The examples below address Natural Language Generation, Biometrics, Semantic technology, Machine Learning platforms, and Robotic process automation.

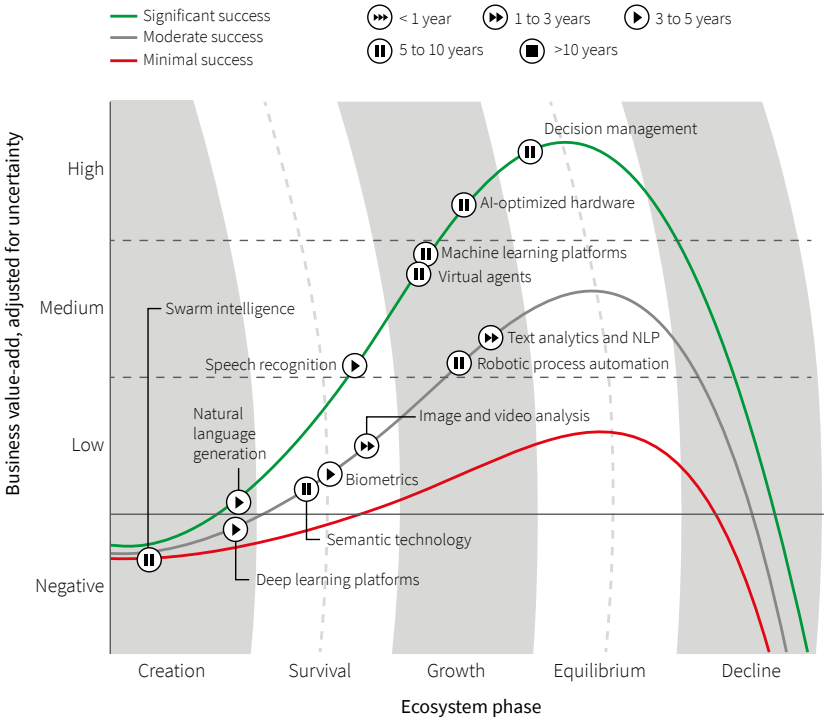


Figure 16: Business value and success rate of AI adoption (source: educba.com).

AI subject	Cybersecurity	Hacker's case	Expectation
Current developments in AI			
Natural Language Generation	Protect classified meetings Complex addition on information assets Complex management of confidential and integrity	Stealing voice recognition Gaining classified information Gaining voice-driven access	Security area within 5 years
Virtual Agents / Chatbot	Chatbot rules assurance Decision tree assurance	Chatbot adjustment Decision tree hacks	Security area within 5-10 years
Machine Learning	Training data assurance Rules based reasoning assurance	Adjust training data Adjust rule-based reasoning	Security area within 5-10 years
Decision management	Decision calculation rules assurance Dashboard confidentiality & integrity assurance	Influencing decision calculation	Security area within 5-10 years
Biometrics	Protecting privacy Managing the correct biometric results	Stealing biometric information Using biometric information	Security area within 5 years
Robotic process automation	Protecting robotic process automation	Changing / (mis) using robotic process automation	Security area within 5-10 years
Cyber-defense	Use of cyber-defense and protecting the algorithms / recognizing patterns of attack	Using AI to observe patterns in data and disrupting the patterns	Security area within 5 years
In 2100			
Surgical robots	Protecting the goal and way of working of surgical robots	Threatening the use of surgical robots	Security area within 50 years
Industrial, domestic, army, service, and other robots	Protecting goal and way of working of these robots	Using robots for different goals	Security area within 50 years
AI/humans merge	Protecting the AI rules and use for humans	Hacking humans	Security area within 60 years

Moving forward to 2120, cybersecurity specialists will need to start weaponizing AI. They can use exploit kits with AI to detect user environment and deliver specific and targeted exploits and use AI machine learning to evade detection.

For security professionals, using AI is a two-part challenge. It's basically about protecting companies' AI initiatives and using the potential of AI to protect digital assets. Today the main questions should be:

- How are we protecting our AI-based services, products, and tools?
- Are AI tools tested?
- How is training data managed for confidentiality and integrity?
- How are the rules and algorithms protected?
- Is a control procedure in place for abnormally behavior by AI programs?
- Are governance and policies updated for AI activities and security elements?
- Is cybersecurity aligned to include AI protection, organization, process, policies, and technologies?

2100 Nanofabricators, advanced 3D printing and molecular assemblers

Futuretimeline.net expects that people will work less than twenty hours per week in 2100. A global cultural shift will take place to focus on creativity and intellectual challenges. The technical revolutions will have created the possibility to reduce working hours and working will become a choice instead of a need. Nanofabricators, advanced 3D printing, and molecular assemblers are trends that will support these expectations.

According to Dvorsky[16] many humans will choose a complete digital existence, getting rid of current biological constraints by uploading minds in which every cognitive detail down to the molecular level and including personality, memories and associations can be digitalized. From a security perspective, brain hacking will become a reality.

A bit more imaginable will be the possibility of brain-linked virtual reality. Kurzweil[17] describes this as "*I see this starting with nanobots in our bodies and brains. The nanobots will keep us healthy, provide full-immersion virtual reality from within the nervous system, provide direct brain-to-brain communication over the internet, and otherwise greatly expand human intel-*

16 *George Dvorsky, '10 Ludicrously Advanced Technologies We Can expect by the year 2100', 11/11/2016.*
17 *Ray Kurzweil, ' The Singularity is Near: When Humans Transcend Biology', September 2006.*

ligence. But keep in mind that nonbiological intelligence is doubling in capability each year, whereas our biological intelligence is essentially fixed in capacity. As we get to the 2030s, the nonbiological portion of our intelligence will predominate."

In a brain-linked virtual reality the challenge will be to make it as real as possible. But, if we can believe Morpheus in The Matrix, real is simply electrical signals interpreted by your brain. Having said that, securing those electrical signals might be a challenge.

An important element in realizing brain-linked virtual reality is the realization of nanofabrication in order to make electrical signals that are interpreted by the brain. Nanofabrication is the design and manufacture of sensors, computers, and other devices with dimensions measured in nanometers (a millionth of a millimeter). According to Sarangan[18] there is no single accepted definition of nanofabrication, nor a definition of what separates nanofabrication from microfabrication. Nanofabrication represents the future of current technology. It will enable the design and fabrication of functional nanomaterials, providing huge possibilities for using existing and future technologies at a larger scale.

In the decades to come nanofabrication will encounter the following challenges:

- Assessing environmental, ethical, human, and social impacts.
- Developing production techniques that make nanofabrication economic and viable.
- Controlling the needed precision in creating and assembling nanostructures.[19]
- Testing reliability and establishing methods and techniques for detection and defect control.[20]
- Lifecycle management of high-volume production of nanoscale properties and quality of nanofabrication.[21]

18 A. Sarangan, 'Fundamentals and applications of Nanophotonics', 2016.

19 Ahmed Busnaina, 'Nanomanufacturing Handbook' , Boca Raton: CRC press, 2007

20 Ahmed Busnaina, 'Nanomanufacturing Handbook' , Boca Raton: CRC press, 2007

21 NSI, 'Sustainable Nanomanufacturing – Creating the industries of the future I Nano, www.nano.gov., 2016.

Secondly enhanced 3D printing will enable molecular assembly. The 3D printing market is expected to be to a $35.6 billion industry by 2024 according to Wohlers Report.[22] Industries such as homebuilding, car-making, aerospace manufacturing, and footwear are investing heavily in 3D printing. In 2020 the homebuilding industry constructed a proof-of-concept prototype house using a 3D printer and needed less than 24 hours to print the house for less than $4,000.

According to Zhou[23], 3D printing is a process for producing objects by adding selected materials together, where necessary following digital three-dimensional model guidance. This new way of printing will provide numerous possibilities through its ability to construct complex structures which were not possible in previous assembly methods. A number of advantages of 3D printing are[24]:

- Drug development; 3D printing makes it possible to manufacture certain medicines cheaper and quicker.
- Local production: currently many products are produced offshore. 3D printing supports localized production as well printing on demand.
- Creating structures which were not possible before.
- Improving fuel efficiency.
- Reducing weight; 3D printing is able to reduce weights of components by 40-80%.
- Cutting cost; 3D printing can reduce labor costs.

Observation: 3D printing can shift production from low-cost countries to everywhere (local).

But what will 3D printing be in 2090? In the Gartner Hype Cycle For Emerging Technologies (2014), 3D printing was at the stage of 'Slope of Enlightenment'. In the Gartner Hype Cycle For Emerging Technologies (2019), Nanoscale 3D printing systems are at the stage of Innovation Trigger with the expectation of reaching a plateau over 10 years.

22 *TJ McCue, 'Significant 3D printing forecast surges to @35.6 Billion, Forbes, March 27th, 2019.*

23 *Huan Zhou, Sarit B. Bhaduri, 'Biomaterials in Translational Medicine', 2019.*

24 *Heleana Neil, 'The importance and potential of 3D Printing', Fabbaloo – 3D printing news, 21st August 2019.*

Although 3D printing is being used within major enterprises, the plateau of productivity has not yet been reached. 3D printing can change almost all industries, starting with traditional manufacturing, supply chain management, and logistics.

According to Simanovsky[25] the following timeline applies to 3D printing:

- 2030, the service supply chain will be disrupted. Spare parts will be printed just in time and have a huge impact on warehousing and transportation.
- 2040, most of our gadgets will be printed to order. This will be done locally, so local printshops will return. The mobile phone will not be printed (it will already be integrated with your physiology).
- 2045, drugs will also be printed at local pharma shops and these drugs will match individual needs.
- 2055, (vegan) food will be printed locally. Overweight will disappear while the printed food will match your health and bodily needs.
- 2060, all body parts will be printed and replaced using 3D printing.
- 2080, just 11 years before SpaceX's roadster has a close encounter with earth[26] and Mars expeditions are already possible, the first people will have 3D printed radiation shields and breathing systems without oxygen.
- 2090, molecular assemblers are the biggest competitor of 3D printing.

Considering the potential of 3D printing and its impact on industries, it's obvious that 3D printing and the objects manufactured need to be secure. Although localized printers are available around the world, the printers will be similar in software and attributes. This makes 3D printers vulnerable to cyber-attacks, both when standalone and in configurations. 3D printers are IT controlled and therefore cybersecurity experts need to address vulnerabilities in the decades to come.

25 G. Simanovsky, 'How advanced will 3D printing be in 100 years?' Quora, 2016.

26 W. Harwood, 'Elon Musk's Tesla will have a close encounter with Earth in 2091', Spaceflight Now, February 14, 2018.

Observation: 3D printers are computer-controlled and therefore vulnerable to cyber-attacks.
All embedded computers can have vulnerabilities. In 2018 popular household 3D printers were vulnerable to a buffer overflow[27]. With this vulnerability hackers could 'upload' crafted instructions / files to the printer and be able to install adjusted code, making printers act as elements in a hacker's network or even print products that were never intended. 3D printers are computer-controlled and run software, so they are vulnerable to security issues. It's just a matter of time before cyber attackers exploit these vulnerabilities. To mitigate this risk 3D printer vendors need to adopt secure coding and make devices secure by design.

If we take a closer look at the context of a single 3D printer, the system model provided by Bayens[28] can be used, see Figure 15.

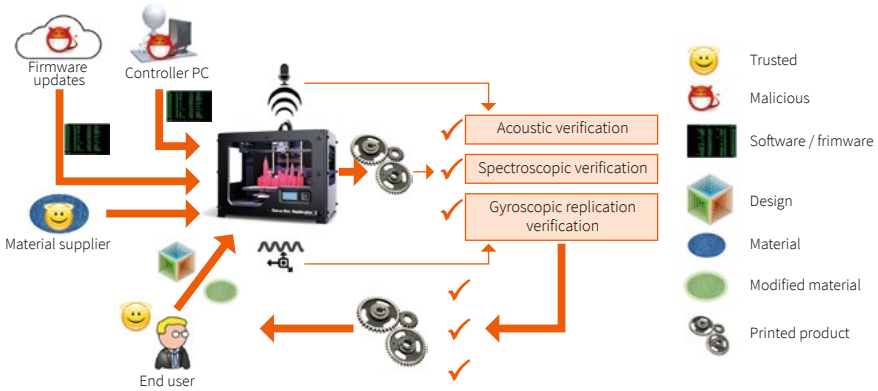


Figure 17: System model 3D printing (source Bayens).

As shown in the system model for 3D printing the possibilities for malicious code are obtained from firmware updates and controller PCs. Vulnerabilities in both can be exploited. Bayens suggests three main verification steps in order to test whether vulnerabilities have been exploited: acoustic verification, spectroscopic verification, and gyroscopic replication verification.

27 *National Vulnerability Database, ' CVE-2018-1000537, Marlin Firmware Buffer Overflow vulnerability', 2018.*

28 *C. Bayens, e.o. ' See no evil, hear no evil, feel no evil, print no evil? Malicious Fill Pattern detection in additive manufacturing', Usenix security symposium, august 2017.*

According to Bayens the first two layers are achieved through acoustic side-channel analysis and spatial sensing, which analyze the sound and physical position of printing components, respectively. The third layer is that of materials verification in which imaging techniques are used to verify that the print is made from the correct material and printed correctly.

Needed? Already in 2016 hackers demonstrated[29] that malicious code was installed in a 3D printer used for a drone's propeller. The propeller looked perfect, but microscopic weaknesses guaranteed failure of the drone.

Another tech trend: the molecular assembler. The basic idea is simple according to Drexler[30]: "*where chemists mix molecules in solution, allowing them to wander and bump together at random, molecular assemblers will instead position molecules, bring them together to the specific location at the desired time. Letting molecules bump at random leads to unwanted reactions-a problem that grows worse as products get larger. By holding and positioning molecules, assemblers will control how the molecules react, building up complex structures with atomically precise control.*"

In 2100 molecular assemblers will create new possibilities in chemistry, biology, engineering, and applied physics. Structures will be built at larger scale and will be both stronger and more capable. Robots will be more human-like in all senses. Machines will be able to self-replicate. Already in 1986 a vision for molecular assemblers was written down by Drexler.[31] The molecular assembler will be the ultimate recycling machine.

Drexler's vision for the future is that molecular will be able to:

- Take apart feces and urine and reconstruct them into edible steaks.
- Capture carbon dioxide from the atmosphere, and use the atoms to create usable plastic or even oil.

29 P. Sneiderman, 'Johns Hopkins team makes hobby drones crash to expose design flaws,' Johns Hopkins, June 2016.

30 E. Drexler, 'The future of nanotechnology: molecular manufacturing,' April 2003.

31 E.K. Drexler, ' Engines of Creation', 1986

- Create sheets of perfect diamond (one of the simplest structures in nature).
- Create all forms of medication, in everyone's home.

According to Burke[32] the nanofabricator will be realized in 2042. Then systems as we now know them will no longer exists. Basically, nanofabricator and molecular assemblers will change the way we currently look at and solve problems.

AI subject	Cybersecurity	Hacker's case	Expectation
Current vulnerabilities in 3D printing			
Vulnerability management embedded software	Protecting embedded software by secure coding	Stealing 3D designs, install hostile software Malicious prints	Current security area
Expose flaws[33] including admin access	Protecting embedded software by secure coding	Stealing 3D designs, install hostile software Malicious prints	Current security area
Poisoned print files[34]	Protecting embedded software by secure coding	Stealing 3D designs, install hostile software Malicious prints	Current security area
Infiltrating digital blueprints	Protecting embedded software by securely coding Bayens' three- layer verification	Stealing 3D designs, install hostile software Malicious prints	Current security area
Carders (is a type of cybercriminal that focuses on credit card fraud)	Prevent easy copying a device that pops onto an ATM card reader or the card itself	Printing skimmers printing fake copies of cards	Current security area
In 2100			
Nanofabricator	Protecting embedded software by secure coding	Sensor manipulation	Security area within 30 years
Molecular assembler	Preventing & detecting molecular poisoning	Molecular poisoning, adding poisoned molecules	Security area within 30 years

32 *J. Burke, 'I've seen the future', September 213.*

33 *Octoprint, 'Security vulnerability: Update to 1.3.6 ASAP!', March 2018*

34 *C. Bayens, e.o. ' See no evil, hear no evil, feel no evil, print no evil? Malicious Fill Patterns detection in additive manufacturing', Usenix security symposium, august 2017.*

2090 Carbon energy is dead & cars will fly

Electricity is an important element of any technical or IT component. Already in 2750 BCE Ancient Egyptian texts[35] revealed an awareness of electricity. But extensive research was done in the 18th century by Benjamin Franklin.[36] He is known for attaching a metal key to the bottom of a moistened kite string and flying the kite in a storm- threatened sky. The spark proved that lightning is electrical in nature. In the late 19th century great progress was made in electrical engineering and today electricity is an essential part of our life. As electricity is part of the critical infrastructure of today's and the future economy, securing this critical infrastructure is of the utmost importance.

Today electricity comes from both carbon as well as sustainable sources (e.g. solar energy). Currently turning electrical power into gas in order to reduce dependency on carbon gas is being researched. Power to gas is described by using electricity to split water into its components of hydrogen (H_2) and Oxygen (O_2) using electrolysis. The H_2 part, which is produced reacts with oxygen to produce methane, which is the main component in natural gas. The natural gas can then be used for generating heat in houses.

Humans are fossil fuel addicted in the current era[37]. Huge amounts of fossil energy such as oil, gas, and coal are used; nearly 15 billion metric tons of fossil fuels are consumed every year[38]. In 2090 the use of these fossil energy is to be expected to stop. Frederica[39] wrote that solutions already exist referring to reports by McKinsey[40]. Frederica wrote: "*These reports indicate that the cost of acting now to make power generation, transport, buildings, and appliances more efficient and to invest in alternative fuels and technologies would be minimal compared with the cost of doing nothing. The benefits of reducing air pollution and global warming would offset a*

35 *Moller, Peter; Kramer, Bernd (December 1991), "Review: Electric Fish," BioScience, American Institute of Biological Sciences.*

36 *Srodes, James (2002), Franklin: The Essential Founding Father, Regnery Publishing.*

37 *Frederica P. Perara, 'Children are likely to suffer most from our fossil fuel addiction, 1 August 2008, Environmental Health Perspectives.*

38 *World Resources Institute, ' Which countries use the most fossil fuels?', May 3rd, 2019.*

39 *Frederica P. Perara, 'Children are likely to suffer most from our fossil fuel addiction, 1 August 2008, Environmental Health Perspectives.*

40 *McKinsey CA. 2007. 'Reducing U.S. Greenhouse Gas Emissions: How much at what cost? Greenhouse Gas Report', 2007.*

substantial fraction of mitigation costs. These benefits include the individual and societal benefits of health and security extending multigenerationally and the monetary savings from fewer cases of children with asthma, developmental delay, cancer, heat stroke, drowning, malnutrition, diarrhea, allergies, and infectious disease."

Interestingly it has been technology inventors such as Elon Musk[41] who contribute to a carbon-energy-free world. Musk has revealed a 'top secret' plan to power the planet, which consists of the following six points:

- Doubling power points for Electric Vehicles (EVs).
- Gigafactories and their batteries will pave the way for powering the future.
- 100 Tesla gigafactories could power the entire world with sustainable energy.
- Build the world's largest virtual power plant (with solar panels and Tesla batteries).
- Very little land space is needed to power the world with solar energy.
- Most roofs will be made using solar-ready tiles.

In 2090 it's to be expected that all cars will be carbon-energy-free, using electricity or hydrogen fuel. According to Bloomberg[42] by 2040 annual EV sales will reach 41 million units. The Fuel Freedom Foundation[43] calculated the use of EVs and alternative fuel vehicles as displayed below.

Electric cars have been around since 2010, or actually since 1890. The technology developments move fast in the car industry, with Tesla being the most innovative. The technology being used is interesting both from a functionality perspective and a security perspective. In 2020 Tesla offered a hack bounty of $500,000 if a hacker can evade the many layers of security found in a brand-new Tesla Model 3[44]. According to the article it was the single largest target in Pwn2Own history (highest hacking bounty). If a hacker can evade the many layers of security, the car can be remotely controlled, creating a risk in the streets. Basically, if a terrorist is able to remotely

41 *Vishal Chhatralia, 'How Elon Musk plans to power the planet with renewable energy', Boss Magazine, 2019.*

42 *Fuel Freedom Foundation, 2019.*

43 *Fuel Freedom Foundation, 2019.*

44 *Davey Winder, 'Can you hack a Tesla Model 3? $500,000 says that you can't', Forbes, January 9, 2020.*

Years	EV sales annual growth rate	EVs added (millions)
2016 – 2020	32%	6.70
2021 – 2025	28%	24.10
2026 – 2030	22%	70.21
2031 – 2035	9%	131.09
2036 – 2040	5%	179.40
2041 – 2045	2%	209.48
2046 – 2050	2%	231.28

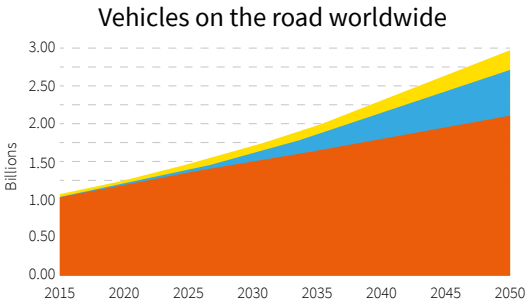


Figure 18: Vehicles on the road worldwide (Source: Fuelfreedom.org).

control the car it can steer a bomb to any place with a street leading to it. If this is already possible now, what will be possible in 2090?

According to Sher[45], the following technologies will be used in the car industry (one of the most progressive sectors):

- 2020-2025 Cars with AI. Although AI is already being used within Tesla, the functionalities are currently limited.
- 2030-2035 Cars without a steering wheel and pedals but with an entire multimedia front panel complete connected to the cloud. Having fully self-driving cars or autonomous driving operational will change a huge number of rules. Without pedals, speeding will no longer be possible (including fines), parking will be not an issue anymore and cars will be far better drivers than humans are today.
- 2040 The car is a service, according to the International Monetary Fund (IMF) and Georgetown University[46]. Over 90% of all cars in the USA, Canada, Europe, and other developed countries will be electric. It won't be necessary to own a car anymore. Updates are already

45 *Yana Sher, 'Cars of the future: What will you drive in 50 years?' IHODL, November 25th, 2018.*

46 *Stephan Leahy, ' Electric cars may rule the world's roads by 2040', National Geographic, September 13th, 2017.*

available via the air and the car can communicate with the cloud. Cars (or driving multimedia boxes) will become a common good.

- And of course, in 2050 cars will fly. Roed[47] has designed a flying car for the year 2053. It's designed as a three-wheeler which tackles land and air and is powered by a slush hydrogen engine.

There are several ways to reach the 'carbon dead' community and currently several technologies are being explored, such as hydrogen fuel cells. These technologies will impact security as well.

The first item is realizing smart energy grids. Smart grids use communication technology and distribute electricity from suppliers to consumers[48].

Tech subject	Cybersecurity	Hacker's case	Expectation
Current vulnerabilities smart cars			
Car control Hacks[49]	Protecting embedded software by secure coding	The smart car takes over	Current security area
Smart Alarm Hack	Protecting embedded software by secure coding	Unlocking car and privacy violations	Current security area
Insecure Smart Car Apps	Protecting embedded software by secure coding	Sending undesired commands via apps	Current security area
Physical damage	Protecting embedded software by secure coding	Poisoning print files to physically damage the printer	Current security area
In 2090			
The elements are likely to be the same as they are now, but the consequences (impact) are likely to be higher (e.g. massive hacking of the controls of cars)			Security area within 30 years

47 *Thomas Larsen Roed, 'Chase 2053,' January 7th, 2011.*

48 *Tony Flick, Justin Morehouse, 'Securing the Smart Grid, 2011.*

49 *Hitachi, 'Smart car security threats: is the connected car a good idea?,' March 26th, 2019.*

2080 Hyper-intelligent computers and androids

Thirty steps linear is equal to 30 steps, but 30 steps exponential is a billion steps (see Figure 17 depicting hyper-intelligent computers). Hyper or super intelligence is defined as 'Any intellect that greatly exceeds the cognitive performance of humans in virtually all domains of interest.'[50]

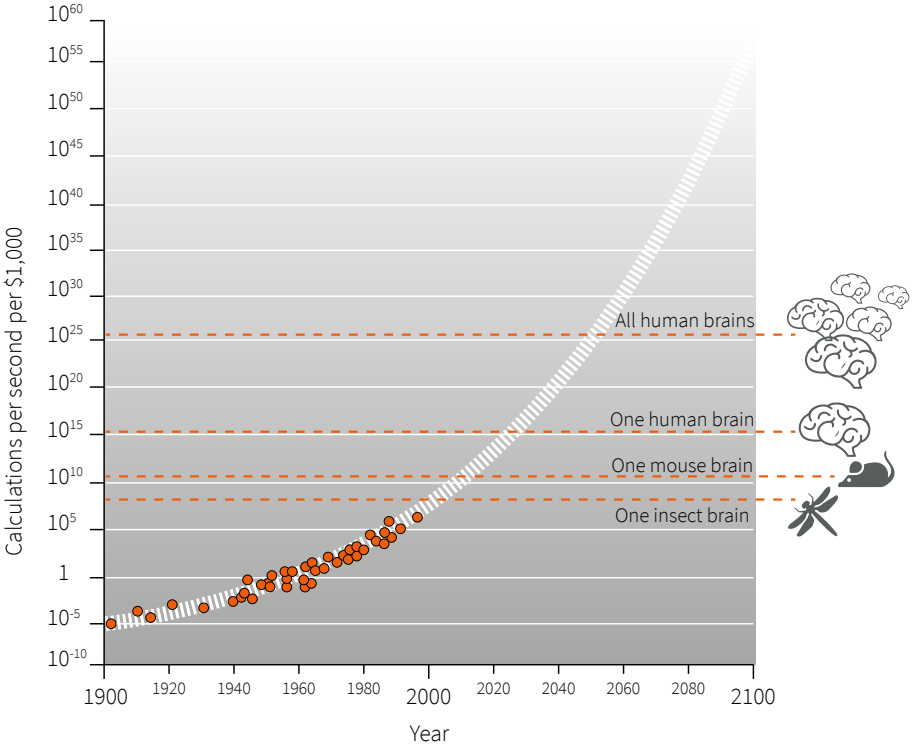


Figure 19: Exponential growth of computing (source: https://www.kurzweilai.net).[51]

50 *Nick Bostrom, 'Superintelligence: Paths, Dangers, Strategies', Oxford university Press, 2014.*

51 *Drake Baer, 'Google's genius futurist has one theory that he says will rule the future – ant it's a little terrifying', may 27th, 2015, source: https://www.businessinsider.com/ray-kurzweil-law-of-accelerating-returns-2015-5?internatio-nal=true&r=US&IR=Tn*

Up to now AI has attempted to copy and improve the cognitive performance of humans. AI combined with the current best processors already exceeds the capabilities of the human brain (e.g. Watson from IBM). Returning to Moore's Law (exponential growth) it's likely that all human brains can be combined in a hyper-intelligent computer (using AI) by the year of 2050.

Hyper-intelligent computers make people afraid. Even Elon Musk[52]: "I think we should be very careful about artificial intelligence," Musk replied. "If I had to guess at what our biggest existential threat is, it's probably that. So we need to be very careful with artificial intelligence. I'm increasingly inclined to think that there should be some regulatory oversight, maybe at the national and international level, just to make sure that we don't do something very foolish. With artificial intelligence we're summoning the demon.

You know those stories where there's the guy with the pentagram, and the holy water, and he's like — Yeah, he's sure he can control the demon? Doesn't work out."

In synchronization with hyper-intelligent computing the use of androids will be widespread. androids are mobile robots with human-like features and expressions and by 2080 they will be widespread in many cities in the world. The use of these machines will start with dangerous jobs, such as fireman and police officer for crowd control and in dangerous situations. A worrying aspect will be the remark by Elon Musk that while the software can prevent the android using excessive force, hackers may want to use androids for other purposes.

52 Alyson Shontell, 'A comment about artificial intelligence left Elon Musk frozen on stage', October 27th, 2014.

Subject	Cybersecurity	Hacker's case	Expectation
Current developments in hyper-intelligent computing			
Virtual Agents / Chatbot	Chatbot rules assurance Decision tree assurance	Chatbot adjustment Decision tree hacks	Security area within 5-10 years
Robotic process automation	Protecting the designed robotic process automation process	Changing / (mis) using the designed robotic process automation	Security area within 5-10 years
Cyber-defense	Use of cyber-defense and protecting the algorithms / recognizing patterns of attack	Using AI to observe patterns in data and disrupting the patterns	Security area within 5 years
In 2080			
AI/humans merge	Protecting the AI rules and use for human	Hacking humans	Security area within 60 years
Androids	Protecting the goal and way of working of androids	Threatening use of androids	Security area within 50 years
Industrial, domestic, the army, service, and other androids	Protecting goal and way of working of these androids	Using androids for different goals	Security area within 50 years

2070 Advanced nanotechnology in clothing

Within 50 years Harry Potter's invisibility cloak might be a reality. But nanotech masks and robes may also be used to block viruses such as the corona virus. Already nano parts are increasingly being used as a coating in order to make clothing waterproof, protective, or block UV.

According to von Goetz and Arvidsson[53] several types of nanoparticles are already added to clothes including:

- *Microbe-killing silver*

  Silver nanoparticles are added to clothing for their powerful ability to kill bacteria and fungi, and to prevent the nasty odors they cause. Nanosilver particles release positively charged

53 *Natalie von Goetz, Rickard Arvidsson, 'The nanotechnology in your clothes', The Guardian, February 14th, 2014*

ions that stop bacterial cells functioning. The particles' tiny size means the garment stays soft and wearable.

- *Silica for waterproofing and stain resistance*
  Nanoparticles of silica incorporated into the weave of a fabric or sprayed onto its surface create a coating that repels water and stain-producing liquids. The angle and roughness of the silica coating creates enough surface tension to ensure that liquids form beads that roll off the fabric rather than soaking into it.

- *Sunblocking titanium dioxide and zinc oxide*
  Ever got sunburnt through your T-shirt? Nanoparticles of titanium dioxide or zinc oxide are incorporated into textiles to protect your garments – and your skin – from sun damage. Both particles scatter the ultraviolet light in sunlight and do so more effectively as nanoparticles rather than as larger particles.

- *Antistatic particles*
  Some fabrics – particularly synthetics such as polyester and nylon – tend to gather static charge. Whisk a top over your head and your hair stands on end. But nanoparticles that conduct electricity, such as zinc oxide, titanium dioxide and antimony-doped tin oxide, can help disperse this charge.

Clothes featuring nanotechnology are largely made from standard fabrics on which a nano-coating has been applied. But in the future, we're likely to see more fabrics made from nanofibers, with nanoparticles and nanofilaments as an integral part of the weave. A new era of "smart" fabrics, for example, could automatically respond to your body and the environment around you.

The risks associated with nanotech in clothing should also be considered. Currently the use of nanoparticles is restricted to nano silver and nano-titanium dioxide. Although the use in of technology in nanotech clothing will change in the decades to come there are environmental

and health issues. Nanosilver may harm the environment when it moves through wastewater which is used on farmland.

There are also health issues related to the use of nanosilver. Some scientists[54] are concerned that too much silver in the environment could make this metal's anti-bacterial benefits less effective when society truly needs them.

In 2008 Prasad described the risks[55] of advanced nanotechnology clothing as follows: "There are, however, genuine environmental risks to nanotechnology, and the nature and extend of these risks has occupied the literature in the field since the beginning. At the grossest level, there is the fear that someone will design self-replicating nanorobots, capable of making copies of themselves from materials found in nature, and that those nanorobots will convert everything in the world into copies of themselves, thus wiping out the entire biosphere."

Subject	Cybersecurity	Hacker's case	Expectation
Advanced Nanotech clothing			
Use of Nano- fabrics	None	None	N/A
In 2070			
Advanced Nano- robots	Protecting the Nano-robots rules and use for human	Hacking Nanorobots	Security area within 50 years
Nanorobot regulation	Protecting the goal and regulatory of nanorobots	Threatening use of Nanorobots	Security area within 50 years
Industrial, Domestic, Army, service, and other use of Nanorobots	Protecting goal and way of working of Nanorobots	Using Nanorobots for different goals	Security area within 50 years

54 *Sarah Tarver-Wahlquist, Tracy Fernandez Rysavy, Andre Floyd, 'The Trouble with Nano-Fabrics', Green America, source: https://www.greenamerica.org/detox-your-closet-search-less-toxic-clothes/trouble-nano-fabrics*

55 *S.K. Prasad, 'Advanced Nanotechnology' in Encyclopedia of Nanoscience, Discovery publishing house pvt. ltd. New Delhi, 2008.*

2060 handheld MRI scanner

According to Futuretimeline[56], the ability to scan, analyze and diagnose the body will have taken a huge leap close to 2060. Currently an MRI machine requires a giant, powerful magnet and has to be within a copper-shielded room. In 2020 the first portable MRI was cleared by the FDA[57]. This weighs 635 kilograms and is about 1.5 meters across. Current MRI scanners weigh about 6000 kilograms and are over two meters high. But by 2060 it will be feasible to have handheld MRI scanners.

2050 Nanobots will plug brains in the cloud

By 2050 the first nanobots will help humans to plug in brains into the cloud. Scientists have already proposed creating the 'internet of thoughts' by inserting nanobots into our bodies.[58] They would navigate the human vasculature, cross the blood-brain barrier and precisely auto-position themselves among the brain cells. The Cloud will used for transfer of neural data to and from supercomputers.

2030 Quantum computing available for everyone

October 24th, 2019, Google claims the breakthrough of the quantum computer[59]. This claim is questioned by IBM. One thing is for sure, the global race to make a quantum computer is in full swing. Companies such as Google, IBM, Microsoft, and others are fighting to make the first stable quantum computer. Google even claims that it has achieved "quantum supremacy" with a quantum computer. This means it can solve a problem in three minutes and twenty seconds which today's supercomputer would take ten thousand years to solve.

56 *Futuretimeline.net, 'Handheld MRI scanners'.*

57 *Medgadget Editors, ' World's first portable MRI cleared by FDA', February 12th, 2020, Medgadget.*

58 *Com Corey, 'Scientists propose putting nanobots in our bodies to create 'global superbrain', 12 April 2019, Silicon republic*

59 *RTLZ, 'Google claims breakthrough quantum computer, IBM doubts the claim', October 24th, 2019.*

Competitor IBM[60], however, criticizes Google and says that a supercomputer would not take ten thousand years, but less than three days. Quantum computers have superfast processors and are not dependent on the use of 0's and 1's. Recent advances have resulted in two 53-qubit processors[61]. Computers that process information in a new way can lead to important breakthroughs. Quantum computers are expected to open doors to possibilities that are currently unimaginable due to their processing speed. As a comparison Tesla's full self-driving capabilities now have the interpretation power of a 10-year-old child (as the driver still has to act) but a quantum computing is faster, smarter, and better than the racing skills of Lewis Hamilton or Max Verstappen. A Formula 1 car steered by quantum computer would always win. But with quantum computing we can also calculate how to make the perfect drug at the molecular level. And, more importantly, it's the basis for artificial intelligence as described for developments up to 2120.

The term quantum computer was first mentioned in 1981 by the American physicist Richard Feynman. The word "quantum" comes from quantum mechanics. That is the branch of natural sciences that studies the behavior of atomic and subatomic particles. Quantum comes from the Latin word that stands for "quantity." Quantum computers have the potential to perform calculations much faster than traditional computers. And even faster than the supercomputers used today. For example, a stable quantum computer is likely to accelerate the growth of artificial intelligence by 2120.

Another property of quantum computers is the phenomenon of quantum entanglement. This means that two particles have a certain bond with each other, regardless of the distance between them. When the state of one of the particles is measured, one immediately knows the state of the second. Regardless of the distance. For example, if particle one turns up, it's known that particle two turns down. Thanks to quantum superposition and quantum entanglement, it's possible for a quantum computer to perform a very large number of calculations simulta-

60 *Edwin Pednault, John Gunnels, Dmitri, Maslov, Jay Gambetta, 'On 'Quantum Supremacy', October 21st, 2019, source: https://www.ibm.com/blogs/research/2019/10/on-quantum-supremacy/*

61 *Edwin Pednault, John Gunnels, Dmitri, Maslov, Jay Gambetta, 'On 'Quantum Supremacy', October 21st, 2019, source: https://www.ibm.com/blogs/research/2019/10/on-quantum-supremacy/*

neously. A security risk related to quantum computers is the possibility to crack encryption. Encryption is now often applied by multiplying two large prime numbers and hanging the encryption on their product. It takes a regular computer centuries to decompose this product into the two original prime numbers, but a quantum computer can do it in seconds. Other methods will need to be devised to encrypt data. The current RSA, Elliptic Curve cryptography and other techniques will no longer be suitable[62]. According to Andy Majot[63] and others:' Once quantum computing technology does advance enough to be implemented in a multipurpose, programmable machine, the world will find itself at a dangerous crossroads. Those governments and organizations with quantum technology would be in the god-like position of rendering some current methods of encryption completely obsolete '

The question is whether data security is at risk now quantum computing is gaining momentum. Lindsay Rand[64] described the possible impact on national security: "*The most suitable applications for quantum computers are problems with large, multi-dimensional parameter spaces that require the manipulation and optimization of significant numbers of independent variables. Consider the ways important national security information is protected and accessed, in technical terms, the ways it is encrypted and decrypted. Due to the high processing power of quantum computers, modern encryption methods that would take classic computers a long time to break would be rendered useless. The unique physical properties of proposed quantum computers would allow them to seek all possible solutions to an encryption algorithm simultaneously, giving an answer that reflects the probability of each outcome. This ability puts national-security-sensitive data at risk. In fact, hackers are already banking on this potentiality and storing available data until some point in the future when the data may be decrypted with quantum computers.*"

62 *Andy Majot, Roman Yampolskiy, 'Global Catastrophic and security implications of quantum computers,' Elsevier Science Direct, February 25th, 2015.*

63 *Andy Majot, Roman Yampolskiy, 'Global Catastrophic and security implications of quantum computers,' Elsevier Science Direct, February 25th, 2015.*

64 *Lindsay Rand, Berit Goodge, 'Information overload: The promise and risk of quantum computing,' Bulletin of the Atomic Science,' November 14, 2019.*

We will need to be proactive with regard to quantum computing. Security leaders must realize that universal quantum computers capable of performing a wide variety of functions will be available in 2030. They should identify which specific types of supremacy will have a major impact.

Today and Tomorrow

Data analytics/Business Intelligence (BI) is about creating information that enables decisions to be taken at all levels within an organization. The process of structuring and analyzing large volumes of data (Big Data), and using it to benefit the organization, has been standard practice for many years now. The analytics trend has highlighted a need for secure data. Adequate levels of confidentiality, integrity, and availability are needed.

The growth in unstructured data (including that of the other metering trend: Internet of Things) is outpacing the introduction of new developments in analytics/BI. As a result, IT leaders still feel that their organizations are generally data rich but relatively poor. In line with this, the successful use of Business Intelligence requires competences such as data management, statistics, tools, industry, company, and interpersonal competences. There are, of course, only a limited number of suitable candidates with this set of competences. It is, therefore, not surprising that IT leaders are already focusing on Business Intelligence and that this trend consistently features among the top IT trends. More recently, recognition and accreditation of these competencies have become firm requirements, to enable non-IT experts to succeed in these initiatives. This applies to most of the IT initiatives that are related to business operations. In the years to come, BI will continue to be one of the most important IT investments for businesses and other organizations.

Given the ongoing focus on Big Data, business intelligence, knowledge management and business analytics, there is a growing debate about where responsibility should lie within the organization. Of the organizations surveyed, 37% indicated that these initiatives would require senior management to report to the CEO. Another 37% indicated that this should involve higher management, in the case of applications, and only 17% stated that this responsibility should lie

with the CIO. In addition, 4% thought this was a matter for senior marketing management and 5% indicated a preference for other senior business management.

This megatrend also features a number of sub-trends, such as:

- Marketers and vendors will use social intelligence to forge smarter strategies. The use of social data analyses has increased in recent years. Newspaper headlines show that the tax authorities follow Facebook and other sources to determine whether tax declarations are in line with the services/activities that are actually being delivered/carried out. The advertisements presented by Google Mail, Nu.nl and other internet services are also related to your latest searches. Today, businesses and organizations will incorporate social media analytics more and more into their Business Intelligence systems and data. This will cause businesses and organizations to deliver additional (and/or more highly tailored) products and services.
- Big Data is not the same thing as Cloud Data. In addition to BI, many businesses and organizations are focusing on Cloud information. They also have access to a range of Cloud Analytics solutions (Private Cloud2) and are making increasing use of Cloud data in their decision-making/analytical processes. One practical example involves consumers who are interested in installing solar panels. The consumer goes online and uses Google Maps to identify the available space on their roof (by drawing lines). The application then displays details of the number of solar panels they could install, as well as the yield and the payback time.
- The community makes the difference. It should be clear that IT has now become part and parcel of everyday life. This trend is now going even further, with the introduction of home domotics (smart meters, robot vacuum cleaners, etc.). These devices are highly user-friendly, and the same goes for BI software. Those companies that use this across a range of communities will make a real difference, and 'their' community will grow. In that sense, BI is supporting both the organization and 'its' community.
- In-memory databases continue to be widely used. Due to the growing use of data, there is a permanent focus on the rate at which results are generated. In-memory databases allow businesses and organizations to accelerate access, analysis, and action. Faster de-

cision-making options can make the difference between winning and losing. In the Netherlands, various organizations are already exploring the potential of in-memory systems. Some are using SAP HANA but there are, of course, a range of options.

- Conversation analytics replaces static dashboards. BI tools have now progressed to the point at which data accessibility and interactivity can be analyzed in the course of a conversation. This includes options for mixing data and requesting new perspectives. In this way, meetings can be better supported, as voice commands can be used to view real-time data from any perspective. This will deliver greater insight into specific topics or situations (something CIOs are already working on, as explained in the previous section).
- 'Self-service analytics' provides new data governance rules. Every user can now apply analytics through the use of 'self-service' options. This is having a major impact on existing data governance rules. Simple governance rules, in which data is 'locked' will be superseded by rules under which data is used securely, while employees use it in an operational management context.
- Mobile analytics continue to expand. Company employees are increasingly using data via mobile applications. Smartphones can be used to obtain real-time data, via a range of BI toolkits. This is already available to vendors and management, but usually in the form of dashboards. However, new options are now available, featuring 'light' analytical tools.
- Sensor-driven data triggers new BI flows. The Internet of Things, drones, robotization, smart watches, and other developments will trigger new and different data streams. For BI, the challenge is to collect, combine and analyze this data, in order to generate new insights.
- More in-depth analytic capabilities for 'dummies'. Advanced tools, particularly in terms of graphic, intuitive modeling options, will enable every employee to perform their own analyses without having to consult an expert or use 'scripting'. Here, it's important that all possible combinations are clear, while any impossible combinations are screened to eliminate potentially dangerous statements (depending on the user group in question). Self-service options will make approaches such as basic forward planning commonplace.
- Business intelligence ownership explodes. The status update on business intelligence reveals a diversity of views about where responsibility for business intelligence should lie. In the near future, the emphasis will be on the democratization of intelligence and on the like-

lihood of a federated concept (central to the guidelines, data governance, decentralized use, analysis, and deployment).

Agility

Business agility and speed to market are essential for business growth in today's economy. Companies such as Microsoft are worth mentioning in this regard. This is because, despite the strengths of Apple, Samsung, and Huawei, they continue to develop products and services for which there is an adequate market. The term "business agility" reflects an organization's ability to respond quickly and adequately to threats, problems, and opportunities, by providing solutions (including IT solutions) that both the customer and the company need. This often requires the efficient switching of processes, rules of responsibility and data. Of course, IT plays a vital part in this. There is an urgent need for business agility. This is reflected by the fact that seventy per cent of the companies on the Fortune 1000 list just ten years ago have since disappeared, due to their inability to adapt to rapidly changing market conditions. It goes without saying that, aside from economy-related factors, IT has played a particularly large part in this.

Business agility was first referred to in a study in 2003. This development was prompted by the fact that businesses and organizations are continuously increasing their use of IT to gain a competitive advantage. Business agility has featured in the top ten IT management concerns every year since, with the exception of 2008 and 2009. Over the years, business agility has ranked third in North America, second in Europe, Asia and Africa and first in Australia and Latin America. Businesses and organizations use IT to reduce their operating costs and increase sales, so we expect that business agility will continue to be an important management issue. A study by Well and Broadbent[65] showed that business-agile organizations achieve higher business value than their counterparts in the same sector (as shown in Figure 18).

65 *Managing the IT Portfolio, "Microsoft Solutions Forum 2004," Peter Weill. File can be obtained from http://download.microsoft.com/download/4/f/3/4f33cdbb-f8c9-4edf-9bd7-6675d67d9eea/ IT_ Portfolio % 20-% 20Sept06.pdf*

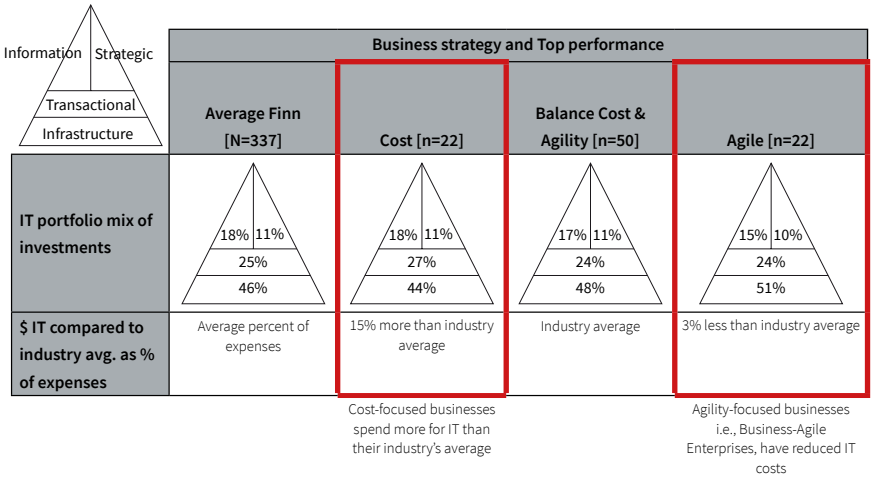


Figure 20: Agile organizations have lower IT costs.

In fact, the IT sector itself has come up with a solution for business agility. One much-discussed trend is Agile/Scrum. Although Scrum is a form of Agile, it's often placed on an equal footing with Agile itself. Business agility solutions can be based on Agile theory. Business agility's disruptive effects confirm that it's indeed a megatrend. Within the space of just a few years, small organizations can become mega-companies that fundamentally change the market. There are many examples, including Netflix, Airbnb, Uber, Tesla, Coolblue, Alibaba, and Apple.

Cloud

A real 'container concept' covering many longstanding IT trends. The term 'cloud' is used for 'remote application management', 'pay per use' (SaaS), and 'organization-independent data storage'. These days, more or less everything happens 'in the cloud'.

The Figure 19 shows the origins, the underlying trends, and other aspects of trends that have disappeared into the cloud.

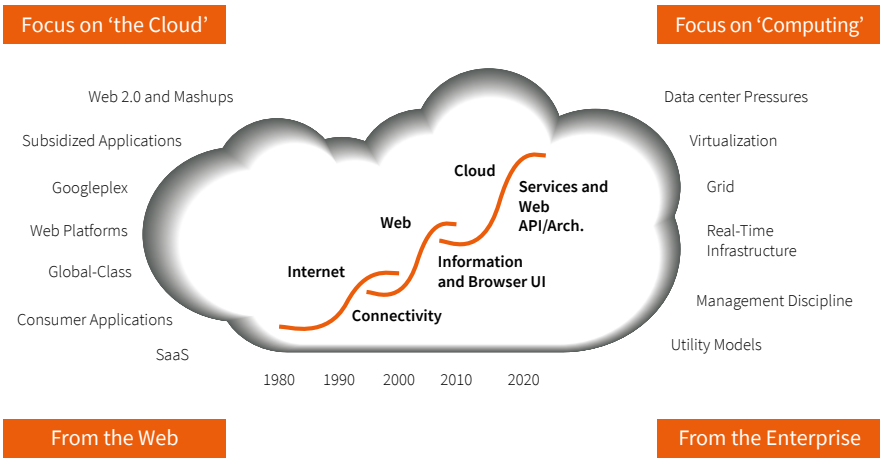


Figure 21: Perspectives of cloud computing (Prentice).

Following on from the previous two figures, an explanation of the final phase (cloudiness) involves examining the professionalization of Cloud applications (what do they mean for my organization?). This is shown in the Figure 20, which focuses on underlying IT trends in particular (also important for business operations):

Step 1 Consolidation	Step 2 Virtualization	Step 3 Automation	Step 4 Utillity	Step 5 Cloud
Consolidation & modernization of resources	Abstraction & resource pooling	Adaptive, secure & repeatable	Self-service & metering	On-demand & scalable
Server consolidation	Server & Storage virtualization	Policy-based provisioning & management	Service Metrics & metering	IaaS, SaaS, PaaS
Tiered storage consolidation	Desktop virtualization	ITIL-based repeatable processes	Service Level Agreement (SLAs)	Service-oriented architecture

Step 1 Consolidation	Step 2 Virtualization	Step 3 Automation	Step 4 Utillity	Step 5 Cloud
Consolidation of dnetwork services	Virtualized network services	Multi-Tier security	Incident response & audit	Inter-cloud federation
Consolidation of disparate Applications	Application virtualization	Multi-Tier data recovery	Continuous availability & failover	Integration of Web 2.0 & web portals
Key enabling capabilities				
Consolidation	Virtualization	ITIL service management	DR & COOP	Cloud internetworking
Modernization	Thin client computing	Network security	Risk / vulnerability management	Integration
Power & cooling	Green IT	Data center security	Situational awareness	Provisioning
High performance computing	Data duplication	Infrastructure protection		

Figure 22 Cloud computing maturity model (Jadhwani, et al.)

Internet of Things

One megatrend that is fundamentally changing the world is the Internet of Things. Such diverse items as appliances, wearables, cars, electricity, street lighting, and even manhole covers in roads, and many other types of 'things' are – or could potentially be – part of the Internet of Things.

An IP address, a sensor, and activity are all that is needed to include a device or a 'thing' in the Internet of Things. Perhaps more so than any other technological megatrend, this is radically changing the way we live and work. It's undergoing explosive development. By the end of 2020, no fewer than 26 trillion 'things' are expected to be linked to the internet. High-quality, affordable bandwidth, plus smartphones and inexpensive sensors are all contributing significantly to this development. There is a very good reason why the Internet of Things is referred to as the fourth industrial revolution.

The concept of the fourth industrial revolution is placing a heavy burden on this megatrend. To merit this label, it must radically change society and the economy. In 1784, these changes were triggered by the first mechanical loom. This was followed by mechanical, electric-powered production in the 20th century. The third industrial revolution took place just a few decades ago, with the rise of electronics and IT. The link between mechanical systems and IT systems (cyber systems) is bringing about the fourth industrial revolution – cyber-physical systems, popularly known as the Internet of Things.

Cyber-physical systems involve integrated computer, network, and physical processes. Embedded computers and networks monitor and control physical processes, using feedback to influence computer actions and the processes themselves. This is extended to include all possible devices, even if the actual objective is not the computer activity as such (e.g. cars, toys, and other devices). When this intelligence is linked to the internet, we get the Internet of Things. This is extremely extensive. The concept map (source: cyberphysicalsystems.org) shown in the figure below provides an impression of cyber-physical systems.

If we link up 'things' based on cyber-physical systems, the resultant 'helicopter view' shows that the world of IT still differs considerably from that of operational technology (OT). The Internet of Things is not yet a reality, but its potential is clear (see the Figure 21).

Cyber-Physical Systems - a Concept Map

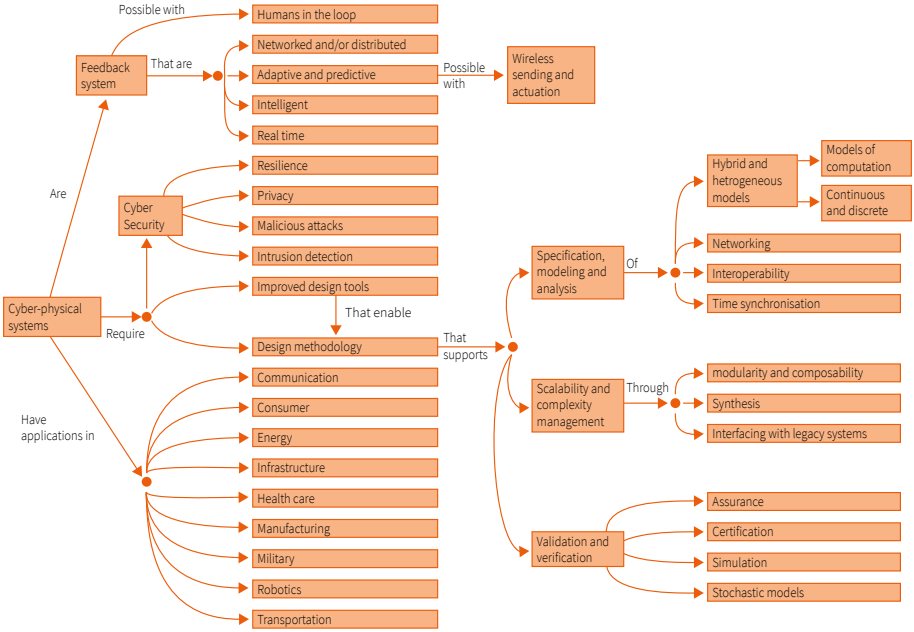


Figure 23: Concept map of cyber-physical systems (source: cyberphysicalsystems.org).

Privacy is a myth

Products and services are increasingly being offered via opaque clouds. As a result, the recipient doesn't know who is offering what and/or whether the source is actually reliable. Add to that the fact that Generation Y has no difficulty in making the data public on the internet, and internet is no longer complicated, but it's still complex.

The cloud makes life easier for IT administrators, as things still happen but it no longer matters where they happen. However, this is a potential nightmare for any self-respecting digital security expert or IT lawyer. Who can you speak to? Who can confirm that the data is really correct? One good example of the potential risks involved concerned a flight from the Netherlands to America in 2010. The United States had sufficient information to act on a potential terrorist

threat (but did not in fact do so). These days there is so much information that people can no longer see the forest for the trees. Perhaps you have heard of Twittergate[66], for example?

Guarantees of privacy are already a myth .... with regard to your company's information or personal details, it's more important to know how, what, and who is involved. It may be sufficient for trusted third parties handling your company's information and your personal details to state that "this information is correct and reliable."

Internet of Things explodes security measures

The Internet of Things era has started; everything can be made intelligent using sensors, monitors and other tech in order to create smart houses, cities, in fact everything. This enormous expanding network of things is causing businesses to increasingly invest in infrastructure applications but also security at all levels, from the sensor itself up to the enterprise software system as shown in the Figure 22. Currently most security professionals are experienced in IT, but increasingly they need to become skilled in operational technology as well.

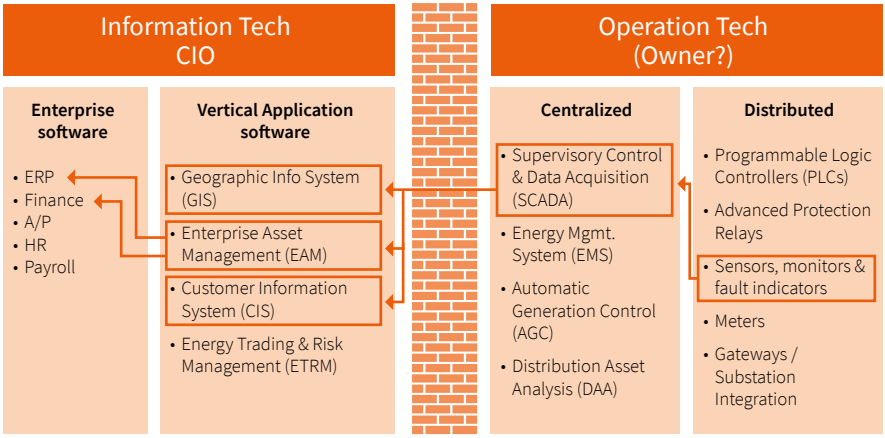


Figure 24: The expanding area of the security professional (source: VinT).

66 *https://thehill.com/opinion/white-house/363027-twittergate-what-did-trump-tweet-and-when-did-he-tweet-it*

These trends show the need for more cybersecurity jobs. But what will be the security job be in the late 21st century? In the next chapter we describe a possible future for the roles within digital security.

End of this section by Prof. Barry Derksen.

Trending roles in digital security

We want to feel safe in this brave (and scary) new world we're creating of machines, robots, and artificial intelligence. This new world will call for new jobs with new skillsets that address future challenges. Not only will the role of the CEO and CFO change due to tech dominance in business but also the role of the security officers and risk and security leaders. Zukin et al. (2018) state "A broader skillset, including communication, change management, and leadership, is required in order to respond quickly and collaboratively to evolving cyber threats."[67]

We identify the following major trends:

- Increasing sophistication and dynamics of cyber-attacks
- Machine learning and artificial intelligence
- Virtual identities
- Data
- Cloud
- Distributed hybrid environments
- New ways of working (DevOps, Agile, Scrum)
- Continuous software development
- Fake news, Deep Fakes and Customer Centricity
- War on talent
- State-sponsored hacking
- Regulatory and assurance (Integrated reporting)

These trends will require other roles in the cyberdomain, such as Cyber Attack Agent, Cyber Calamity Forecaster, Machine Risk Officer, Virtual Identity Defender, Data Trash Engineer, Cyber Diplomat, Cloud Orchestration Architect, Security Vaccinator, Cyber Talent Magnet, and AI Auditor. To give you an idea about what those roles mean we present a brief explanation per role in the section below. We then converge this into our vision of the role of the CISO. Our objective

67 *L. Zuzkin, J. Lopez, E. Wiess Kaya & A. Smallwood, „Cybersecurity readiness trough workforce development," in Navigating the digital age, Tim Dempsey, 2015, pp. 307-311.*

is not to be exhaustive, but to give you some of the major trends based on our experience and external research reports and articles for HR firms such as Egon Zehnder and Korn Ferry[68].

Due to the rapidly changing threat landscape and the morphing actors it's hard to keep up with this knowledge and translate it into actions. The **Cyber Calamity Forecaster** reveals overlooked possibilities and exposes unexamined assumptions about the cyber world. The ideal candidate will provide analytical, advisory, and technical expertise and analysis related to global cyber activities by assessing the current and predicted cyber environments and geopolitical developments in order to issue cyber products, alert bulletins, and forecasts. But this forecaster requires three major new capabilities that need to be combined into a single role.

In today's network security, vigilance with respect to arising new threats and attack vectors is becoming ever more important. Rapid detection, risk assessment, and preventive or mitigating measures are gaining prominence.

For this, **Cyber Threat Agents** or Security Operations Centers (SOCs) rely on a vast body of reports of newly detected (or suspected) threat avenues which are reported in public forums: newsfeeds, mailing lists, Twitter streams, etc. There are many non-public sources as well such as for-pay vendor threat bulletins and announcements in closed channels. This represents a growing challenge, which is a specific instance of the 'firehose' data problem. A lot of data is available. Beforehand, its veracity is never beyond doubt. Moreover, it's not guaranteed to be structured in such a way that automated or semi- automated processing is easily enabled. And, with many data sources, potentially shedding light (potentially from different perspectives) on issues that share an underlying coherence, discovering the relationship between reports from various sources is important. Also of note is the fact that data sources are lingual, with a wide range of potential source languages. Many are in English (of varying quality), but far from all;

68 *Cognizant, "21 More jobs of the future; A guide to getting and staying employed through 2029," Cognizant Center for the future of work, London, 2018. & J. Cummings, "Building a cyber savvy Board," in Navigating the digital age, Korn Ferry, 2018, pp. 313-318.*

and one should never exclude the possibility that a highly relevant and urgent report could be published in Russian, Korean, Chinese, German, or French first.

Given the size ('firehose') of the data stream, the scalability problem arises; high-level automation is called for. With this problem in mind we define three related capabilities:

1. Assessing data source quality
2. Intelligent correlation, relevance, and risk determination
3. Automation of data source handling process flow and directing that to target audiences in a presentable and actionable format.

Based on the gathered threat data the calamity forecaster can do trend analysis on sectors (e.g. finance, retail, manufacturing), countries, platforms (Microsoft, Oracle, etc.), and environments (industrial plants). This role is becoming increasingly important since most people can no longer see the wood for the trees.

The role of ***Machine Risk Officer*** will be essential in developing new trust mechanisms and imagining new risk-benefit approaches for working with intelligent machines. The employee in this position will define roles and responsibilities between humans and machines and set the rules for how human counterparts should handle errors caused by machines.

The role of ***Cyber Diplomat*** will be essential for managing stakeholders and regulators and finding collaboration and allies with other public and private companies and government. The reason why wars are won is by having the right – and enough – allies. Going to war without them is a receipt for failure, as history teaches us (think of Napoleon and Hitler). The employee in this position will form strong alliances and influence the external world about the opinion of the entity itself.

In the role of the ***Security Pusher***, you'll be expected to analyze every situation in which customers have contact with clients' brand or business, qualify the emotions involved, and then propose a subscription strategy. This job requires investigating, tracking, shaping, and recom-

mending decisions to ensure that cyber risks are dealt with in line with the risk appetite and in alignment with customer behavior. This requires frequent interaction with customers, stakeholders, and others involved in delivering services to operate effectively. This role emerges in managed security service providers and integrators that have certain liabilities toward their customers if security advisories are not being followed up by companies.

As a ***Cyber Attack Agent/SEAL***, you'll form part of a new Special Operations division within the SOC, tasked with developing, undertaking, and leading the cyber- deterrent program. As a key member of this team, you will assist in developing, and in wartime delivering, strategic cyber offenses against adversaries' infrastructure and public and private sector systems. To be considered for this critical role, you must display an excellent track record of cyber hacking, "gray-hat-focused" software development, or distributed denial-of-service attack experience. Cyber-attack agents/seals will need to operate as an effective and highly nimble team, collaborating closely with each other, as well as with the NCSC's cybersecurity teams.

In the role of ***Data Trash Engineer*** you'll apply analytical rigor and statistical methods to data trash in order to guide decision-making, product development, and strategic initiatives. This will be done by creating a "data trash nutrition labeling" system that will rate the quality of waste datasets and manage the "data-growth-data-trash" ratio. This role is needed to avoid 'obese' data collection by organizations and to adhere to GDPR regulatory requirements such as data retention schemes.

The ***Cyber Philosopher*** will keep discussions about the balance between humanity and machines alive, to prevent "judgment day" from happening.

The ***AI Auditor*** will form an independent opinion about the integrity of the AI. This person will be part of a governmental institute that audits without any financial incentives. The auditor cannot be part of a commercial organization.

The ***Security User Experience (SUX) Designer*** is an expert in building security within products and services and not giving customers an unfriendly experience. This is due to the way security has been designed as an integral part of the product or service, which results in a perfect balance between ease of use and a more secure and safe experience. In a world where it becomes unknown who can be trusted, trust will become essential for an effective business strategy.

For these future roles you need highly educated talent. Many learning and certification programs are very hard to navigate for many HR professionals or recruiters. See the figure below.

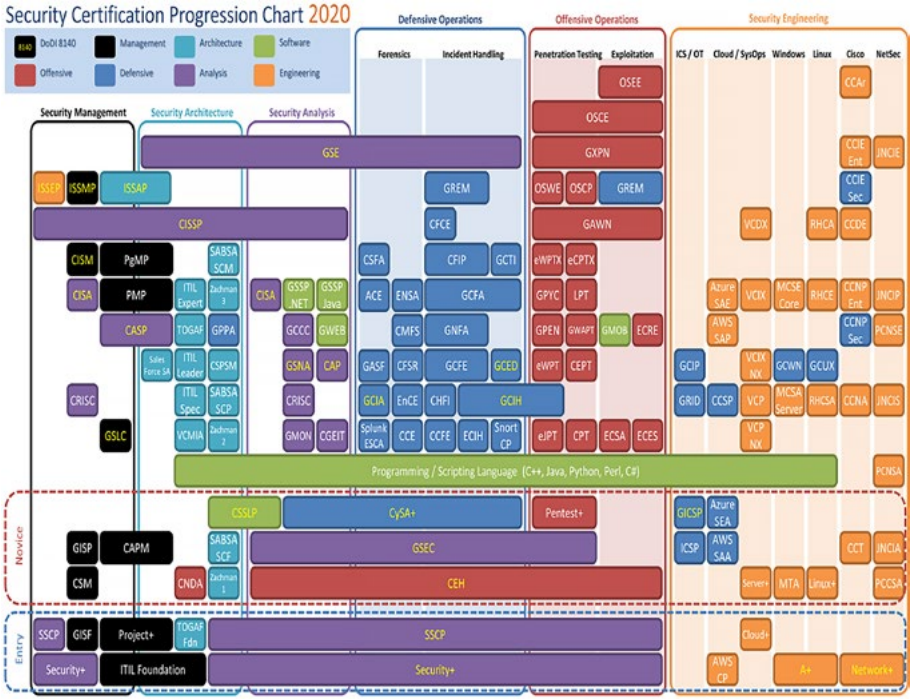


Figure 25: Overview of all security-related certifications.[69]

69 *Source; https://www.reddit.com/r/cybersecurity/comments/e23ffz/security_certification_progression_chart_2020/*

For the HR professional it is becoming more and more complex to distinguish talented people from amateurs. You simply can't judge a certification; you need to seek deeper into intrinsic motivations and personal capabilities. This seems obvious, but in digital security it's hard for a HR professional to determine how good someone actually is in a certain domain.

In an article on "Seeking the purple squirrel" [70] Lee proposes opting for an open job description saying "desired experience"; "*Security is a rapidly evolving space, made up of numerous different technologies, and no single person is expected to possess every characteristic on this list. A curious mind, an ability to think about the rules and how to break them, and a willingness to learn are the most important traits we look for. If you have some of the following and are willing to learn more of them, we want to hear from you.*"

Despite enormous progress in the industry, the race for talent and the search for data and information inaccuracy remains an enormous challenge for many organizations. This is substantiated by inadequate detection rates and slow responses to attacks. The main root cause for this is insufficiently configured security tools and a lack of craftmanship. But the stakes are high. An inadequate and seemingly weak response to breaches can trigger a negative impact on the company's perceived value and potentially on its share price. This information rarely trickles down to operational teams. We firmly believe that – according to a recent report by Wakefield Research and Deloitte[71] – this is the main reason why 50% of CISOs want to outsource their SOC and get more 'bang for their buck'.

70 *Lee, M. (2019) ISACA Journal; Stop Looking for the Purple Squirrel: What's Wrong With Today's Cybersecurity Hiring Practice*

71 *Wakefield Research and Deloitte Report on The future of cyber survey 2019, polled 500 C-level executives who oversee cybersecurity at companies with at least $500 million in annual revenue including 100 CISOs, 100 CSOs, 100 CTOs, 100 CIOs, and 100 CROs*

The role of the Chief Information Security Orchestrator (CISO)

Three roles for the modern Chief Information Security Orchestrator

We see the role of the CISO expanding to 'economist', 'talent magnet' and 'orchestrator', with a clear vision of how to address the pitfalls at the following organizational levels.

As an economist because the CISO needs to rely on detailed, reliable source data to determine the cyber-risk level in the context of all other risks. And they sell to the Board the 'biggest bang for their buck', based on facts and figures.

As a talent magnet because the ongoing 'war' on security talent requires continuous 'sharpening of the saw' and streamlining of operational, tactical and strategic objectives. This means that the CISO needs to lead and influence the hiring of top-notch staff who are capable of positively influencing risk and security owners – they need to be capable of engineering KRIs and KPI mechanisms. Hence the need to forecast future roles.

As an orchestrator because 'third-party risks' are the biggest risk for platform-based business models working in a large eco-API-based-system that require clear, predefined indicators to monitor the cyber performance across many environments. This means that the CISO needs to orchestrate the security of the entire chain, so that he or she gains full visibility on the effectiveness of the security controls[72].

72 *K. Bittianda, S. LaCroix & C. Patrick, „Evaluating and attracting your next CISO: More sophisticated approaches for a more sophisticated role," in Navigating the digital age, Egon Zehnder, 2018, pp. 319-323.*

Key takeaway messages on trending

Technology changes fast. Right now we are at a stage where new technologies are no longer only based on further developing current technologies using Moore's Law, but also creating new technologies such as quantum computing. We also see technology developments in business where security was never important and therefore undervalued. These developments introduce new risks as well as new professional roles for digital security. For this section we offer the following takeaway:

1. Keep your eyes open for tomorrow and the day after tomorrow, because, before you know it, you'll be too late. Use 10% of your time to start anticipating future trends and understanding their impact and stop focusing on what went wrong yesterday.
2. Anticipate timely on what talent is needed for the future requirements of the organization. What you need today you might not need by tomorrow. The role of the CISO is becoming more and more an orchestrator of the right capabilities. Internally (team establishment) as well as externally (e.g hiring process from external specific contractors).
3. Talk to industry peers that are frontrunners in Digital. You can learn from others (including there mistakes). Allocate one day a month to visit another tech leader and ask them to present what they are doing. You will be suprised how willing others want to share their idea's and lessons with others.

Interlude 3: Ecosystems & coalitions

Cyber risk ought to be in everyone's DNA. Like in healthcare, our customers should be able to trust that whoever is taking care of managing their risks is a skilled, educated, and experienced professional. In that regard, major steps have been taken in the last 20 years. We are not there yet, but we are heading in the right direction. In any case, it has become apparent that awareness can't be forced. We may just have to be patient. As in a natural process, cyber risk – awareness and alertness – will no doubt be in everyone's DNA in another 20 years. As far as the maturity of the field is concerned, it will certainly need a generation.

There are also major differences per market segment. The financial sector, for example, is more than five years ahead of the manufacturing industry. This gives rise to the thought that other sectors should be able to catch on quickly. After all, they don't have to reinvent the wheel. But unfortunately, it doesn't work that way. Collaboration remains a precarious subject because it might endanger your competitive advantage. While in reality the only risk is that others may be aware of the fact that you have been hacked, or vice-versa.

Within healthcare there are some excellent examples of collaboration. For instance, the Dutch Computer Emergency Response Team (Z-CERT) works as a center of expertise in the field of cyber risk. Information on threats of all kinds is collected from and spread across Europe. Based on this, the center supports healthcare providers with knowledge, support, and forensic expertise when they are affected by a security incident. Z-CERT is a foundation, so there is no profit motive and thus no perverse incentive. Following the lead of this example in healthcare every industry should initiate CERTs or Cyber-Security Incident Response Teams (CSIRT).

A great deal of cyber-risk prevention is generic. There is much that can be transferred to other market segments. For one thing, everyone is fighting the same enemy. Secret servic-

es from different countries work together against common enemies. Why is that so hard in cyber risk?

One of the more easily transferable and particularly effective methods is the checklist. These seem to have fallen out of favor. Unfortunately, because the rigidly disciplined completion of checklists can prevent a great deal of misery. They form a safety net against forgetting essential actions in certain situations: have the passwords been reset? Has that patch been implemented?

The checklist originates from aviation. After a prototype of the Boeing B-17 – also known as The Flying Fortress – crashed in 1935, the cause was investigated. It turned out that both pilots – who got killed in the crash – had forgotten to disengage a crucial lever before take-off. After this fatal warning, a comprehensive and detailed checklist was set up to ensure that the many actions were carried out in the correct order. Since then, every major incident is investigated extensively. Often this results in new regulations and extended checklists. This method was later copied by the healthcare sector, so that a surgeon or an anesthetist in the operating room doesn't forget anything that might be fatal. Checks can be essential to overcome complexity. Strangely enough, people in IT still believe that everything can be done without. Even something as simple as an incident response checklist is hardly ever used. So for each incident, those involved have to invent the best course of action on the spot. Time and again. Apparently the business has so far accepted this error-prone way of working.

Wouldn't it be a good idea to appoint a sort of boss-of-all-incidents? This can even be a rotating responsibility if necessary. Just like a family doctor in healthcare, the person who is a gatekeeper for all the disciplines involved in a patient's treatment. This person would be skilled and experienced in cyber risk and can function as the source of information for everyone.

In addition to the checklist, preparation works very well. Through gamification – learning by doing – you can train situations in a simulation. When things go wrong and there is little time to sort things out, people who have been through a gamification training are always better prepared. They have experienced it once, so they've got the hang of it. You see this in Formula 1 racing, where the drivers spend many hours in the simulator. Unfortunately, little use is made of this in cyber risk. A disaster recovery test is often skipped in practice, because day-to-day business takes precedence.

Looking at the bigger picture, we have to conclude that cyber risk lacks overall direction[73]. The good news is that there are many cyber-risk initiatives. For instance, in the Netherlands there are the Cyber Security Council (CSC) and the National Cyber Security Center (NCSC) of the government. The bad news is that there is no agreement about what the outcome of all these initiatives should be. Because they are driven by subsidies[74], there is no business direction. An initiative generally starts with the announcement: here you have money. Only then does the question arise: what are you going to do with it? And a question that is hardly ever asked is: how does your initiative fit into the larger picture of cyber risk? Or, to make it more holistic, into the larger picture of IT? Moreover, such initiatives on the whole die an inglorious death when the money is spent. Central management and the pursuit of a common outcome would yield enormous benefits. It could reduce the number of botnets or investigate the surprising possibilities of quantum computing.

An example of a good coalition is the Dutch Center for Information Security and Privacy Protection (CIP). Members are mainly in the public sector, including banking institutions, regulators, over 150 municipalities, all provinces, all ministries, and organizations such as the UWV, TNO and the Sociale Verzekeringsbank (SVB). The CIP provides solid advice and guidelines that are structurally taken up by working groups. Such an initiative should also

73 Potomac examined several cyber initiatives in The Netherlands: https://www.potomacinstitute.org/academic-centers/cyber-readiness-index

74 Such as under the heading of the European program: Horizon 2020 (https://bit.ly/2CVI2bR).

be launched in other sectors - the manufacturing industry, the agricultural sector and so on. Control should lie with trade organizations of each market segment.

Why is there an overall lack of direction? One reason is because most people are in this business for their own gain. This can carry on as long as no real pain is felt. Shared pain will lead to a common interest. Starting with establishing that there is a common problem. Once that has been done, all parties should put in some money in proportion to their turnover. All participants then have an interest in and benefit from this joint initiative. Although they are commendable, almost none of those countless initiatives without a mandate is making a real difference.

“In life, lots of people know what to do, but few people actually do what they know. Knowing is not enough! You must take action”

Tony Robbins

07

Twelve ways to combat the silent enemy

This chapter gives you an overview of the 12 most important actions to start with if you want to make digital security a success. As you've read in this book, you'll have seen that this is not about technology or the latest security processes or methodology; it's about doing things related to *yourself*, *your team*, and/or the *people within your organization*.

1. ***Everyone has a plan, until they get punched in the face.*** Strategy is more than just an digital security plan. It's about constant training and maintaining physical and mental fitness. Strategy is also about economics, stakeholder management, and creating smart coalitions.
2. ***Culture eats strategy but loves to tango with change management***. Dare to take the lead in the dance and be the first to attract people on the dance floor. Create and quantum communicate your compelling vision, empathize with past losses, plan for wins, and celebrate.
3. ***Act as a Navy Seal: discipline, discipline, discipline***. Being secure is about knowing what you're doing, and to get there, you need discipline. Do the things you need to do every day consistently and make use of lessons learned from aviation, the army and healthcare by using checklists.
4. ***Identify the ducks and the eagles*** and make sure you're not a duck. Thus, self-reflection on your own capabilities is required before you embark on leadership. An eagle dares to lead the dance, has the discipline to hunt, and always maintains oversight.
5. ***Influence people by providing purpose***, direction, and motivation to accomplish the mission. Activate the intrinsic motivation of the people to take extreme ownership and encour-

age them to become the best. By the way, people won't follow a quacking and "nagging" duck.

6. ***Winning is not a one (wo)man show***. Since this profession is extremely diverse you can't succeed on your own. You need skillful people who are willing to "tango."
7. ***Focus on the "biggest bang for your buck."*** Identify crown jewels and the protect surface and use your existing technology to the max. Don't spend more but less and calculate the security benefits (ROSI). And don't let the intern do your administration or someone else do your training sessions.
8. ***Smart security measuring and reporting.*** You don't want to measure useless information. Security metrics must be carefully selected, formulated smart and orchestrated and automated to the max, so they resonate in the business.
9. ***Start telling and stop explaining.*** Specifically, to internal and external stakeholders, demonstrate extreme craftsmanship and ownership. Always be prepared for the fight.
10. ***The smell of the place is the biggest driver for success.*** Establish a fruitful atmosphere of collaboration and openness. Encourage the "Spring in Fontainebleau " that people will want to go to.
11. ***In time of peace prepare for war.*** Be the fittest in the room; train, simulate, exercise, and test your fitness to be prepared for the real fight. You need 10,000 hours of methodical practice in your profession to excel.
12. ***Winter is coming.*** What went wrong yesterday doesn't add value, but the challenges of the future are far more important. Take 10% of your time to start anticipating future trends and understanding their impact. Talk to your industry peers how they deal with this and you will learn a lot.

“Never interrupt your enemy when he is making a mistake”

Sun Tzu

Epilog

Cybersecurity has become essential for boards of directors and senior business executives. This shift is driven by regulation, the increasing prominence of cyber-attacks in the global news, or even a cyber incident in their enterprise.

The role of Chief Information Security Officers (CISOs) is evolving towards Digital Security leaders, from being solely technical experts in IT to becoming strategic business enablers and leaders who deliver significant value at the highest levels of corporate governance. As cybersecurity transcends from being exclusively a technical concern to a business value priority, its relevance in boardroom discussions rises significantly. This shift catalyses an enterprise's security program, needing sophisticated execution by the CISO.

Simplicity is critical in security, as complexity poses a significant threat to it. Adopting a straightforward approach in presenting the topic to the board and senior business executives is vital to succeeding as a CISO. I adhere to the 'grandfather test,' ensuring that every message I convey is easily comprehensible, even to someone unfamiliar with security terms. In addition to clear and straightforward communication, an effective security program relies on robust Key Performance Indicators (KPIs) with actionable insights to drive the security agenda enterprise-wide. This is securing funding, appropriate resources, and the right execution from top level governance to the last line of control of an enterprise.

It's also crucial to acknowledge that each organization's security program is unique and shaped by its industry vertical, value chain , and corporate culture. While leveraging globally accepted standards and frameworks (like NIST CSF and ISO27001) is highly recommended, customization to align with the specific needs of the enterprise is essential to foster a business-tuned and value-driven security program in your enterprise.

This book's content helps any digital security leader examine all the relevant perspectives, ranging from governance to funding to measuring value creation. I hope you enjoyed reading and applying it as much as I did. Within ten years, a new edition will emerge in which security is integrated into most of our core activities.

Mathias Bücherl

Group CISO at Heidelberg Materials AG

About the authors



Yuri Bobbert is CEO of Anove International, Global CSO at ON2IT and Academic Director / Professor at Antwerp Management School (AMS). He has advised more than 300 companies, including NN Group and UWV as Head of Digital Security. Within NN Group he was the Security, Risk and Compliance leader of the Delta Lloyd merger. This is where he met Mark Butterhoff and shared their initial vision and values. From 2004-2014 Yuri was CEO of a Digital Security advisory and integration company. Yuri holds a double PhD from both the University of Antwerp and Radboud University in the Netherlands and a Master in Business Informatics.His first book was published in 2010 which defines and positions his methods; the second in 2014, describing 25 companies that have applied these methods. In 2018 he published two books: "Critical success factors for effective business information security" and "Cybersecurity in 60 minutes" for Boards and supervisory bodies. In 2021 he published the books "Digital Value creation" and "Strategic Approaches for Security Governance" Bobbert is co-founder of technology solutions such as Anove, SecuriMeter, SECA/Lockchain and Meetingwizard GSS Software. And published 100+ articles.



Mark Butterhoff has gained experience over the last 23 years in various roles. He has a long history at KPMG, where he worked in information security, IT auditing, and management consulting. After that he worked for several years as program manager and interim manager restructuring and changing mainly IT organizations as well as a post as Interim Chief Information Security Officer. So far he has helped over 80 companies in 17 countries. Alongside his work he also teaches at the TIAS Business School in the Netherlands. Mark has completed studies in various topics, including Business Informatics and IT Auditing. In 2016 he published a book entitled "Discover the IT Cherry," which describes how to become the most valued IT organization by building trust and creating experiences instead of using the latest technology or implementing new processes. His experiences from work and the insights gained from writing this book were also the basis for writing this book. Solid technology and processes are massively important in cybersecurity; however, they won't help you win the war against this silent enemy. Just as in sports, the army, aviation, healthcare, etc., it's mostly leadership and the people in your organization that make the difference.

Figures & tables

Table 1	Spending on security, taken from Dutch Investments in ICT and cybersecurity	14
Figure 1	Underlying logic of Army leadership (taken from ADRP 6.22, Army Leadership – August 2019, Headquarters, Department of the Army).	31
Figure 2	Level 5 Hierarchy Leadership by Jim Collins.	32
Figure 3	CISO leadership competencies required per level (Taken from the Russell Reynolds Capability Model).	34
Table 2	Taken from What Makes a Great Leader (Daniel Goleman)	39
Table 3	Taken from Dare to Lead (Brené Brown) the criteria for armored and daring leadership	39
Figure 4	Managing the Shit of Yesterday (taken from Hinssen, The Day after Tomorrow).	53
Figure 5	Johari window	57
Figure 6	Porter's Five Forces Model.	93
Figure 7	The Lippitt & Knoster Change Model.	121
Table 4	Eight reasons why "Digital security change management interventions fail"	122
Figure 8	The Kübler-Ross change curve.	131
Figure 9	Integrated Culture: Leader Statements from "The Leader's Guide to Corporate Culture," by Boris Groysberg et al, HBR.	138
Figure 10	Eight soft controls, Muel Kaptein.	143
Figure 11	The Learning Pyramid of National Training Laboratories.	147
Figure 12	The relation of stress and the development of combat exhaustion to the combat efficiency of the average soldier.	152
Figure 13	COBIT5 EDM model for defining processes (taken from ISACA).	165
Figure 14	The Chief Information Security Officer Mindmap 2021, by Rafeeq Rehman	188
Figure 15	Artificial intelligence techniques (source: Chen and others).	241
Figure 16	Business value and success rate of AI adoption (source: educba.com).	244
Figure 17	System model 3D printing (source Bayens).	250
Figure 18	Vehicles on the road worldwide (Source: Fuelfreedom.org).	255
Figure 19	Exponential growth of computing (source: https://www.kurzweilai.net).	257
Figure 20	Agile organizations have lower IT costs.	269
Figure 21	Perspectives of cloud computing (Prentice).	270
Figure 22	Cloud computing maturity model (Jadhwani, et al.)	270
Figure 23	Concept map of cyber-physical systems (source: cyberphysicalsystems.org).	273
Figure 24	The expanding area of the security professional (source: VinT).	274
Figure 25	Overview of all security-related certifications.	280

Appendices

A1 Business case criteria

Table A1-1 Business case tasks prior, during, and after implementation (according to Maes)

	Business Case tasks
BEFORE implementation	Understand investment relevance
	Split business case: • Into high-level and detailed business cases • Per sub-investment
	Assess investment: • Feasibility (organizational, financial, technical) • Viability (economic, marketability, strategic)
	Indentify, structure and determine explicit metrics and values of: • Benefits, costs, and risks (if successful and in case of failure) • Resource requirements (financial, timing, staff) • User requirements • Critical success factors
	Link benefits and changes explicitly
	Develop a: • Work plan, action plan, roadmaps • Benefits-delivery plan
	Develop and validate • Proof-of-concept, prototype
	Perform and determine: • What-if analyses and failure analysis • Preferred solutions • Investment alternatives
	Assign responsibilities and accountabilities: • Investment team • Investment sponsor • Benefit owners in relation to investment objectives and benefits
	Identify and assure: • Stakeholder opinion (via workshop, …) • Stakeholder ability to achieve investment change • Stakeholder confirmation of business case • Stakeholder commitment (e.g. top management)
	Evaluate the business case
	Communicate the business case (stress investment vision, objectives, stakeholder commitment)
	Approve the business case or stop the investment

	Business Case tasks
DURING Implementation	Audit investment decision
	Allocate investment resources
	Establish evaluation team
	Monitor, evaluate and report on: • Investment progress, budget and performance • Investment changes
	Review and update business case based on: • Investment progress and performance • New insights from stakeholders • Organizational, technical and, market changes
	Identify and assure: • Stakeholder opinion (via workshop, …) • Stakeholder ability to achieve investment change • Stakeholder confirmation of business case • Stakeholder commitment (e.g. top management)
	In case of investment failure, reassess business case, assumptions and feasibility
AFTER implementation	Evaluate investment performance against stated investment objectives, industry benchmarks or an ideal performance level
	Understand failure reasons
	Acquire lessons learned
	Audit investment performance
	Determine further investment opportunities and business cases
	Reward in relation to performance

Table A1-2 Business case content

	Business case content	
Investment description	Project planning and roadmaps (tables, figures) Project description	Drivers for Change
Investment objectives	Explicit project objectives Performance goals Business goals	Align and link objectives of: • Business and IS • Investment and organization
Investment requirements	Requirements Resource requirements Customer needs Organizational needs	Technical needs Market needs Strategic requirements
Investment impact	Benefits and costs (business and technological) over consecutive years: • Tangible and intangible • Monetary and non-monetary • Quantifiable, measurable and observable • Certain and uncertain • Direct and indirect • Realistic Clear benefit definition	Cost-benefit analysis Financial investment justification Financial plan / benefits plan Feasibility study Organizational changes Link investment metrics to business performance Business variables and measures are targeted against baselines prior to investing
Investment risks	Investment risk factors (technical and business-change risks)	Risk management plan
Investment assumptions, considerations and scenarios	Realistic assumptions Organizational, strategic, operational, technological issues Time / organizational constraints Qualitative considerations	Intervening variables Best practice research Investment options Realistic technology scenarios
Investment governance	Roles and responsibilities Accountability	Compliance

Table A1-3 Business case goals

	Business case goals	
BEFORE implementation	• to ensure an investment owner is assigned • to ensure basic investment information is collected • to identify how IT and business changes will deliver the identified benefits • to increase the investment success rate • to link benefits to organisational changesand to investment objectives • to convince people • to ensure involvment, support and get commitment • to increase motivation and stimulate action • to obtain investment resources (funding, staff, time...)	• to improve the relationship and develop trust • to communicate an investment's concept status and results among its stakeholders • to transfer knowledge • to compare investments • to balance risks between investments • to filter out unattractive investment ideas • to identify 'low-hanging fruits' • to identify high-priority investments • to prioritise investments • to get investment approval • to make well-founded investment decisions • to successfully launch an investment
DURING implementation	• to obtain additional investment resources (funding, staff, time...) • to revove unattractive investments	• to disallow additional resources for an unattractive investment
AFTER implementation	• to execute a post evaluation • to objectively evaluate investment outcome	• to demonstrate an investment's impact

Table A1-4 Business case stakeholders

	Business case stakeholders	
BEFORE implementation	• Board of directors • Executive committee • CEO / CFO / CPO / CIO • Strategy management group • Senior management • Business executives / managers together with IT management and business architects • Business unit manager • Business / investment sponsor • Business planning board • Portfolio management team • Project investment department • Capital IT project management board • Project centre of excellence • Project manager	• Financial organisation / staff • Capital control group • IT steering committee • IT management team • Business demand office in IT side • Internal / external end users from business and IT • Division information managers • Designers • Operational manegers • Uninvolved project leaders and auditors • Human resources / organisation department • A devil's advocate
DURING implementation	• Financial organisation	
AFTER implementation	• Post-implementation review team	• Finance organisation

A2 CISO (self) assessment template

Taken from Russell Reynolds[1]

HOW TO USE THE CALM MODEL? Start with the question, "What level of CISO do you have?" and ask yourself what the current organizational attitude toward cyber is. Follow some of the assumptions made by Russell Reynolds, and work out where you think the organization is at the moment: is it a Level 1 place or is it more than that? Then ask yourself where the organization wants to be, and over what period it wants to get there.

Lastly, look at the table that focuses on what a CISO actually does. Work your way down the table through some of the observations and see if you can figure out either what the current capability of your CISO is, or what the future requirement will look like.

You now have a clearer view of what level of CISO is most likely to succeed in your organization.

1 *Russell Reynolds Associates is a global leader in assessment, recruitment, and succession planning for Boards of Directors, CEOs and key roles within the C-suite. With more than 370 consultants in 46 offices around the world, Russell Reynolds works closely with public, private, and nonprofit organizations across all industries and regions. They help clients build teams of transformational leaders who can meet today's challenges and anticipate the digital, economic, environmental, and political trends that are reshaping the global business environment.*

What does the CISO do?	Current CISO	Benchmark Peers	Desired CISO	Short rationale
Identify: Critical Assets and Crown Jewels				
Protect: e.g., Access Control / Training / Data Security				
Detect: e.g., Continuous Monitoring / Anomalies and Events				
Respond: e.g., Communications / Mitigation				
Recover: e.g., Improvements / Recovery Planning				
Automates as much as possible				
Confidently protects all types of Technology				
Gets Insight from Data and Analytics				
Shapes the culture toward Cyber				
Gains control of new developments and changes				
Is integral to the digital innovation agenda, e.g., use of the Cloud				
Keeps knowledge current using external sources				
Shares information with industry peers				
Sets appropriate budget for cyber initiatives				
Stays connected with government agencies				
Stays knowledgeable of the regulatory environment, e.g., GDPR				

Over the years we've seen the digital security profession transformed into an overhyped and fuzzy domain that is often referred to as cybersecurity. Since many authors have written a great deal on this subject in books, journals, and social media blogs, our aim here is to enrich this field with our opinions, viewpoints, and expertise. Thanks to a combined total of forty-five years of experience – experience from our academic backgrounds as well as from our work as security and tech leaders – we are able to focus on things that should work in theory but fail in practice due to all kinds of intangible, "silent" factors. Our intention is not to be exhaustive, nor to criticize others, but to shed fresh light on crucial cyber-related allies, enemies, and issues that are rarely taken into account and talked about, but we believe you should know to help you combat the silent enemy of digital security.

"Security is a complex topic and the authors brought the essentials and the complexity to me in a very understandable, usable and completing style. Very exciting read, especially because the authors wrote the chapters from a practical perspective with a nice balance of academic and creative models. You can apply the 'takeaway messages' immediately."
– Amir Arooni, Board member and CIO at Discover Financial Services (DFS) –

"This book effectively dismantles the complexity often associated with Security, offering a holistic, straightforward approach to making it actionable within enterprises. Bridging theoretical models with accessible explanations empowers readers to launch an enterprise security program with ease and comprehension."
– Mathias Bücherl, Group CISO at Heidelberg Materials AG –

"This book is a 'must read' for any manager involved in the topic of digital security."
– Prof. Dr. Ron Meyer –

"A must-read reference guide that connects theories and models to practical instruments and approaches in the field of digital security."
– Prof. Dr. Steven de Haes, Dean at Antwerp Management School –

"When starting in my new CISO role, the book gave me an overview of key topics to consider. It learned me a lot about relevant leadership skills and how to behave in order to become successful as a CISO. By providing insights into relevant research it gives input for decision making and how to approach challenges I encounter."
– Corence Klop, Chief Information Security Officer (CISO) at the Rabobank –

